Київський столичний університет імені Бориса Грінченка

Володимир Соколов, Наталія Коршун

ОРГАНІЗАЦІЯ ЗАХИСТУ РОЗПОДІЛЕНИХ ІНФОРМАЦІЙНИХ РЕСУРСІВ

Навчальний посібник

для здобувачів третього (освітньо-наукового) рівня вищої освіти
спеціальності 125/F5 «Кібербезпека та захист інформації»
галузі знань 12/F «Інформаційні технології спеціальності»

Київ — 2026

УДК 004.056:004.75(075.8)
ББК 16.8
С594

Рекомендовано до видання Вченою радою
факультету інформаційних технологій та математики
Київського столичного університету імені Бориса Грінченка
(протокол № 9 від 16 вересня 2026 р.)

Рецензенти:
Смірнов Олексій Анатолійович, доктор технічних наук, професор, Центральноукраїнський національний технічний університет;
Опірський Іван Романович, доктор технічних наук, професор, Національний університет «Львівська політехніка».

Соколов В. Ю., Коршун Н. В. Організація захисту розподілених інформаційних ресурсів : навчальний посібник для здобувачів третього (освітньо-наукового) рівня вищої освіти. Київ, КСУБГ, 2026, 324 с. — 17 розділів, додаток.

Навчальний посібник охоплює теоретичні основи та практичні аспекти організації захисту розподілених інформаційних ресурсів, систем і мереж. Розглянуто архітектури розподілених систем і властивий їм простір загроз, класи розподілених систем і вразливостей, децентралізовані P2P-моделі та атаки на них, безпеку скоординованих ресурсів і координаційних служб, нормативно-правове та стандартизаційне забезпечення захисту інформації в Україні та Європейському Союзі, математичні й системно-аналітичні методи оцінювання захищеності, моделювання загроз і управління ризиками, криптографічні механізми та інфраструктуру відкритих ключів, керування доступом, захист мережевої інфраструктури (зокрема безпроводових сегментів), архітектуру нульової довіри, захист хмарних, контейнерних і децентралізованих ресурсів, моніторинг та аудит безпеки, реагування на інциденти й забезпечення неперервності функціонування, а також захист ресурсів об'єктів критичної інфраструктури та операційних технологій. Заключний розділ присвячено управлінню безпекою, практикам DevSecOps і методології наукових досліджень у предметній галузі.

Кожен розділ завершується висновками та питаннями для самоперевірки, а розділи, що відповідають змістовим модулям робочої програми, — також блоком співвіднесення матеріалу з програмними результатами навчання. Посібник призначено для аспірантів галузі знань 12/F «Інформаційні технології» спеціальності 125/F5 «Кібербезпека та захист інформації», а також буде корисним науковим і науково-педагогічним працівникам, фахівцям із захисту інформації та кібербезпеки.

© Володимир Соколов, Наталія Коршун 2026
© Київський столичний університет імені Бориса Грінченка, 2026

Зміст

Основні терміни та скорочення 1

Вступ 3

1 Розподілені інформаційні ресурси та системи: архітектури, властивості й простір загроз 7
- 1.1 Поняття інформаційного ресурсу та розподіленого інформаційного ресурсу . . . 7
- 1.2 Таксономія архітектур розподілених систем і профілі їхніх вразливостей . . . 9
- 1.3 Фундаментальні властивості розподілених систем та їхні безпекові наслідки . . . 10
- 1.4 Вісім хибних припущень розподілених обчислень: безпекова інтерпретація . . . 12
- 1.5 Моделі відмов, консенсус і межа досяжних гарантій цілісності 13
- 1.6 Властивості безпеки розподілених інформаційних ресурсів . 14
- 1.7 Простір загроз і поверхня атаки розподіленої системи . . . 15
- 1.8 Український контекст: розподілені державні ресурси й стійкість під час війни . . . 16
- 1.9 Термінологічний апарат розділу . . . 18

Висновки до розділу . . . 18

Питання для самоперевірки . . . 19

2 Класи розподілених систем і вразливостей 21
- 2.1 Класи розподілених систем . . . 21
- 2.2 Класи вразливостей і загроз . . . 23
- 2.3 Контроль доступу/допуску та керування ідентифікаторами . 25
- 2.4 Транспортування даних . . . 28
- 2.5 Служби управління ресурсами та координація . . . 30
- 2.6 Безпека даних . . . 32

Висновки до розділу . . . 34

Питання для самоперевірки . . . 35

3 Децентралізовані моделі P2P і атакуючі P2P системи 37
- 3.1 Неструктуровані протоколи P2P . . . 37
- 3.2 Структуровані протоколи P2P . . . 39

3.3 Гібридні протоколи P2P 42
3.4 Ієрархічні протоколи P2P 43
3.5 Типи атак 45
3.6 Напади та їх пом'якшення 46
Висновки до розділу 49
Питання для самоперевірки 50

4 Розподілені системи: скоординована кластеризація ресурсів 53
4.1 Стилі координації систем 53
4.2 Надійне та безпечне групове спілкування 55
4.3 Координаційні властивості 59
4.4 Схема керування та координації реплікації: основа пом'якшення атак 61
Висновки до розділу 65
Питання для самоперевірки 66

5 Розподілені системи: координаційні класи та напади 69
5.1 Координаційні класи та атакованість: узагальнена модель . . 69
5.2 Клас координації ресурсів: розгляд інфраструктури 71
5.3 Клас координації послуг: розгляд програм 76
5.4 Порівняльний аналіз атакованості координаційних класів . . 80
Висновки до розділу 83
Питання для самоперевірки 83

6 Нормативно-правове та стандартизаційне забезпечення захисту розподілених інформаційних ресурсів 85
6.1 Ієрархія джерел вимог до захисту розподілених ресурсів . . . 85
6.2 Законодавство України: правові режими інформації та розподілені ресурси 86
6.3 Стратегія кібербезпеки та система суб'єктів забезпечення кібербезпеки 87
6.4 Підзаконне регулювання: правила, кіберзахист критичної інфраструктури, експертиза й ліцензування 88
6.5 Система НД ТЗІ та функціональні профілі захищеності 88
6.6 КСЗІ і СУІБ: порівняння та сценарії інтеграції 89
6.7 Родина ISO/IEC 27000 і критерії оцінювання ІТ-безпеки 91
6.8 Право ЄС та євроінтеграційні зобов'язання України 92
6.9 Каталоги заходів як мова проєктування та таблиці відповідності 93
6.10 Оцінювання відповідності, аудит і юридична відповідальність 94
Висновки до розділу 95
Питання для самоперевірки 96

7 Математичні та системно-аналітичні основи оцінювання захищеності розподілених систем 99
7.1 Системний аналіз розподіленої системи захисту 99
7.2 Формальні моделі політик безпеки 100
7.3 Теоретико-графові методи 103
7.4 Ймовірнісні та стохастичні моделі 105
7.5 Моделі масового обслуговування та стійкість до DDoS 106
7.6 Теоретико-ігрові моделі протистояння 107
7.7 Багатокритеріальне оцінювання захищеності 108
7.8 Метрики захищеності 109
7.9 Ентропійні та інформаційно-теоретичні підходи 110
7.10 Розгорнутий приклад комплексного розрахунку 110
Висновки до розділу 113
Питання для самоперевірки 114

8 Моделювання загроз і управління ризиками розподілених інформаційних ресурсів 117
8.1 Понятійний апарат ризик-менеджменту інформаційної безпеки 117
8.2 Інвентаризація та категоризація розподілених активів 118
8.3 Модель порушника та модель загроз 120
8.4 Методології моделювання загроз 121
8.5 Kill chain, MITRE ATT&CK і матриця покриття 123
8.6 Оцінювання ризиків: якісні та кількісні підходи 123
8.7 Ризики ланцюга постачання програмного забезпечення . . . 125
8.8 Оброблення ризику та оптимальний розподіл бюджету . . . 126
8.9 Комунікація ризику, ризик-реєстр та інтеграція із СУІБ 128
8.10 Кейс: моделювання загроз розподіленого державного реєстру 128
Висновки до розділу 130
Питання для самоперевірки 131

9 Криптографічні механізми та інфраструктура відкритих ключів у розподілених системах 133
9.1 Роль криптографії в розподілених системах і поняття криптографічного протоколу 133
9.2 Симетричні примітиви, режими роботи та автентифіковане шифрування 134
9.3 Національні криптографічні стандарти України 135
9.4 Асиметрична криптографія та узгодження ключів 136
9.5 Захищені канали: TLS 1.3, mTLS та IPsec 138
9.6 Інфраструктура відкритих ключів 139

9.7 Електронні довірчі послуги в Україні 140
9.8 Керування ключами: HSM, KMS, розділення секрету та порогові схеми 141
9.9 Криптографія для обчислень над захищеними даними 142
9.10 Постквантовий перехід і криптоаджилність 143
9.11 Кейс: захист обміну між вузлами розподіленого державного реєстру 144
Висновки до розділу 144
Питання для самоперевірки 145

10 Ідентифікація, автентифікація та керування доступом у розподілених системах 147
10.1 Понятійний апарат: ідентифікація, автентифікація, авторизація, підзвітність 147
10.2 Автентифікація: фактори, рівні достовірності, стійкі до фішингу методи 148
10.3 Протоколи автентифікації в розподілених середовищах . . . 149
10.4 Моделі керування доступом та їх формалізація 152
10.5 Централізоване й децентралізоване адміністрування доступом 155
10.6 Керування привілейованим доступом 156
10.7 Керування доступом до хмарних і мікросервісних ресурсів . 157
10.8 Децентралізована ідентичність: DID та верифіковані посвідчення 158
10.9 Українська практика електронної ідентифікації 158
10.10 Аудит прав доступу та аналітика ідентичності 159
10.11 Кейс: схема керування доступом для розподіленої відомчої ІКС 160
Висновки до розділу 161
Питання для самоперевірки 162

11 Захист мережевої інфраструктури розподілених систем, зокрема безпроводових сегментів 165
11.1 Мережева архітектура розподіленої системи як об'єкт захисту 165
11.2 Сегментація та мікросегментація 166
11.3 Засоби мережевого захисту та їх розміщення в топології . . . 168
11.4 Захищені канали між сегментами 169
11.5 Безпека протоколів мережевої інфраструктури 170
11.6 Захист безпроводових сегментів розподілених систем 171
11.7 Стійкість до відмов і атак на доступність 175
11.8 Програмно визначені мережі та віртуалізація мережевих функцій 176

11.9 Моніторинг мережевого трафіку 176
11.10 Кейс: захищена мережева архітектура розподіленої установи 177
Висновки до розділу 178
Питання для самоперевірки 179

12 Архітектура нульової довіри та захист хмарних і контейнерних розподілених ресурсів 181
12.1 Криза периметрової моделі захисту 181
12.2 Архітектура нульової довіри за NIST SP 800-207 182
12.3 Зрілість і практика впровадження 185
12.4 SDP, SASE та SSE 186
12.5 Хмарні моделі та спільна відповідальність 187
12.6 Безпека контейнерів і оркестрації 188
12.7 Безсерверні обчислення та мікросервіси 190
12.8 Захист даних у хмарі 191
12.9 Українські аспекти 191
12.10 Кейс: перехід відомчої розподіленої системи до нульової довіри 193
Висновки до розділу 193
Питання для самоперевірки 194

13 Захист розподілених баз даних, сховищ даних і технологій розподіленого реєстру 197
13.1 Розподілене зберігання даних як об'єкт захисту 197
13.2 Узгодженість, транзакції та безпека даних 199
13.3 Консенсус як механізм забезпечення цілісності 200
13.4 Керування доступом до розподілених даних 201
13.5 Шифрування даних у розподілених сховищах 202
13.6 Забезпечення цілісності та достовірності записів 203
13.7 Загрози прикладного рівня та захист приватності 204
13.8 Технології розподіленого реєстру та блокчейн 205
13.9 Резервне копіювання й архівування розподілених даних . . . 207
13.10 Українські аспекти: захист державних електронних реєстрів . 208
13.11 Кейс: проєктування захисту розподіленого сховища даних відомства 209
Висновки до розділу 210
Питання для самоперевірки 210

14 Моніторинг безпеки, виявлення вторгнень та аудит розподілених систем 213
14.1 Наукові засади моніторингу: спостережуваність розподіленої системи 213

14.2 Джерела подій безпеки та нормалізація телеметрії 214
14.3 Централізоване збирання, зберігання та цілісність журналів . 215
14.4 Системи виявлення вторгнень: класифікація та якість виявлення 217
14.5 Кореляція та аналітика: SIEM, UEBA, SOAR 218
14.6 Полювання на загрози та кіберрозвідка 219
14.7 Організація центру безпеки (SOC) 220
14.8 Аудит безпеки ІКС 221
14.9 Тестування захищеності 223
14.10 Кейс: моніторинг безпеки розподіленої ІКС із трьома майданчиками 223
Висновки до розділу 225
Питання для самоперевірки 225

15 Реагування на інциденти, неперервність функціонування та відновлення розподілених сервісів 227
15.1 Понятійний апарат і класифікація інцидентів 227
15.2 Життєвий цикл реагування на інциденти 229
15.3 Організація реагування та національна система 230
15.4 Технічні аспекти реагування в розподіленому середовищі . . 232
15.5 Цифрова криміналістика розподілених систем 232
15.6 Управління неперервністю діяльності та показники відновлення 233
15.7 Планування відновлення після катастроф 235
15.8 Кіберстійкість розподілених систем 236
15.9 Тестування планів і навчання 237
15.10 Український досвід і кейс відновлення відомчої ІКС 238
Висновки до розділу 240
Питання для самоперевірки 240

16 Захист розподілених ресурсів об'єктів критичної інфраструктури, операційних технологій та IoT 243
16.1 Критична інфраструктура як розподілена соціотехнічна система 243
16.2 Нормативні вимоги до кіберзахисту об'єктів критичної інфраструктури 245
16.3 Операційні технології та промислові системи керування . . . 246
16.4 Промислові протоколи та їхні вразливості 247
16.5 Стандарт IEC 62443: зони, канали й рівні захищеності 248
16.6 Загрози та інциденти в операційних технологіях 249
16.7 Захисні заходи для OT-середовищ 251

16.8 Інтернет речей та промисловий Інтернет речей 252
16.9 Периферійні та кіберфізичні системи 253
16.10 Кейс: планування кіберзахисту розподіленого об'єкта водопостачання 254
Висновки до розділу 255
Питання для самоперевірки 256

17 Управління безпекою розподілених ресурсів: СУІБ, DevSecOps і напрями наукових досліджень 259
17.1 Система управління інформаційною безпекою як механізм інтеграції 259
17.2 Політики та документована інформація 261
17.3 Вимірювання дієвості: показники, метрики, дашборди 262
17.4 Моделі зрілості та оцінювання спроможностей 263
17.5 Безпека життєвого циклу розроблення: SSDF і DevSecOps . . 263
17.6 Керування вразливостями та змінами 265
17.7 Людський і організаційний вимір 266
17.8 Економіка захисту розподілених ресурсів 266
17.9 Штучний інтелект: інструмент захисту і нове джерело загроз 267
17.10 Методологія наукових досліджень аспіранта 268
17.11 Відкриті наукові проблеми й перспективні напрями 270
Висновки до розділу 271
Питання для самоперевірки 272

Список використаних джерел 275

Додаток А. Завдання для самостійної роботи 309

Основні терміни та скорочення

АС	автоматизована система
ВМ	віртуальна машина
ГІР	державний інформаційний ресурс
ЕДП	електронні довірчі послуги
ЄС	Європейський Союз
ІКС	інформаційно-комунікаційна система
IoT	Інтернет речей (Internet of Things)
ІР	інформаційний ресурс
КЕП	кваліфікований електронний підпис
КСЗІ	комплексна система захисту інформації
НД ТЗІ	нормативний документ системи технічного захисту інформації
НСД	несанкціонований доступ
ОІД	об'єкт інформаційної діяльності
ОКІ	об'єкт критичної інфраструктури
ОС	операційна система
ОТ	операційні технології
ПЗ	програмне забезпечення
ПРН	програмний результат навчання
СУІБ	система управління інформаційною безпекою
ФПЗ	функціональний профіль захищеності
ЦСК	центр сертифікації ключів
ABAC	Attribute-Based Access Control 'атрибутне керування доступом'
AEAD	Authenticated Encryption with Associated Data 'автентифіковане шифрування з асоційованими даними'
API	Application Programming Interface 'прикладний програмний інтерфейс'
BFT	Byzantine Fault Tolerance 'візантійська відмовостійкість'
BIA	Business Impact Analysis 'аналіз впливу на діяльність'

CAP	Consistency, Availability, Partition tolerance ‘узгодженість, доступність, стійкість до розділення мережі’
CTI	Cyber Threat Intelligence ‘кіберрозвідка про загрози’
DDoS	Distributed Denial of Service ‘розподілена атака на відмову в обслуговуванні’
DHT	Distributed Hash Table ‘розподілена геш-таблиця’
DLT	Distributed Ledger Technology ‘технологія розподіленого реєстру’
IAM	Identity and Access Management ‘керування ідентичністю та доступом’
IDS/IPS	Intrusion Detection System / Intrusion Prevention System ‘системи виявлення / запобігання вторгненням’
MFA	Multi-Factor Authentication ‘багатофакторна автентифікація’
MPC	Multi-Party Computation ‘багатостороннє обчислення’
P2P	Peer-to-Peer ‘однорангова (децентралізована) взаємодія вузлів’
PKI	Public Key Infrastructure ‘інфраструктура відкритих ключів’
RBAC	Role-Based Access Control ‘рольове керування доступом’
RPO	Recovery Point Objective ‘цільова точка відновлення’
RTO	Recovery Time Objective ‘цільовий час відновлення’
SBOM	Software Bill of Materials ‘специфікація складу програмного забезпечення’
SIEM	Security Information and Event Management ‘система керування подіями та інформацією безпеки’
SOAR	Security Orchestration, Automation and Response ‘оркестрування, автоматизація та реагування’
SOC	Security Operations Center ‘центр забезпечення кібербезпеки’
TLS	Transport Layer Security ‘протокол захисту транспортного рівня’
ZTA	Zero Trust Architecture ‘архітектура нульової довіри’

Вступ

Розподілені інформаційні ресурси перестали бути окремим класом систем і стали типовою формою існування інформації. Державні реєстри, банківські платіжні системи, освітні та наукові платформи, системи керування енергетичними й транспортними об'єктами — усе це сукупності даних, застосунків і обчислювальних вузлів, розосереджених між майданчиками, хмарними середовищами, периферійними пристроями та каналами електронних комунікацій. Захист таких ресурсів принципово відрізняється від захисту зосередженої системи: тут немає єдиного периметра, єдиного адміністратора й навіть єдиного моменту часу, спільного для всіх вузлів; натомість є часткові відмови, недовірені посередники, багатостороння відповідальність і потреба ухвалювати рішення про доступ за неповної інформації.

Досвід України останніх років зробив ці питання предметом не лише академічного інтересу. Атаки на об'єкти критичної інфраструктури, масштабні кампанії проти державних інформаційних ресурсів, необхідність швидкої міграції даних до хмарних середовищ і забезпечення роботи сервісів в умовах руйнувань та знеструмлень перетворили організацію захисту розподілених ресурсів на питання національної стійкості. Одночасно змінилося й нормативне поле: оновлено законодавство про кібербезпеку та критичну інфраструктуру, гармонізовано з європейськими вимогами національні стандарти, сформульовано зобов'язання щодо наближення до Директиви (ЄС) 2022/2555 (NIS2).

Мета і завдання навчальної дисципліни

Мета курсу — формування в аспірантів знань, умінь і навичок із застосування теоретичних основ та організації захисту розподілених інформаційних ресурсів для забезпечення їх безпеки.

Завдання курсу — отримання теоретичних знань та практичних умінь з дослідження теорій і технологій забезпечення безпеки розподілених інформаційних ресурсів, систем та мереж і набуття таких компетентностей:

- здатність застосовувати сучасні інформаційні технології під час створення захищених розподілених інформаційних систем і захисту інформації в них;
- здатність робити оцінки та знаходити відповідні рішення щодо застосування розподілених інформаційних систем і захисту інформації в них;

- здатність до вдосконалення, модернізації та уніфікації розподілених інформаційних систем, засобів і технологій забезпечення безпеки, обробки та перетворення інформації.

Структура посібника

Матеріал згруповано у п'ять логічних блоків.

Блок I. Розподілені системи як об'єкт захисту (розділи 1–5) відкривається розділом про архітектури розподілених систем і властивий їм простір загроз. Далі йдуть чотири розділи, що відповідають змістовим модулям робочої програми дисципліни: класи розподілених систем і вразливостей (модуль I), децентралізовані моделі P2P та атаки на них (модуль II), скоординована кластеризація ресурсів (модуль III), координаційні класи та напади (модуль IV). Блок формує системне бачення того, як спосіб розподілу й координації ресурсів визначає поверхню атаки та межі досяжних гарантій безпеки.

Блок II. Теоретико-нормативні засади (розділи 6–8) формує понятійний апарат: нормативно-правове та стандартизаційне поле України, Європейського Союзу й міжнародних організацій; математичні та системно-аналітичні методи оцінювання захищеності; методології моделювання загроз і управління ризиками. Цей блок є основою для компетентності КФ-2.

Блок III. Механізми та технології захисту (розділи 9–13) присвячено власне засобам: криптографічним механізмам та інфраструктурі відкритих ключів, ідентифікації, автентифікації й керуванню доступом, захисту мережевої інфраструктури разом із безпроводовими сегментами, архітектурі нульової довіри та захисту хмарних і контейнерних середовищ, захисту розподілених баз даних, сховищ і технологій розподіленого реєстру. Блок безпосередньо працює на ПРН 7 у частині адміністрування доступом і протидії несанкціонованому доступу.

Блок IV. Операційна безпека та стійкість (розділи 14–16) охоплює моніторинг безпеки, виявлення вторгнень і аудит, реагування на інциденти, неперервність функціонування та відновлення, а також захист ресурсів об'єктів критичної інфраструктури й операційних технологій. Це ядро ПРН 4 у частині неперервності бізнес-процесів і компетентності КФ-7.

Блок V. Управління та дослідження (розділ 17) інтегрує попередній матеріал у систему управління інформаційною безпекою, розглядає практики безпечного розроблення й експлуатації, економіку безпеки та методологію наукових досліджень у предметній галузі, що відповідає дослідницькій складовій ПРН 4.

Як працювати з посібником

Посібник розраховано на здобувачів третього (освітньо-наукового) рівня вищої освіти, які вже володіють базовими знаннями з інформаційної безпеки, комп'ютерних мереж і криптографії. Тому виклад побудовано не як первинне ознайомлення з предметом, а як систематизація на рівні моделей, доказових аргументів і критичного аналізу чинних рішень. Формули супроводжуються поясненням позначень і, де це доречно, числовими прикладами, які варто відтворити самостійно.

Питання для самоперевірки наприкінці кожного розділу навмисно неоднорідні: частина з них перевіряє відтворення матеріалу, частина потребує аналізу й порівняння, а завершальні питання сформульовано як дослідницькі завдання — вони можуть слугувати відправною точкою для наукової статті або фрагмента дисертаційного дослідження. Аспірантові рекомендується опрацьовувати їх у зв'язці з власною темою дослідження.

Посилання на джерела наведено в квадратних дужках; повний список подано наприкінці видання. Перевагу віддано чинним нормативним документам України, національним та міжнародним стандартам, документам Європейського Союзу, публікаціям NIST, ENISA та рецензованим науковим працям. Усі нормативні акти слід перевіряти на чинність редакції на момент використання: законодавство у сфері кібербезпеки й критичної інфраструктури змінюється швидко.

Термінологічне зауваження

У виданні послідовно вживається термін **безпроводові** (мережі, канали, технології) як український відповідник англійського *wireless*. Англомовні терміни, що не мають усталеного українського відповідника, наводяться в дужках мовою оригіналу при першому вживанні. Скорочення ІКС уживається у значенні «інформаційно-комунікаційна система» відповідно до чинної редакції Закону України «Про захист інформації в інформаційно-комунікаційних системах», ОІД — «об'єкт інформаційної діяльності», ОКІ — «об'єкт критичної інфраструктури».

РОЗДІЛ 1

Розподілені інформаційні ресурси та системи: архітектури, властивості й простір загроз

Цей розділ формує понятійний і методологічний фундамент курсу. Його завдання — не переказати відомості про розподілені обчислення, а показати, чому саме *розподіленість* перетворює задачу захисту інформаційного ресурсу на якісно іншу проблему, ніж захист локалізованої системи. Послідовно розглянуто законодавче та науково-технічне трактування інформаційного ресурсу, таксономію архітектур із специфічними профілями вразливостей, фундаментальні властивості розподілених систем і породжені ними класи загроз, моделі відмов та межі досяжних гарантій цілісності, а також простір загроз у прив'язці до українського контексту. Матеріал розділу є передумовою для нормативного (розділ 6), математичного (розділ 7) і ризик-орієнтованого (розділ 8) блоків, а безпосередньо за ним ідуть розділи 2–5, що поглиблюють класифікацію розподілених систем, P2P-моделі та координаційні класи під кутом безпеки.

1.1 Поняття інформаційного ресурсу та розподіленого інформаційного ресурсу

1.1.1 Законодавче трактування

Українське законодавство не оперує єдиною консолідованою дефініцією «розподілений інформаційний ресурс», однак вибудовує її з кількох нормативних шарів. Закон України «Про інформацію» визначає інформацію як будь-які відомості та/або дані, які можуть бути збережені на матеріальних носіях або відображені в електронному вигляді, і вводить режими доступу до неї [54]. Закон України «Про захист інформації в інформаційно-комунікаційних системах» подає **інформаційно-комунікаційну систему** (ІКС) як сукупність інформаційних та електронних комунікаційних систем, які під час обробки інформації діють як єдине ціле, а також визначає обробку, захист і власника інформації [52]. Закон України «Про основні засади забезпечення кібербезпеки України» додає категорії **кіберпростору**, **кіберзахисту**, **об'єкта кіберзахисту** та **критичної інформаційної інфраструктури** [58], а Закон «Про критичну інфраструктуру» — секторальну модель об'єктів, від яких залежить життєдіяльність держави [55].

Ключовий для нашої предметної області нормативний зсув стався у 2021–2022 рр. Закон України «Про публічні електронні реєстри» вводить поняття публічного електронного реєстру як інформаційно-комунікаційної

системи, що забезпечує збирання, накопичення, захист, облік і надання реєстрових даних [59], а Закон України «Про хмарні послуги» легалізує обробку інформації публічних користувачів у хмарних середовищах, забороняючи водночас обробку службової інформації та державної таємниці з використанням центрів обробки даних за кордоном (з окремим винятком для оборонного сектору в період воєнного стану) [62]. Разом із Правилами забезпечення захисту інформації [42] і Загальними вимогами до кіберзахисту об'єктів критичної інфраструктури [22] це утворює правовий каркас, у якому державний інформаційний ресурс за визначенням є *розподіленим*: його компоненти розміщені на різних майданчиках, у різних юрисдикціях та під різними режимами адміністрування.

1.1.2 Науково-технічне трактування й формалізація

У науково-технічному сенсі **інформаційний ресурс** — це впорядкована сукупність даних разом із засобами їх зберігання, оброблення та надання, що має ідентифікованого власника, визначену цінність і життєвий цикл. **Розподілений інформаційний ресурс** — інформаційний ресурс, компоненти якого (дані, обчислення, керування доступом, засоби захисту) розміщені на множині автономних вузлів, взаємодія між якими відбувається виключно через обмін повідомленнями мережею, що не є повністю надійною й повністю контрольованою власником ресурсу. Саме останнє застереження є критичним для безпеки: класичне означення розподіленої системи як сукупності незалежних комп'ютерів, що постає перед користувачем як єдина когерентна система [394], приховує від користувача ту саму структуру, яку зловмисник навпаки прагне виявити й використати.

Для подальших побудов зафіксуємо формальну модель. Розподілену систему подамо кортежем

$$S = \langle N,\ L,\ D,\ \mathcal{R},\ \Pi,\ \Theta \rangle, \tag{1.1}$$

де $N = \{n_1, \dots, n_k\}$ — множина вузлів; $L \subseteq N \times N$ — множина логічних каналів взаємодії; $D = \{d_1, \dots, d_m\}$ — множина об'єктів даних; $\mathcal{R} : D \to 2^N$ — відображення розміщення (реплікації й фрагментації), що кожному об'єкту даних ставить у відповідність підмножину вузлів-носіїв; Π — політика безпеки (сукупність правил доступу, криптографічних та організаційних заходів); Θ — модель довіри, тобто відношення, яке визначає, у якому обсязі кожен вузол покладається на твердження інших вузлів. Локалізована система є виродженим випадком, коли $|N| = 1$: тоді $L = \varnothing$, а Θ тривіальне. Отже, специфічні для розподіленості загрози — це загрози, які виникають саме на компонентах L, $\mathcal{R}$ та Θ, і жоден захід, що діє лише на рівні окремого вузла, їх не усуває.

Ієрархія понять вибудовується так: *інформаційний ресурс* (об'єкт захисту) → *інформаційна система* (засіб оброблення) → *ІКС* (інформаційна система разом з електронними комунікаціями) → *розподілена ІКС* (ІКС із багатьма автономними вузлами керування). Юридично об'єктом захисту є інформація, технічно — система, організаційно — процес; розбіжність цих трьох ракурсів є типовим джерелом прогалин у побудові комплексних систем захисту інформації [34].

1.2 Таксономія архітектур розподілених систем і профілі їхніх вразливостей

Архітектура визначає, як розподілено стан, керування й довіру, а отже — де саме розташовані критичні точки відмови та найпривабливіші цілі атаки. Класифікацію узагальнено на рис. 1.1.

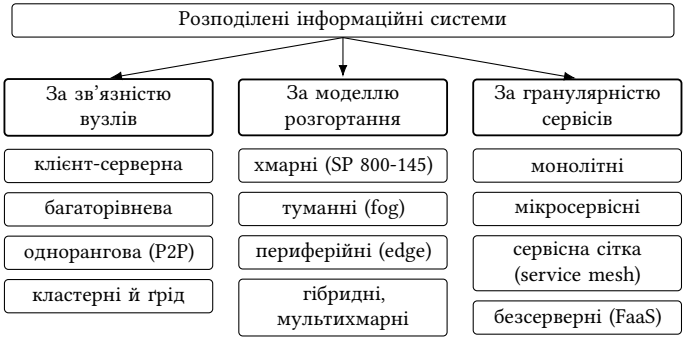


Рис. 1.1 — Таксономія архітектур розподілених систем за трьома незалежними ознаками

Три ознаки на рис. 1.1 є ортогональними: реальна система характеризується трійкою значень (наприклад, мікросервісна багаторівнева система у гібридній хмарі з периферійними, зокрема безпроводовими, сегментами збору даних). Хмарні моделі трактуємо строго за NIST SP 800-145: IaaS, PaaS, SaaS та чотири моделі розгортання [279]; туманні — за NIST SP 500-325 [224]. Кожна архітектура має характерний профіль вразливостей (табл. 1.1).

Таблиця 1.1 — Архітектури розподілених систем та домінантні профілі їхніх вразливостей

Архітектура	Домінантний профіль вразливостей
Клієнт-серверна	Централізована точка відмови; компрометація сервера дає доступ до всього ресурсу; атаки на сеанс і на автентифікацію клієнта
Багаторівнева	Довіра між рівнями за замовчуванням; обхід рівня подання й прямий доступ до рівня даних; ін'єкції на межі рівнів [320]
Однорангова (P2P)	Sybil-атаки та затьмарення (eclipse); отруєння таблиць маршрутизації; відсутність центру відкликання довіри
Кластерні, ґрід	Спільні механізми планування як спільний вектор; латеральне переміщення між вузлами з єдиними обліковими даними
Хмарні	Помилки конфігурації, надмірні ролі, спільна відповідальність, витоки через метадані примірників [358, 233]
Туманні, периферійні	Фізична доступність вузлів; слабкі безпроводові канали; обмежені ресурси для криптографії й оновлень
Мікросервісні, service mesh	Різке зростання числа міжсервісних викликів; надмірна довіра всередині периметра; компрометація sidecar-проксі
Безсерверні (FaaS)	Ін'єкції через події, «отруєні» залежності, складність спостережуваності, ефемерність доказової бази
Гібридні, мультихмарні	Розрив політик між провайдерами; федеративні токени як універсальний ключ; неузгоджене журналювання

Наскрізним висновком є те, що з переходом від верхніх рядків табл. 1.1 до нижніх переважна частка ризику зміщується від «зламу периметра» до *некоректної конфігурації довіри* між компонентами — саме тому подальші розділи (зокрема розділ 12) розглядають архітектуру нульової довіри як системну відповідь [342].

1.3 Фундаментальні властивості розподілених систем та їхні безпекові наслідки

1.3.1 Прозорість, масштабованість, часткові відмови

Прозорість (доступу, розміщення, міграції, реплікації, відмов) є проєктною чеснотою й водночас безпековою проблемою: приховуючи від застосунку факт, що дані отримано з іншої репліки або іншої юрисдикції, вона робить непомітними й підміну джерела, і порушення вимог локалізації даних [328]. **Масштабованість** породжує еластичність, а разом з нею — можливість економічного виснаження ресурсів (атаки типу *denial-of-wallet*), коли автоматичне масштабування перетворює атаку на доступність в атаку на бюджет.

Часткова відмова — властивість, якої принципово не має локалізована система: частина вузлів працює, частина ні, і жоден вузол не має достовірного знання про те, які саме. Для захисту це означає, що стан «немає відповіді» є нерозрізненним із станами «вузол знищено», «канал перервано», «вузол скомпрометовано й мовчить». Отже, будь-який механізм безпеки,

що покладається на негативну відповідь (наприклад, синхронну перевірку відкликання сертифіката [140]), потребує явно визначеної політики поведінки за відсутності відповіді: *fail-closed* чи *fail-open*.

1.3.2 Асинхронність і відсутність глобального часу

В асинхронній моделі немає верхньої межі на затримку доставки повідомлення й на швидкість обчислень вузла. Немає й глобального годинника: порядок подій можна встановити лише частково, через відношення «сталося раніше» та логічні мітки часу [259]. Безпекові наслідки є прямими й серйозними:

- атаки повторного відтворення й зсуву вікна валідності токенів (`iat`, `nbf`, `exp` у JWT [240]) стають можливими в разі розсинхронізації годинників вузлів;
- кореляція подій у SIEM за часовими мітками різних вузлів дає хибну причинність, якщо не використано логічні або гібридні годинники;
- компрометація служби синхронізації часу перетворюється на повноцінний вектор атаки на криптографічні протоколи й на журнали аудиту (докладніше — у розділі 14).

1.3.3 Теорема CAP, модель PACELC і моделі узгодженості

Теорема CAP стверджує, що за наявності мережного розділення (P) система не може одночасно гарантувати лінеаризовність (C) і доступність (A); практично вибір робиться між CP і AP [185]. Модель PACELC уточнює: *якщо* є розділення (P), обирають між A і C; *інакше* (Else, E) — між затримкою (L) і узгодженістю (C) [71]. З погляду безпеки істотно, що мережне розділення — не лише природна подія, а й *керований зловмисником* стан: цілеспрямована атака на маршрутизацію, DNS або канал зв'язку переводить систему в той режим, у якому її гарантії свідомо ослаблені. Це формує окремий клас загроз — **атаки на модель узгодженості**:

- у AP-системах штучне розділення дає змогу здійснити подвійне витрачання або обійти обмеження (наприклад, повторно використати одноразовий код, бо репліки ще не зійшлися);
- у CP-системах те саме розділення є економічно ефективною відмовою в обслуговуванні: досить ізолювати кворум, аби система коректно, але цілком припинила роботу;
- механізми остаточної узгодженості (eventual consistency) створюють вікно, у якому відкликання прав доступу ще не поширилося на всі репліки — класична причина «привидів доступу» після звільнення співробітника [251].

Практичний висновок для проєктувальника: модель узгодженості має обиратися не лише за критерієм продуктивності, а й як *параметр політики безпеки*, з явним аналізом того, які інваріанти безпеки порушуються у вікні неузгодженості.

1.4 Вісім хибних припущень розподілених обчислень: безпекова інтерпретація

Сформульовані Л. П. Дойчем (L. Peter Deutsch) і доповнені Дж. Гослінгом «вісім хибних припущень розподілених обчислень» традиційно розглядають як інженерні пастки [394]. Проте кожне з них має і безпекове прочитання, у якому хибність припущення стає готовим вектором атаки:

1. *Мережа надійна.* Наслідок: механізми захисту, що припускають доставку (розсилання списків відкликання, синхронне журналювання), деградують у fail-open. Атака: селективне блокування контрольного трафіку.
2. *Затримка дорівнює нулю.* Наслідок: тайм-аути автентифікації підбираються «з запасом», що розширює вікно для атак повторного відтворення й перехоплення сеансу.
3. *Пропускна здатність нескінченна.* Наслідок: повне журналювання й глибока інспекція трафіку вимикають «для швидкодії», створюючи сліпі зони моніторингу.
4. *Мережа безпечна.* Найпряміше припущення: воно легітимізує довіру до внутрішнього сегмента й уможливлює латеральне переміщення; його заперечення — це і є принцип нульової довіри [342, 186].
5. *Топологія незмінна.* Наслідок: статичні списки дозволених адрес та правила фаєрвола застарівають; у контейнерних середовищах адреса вузла не є ідентичністю — потрібна криптографічна ідентичність робочого навантаження.
6. *Адміністратор один.* Наслідок: у мультихмарній системі політики формуються різними командами; розрив між ними — типове джерело надлишкових прав і неузгодженого аудиту.
7. *Вартість транспортування нульова.* Наслідок: наскрізне шифрування й підписування кожного повідомлення сприймають як «дорогі» й обмежують периметром, залишаючи міжсервісний трафік у відкритому вигляді.
8. *Мережа однорідна.* Наслідок: різні стеки (провідні, безпроводові, промислові) мають різні моделі загроз; уніфікована політика захисту або надмірна для одних, або недостатня для інших [212].

Дидактична цінність цього переліку для аспіранта полягає в тому, що він є готовим чек-листом для критичного аналізу будь-якої архітектурної пропозиції: для кожного припущення слід указати, де саме в системі воно неявно зроблено і який захід його компенсує.

1.5 Моделі відмов, консенсус і межа досяжних гарантій цілісності

Формально відмови класифікують за спостережуваною поведінкою вузла (табл. 1.2). Ця класифікація є безпосереднім містком між надійністю й безпекою: зловмисник — це вузол, який реалізує найгіршу з допустимих моделей поведінки.

Таблиця 1.2 — Моделі відмов вузлів і їхнє безпекове прочитання

Модель	Прояв	Безпекове прочитання
Crash (аварійна зупинка)	Вузол припиняє роботу й більше не відповідає	Відмова в обслуговуванні; втрата свідчень аудиту
Omission (пропуски)	Вузол не надсилає або не приймає частину повідомлень	Селективна цензура подій безпеки, приховування тривог
Timing (часові)	Відповідь поза допустимим інтервалом	Порушення протоколів із часовими припущеннями, зсув вікон валідності
Byzantine (довільні)	Вузол надсилає різним адресатам суперечливі або підроблені дані	Модель скомпрометованого або зловмисного вузла, інсайдер

Задача **консенсусу** полягає в тому, щоб коректні вузли дійшли спільного рішення за умов відмов. Результат Фішера, Лінч і Патерсона (FLP) доводить, що в повністю асинхронній системі не існує детермінованого протоколу, який гарантує досягнення консенсусу за наявності навіть однієї аварійної відмови [172]. Це не інженерна незручність, а фундаментальна межа: будь-яка реальна система обходить її, послаблюючи модель (часткова синхронність, детектори відмов) або відмовляючись від детермінованої термінації (рандомізація). Для безпеки звідси випливає принципова теза: *абсолютна гарантія узгодженого стану в розподіленій системі недосяжна*, тож політику захисту слід будувати як таку, що коректно поводиться у стані невизначеності.

Для візантійських відмов класичний результат Лемпорта, Шостака і Піза встановлює нижню межу кількості вузлів: за усних (неавтентифікованих) повідомлень узгодження можливе лише тоді, коли

$$n \geq 3f + 1, \tag{1.2}$$

де n — загальна кількість вузлів, f — максимальна кількість візантійських вузлів [260]. За наявності неспростовних (підписаних) повідомлень у

синхронній моделі це обмеження знімається: узгодження досяжне за будь-якої кількості зрадників [260] — що є одним з найважливіших практичних аргументів на користь криптографічного підписування міжвузлової взаємодії (розділ 9). Слід, однак, пам'ятати, що в частково синхронних моделях, на які спираються практичні BFT-протоколи, межа $n \geq 3f + 1$ зберігається й за наявності підписів (розділ 13). Іншими словами, *криптографія купує стійкість там, де її не може дати сама лише надлишковість*: збільшення n без автентифікації повідомлень підвищує вартість атаки лінійно, тоді як підписування змінює саму межу досяжного.

1.6 Властивості безпеки розподілених інформаційних ресурсів

Базова тріада конфіденційність — цілісність — доступність, закріплена в ISO 7498-2 [228] та ДСТУ EN ISO/IEC 27001:2023 [20], для розподілених ресурсів є необхідною, але недостатньою. Термінологія RFC 4949 [365] і практика побудови розподілених систем додають: **автентичність** (походження даних і сутності), **підзвітність** (можливість однозначно приписати дію суб'єктові), **невідмовність**, **спостережуваність** (можливість відновити внутрішній стан за зовнішніми сигналами) і **приватність**. Спостережуваність варто виокремити як властивість, специфічну саме для розподілених систем: у монолітній системі вона тривіальна, у мікросервісній — потребує окремої підсистеми наскрізного трасування, без якої розслідування інциденту неможливе в принципі.

Доступність розподіленого ресурсу піддається кількісному оцінюванню. Для n незалежних реплік з коефіцієнтами готовності a_i, з яких для обслуговування достатньо будь-якої однієї, і для послідовного ланцюга з m критичних ланок маємо:

$$A_{\parallel} = 1 - \prod_{i=1}^{n} \bigl(1 - a_i\bigr), \qquad A_{\rightarrow} = \prod_{j=1}^{m} a_j. \tag{1.3}$$

Для систем із кворумом, де рішення ухвалюється за наявності щонайменше q працездатних вузлів з n однакових з готовністю a:

$$A_{q/n} = \sum_{k=q}^{n} \binom{n}{k} a^{k} \bigl(1 - a\bigr)^{n-k}. \tag{1.4}$$

Числова ілюстрація. Нехай $a = 0{,}99$ (близько 3,65 доби простою на рік), $n = 5$, $q = 3$. Тоді $A_{3/5} \approx 0{,}99999$, тобто очікуваний простій скорочується приблизно до 5 хвилин на рік. Проте цей результат справедливий *лише за умови незалежності відмов*. Саме тут проходить головна межа між надійністю й безпекою: спільна вразливість програмного забезпечення, спільний

постачальник, спільний майданчик або спільний обліковий запис адміністратора роблять відмови повністю корельованими, і тоді $A_{q/n}$ вироджується в a одного компонента. Кількісні методи оцінювання захищеності (зокрема імовірнісні моделі й графи атак) розглянуто в розділі 7, а стійкість систем як окрема інженерна дисципліна — у NIST SP 800-160 Vol. 2 [343].

1.7 Простір загроз і поверхня атаки розподіленої системи

Поверхня атаки розподіленої системи — сукупність усіх точок, через які неавторизована сутність може подати вхідні дані, отримати вихідні дані або здобути привілеї. У дусі формальної метрики поверхні атаки, запропонованої П. Манадхатою та Дж. Вінг [275], її оцінюють як зважену суму внесків трьох груп ресурсів — методів (точок входу коду) M, каналів C і елементів даних I:

$$\mathrm{AS}(S) = \sum_{r \in M \cup C \cup I} \frac{\mathrm{dmg}(r)}{\mathrm{eff}(r)}, \tag{1.5}$$

де $\mathrm{dmg}(r)$ — потенційна шкода від використання ресурсу r, а $\mathrm{eff}(r)$ — зусилля (вартість) доступу до нього. Для розподіленої системи істотним є те, що потужність множини каналів (у моделі (1.1) — множини L) у гіршому випадку зростає квадратично з кількістю вузлів ($|L| \le |N|(|N|-1)$), а перехід від моноліту до мікросервісів множить кількість точок входу M на десятки. Структуру поверхні атаки за рівнями подано на рис. 1.2.



Рис. 1.2 — Рівнева структура поверхні атаки розподіленої системи та характерні вектори (класифікація узгоджена з [288])

Загрози доцільно класифікувати щонайменше за трьома незалежними ознаками: за *джерелом* (зовнішній порушник, інсайдер, постачальник, при-

родний або воєнний чинник), за *вектором* (мережа, застосунок, ланцюг постачання, фізичний доступ, соціальна інженерія) та за *наслідком* (порушення конфіденційності, цілісності, доступності, підзвітності). Для розподілених систем окремо виділяють три класи, які практично відсутні в локалізованих:

Латеральне переміщення.
Використання легітимних механізмів довіри між вузлами для розширення плацдарму після початкової компрометації; у термінології MITRE ATT&CK це окрема тактика *Lateral Movement* [288]. Саме цей клас робить порівняно незначну початкову вразливість (наприклад, скомпрометовану робочу станцію) фатальною для всього ресурсу.

Атаки на ланцюг постачання.
Компрометація не самої системи, а її компонентів: бібліотек, образів контейнерів, конвеєрів складання, оновлень. За даними ENISA, 66 % проаналізованих атак на ланцюг постачання були зосереджені на коді постачальника, тобто організацію-клієнта уражали через довірений компонент, а не безпосередньо [163, 103].

Атаки на довіру між вузлами.
Підміна ідентичності вузла, зловживання федеративними токенами, компрометація центру сертифікації або служби видачі токенів. Особливість у тому, що після успіху такої атаки всі подальші дії зловмисника є *криптографічно легітимними* й не виявляються засобами контролю цілісності.

Панорамні огляди ландшафту загроз (ENISA Threat Landscape [161]) і матриці технік [288] слід використовувати як взаємодоповнювальні джерела: перше дає пріоритети й тенденції, друге — операційну деталізацію для побудови сценаріїв виявлення. Методику побудови моделі загроз на цій основі докладно розглянуто в розділі 8 [366].

1.8 Український контекст: розподілені державні ресурси й стійкість під час війни

Українська екосистема електронного урядування є показовим прикладом розподіленого інформаційного ресурсу національного масштабу. Єдиний державний вебпортал електронних послуг «Дія» [40] функціонує як фасад над десятками автономних публічних електронних реєстрів, кожен з яких має власного держателя, власного адміністратора й власний режим захисту [59]. Архітектурно це багаторівнева федеративна система з інтеграційним шаром обміну даними: порушення довіри або доступності будь-якого базового реєстру негайно виявляється в деградації сервісів верхнього рівня, а компрометація інтеграційного шару потенційно уражає всі реєстри одночасно.

Кейс: перенесення державних реєстрів у хмару (2022). До лютого 2022 р. значна частина державних інформаційних ресурсів зберігалася в обмеженому числі фізичних дата-центрів на території України. У моделі (1.1) це означало $\mathcal{R}(d)$ малої потужності з максимально корельованими відмовами: єдине кінетичне ураження майданчика знищувало і продуктив, і резерв. Із початком повномасштабного вторгнення держава здійснила екстрений перехід до географічно розподіленої моделі: постановою Кабінету Міністрів України від 12.03.2022 № 263 було врегульовано функціонування ІКС та публічних електронних реєстрів в умовах воєнного стану, зокрема дозволено розміщення й оброблення їхніх даних поза межами України [11]; системне регулювання хмарних послуг забезпечив ухвалений ще 17.02.2022 Закон «Про хмарні послуги», який набрав чинності вже в умовах воєнного стану [62]. Координацію кіберзахисту й реагування забезпечували Держспецзв'язку [8] та урядова команда CERT-UA [117].

Аналітичні уроки цього кейсу для теорії захисту розподілених ресурсів формулюються так:

1. *Географічний розподіл є засобом безпеки, а не лише надійності.* Він знижує кореляцію відмов, яка, як показано формулою (1.4), є визначальною для реального рівня доступності.
2. *Розподіленість переносить, а не усуває ризик.* Винесення даних до зовнішнього провайдера змінює профіль загроз: замість кінетичного ураження на перший план виходять юрисдикційні ризики, залежність від постачальника й модель спільної відповідальності [233, 62].
3. *Правова готовність є частиною технічної стійкості.* Швидкість міграції визначалася не технічними можливостями, а наявністю нормативної підстави; відсутність заздалегідь ухвалених правових механізмів є вразливістю системи в тому самому сенсі, що й відсутність резервної копії.
4. *Гібридна модель загроз.* Досвід України унікальний тим, що кібератаки поєднувалися з фізичним ураженням інфраструктури та знеструмленням; це вимагає моделювання одночасних скорельованих подій на різних рівнях рис. 1.2, чого класичні каталоги загроз здебільшого не передбачають.

Із цього випливає й актуальний напрям наукових досліджень: побудова моделей захищеності розподілених ресурсів, які явно враховують кореляцію відмов, керовану супротивником, і поєднання кібернетичних та кінетичних впливів — задача, що прямо продовжує проблематику кіберстійкості [343, 60] і активно опрацьовується українською науковою спільнотою [23, 29, 1].

1.9 Термінологічний апарат розділу

Термінологічна неузгодженість є практичною перешкодою: українські нормативні акти, переклади стандартів і англомовна наукова література послуговуються різними позначеннями тих самих сутностей. Табл. 1.3 фіксує вживання термінів, прийняте в цьому посібнику.

Таблиця 1.3 — Термінологічний апарат розділу

Українською	Англійською	Уточнення вживання
Розподілений інформаційний ресурс	distributed information resource	Об'єкт захисту; ширше за «розподілену БД»
Інформаційно-комунікаційна система	information and communication system	Термін Закону [52]; замінив «ІТС»
Часткова відмова	partial failure	Стан, коли частина вузлів працездатна
Візантійська стійкість	Byzantine fault tolerance	Стійкість до довільної поведінки вузлів
Модель узгодженості	consistency model	Контракт щодо видимості оновлень
Поверхня атаки	attack surface	Сукупність точок можливого впливу
Латеральне переміщення	lateral movement	Тактика ATT&CK після компрометації
Ланцюг постачання	supply chain	Джерело компонентів і оновлень
Спостережуваність	observability	Відновлюваність стану за телеметрією
Безпроводовий сегмент	wireless segment	Периферійні та IoT-канали
Кіберстійкість	cyber resilience	Здатність зберігати функції під впливом

Висновки до розділу

Розподіленість не є кількісним ускладненням задачі захисту — вона змінює її якісно. Формальна модель (1.1) показує, що специфічні загрози локалізовані на компонентах, яких у локалізованій системі просто не існує: каналах взаємодії, відображенні розміщення даних і моделі довіри між вузлами. Таксономія архітектур (рис. 1.1, табл. 1.1) демонструє, що з еволюцією від клієнт-серверної моделі до мікросервісних, безсерверних і мультихмарних середовищ основна частка ризику зміщується від подолання периметра до некоректної конфігурації довіри.

Фундаментальні властивості розподілених систем — часткові відмови, асинхронність, відсутність глобального часу — породжують самостійні класи загроз, а компроміси, зафіксовані теоремою CAP і моделлю PACELC, показують, що модель узгодженості є параметром політики безпеки, а не лише продуктивності. Результат FLP і межа $n \geq 3f + 1$ окреслюють теорети-

чний горизонт досяжних гарантій: абсолютна узгодженість недосяжна, а надлишковість без криптографічної автентифікації повідомлень не забезпечує візантійської стійкості. Кількісні співвідношення (1.3)–(1.4) підкреслюють, що реальна доступність визначається не числом реплік, а *незалежністю* їхніх відмов.

Простір загроз розподіленої системи має рівневу структуру (рис. 1.2) і три специфічні класи — латеральне переміщення, атаки на ланцюг постачання й атаки на довіру між вузлами. Український досвід забезпечення функціонування державних реєстрів в умовах повномасштабної війни підтверджує ці висновки емпірично та додає власний: правова й організаційна готовність до перерозподілу ресурсу є такою самою складовою стійкості, як і технічні механізми захисту. Ці положення є вихідними для розділів змістових модулів (розділи 2–5), а також для нормативного, математичного та ризик-орієнтованого блоків посібника.

Питання для самоперевірки

1. Як співвідносяться поняття «інформаційний ресурс», «інформаційна система», «інформаційно-комунікаційна система» та «розподілена система» у чинному законодавстві України?
2. Які компоненти формальної моделі (1.1) відсутні в локалізованій системі й чому саме вони визначають специфіку захисту розподіленого ресурсу?
3. Наведіть три ознаки таксономії архітектур розподілених систем і поясніть, чому вони є ортогональними.
4. Чим профіль вразливостей однорангової (P2P) архітектури принципово відрізняється від профілю багаторівневої?
5. Поясніть, чому властивість прозорості, будучи проєктною чеснотою, є водночас безпековою проблемою. Наведіть приклад.
6. Чому стан «немає відповіді від вузла» є проблемою саме для механізмів безпеки? Порівняйте політики fail-open і fail-closed.
7. Як відсутність глобального часу впливає на достовірність кореляції подій у системах моніторингу безпеки?
8. Сформулюйте теорему CAP і модель PACELC. Чому мережне розділення слід розглядати як стан, керований порушником?
9. Які інваріанти безпеки можуть порушуватися у вікні остаточної узгодженості? Наведіть щонайменше два приклади.
10. Дайте безпекову інтерпретацію щонайменше п’яти з «восьми хибних припущень розподілених обчислень» стосовно конкретної відомої вам системи.

11. Порівняйте моделі відмов crash, omission, timing і Byzantine за наслідками для цілісності та підзвітності.
12. У чому полягає результат FLP і які практичні наслідки він має для проєктування політик безпеки розподілених систем?
13. Обчисліть $A_{q/n}$ для $n = 7$, $q = 4$, $a = 0{,}98$ і поясніть, за яких умов отримане значення втрачає силу.
14. Побудуйте оцінку поверхні атаки за формулою (1.5) для гіпотетичної мікросервісної системи з десяти сервісів і поясніть, які припущення ви зробили щодо dmg та eff.
15. Які уроки перенесення українських державних реєстрів у хмарні середовища є узагальнюваними для інших держав, а які зумовлені специфікою воєнного стану?

РОЗДІЛ 2

Класи розподілених систем і вразливостей

Розділ відповідає змістовому модулю I «Класи розподілених систем і вразливостей» (тема 1) робочої програми дисципліни й систематизує загрози розподіленим інформаційним ресурсам залежно від того, як розподілено керування, ідентичність, транспортування, координацію і дані. Структуру викладу узгоджено з галуззю знань Distributed Systems Security зведення CyBOK[1] [390] і поглиблено формальними моделями, кількісними оцінками й українським контекстом. На відміну від розділу 1, де архітектури класифіковано за зв'язністю вузлів, моделлю розгортання і гранулярністю сервісів, тут головною ознакою є *схема координації*: саме вона визначає, де розташована довіра і що атакує порушник.

2.1 Класи розподілених систем

2.1.1 Формальна модель і ознака координації

Розподілену систему подамо кортежем

$$\mathcal{D} = \langle V,\, E,\, R,\, S,\, \Gamma \rangle,$$

де V — множина вузлів; $E \subseteq V \times V$ — логічні канали, що утворюють **оверлейний граф** $G = (V, E)$ поверх фізичної мережі; R — ресурси; S — послуги; Γ — **схема координації**, тобто правило, яке для кожного рішення (куди направити запит, хто зберігає ключ, у якому порядку застосувати операції) вказує, *хто* його ухвалює і на основі *якого* подання стану. Для вузла v позначимо $N(v)$ множину сусідів, а $\mathrm{view}(v)$ — спостережувану ним частину глобального стану.

За CyBOK [390] розрізняють два широкі класи. У **децентралізованих** системах Γ локальна: вузол ухвалює рішення лише на підставі $\mathrm{view}(v)$, глобального координатора немає; типовий представник — однорангові (**P2P**) системи. У **скоординованих** системах обмін повідомленнями, реплікація й упорядкування створюють *ілюзію* логічно централізованого ресурсу чи служби. Цей клас поділяють на **координацію ресурсів** (Γ_R), коли служба реплікується на розподіленій платформі під керуванням планувальника чи площини керування (кластери високопродуктивних обчислень, HPC; ґрід,

[1] Матеріал розділу частково ґрунтується на CyBOK © Crown Copyright, The National Cyber Security Centre 2021, ліцензія Open Government Licence v3.0 (http://www.nationalarchives.gov.uk/doc/open-government-licence/). Виклад є авторським, з доповненнями й поглибленнями.

хмари, мережі доставки контенту, CDN), і **координацію послуг** (Γ_S), коли розосереджені учасники спільно породжують одну колективну послугу із заданими вимогами узгодженості (транзакційні бази даних, сховища «ключ–значення», розподілені реєстри, сервісні архітектури, системи публікації–підписки). Межа умовна: хмарна платформа (Γ_R) зазвичай містить службу координації (Γ_S) у власній площині керування.

2.1.2 Підкласи однорангових систем

P2P-системи поєднують симетрію інтерфейсів (вузол є і клієнтом, і сервером), стійкість до відмов, живучість даних завдяки реплікації, використання ресурсів на краю мережі й неоднорідність внесків учасників; їхні базові операції — *іменування*, *маршрутизація* і *пошук* [390]. **Неструктуровані** мережі (Gnutella, Freenet) шукають затопленням або випадковими блуканнями. **Структуровані** мережі на основі розподіленої геш-таблиці (DHT), як-от Chord [387] чи Kademlia [277], розміщують ідентифікатори вузлів і ключів у просторі $[0, 2^w - 1]$, відповідальність за ключ визначає функція відстані (для Kademlia $d(a, b) = a \oplus b$), а пошук завершується за $O(\log |V|)$ кроків. **Гібридні** мережі (BitTorrent із трекерами та DHT) поєднують обидва підходи, а **ієрархічні** (суперузли eDonkey, KaZaA) передають частині вузлів координаційну роль. Розподілені реєстри займають проміжне місце: поширення транзакцій у них однорангове, а ведення реєстру є координацією послуги через консенсус (розділ 13). Таксономію подано на рис. 2.1.

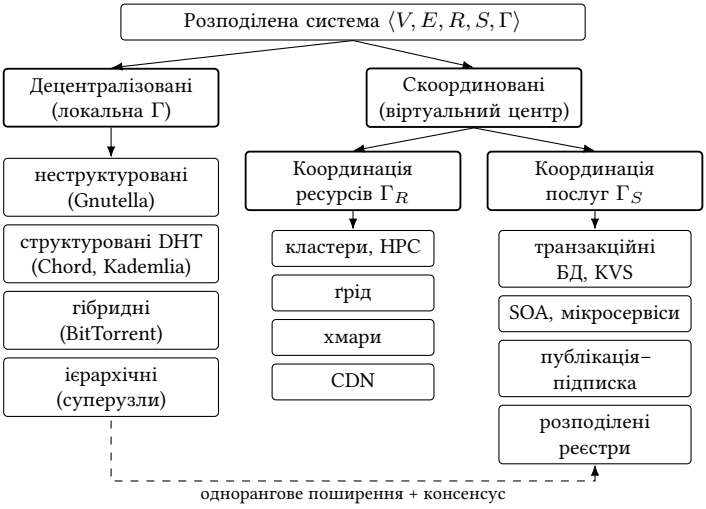


Рис. 2.1 — Таксономія розподілених систем за типом координації (за [390])

2.1.3 Ознаки класифікації та наслідки для поверхні атаки

Клас конкретної системи визначають за ознаками: *носій рішень* (вузол, координатор, кворум); *повнота подання стану*; *режим допуску* (відкритий чи дозвільний); *вимоги узгодженості*; *якір довіри*. Їхні значення визначають, де концентрується ризик (табл. 2.1).

Таблиця 2.1 — Класи розподілених систем за ознаками координації

Ознака	Децентралізовані	Координація ресурсів	Координація послуг
Носій рішень	кожен вузол локально	планувальник, площина керування	кворум або лідер протоколу узгодження
Подання стану	часткове, $N(v)$	глобальне в координаторі	погоджене між репліками
Допуск	переважно відкритий	дозвільний, через оператора	дозвільний або економічний
Якір довіри	відсутній або ідентифікатор-ключ	оператор платформи	більшість чесних учасників
Концентрація ризику	ідентичність і маршрутизація	координатор, метадані, багатоорендність	упорядкування, фіксація, спільний стан

Децентралізовані системи не мають ні єдиної точки відмови, ні органу, що засвідчує відповідність ідентифікатора фізичній сутності. Системи з координацією ресурсів переносять ризик на площину керування, компрометація якої дає контроль над усіма орендарями. Системи з координацією послуг уразливі щодо *семантики* спільного стану: порушник, що не може зламати криптографію, нав'язує хибний порядок або хибний час.

2.2 Класи вразливостей і загроз

2.2.1 Вразливість, загроза, атака: розподілене прочитання

Вразливість — вада проєктування чи експлуатації, що дозволяє скомпрометувати систему; **загроза** — можливість або ймовірність завдання шкоди через вразливість [390, 365]. За таксономією Авіжієніса–Лапрі–Ренделла–Лендвера вразливість є внутрішньою вадою (fault), яка разом із зовнішньою зловмисною взаємодією — **атакою** — породжує помилковий стан (error) і відмову послуги (failure) [86]. У розподіленій системі помилковий стан одного вузла *поширюється* каналами оверлею, а безпека є *наскрізною* (end-to-end) властивістю всього шляху даних. Тому вразливості доцільно групувати не за технологіями, а за *функціональними блоками*, що визначають розподіленість і водночас утворюють поверхню атаки.

2.2.2 Чотири функціональні елементи

Згідно з CyBOK [390], функціонування розподіленої системи охоплює послідовність чотирьох елементів $\mathcal{F} = \{F_A, F_T, F_C, F_D\}$ (рис. 2.2): F_A — *по-*

токи даних і доступ, тобто надходження авторизованих входів під контролем доступу та допуску; F_T — *транспортування* даних до ресурсів і між ними; F_C — *координація*: синхронізація, реплікація, членство, упорядкування, консенсус, фіксація транзакцій; F_D — *керування даними* для застосунків (транзакції, бази даних, сховища, обчислення).

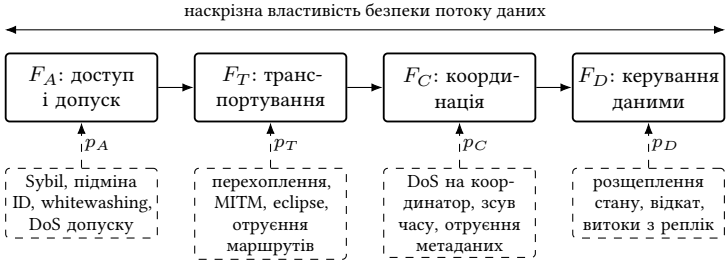


Рис. 2.2 — Функціональні елементи розподіленої системи та характерні атаки на них (за [390])

Нехай потік даних послідовно проходить усі чотири елементи, а p_i — імовірність того, що за розрахунковий період порушник успішно використає вразливість елемента F_i, $i \in \{A, T, C, D\}$. За припущення незалежності імовірність компрометації наскрізної властивості потоку

$$P_{\text{e2e}} = 1 - \prod_{i \in \{A,T,C,D\}} (1 - p_i)\,. \tag{2.1}$$

Для $p_A = 0{,}02$, $p_T = 0{,}01$, $p_C = 0{,}03$, $p_D = 0{,}02$ дістаємо $P_{\text{e2e}} = 1 - 0{,}98 \cdot 0{,}99 \cdot 0{,}97 \cdot 0{,}98 \approx 0{,}078$: наскрізний ризик майже вчетверо перевищує ризик типового елемента ($p = 0{,}02$) і майже у вісім разів — ризик найзахищенішого ($p_T = 0{,}01$). Формула (2.1) спирається на незалежність та ізольовано оцінені p_i. Реальні атаки *композиційні* (Sybil-вузли, допущені через F_A, здійснюють eclipse на рівні F_T і порушують F_C): успіх на одному елементі підвищує умовні ймовірності на наступних, тож ізольовані оцінки p_i занижують реальний ризик. За довільної залежності подій гарантовано лише межі $\max_i p_i \le P_{\text{e2e}} \le \sum_i p_i$, а точніше оцінювання потребує моделей ризику розділу 8 та методів на кшталт [38].

2.2.3 Відображення елементів на вразливості та атаки

Для P2P-систем CyBOK виокремлює **P2P-операції** (P-OP: виявлення, запит, маршрутизація, завантаження) і **P2P-структури даних** (P-DS: таблиці маршрутизації, спільні ресурси) [390]. Крім DoS/DDoS, специфічними атаками на них є *змова* вузлів проти механізмів репутації, *забруднення* контенту й

отруєння індексів [264], *whitewashing* і цензурування, *атаки на маршрутизацію*, *шахрайство з картами буфера* в потоковому мовленні, *Sybil-* [152] та *eclipse*-атаки [369]. На відміну від клієнт-серверних аналогів, порушник мусить масштабувати частку своїх вузлів пропорційно розміру оверлею й координувати їхню змову. Узагальнення для всіх класів систем подано в табл. 2.2.

Таблиця 2.2 — Функціональні елементи, вразливості, атаки та наслідки для CIA

Елемент	Типові вразливості	Атаки	CIA
F_A доступ і допуск	дешеві ідентифікатори; відкритий допуск; багато точок перевірки прав; довіра до самопроголошених атрибутів вузла	маскування, підміна й крадіжка ідентифікатора, Sybil, whitewashing, виснаження ресурсів допуску	C, I, A
F_T транспортування	відсутність автентифікації кінцевих точок; часткове подання стану; маршрутизація на основі непідтверджених даних	перехоплення, MITM, вибіркове відкидання, отруєння маршрутів, eclipse, хибні події pub/sub	C, I, A
F_C координація	виділений лідер; залежність від часу; неавтентифіковані реєстри й конфігурації; однорідність реплік	DoS на координатор, штормові перевибори, зсув часу, порушення порядку, отруєння метаданих	I, A
F_D керування даними	слабка узгодженість; кеші без контексту авторизації; неконтрольовані копії; відсутність походження	розщеплення й відкат стану, забруднення, витоки через репліки, побічні й приховані канали	C, I, A

Зіставлення з табл. 2.1 показує: для децентралізованих систем домінують рядки F_A і F_T, для координації ресурсів — F_A і F_C, для координації послуг — F_C і F_D.

2.3 Контроль доступу/допуску та керування ідентифікаторами

2.3.1 Допуск вузлів на відміну від доступу користувачів

Контроль допуску (admission control) визначає, *чи може* ресурс, служба або вузол стати учасником розподіленої системи, тоді як **контроль доступу** визначає, *які дії* вже допущений суб'єкт може виконувати над об'єктами [390]. Формально в момент t система підтримує множину членства $M_t \subseteq \mathcal{I}$ над простором ідентифікаторів $\mathcal{I}$. Політика допуску $\mathrm{adm}\colon \mathcal{I} \times \mathcal{E} \to \{\top, \bot\}$ відображає пару «кандидат–свідчення» (сертифікат, атестацію платформи, розв'язану криптографічну задачу, рекомендацію наявних учасників) на рішення, а відношення доступу $Acc \subseteq \mathcal{I} \times O \times A$ застосовне лише до суб'єктів із M_t. Отже, контроль доступу є *умовним* щодо допуску: жодна досконала

політика RBAC чи ABAC (див. розділ 10) не захистить систему, у якій M_t заповнено ідентифікаторами порушника.

Специфіка допуску в розподіленій системі така. Точок перевірки багато, а службовий обмін для контролю доступу сам розширює поверхню атаки. Для вузла ідентифікатор визначає не лише «хто», а й «*де*»: у DHT він задає позицію в адресному просторі, тож вибір власного ідентифікатора рівнозначний вибору жертви. Допуск стосується й не-людських сутностей (реплік, агентів, пристроїв IoT, безпроводових сенсорів), свідчення ідентичності яких доводиться будувати на апаратних коренях довіри або ключах вузла. Нарешті, допуск ресурсомісткий і тому є мішенню DoS: затоплення запитами на приєднання виснажує координатор або змушує вузли P2P безперервно перебудовувати таблиці маршрутизації (штучний *churn*) [390].

2.3.2 Атаки на ідентичність вузлів

2.3.2.1 Sybil-атака

Дусер довів, що без логічно централізованого органу, який засвідчує відповідність ідентифікатора фізичній сутності, порушник завжди може представити системі більше ідентичностей, ніж контролює сутностей; усунути це можна лише за нереалістичних припущень про однаковість ресурсів усіх учасників і одночасність їхньої перевірки [152]. Нехай h — кількість чесних ідентифікаторів, B — бюджет порушника, c — вартість створення та підтримання однієї ідентичності, яку висуває політика adm. Тоді частка ідентичностей порушника

$$f = \frac{s}{s+h}, \qquad s = \left\lfloor \frac{B}{c} \right\rfloor . \tag{2.2}$$

Для $h = 10\,000$ і $B = 5\,000$ умовних одиниць за $c = 0{,}5$ (оренда IP-адреси у хмарі) маємо $s = 10\,000$ і $f = 0{,}5$; підвищення вартості до $c = 5$ (наприклад, через прив'язку до перевіреної юридичної особи) дає $s = 1\,000$ і $f \approx 0{,}09$. Отже, будь-який захист від Sybil зводиться до *підвищення* c або *обмеження* s, а частка f є вхідною величиною для оцінок eclipse та захоплення кворуму в підрозділах 2.4 і 2.5. Відомі приклади — Sybil-атаки на DHT BitTorrent і мережу Tor [390]; споріднену проблему скоординованих бот-акаунтів у соціальних мережах досліджено в [30].

2.3.2.2 Крадіжка й підміна ідентифікаторів

Маскування — використання чужого ідентифікатора для отримання його прав — найчастіше реалізується крадіжкою довготривалих облікових даних вузла (ключів, токенів службових облікових записів, клієнтських сертифікатів), повторенням перехопленого свідчення або підміною ідентифі-

катора в неавтентифікованому протоколі виявлення. В оверлеях поширене *захоплення позиції*: порушник генерує ідентифікатори, доки не отримає найближчий до цільового ключа. Протидія — самосертифікуючі ідентифікатори (геш відкритого ключа) або ідентифікатори, призначені центром сертифікації без права вузла обирати позицію [115].

2.3.2.3 Whitewashing

Вузол зі зіпсованою репутацією виходить із системи й повертається з новим ідентифікатором як «чистий» учасник [390]. Якщо G — вигода від шкідливої поведінки за цикл, а ρ_0 — цінність початкової репутації новачка, стратегія вигідна за $G > c - \rho_0$. Звідси правила: новачок отримує мінімальну довіру ($\rho_0 \to 0$), а вартість ідентичності має перевищувати вигоду від одного циклу зловживань.

2.3.3 Розподілене керування ідентифікаторами

Механізми протидії утворюють спектр від централізованих до децентралізованих (табл. 2.3). Централізований орган допуску найефективніший, але суперечить відкритості P2P; децентралізовані методи працюють лише доти, доки частка змовників не досягне критичної маси, і можуть конфліктувати з анонімністю та ощадливістю ресурсів [390, 404].

Таблиця 2.3 — Механізми протидії атакам на ідентичність вузлів

Механізм	Що підвищує або обмежує	Обмеження
Центр сертифікації ідентифікаторів [115]	c через перевірку сутності; позицію в оверлеї призначає центр	точка відмови й довіри; суперечить відкритості
Самосертифікуючі ідентифікатори	прив'язують ID до ключа, унеможливлюють підміну	не обмежують кількість ключів, тож не зупиняють Sybil
Криптографічні задачі, доказ ресурсу	c пропорційно обчисленням чи пам'яті	вигідні порушникові з потужною інфраструктурою
Обмеження за мережевими префіксами	s на одну підмережу або автономну систему	обходиться ботнетами з розосередженими адресами
Соціальний граф довіри [422]	s кількістю «атакувальних ребер» до чесних вузлів	припущення про швидке перемішування графа
Репутація з нульовим стартом	вигоду від whitewashing	повільне залучення нових чесних учасників
Прив'язка до апаратних коренів довіри	c до вартості фізичного пристрою	ланцюг постачання, відкликання скомпрометованих

У скоординованих системах керування ідентифікаторами будується як ієрархія або федерація просторів імен: оператор видає вузлам короткоживучі посвідчення за результатами атестації. Федеративні протоколи й DID розглянуто в розділі 10; для *вузла* ж ключовим є не автентифікація сеансу,

а унеможливлення дешевого масового породження ідентичностей і контроль їхньої *позиції* в топології. Українські дослідники пропонують, зокрема, обмін ідентифікаційними даними між вузлами пірингової мережі каналом NFC із доказами з нульовим розголошенням, використовуючи фізичну близькість як додаткове свідчення допуску [26].

2.4 Транспортування даних

2.4.1 Оверлей, підкладка й позиції порушника

Кожне ребро (u, v) оверлею відображається на шлях у фізичній мережі (підкладці, underlay), тож порушник може перебувати *на шляху* в підкладці (провайдер, скомпрометований маршрутизатор, точка доступу безпроводового сегмента), *усередині оверлею* (допущені шкідливі вузли) або в обох позиціях. Загрози охоплюють маршрутизацію, обмін повідомленнями, «публікацію–підписку», запуск реакцій на події та стек проміжного програмного забезпечення [390]. *Пасивні* атаки (підслуховування, аналіз трафіку) розкривають зміст або принаймні граф взаємодій навіть для зашифрованих даних; *активні* — модифікують, повторюють, затримують і вибірково відкидають повідомлення. У **атаці посередника** (MITM) порушник встановлює окремі з'єднання з обома сторонами й непомітно змінює повідомлення, якщо кінцеві точки не автентифікуються [390]; у системах «публікація–підписка» додаються хибні публікації й затоплення подіями.

2.4.2 Маніпуляції маршрутизацією на рівні оверлею

Шкідливому вузлу оверлею достатньо неправдиво відповідати на запити пошуку. **Отруєння таблиць маршрутизації** вносить до таблиць чесних вузлів фіктивні контакти; **атаки притягання** й **відштовхування** штучно підвищують привабливість шкідливих вузлів або знижують привабливість чесних під час вибору шляху [390]. Нехай пошук ключа проходить ℓ проміжних вузлів, кожен з яких незалежно є шкідливим з імовірністю f (див. (2.2)), а шкідливий вузол зриває пошук. Тоді ймовірність успіху одного пошуку та пошуку через r неперетинних шляхів становлять

$$P_1 = (1-f)^{\ell}, \qquad P_r = 1 - \bigl(1-(1-f)^{\ell}\bigr)^{r}. \tag{2.3}$$

Для мережі з $|V| = 10^6$ вузлів у Chord середня довжина пошуку близька до $\tfrac{1}{2}\log_2 |V| \approx 10$ [387]; за $f = 0{,}1$ маємо $P_1 = 0{,}9^{10} \approx 0{,}35$, а за $r = 4$ неперетинних шляхів — $P_4 = 1 - 0{,}65^4 \approx 0{,}82$. Надлишкова маршрутизація підвищує стійкість ціною множення службового трафіку, тому її поєднують із перевіркою щільності ідентифікаторів у таблицях [115, 404].

2.4.3 Eclipse-подібна ізоляція

Eclipse-атака оточує чесний вузол змовниками, які частково або повністю перекривають його подання решти системи й можуть приховувати, підміняти та затримувати всі його зовнішні взаємодії (рис. 2.3). Це композиційна атака, що поєднує Sybil, отруєння маршрутів, DoS і цензурування [390, 369]. Якщо вузол підтримує d вихідних з'єднань, обраних незалежно з пулу адрес із часткою адрес порушника f_{eff}, імовірність повної ізоляції

$$P_{\text{ecl}} = f_{\text{eff}}^{\,d}. \tag{2.4}$$

Для $d = 8$ і $f_{\text{eff}} = 1/11$ (приклад до (2.2)) маємо $P_{\text{ecl}} \approx 4{,}7 \cdot 10^{-9}$, а для $f_{\text{eff}} = 0{,}5$ — уже $\approx 3{,}9 \cdot 10^{-3}$. Визначальна саме *ефективна* частка: достатньо заповнити своїми адресами таблиці самої жертви. Так було ізольовано вузол Bitcoin: після затоплення таблиць адрес (зокрема з наступним перезапуском жертви) усі її з'єднання вели до вузлів порушника, що відкривало шлях до подвійних витрат, егоїстичного майнінгу й штучних розгалужень ланцюга [197]; для Ethereum подібна атака потребувала лише двох хостів, а вразливість автори пов'язали із запозиченням протоколу Kademlia [276]. Протидія зменшує f_{eff} і збільшує d: випадкове витіснення записів, обмеження адрес з однієї підмережі, «якірні» з'єднання після перезапуску, обмеження вхідного ступеня й аудит симетричності таблиць сусідів [369, 197].

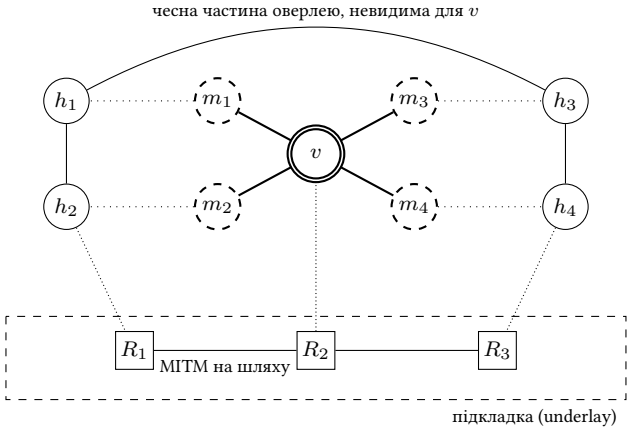


Рис. 2.3 — Eclipse-ізоляція вузла v в оверлеї та позиція порушника на шляху в підкладці: h_i — чесні вузли, m_i (штрихові) — шкідливі, R_i — маршрутизатори (за [369, 390])

2.4.4 Захищені канали та їхні межі

Базовою відповіддю на загрози F_T є канали із взаємною автентифікацією, конфіденційністю й цілісністю — TLS 1.3 і mTLS [336], IPsec [247]; криптографію та PKI розглянуто в розділі 9, а розміщення захищених каналів, зокрема в безпроводових сегментах, — у розділі 11. Для оверлеїв суттєві три уточнення: ключ каналу має бути прив'язаний до *оверлейного* ідентифікатора, інакше порушник отримає захищений канал до хибного учасника; канал не рятує від шкідливого вузла на *іншому кінці*, тож від отруєння маршрутів та eclipse захищають лише механізми рівня оверлею; шифрування не приховує метаданих обміну.

2.5 Служби управління ресурсами та координація

2.5.1 Склад координаційного шару

Елемент F_C охоплює механізми (переважно протоколи проміжного програмного забезпечення) синхронізації, реплікації, зміни членства, упорядкування, консенсусу й фіксації транзакцій [390]. Практично це **планування й розподіл ресурсів** (менеджери кластерів, планувальники ґріду й HPC, площини керування хмар), **служби імен і каталогів** (реєстри служб, виявлення сервісів, каталоги учасників; захист DNS — у розділі 11), **синхронізація часу** (фізичні годинники NTP і PTP та логічні годинники Лемпорта, що впорядковують події без глобального часу [259]) і **координаційні служби** на кшталт ZooKeeper та etcd, які в реплікованій логічно централізованій службі надають конфігурацію, членство, вибір лідера й блокування з лінеаризованими змінами стану [206, 399].

Стан координаційного шару подамо кортежем $\sigma_C = \langle cfg, M_t, lead, lease, \prec \rangle$ — конфігурація, членство, лідер, чинні оренди (leases) і частковий порядок операцій. Над ним формулюються інваріанти безпеки: не більше одного лідера на епоху, взаємне виключення власників оренди, узгодженість $\prec$ з причинністю, автентичність *cfg*. Атака на F_C — це спроба порушити інваріант або зробити σ_C недоступним; оскільки σ_C керує рештою елементів, ефект множиться: один хибний запис у реєстрі служб перенаправляє трафік тисяч клієнтів.

2.5.2 Атаки на координацію

2.5.2.1 DoS на координатор

Логічно централізована координація має спостережувану точку концентрації — лідера, планувальник, сервер каталогу. Порушник виснажує саме її або затримує службові повідомлення, спричиняючи *штормові перевибори*: лідер постійно втрачає повноваження через пропущені «серцебиття», і формально працездатна система не виконує записів. Нехай ансамбль має

$n = 2k + 1$ реплік із незалежною стаціонарною доступністю a, а служба працює, доки доступна більшість. Тоді

$$A_n = \sum_{j=k+1}^{n} \binom{n}{j} a^j (1-a)^{n-j}, \qquad P_{\text{захопл}}(n, q) = \sum_{j=k+1}^{n} \binom{n}{j} q^j (1-q)^{n-j}, \tag{2.5}$$

де $P_{\text{захопл}}$ — імовірність того, що порушник, компрометуючи кожну репліку незалежно з імовірністю q, отримає більшість. Перша формула є окремим випадком кворумної моделі доступності з розділу 1 для кворуму більшості ($k + 1$ з n); як і там, для $n = 5$ і $a = 0{,}99$ маємо $A_5 \approx 0{,}99999$. Якщо ж DoS-атака виводить з ладу дві репліки, решта трьох мусять бути доступними одночасно: $A = 0{,}99^3 \approx 0{,}970$ — нижче, ніж в однієї репліки без атаки, тобто майже доба простою на місяць. Для захоплення за $q = 0{,}2$ маємо $P_{\text{захопл}}(5; 0{,}2) \approx 0{,}058$ і $P_{\text{захопл}}(7; 0{,}2) \approx 0{,}033$. Проте однакове програмне забезпечення на всіх репліках робить компрометації корельованими, і одна вразливість дає порушникові *усі* репліки, тож розмір ансамблю підвищує стійкість лише разом із різноманітністю реалізацій і рознесенням по доменах відмов. Візантійські моделі та їхні пороги розглянуто в розділах 1 і 13.

2.5.2.2 Порушення упорядкування й часу

Порушник, що контролює канал, змінює порядок доставки, повторює старі або затримує нові повідомлення, щоб репліки застосували операції в різній послідовності. Особливо вразливі схеми, де порядок визначає *заявлена* мітка часу: за стратегією «останній запис перемагає» запис із навмисно майбутньою міткою витіснятиме всі легітимні оновлення [251]. Зсув фізичного часу руйнує оренди й блокування (два вузли одночасно вважають себе власниками), строки чинності сертифікатів і токенів, TTL кешів і кореляцію журналів. Для NTP показано, що порушник, зокрема поза шляхом передавання, здатен перешкоджати синхронізації або зсувати час клієнтів [274]; відповідь — криптографічний захист NTS [173], кілька незалежних джерел часу та протоколи, безпека яких не залежить від точності годинників (логічні годинники, епохи, монотонні лічильники).

2.5.2.3 Отруєння метаданих

Метадані координації (записи реєстрів, каталоги, конфігурації, заявлені ресурси вузлів) часто захищені слабше за дані застосунків, хоча керують ними. Типові сценарії: реєстрація шкідливого примірника під ім'ям легітимної служби; запис хибної конфігурації в доступний із мережі неавтентифікований ZooKeeper чи etcd (etcd підтримує TLS з автентифікацією клієнтів

і однорангових вузлів за сертифікатами, але її треба ввімкнути [399]); неправдиве оголошення вузлом своїх ресурсів; маніпуляція планувальником для розміщення навантаження порушника на одному фізичному хості з жертвою заради побічних каналів, що експериментально продемонстровано в публічній хмарі [340]. Захист площини керування оркестраторів розглянуто в розділі 12.

2.6 Безпека даних

Властивості CIA застосовні до кожної ланки ланцюга даних (отримання, розподіл, зберігання, використання) і до інтерфейсів між ними: загрози конфіденційності охоплюють витоки, зокрема побічними й прихованими каналами; затримка чи відмова в доступі загрожує доступності; цілісність охоплює й узгодженість, яку спостерігають учасники [390]. Консенсус, кворумну реплікацію, шифрування сховищ і реєстри викладено в розділі 13; тут наголос — на наслідках розподіленості.

2.6.1 Цілісність і узгодженість у реплікованому середовищі

Нехай $\sigma_i(t)$ — стан репліки i, а $\mathcal{O}$ — множина авторизованих операцій. Цілісність реплікованих даних має дві складові: *автентичність походження* (стан отримано лише операціями з $\mathcal{O}$) і *узгодженість* (стани реплік збігаються в сенсі обраної моделі). Порушення будь-якої з них є порушенням цілісності навіть без «зламу». Небезпечні сценарії: *застаріла авторизація* — відкликане право ще не дійшло до репліки чи кешу, де виконується перевірка (різновид TOCTOU); *розщеплення й відкат стану* — недовірене сховище показує різним клієнтам різні або старі версії, що виявляється лише криптографічним зчепленням версій і обміном доказами побаченого стану; *шкідлива репліка* — правдоподібна, але хибна відповідь, проти якої відповідь приймають лише за погодженням достатньої кількості реплік, а ключі служби розподіляють пороговими схемами [335].

2.6.2 Тривалість зберігання

Логічне видалення не знищує копій у репліках, знімках, резервних копіях, журналах реплікації, кешах і на вузлах CDN. У зрештою узгоджених сховищах видалення реалізують «надгробками» (tombstones); якщо їх прибрати до синхронізації всіх реплік, запис «воскресає» з відсталої репліки, що суперечить праву на стирання й обмеженню строку зберігання персональних даних [328, 53]. Практичні підходи — облік усіх місць зберігання, криптографічне стирання (знищення ключа), узгодження строку життя надгробків із максимальним відставанням реплік.

2.6.3 Походження даних

Походження (provenance) описує, звідки дані взялися, якими процесами й від чийого імені їх перетворено. W3C PROV-DM подає його орієнтованим ациклічним графом над сутностями (Entity), діями (Activity) й агентами (Agent) з відношеннями `wasGeneratedBy`, `used`, `wasDerivedFrom`, `wasAttributedTo` тощо [291]. У розподіленому середовищі граф складається з фрагментів різних вузлів, тож кожен фрагмент має бути підписаний агентом-автором і зчеплений із попередніми, інакше порушник «відмиє» забруднені дані, приписавши їм довірене походження. Захищене походження є основою розслідування інцидентів, доказовості й протидії атакам забруднення.

2.6.4 Витоки через репліки та кеші

Репліки для аналітики чи тестування часто розміщують у зонах зі слабшим контролем; геореплікація переносить копію в іншу юрисдикцію; кеш, ключ якого не враховує контексту авторизації, віддає персоналізовану відповідь сторонньому; сама коротша затримка влучання в кеш розкриває факт недавнього звернення. У багатоорендних платформах спільні фізичні ресурси утворюють побічні канали між орендарями [340]. Отже, класифікація даних і політика доступу мають поширюватися на *кожну копію*.

2.6.5 Кейс: система електронної взаємодії «Трембіта» та X-Road

Українська система електронної взаємодії державних електронних інформаційних ресурсів «Трембіта» є системою з координацією послуг, у якій простежуються всі чотири елементи $\mathcal{F}$ [9]; порівняння дає близька за архітектурними рішеннями європейська платформа X-Road [418].

F_A. Підключення відбувається за договором із держателем системи (Мінцифри), після чого адміністратор (ДП «ДІЯ») надсилає налаштування для розгортання локального компонента; система забезпечує електронну ідентифікацію та автентифікацію учасників [9]. Допуск дозвільний і прив'язаний до юридичної особи, тож вартість c у (2.2) висока, а масова Sybil-атака практично виключена. У X-Road центр сертифікації видає сертифікати автентифікації серверам безпеки й сертифікати підпису організаціям зі статусом за OCSP [418].

F_T. Шлюзи безпечного обміну виконують шифрування, уніфіковане накладення кваліфікованої електронної печатки й керування правами доступу до сервісів [9]; сервери безпеки X-Road встановлюють канали із взаємною автентифікацією за сертифікатами [418], тобто автентифікується учасник, а не адреса.

F_C. Ядро системи розповсюджує службові дані між шлюзами, а каталог обліковує учасників, ресурси й сервіси [9] — це мішені для DoS і отрує-

ння метаданих. У X-Road глобальну конфігурацію підписує центральний сервер, а сервери безпеки кешують її разом із відповідями OCSP, тож тимчасова недоступність центральних джерел не зупиняє обміну [418].

F_D. Забезпечуються цілісність і автентичність повідомлень, відомості про історію їхнього руху, протоколювання дій учасників і фіксація фактів передачі персональних даних [9]; у X-Road журнали підписаних повідомлень періодично засвідчуються позначками часу [418], що реалізує захищене походження.

Залишкові ризики: компрометація шлюзу учасника дає порушникові легітимну підписану ідентичність, від якої не захищає жоден механізм допуску; ядро й каталог лишаються критичними об'єктами F_C; журнали самі стають сховищем персональних даних. В умовах воєнного стану саме ці елементи потребують посиленого моніторингу (розділ 14) і планів відновлення (розділ 15).

Висновки до розділу

Схема координації Г є визначальною ознакою класу розподіленої системи з погляду безпеки. Децентралізовані (P2P) системи позбавлені єдиної точки відмови, але й органу, що засвідчує ідентичність, тож їхня поверхня атаки зосереджена в іменуванні, маршрутизації й частковому поданні стану. Системи з координацією ресурсів концентрують ризик у площині керування та метаданих, а системи з координацією послуг — у семантиці спільного стану: порядку, часі, фіксації та узгодженості.

Чотири функціональні елементи — доступ і допуск, транспортування, координація, керування даними — дають технологічно нейтральну схему класифікації вразливостей. Безпека наскрізна, тож ризик потоку не менший за ризик найслабшого елемента й накопичується вздовж усього шляху, а реальні атаки композиційні: Sybil-ідентичності, допущені через F_A, реалізують eclipse у F_T і захоплюють кворум у F_C. Моделі (2.2)–(2.5) пов'язують ці етапи через частку ідентичностей порушника f і вказують важелі захисту: вартість ідентичності, кількість незалежних сусідів і шляхів, розмір і різноманітність ансамблю. Усі вони спираються на припущення про незалежність, яке однорідне програмне забезпечення систематично порушує, — відкритий напрям досліджень. Кейс «Трембіти» та X-Road показує, що дозвільний допуск, підписані метадані, кешування координаційних даних і захищене походження утворюють узгоджений комплекс заходів для систем із координацією послуг.

Питання для самоперевірки

1. Чим децентралізовані системи відрізняються від скоординованих за схемою координації Г? Наведіть по два представники координації ресурсів і координації послуг.
2. Опишіть підкласи P2P-систем (неструктуровані, структуровані, гібридні, ієрархічні) та поясніть, чому в структурованих DHT вибір ідентифікатора вузла має безпекове значення.
3. Назвіть п'ять ознак класифікації розподілених систем і покажіть, як їхні значення визначають концентрацію ризику для кожного класу.
4. Охарактеризуйте чотири функціональні елементи розподіленої системи за CyBOK і наведіть для кожного дві вразливості та відповідну атаку.
5. Чим контроль допуску відрізняється від контролю доступу? Чому політика доступу є умовною щодо політики допуску?
6. Сформулюйте результат Дусера щодо Sybil-атак. Використовуючи формулу (2.2), визначте, якою має бути вартість ідентичності, щоб за $h = 50\,000$ і $B = 10^4$ частка порушника не перевищувала $5\,\%$.
7. За якої умови whitewashing є раціональною стратегією і які проєктні рішення цю умову руйнують?
8. Обчисліть за формулою (2.3) імовірність успіху пошуку при $\ell = 12$, $f = 0{,}15$ для $r = 1$ і $r = 3$. Які накладні витрати супроводжують збільшення r?
9. Поясніть механізм eclipse-атаки на вузол Bitcoin. Чому в формулі (2.4) визначальною є ефективна, а не загальномережева частка порушника?
10. Чому захищений канал (TLS, IPsec) не захищає від атак на маршрутизацію оверлею? Що має бути прив'язано до ключа каналу в однорангових системах?
11. Порівняйте за формулою (2.5) стійкість ансамблів координаційної служби з $n = 3$, 5 і 7 реплік до DoS-атаки, що виводить із ладу дві репліки.
12. Дослідницьке: запропонуйте модель імовірності захоплення кворуму з корельованими вразливостями реплік (наприклад, спільна версія програмного забезпечення) і порівняйте її з біноміальною моделлю.
13. Дослідницьке: як поєднати вимоги права на стирання персональних даних із захищеним незмінним походженням даних у реплікованому середовищі? Запропонуйте архітектурне рішення та критерії його оцінювання.

14. Дослідницьке: проаналізуйте систему «Трембіта» за чотирма функціональними елементами, визначте залишкові ризики координаційного шару й запропонуйте метрики для їхнього моніторингу.

РОЗДІЛ 3

Децентралізовані моделі P2P і атакуючі P2P системи

Розділ відповідає змістовому модулю II «Децентралізовані моделі P2P і атакуючі P2P системи» (тема 2) робочої програми дисципліни. Назву теми слід розуміти як «атаки на P2P-системи та їх пом'якшення»: ідеться про загрози одноранговим оверлеям, а використання P2P-мереж як знаряддя (ботнети) розглянуто лише в кейсі. Розділ поглиблює розділ 2, де запроваджено модель $\langle V, E, R, S, \Gamma\rangle$, підкласи P2P (підрозділ 2.1) і базові атаки на ідентичність і маршрутизацію (підрозділи 2.3, 2.4). Тут розглянуто протоколи чотирьох класів, кількісні моделі їхньої ефективності та стійкості, класифікацію атак за CyBOK[1] [390] і механізми пом'якшення з оцінкою їхньої ціни. Консенсус і розподілені реєстри викладено в розділі 13.

3.1 Неструктуровані протоколи P2P

3.1.1 Пошук затопленням

У неструктурованому оверлеї граф $G = (V, E)$ утворюють випадкові з'єднання, а розміщення ресурсу не залежить від топології. Пошук ведеться за іменем чи ключовими словами, тобто підтримує складні запити, але не має детермінованого шляху до ресурсу [390, 271]. У Gnutella 0.4 повідомлення Ping/Pong слугують для виявлення вузлів, Query/QueryHit — для пошуку; кожне має глобальний ідентифікатор (GUID) для відкидання дублікатів і лічильник **TTL**, що зменшується на кожному кроці, а QueryHit повертається зворотним шляхом (рис. 3.1). Оверлей Gnutella виявився погано узгодженим із топологією підкладки [338].

Нехай вузли мають середній ступінь k, запит породжується з TTL τ, а граф локально подібний до дерева: вузол, що вперше отримав запит на кроці $i < \tau$, пересилає його $k-1$ сусідам. Кількість охоплених вузлів і повідомлень

$$R_\tau = \min\Bigl\{N,\ \sum_{i=1}^{\tau} k(k-1)^{i-1}\Bigr\}, \qquad M_\tau \approx k + (k-1)\,R_{\tau-1}, \tag{3.1}$$

де N — розмір мережі. Якщо ресурс реплікований на частці ρ вузлів, імовірність його знаходження

$$P_{\text{find}} = 1 - (1-\rho)^{R_\tau} \approx 1 - e^{-\rho R_\tau}. \tag{3.2}$$

[1]Матеріал розділу частково ґрунтується на CyBOK © Crown Copyright, The National Cyber Security Centre 2021, ліцензія Open Government Licence v3.0. Виклад є авторським, з доповненнями й поглибленнями.

Для $k=4$, $\tau=7$ маємо $R_7 = 4(3^7-1)/2 = 4372$ і за $\rho = 10^{-4}$ (сто копій у мільйонній мережі) $P_{\text{find}} \approx 0{,}35$. Для $k=6$ вже $R_7 = 117\,186$ і $P_{\text{find}} \approx 1$, але кожен запит породжує понад 10^5 повідомлень, а з наближенням R_τ до N зростає частка дублікатів.

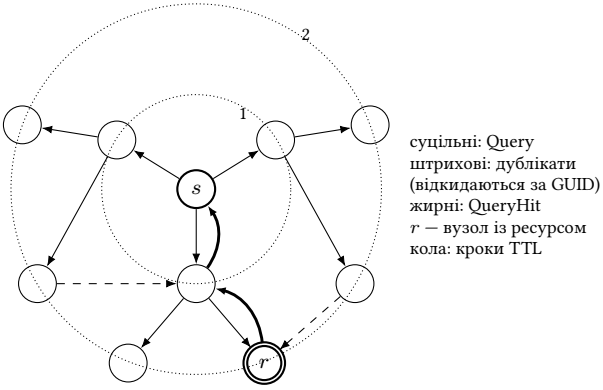


Рис. 3.1 — Пошук затопленням у неструктурованому оверлеї (за [390, 271])

3.1.2 Випадкові блукання та епідемічні протоколи

Альтернатива затопленню — w **випадкових блукань** завдовжки L кроків із періодичною перевіркою в ініціатора [272]. У добре перемішаному графі $P_{\text{find}} \approx 1 - e^{-\rho w L}$ за wL повідомлень: для $w=16$, $L=1024$, $\rho=10^{-4}$ це $\approx 0{,}81$ за $16\,384$ повідомлень замість понад 10^5, але з більшою затримкою. Блукання застосовують і для рівномірної вибірки вузлів [187], а реплікація пропорційно квадратному кореню з популярності мінімізує очікувану вартість пошуку [272].

Епідемічні (gossip) протоколи поширюють оновлення, як інфекцію: «інфікований» вузол періодично передає стан випадковому партнерові; Демерс та співавт. застосували схеми anti-entropy і rumor mongering до підтримання реплікованих баз даних [145]. У середньопольовому наближенні частка поінформованих вузлів $i(t)$ задовольняє

$$\frac{di}{dt} = \beta\, i\,(1-i), \qquad t^{*} = \frac{1}{\beta}\,\ln\frac{i^{*}(1-i_0)}{i_0\,(1-i^{*})}, \tag{3.3}$$

де β — інтенсивність успішних контактів за раунд, $i_0 = 1/N$, t^{*} — час досягнення частки i^{*}. Для $N=10^6$, $\beta=1$, $i^{*}=0{,}999$ маємо $t^{*} \approx 20{,}7$ раунду; точний результат Піттеля для push-моделі — $\log_2 N + \ln N + O(1) \approx 33{,}7$ раунду до охоплення *всіх* вузлів [322]. Якщо частка f вузлів не пересилає

повідомлень, $\beta_{\text{eff}} \approx \beta(1-f)$, і за $f = 0{,}3$ маємо $\approx 29{,}6$ раунду: gossip деградує плавно. Проте хибна «чутка» порушника поширюється так само швидко, тому повідомлення мають автентифікуватися на кожному кроці.

3.1.3 BitTorrent як мережа обміну

BitTorrent не є пошуковою мережею: метаінформація містить геш SHA-1 кожного фрагмента, рій учасників утворює неструктурований випадковий граф, а обмін регулює алгоритм *choking* за принципом «око за око» з оптимістичним розблокуванням [135]. Виявлення ж учасників спирається на трекер або на DHT на основі Kademlia [270], тож BitTorrent поєднує неструктурований обмін зі структурованим чи централізованим виявленням (підрозділ 3.3).

3.1.4 Безпекові наслідки

Відсутність гарантій: знаходження ймовірнісне, тому цензурування неможливо відрізнити від рідкісності ресурсу. *Відкритість членства:* вузли приєднуються без перевірки, а Ping/Pong розкриває адреси учасників, спрощуючи їх перелік. *Зловживання затопленням:* один запит породжує M_τ повідомлень, тож за $k = 6$, $\tau = 7$ сто запитів на секунду дають понад 10^7 повідомлень на секунду; шкідливий вузол також завищує TTL і підробляє QueryHit. Вимірювання виявили й схильність частини учасників спотворювати заявлені характеристики, щоб уникнути роздачі [350], — передумову *free-riding*.

3.2 Структуровані протоколи P2P

3.2.1 Ключовий простір і Chord

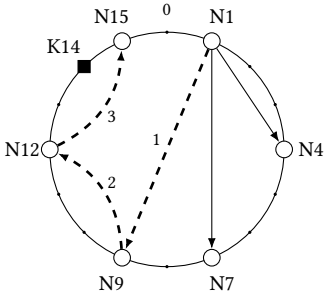
Структуровані протоколи зберігають покажчики на ресурси в **розподіленій геш-таблиці** (DHT): ідентифікатори вузлів і ключі належать простору $[0, 2^w - 1]$ ($w = 128$ або 160), а функція відстані $d(a,b)$ визначає відповідальність за ключ і напрям пересилання [390]. Таблиці маршрутизації містять порядку $k \cdot w$ записів, і близьких вузлів знають більше, ніж далеких; пошук займає $O(\log N)$ кроків [390, 271].

Chord упорядковує m-бітові ідентифікатори на кільці за модулем 2^m; ключ K зберігає $\text{successor}(K)$ — перший вузол з ідентифікатором, не меншим за K [387]. Вузол n підтримує **finger-таблицю**

$$\text{finger}_n[i] = \text{successor}\big((n + 2^{i-1}) \bmod 2^m\big), \qquad 1 \le i \le m, \tag{3.4}$$

тож перехід до найближчого попереднього finger-вузла щонайменше вдвічі скорочує відстань до ключа. Для кільця з $m = 4$ і вузлами N1, N4, N7, N9, N12, N15 (рис. 3.2) таблиця N1 містить N4, N4, N7, N9, а пошук K14 проходить шлях N1 $\to$ N9 $\to$ N12 $\to$ N15. Коректність при **churn** забезпечує

періодична стабілізація: перевірка наступника, оновлення finger-записів і список із $r = O(\log N)$ наступників [387].



finger-таблиця N1

i	$1 + 2^{i-1}$	succ
1	2	N4
2	3	N4
3	5	N7
4	9	N9

стрілки з N1: finger-покажчики
штрихові 1–3: пошук K14

Рис. 3.2 — Кільце Chord ($m = 4$), finger-таблиця вузла N1 і шлях пошуку ключа K14 (за [387])

3.2.2 Pastry, Kademlia, CAN

Pastry подає 128-бітові ідентифікатори цифрами з основою 2^b [345]. Таблиця має $\lceil \log_{2^b} N \rceil$ рядків по $2^b - 1$ записів (у рядку ℓ — вузли зі спільним префіксом довжиною ℓ цифр), її доповнюють множина листків L (числово найближчі вузли) і множина сусідства M (найближчі за мережею). Кожен крок подовжує спільний префікс принаймні на цифру: для $b = 4$ і $N = 10^6$ це до п'яти кроків за 75 записів таблиці.

Kademlia визначає відстань як побітове виключне АБО [277]:

$$d(x, y) = x \oplus y, \qquad j(x, y) = \lfloor \log_2 d(x, y) \rfloor, \tag{3.5}$$

де j — номер **k-бакета** для контакту y (відстані $[2^j, 2^{j+1})$). Для 4-бітових $x = 0011_2$ і $y = 1010_2$ маємо $d = 1001_2 = 9$ і $j = 3$: y лежить у «дальній» половині простору, для якої x зберігає не більше k контактів. Метрика симетрична й *однонаправлена* (для x і Δ існує єдине y з $d(x, y) = \Delta$), тож пошуки одного ключа сходяться до тих самих вузлів. Бакет вміщує до k контактів ($k = 20$ в оригіналі, $k = 8$ у DHT BitTorrent [270]); новий контакт витісняє найдавніше бачений лише тоді, коли той не відповідає, тобто перевага надається довгоживучим вузлам. Пошук ітеративний з α паралельними запитами, а симетрія метрики дозволяє навчатися з отриманих запитів без окремої стабілізації [93].

CAN розбиває d-вимірний тор на зони [327]: кожен вузол має $2d$ сусідів, а маршрут — $(d/4)\, N^{1/d}$ кроків, тобто для $N = 10^6 \approx 32$ за $d = 4$ і ≈ 10 за $d = 10$; кілька незалежних координатних просторів («реальностей») є прообразом надлишкової маршрутизації. Порівняння подано в табл. 3.1.

Таблиця 3.1 — Порівняння структурованих протоколів P2P

Протокол	Геометрія, метрика	Стан вузла	Кроки	Безпекова особливість
Chord	кільце, відстань за годинниковою стрілкою	$O(\log N)$ fingers, список наступників	$O(\log N)$	стабілізацію можна зірвати хибними наступниками
Pastry	префіксне дерево з основою 2^b	$(2^b-1)\lceil \log_{2^b} N\rceil + \lvert L\rvert + \lvert M\rvert$	$< \lceil \log_{2^b} N\rceil$	вибір за близькістю відкриває таблиці для отруєння
Kademlia	XOR-метрика, бінарне дерево	k-бакети, до $k \cdot w$ записів	$O(\log N)$	перевага старим контактам; збіжність шляхів
CAN	d-вимірний тор, евклідова	$2d$ сусідів	$(d/4)N^{1/d}$	малий стан полегшує ізоляцію зони

За експоненційного розподілу тривалості сеансу із середнім μ запис, не перевірений протягом T, застарів з імовірністю $1 - e^{-T/\mu}$ ($\approx 0{,}22$ для $T = 15$ хв, $\mu = 60$ хв). Крок Kademlia зривається, лише коли застаріли всі k кандидатів ($0{,}22^8 \approx 5 \cdot 10^{-6}$), тоді як Chord без резервних записів — за відмови одного finger-вузла. Порушник може штучно підвищувати churn; Kademlia стійкіша до цього завдяки перевазі довгоживучих контактів [93].

3.2.3 Безпекові властивості структурованих оверлеїв

Призначення ідентифікаторів. Позиція визначає відповідальність за ключі, тож вільний вибір ідентифікатора рівнозначний вибору жертви (підрозділ 2.3). У DHT BitTorrent виявлено «горизонтальну» атаку, що розсіює Sybil-вузли по простору для стеження, і «вертикальну», що заповнює таблицю конкретного вузла; кількість Sybil-вузлів оцінено у $\approx 300\,000$ [413]. BEP 42 констатує, що запустити вісім вузлів поблизу цільового info-hash і перехопити його обслуговування дуже легко, і пропонує обмежувати ідентифікатор залежно від зовнішньої IP-адреси [309]; прив'язка ж до гешу відкритого ключа дозволяє ще й підписувати повідомлення [93].

Передбачуваність маршрутів. Детермінована маршрутизація й однонаправленість XOR-метрики означають, що вузли поблизу ключа перехоплюють і спостерігають *усі* запити до нього; у мережі KAD продемонстровано створення численних ідентифікаторів з однієї машини й приховування вмісту за ключовими словами [385]. Це локальна eclipse *ключа*, а не вузла (загальний механізм — у підрозділі 2.4).

Отруєння таблиць. Шкідливий вузол у відповідь на FIND_NODE повертає «ближчих» до ключа змовників [93]. У Pastry заповнення за мережевою близькістю дозволяє порушникові поруч із жертвою домінувати в її таблиці, тому Castro та співавт. запропонували *обмежену* таблицю, де кожен запис — вузол, найближчий до заданої точки простору [115]. Сіт і Морріс

сформулювали базові правила: кожен крок має наближати до ключа, ідентифікатор — бути перевірюваним, а твердження про збереження даних — перевірятися читанням з реплік [371].

3.3 Гібридні протоколи P2P

3.3.1 Централізований індекс і децентралізований обмін

Гібридні протоколи поєднують ефективне виявлення з масштабованим поширенням [390]. У **моделі Napster** сервер зберігав індекс файлів під'єднаних користувачів: пошук був одним повним запитом до сервера, а передавання — безпосереднім. Трекерний BitTorrent відтворює цю схему: трекер у відповідь на `announce` повертає список учасників рою [135]; доповнення DHT [270] зробило трекер необов'язковим, причому розподілені трекери розроблено частково через юридичні проблеми, а також заради доступності [413].

Централізований компонент є *пріоритетною ціллю*: DoS на індекс чи трекер зупиняє виявлення для всіх, а його компрометація дозволяє цензурувати, підмінювати списки учасників (спрямовуючи рій на сторонній хост) і збирати журнали «хто що завантажував». Він же створює *юридичну вразливість*: оператор ідентифікований і підпадає під судові рішення. Після позовів до Napster розповсюджувачі децентралізованого програмного забезпечення позиціонували себе як його альтернативи, проте Верховний суд США у справі MGM v. Grokster (2005) визнав, що розповсюджувач, який заохочує використання свого програмного забезпечення для порушень, несе відповідальність, хоча вузли обмінюються даними без центральних серверів [282]. Децентралізація знижує технічну, але не обов'язково правову вразливість.

3.3.2 Реєстри та сервери початкового підключення

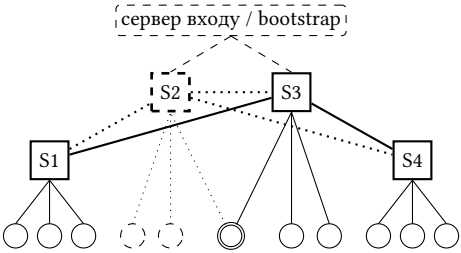
Будь-який оверлей має **проблему початкового підключення** (bootstrap): новому вузлу потрібна адреса чинного учасника. Її отримують із вбудованих адрес, DNS-сідів (як у Bitcoin), вебкешів чи кешу попередніх сеансів. Атака на ці елементи має непропорційний ефект: DoS на сіди блокує приєднання, а підміна відповіді (компрометація сіда чи підробка DNS, див. розділ 11) з першої секунди поміщає вузол в оточення порушника — найдешевший варіант eclipse. Протидія: кілька незалежних сідів різних операторів, об'єднання їхніх відповідей, резервні вбудовані адреси, збереження перевірених з'єднань між перезапусками (підрозділ 3.6). Отже, централізований індекс дає найвищу ефективність і повноту, але концентрує технічний, приватнісний і юридичний ризики; децентралізоване виявлення розподіляє ризик, успадковуючи атаки підрозділу 3.2. Практичний компроміс —

багатоджерельність: кілька трекерів, DHT і обмін адресами між учасниками.

3.4 Ієрархічні протоколи P2P

3.4.1 Суперпіри та багаторівневі оверлеї

Ієрархічні протоколи відступають від рівності вузлів: учасники з кращою смугою, стабільністю чи публічною адресою стають **суперпірами**, а «листові» вузли надсилають запити спершу їм; це зменшує кількість повідомлень і дозволяє кешувати популярний вміст (eDonkey, KaZaA) [390]. У FastTrack звичайний вузол передає суперпірові метадані своїх файлів, а суперпіри утворюють неструктурований оверлей для пошуку [262]. Ранній Skype мав суперпіри, що ретранслювали трафік вузлів за NAT, але автентифікацію виконував централізований сервер входу [92], поєднуючи ієрархічну й гібридну схеми (рис. 3.3). Безпековий наслідок — *самопризначення*: порушник, що заявив достатні ресурси, стає суперпіром і отримує видимість запитів листових вузлів, можливість забруднювати результати й відкидати трафік (ієрархічна форма атаки притягання).



S2 (штриховий) виведено з ладу: його листові вузли ізольовані, вузол із подвійним контуром лишається зв'язаним через S3

Рис. 3.3 — Дворівневий оверлей із суперпірами та централізованим сервером входу (за [262, 92])

Мережі розподілених реєстрів мають неформальну ієрархію: *повні вузли* перевіряють усі блоки й транзакції, а *легкі* клієнти отримують лише заголовки й докази включення від повних вузлів, до яких під'єднані. Легкому клієнтові в оточенні порушника не можна нав'язати хибний ланцюг без витрат на доказ роботи, але легко приховати від нього реальні транзакції. Ефективна ієрархія виникає й через концентрацію вузлів у небагатьох автономних системах: перехоплення BGP-префіксів дозволяє розділити мережу Bitcoin і затримувати доставку блоків [80] (BGP — у розділі 11, консенсус — у розділі 13).

3.4.2 Стійкість до цілеспрямованого виведення з ладу

Безмасштабні мережі з розподілом ступенів $P(k) \propto k^{-\gamma}$ надзвичайно стійкі до випадкових відмов, але швидко розпадаються при цілеспрямованому видаленні вузлів найвищого ступеня, тоді як мережі з експоненційним розподілом реагують на обидва сценарії однаково [75]. За **теорією перколяції** гігантська зв'язна компонента існує, доки

$$\kappa = \frac{\langle k^2 \rangle}{\langle k \rangle} > 2, \qquad p_c = 1 - \frac{1}{\kappa_0 - 1}, \tag{3.6}$$

де $\langle k \rangle$, $\langle k^2 \rangle$ — моменти розподілу ступенів, κ_0 — значення κ до відмов, p_c — критична частка випадково вилучених вузлів [137]. Для безмасштабних мереж з $\gamma \leq 3$ величина $\kappa_0 \to \infty$ при $N \to \infty$, тож $p_c \to 1$, а за цілеспрямованої атаки критична частка мала [136].

Приклад. Нехай $1\,\%$ вузлів — суперпіри ступеня 200, а $99\,\%$ — листові вузли, під'єднані до двох суперпірів. Тоді $\langle k \rangle = 0{,}01 \cdot 200 + 0{,}99 \cdot 2 = 3{,}98$, $\langle k^2 \rangle = 0{,}01 \cdot 200^2 + 0{,}99 \cdot 4 = 403{,}96$, $\kappa_0 \approx 101{,}5$ і $p_c \approx 0{,}99$: випадкові відмови мережа витримує майже до останнього вузла. Однак листові вузли з'єднані лише із суперпірами, тож виведення з ладу тих самих $1\,\%$ вузлів знищує зв'язність повністю, а вилучення половини суперпірів ізолює частку $0{,}5^2 = 0{,}25$ листових вузлів. Випадковий (пуассонівський) граф із $\langle k \rangle = 4$ має $\langle k^2 \rangle = 20$, $\kappa_0 = 5$ і $p_c = 0{,}75$ для випадкових відмов; цілеспрямоване вилучення вузлів найвищого ступеня знижує цей поріг, але значно менше, ніж у мережі із суперпірами, бо ступені вузлів близькі до середнього [75]. Ієрархія обмінює стійкість до цілеспрямованих атак на ефективність (табл. 3.2).

Таблиця 3.2 — Порівняння класів протоколів P2P

Ознака	Неструктуровані	Структуровані	Гібридні	Ієрархічні
Пошук	затоплення, блукання	ключова маршрутизація	запит до індексу	через суперпіри
Гарантія знаходження	імовірнісна	детермінована за $O(\log N)$	повна в межах індексу	висока в межах рівня
Службовий трафік	високий	помірний, стабілізація	низький	низький
Випадкові відмови	висока стійкість	висока за реплікації	залежить від центру	висока
Цілеспрямовані атаки	помірна стійкість	вразливі позиції біля ключа	єдина точка відмови	вразливі суперпіри
Критичні цілі	затоплення, перелік вузлів	призначення ID, таблиці	індекс, трекер, сіди	суперпіри, сервер входу

3.5 Типи атак

CyBOK виокремлює два об'єкти захисту [390]: **P2P-операції** (P-OP) — виявлення, запит, маршрутизацію, завантаження, доступні через службовий інтерфейс протоколу, і **P2P-структури даних** (P-DS) — таблиці маршрутизації та спільні ресурси, доступні з мережі або локально на хості. Атаки або порушують зв'язність і доступ до інших вузлів, або псують структури даних, використовуючи координацію обміном повідомленнями й часткове подання системи кожним вузлом. За відсутності автентифікації, захищеного зберігання чи захищеної маршрутизації наслідками стають пропуск повідомлень, підробка й забруднення вмісту, цензурування та отруєння таблиць; окремо виділяють штучний churn і шахрайство в P2P-іграх [390].

DoS/DDoS (P-OP). Надмірні повідомлення виснажують вузли, зривають приєднання та `put`/`get` [390]; підсилюються затопленням (3.1) або спрямовуються на індекс чи трекер.

Змова (P-OP). Узгоджені дії групи вузлів проти механізмів репутації, довіри чи розподілу смуги; основа Sybil- та eclipse-атак.

Забруднення, отруєння індексу (P-DS). Часткова зміна вмісту (як-от «typhoid»-копія з рекламою, що далі поширюється чесними вузлами) або масове внесення фіктивних записів до індексу [390, 264]; у KaZaA виміряно значну поширеність забруднених версій популярних файлів [263].

Whitewashing, цензурування (P-DS). Зміна, видалення даних чи відмова в доступі; про whitewashing див. підрозділ 2.3.

Маршрутизація (P-DS). Відкидання й затримка, отруєння таблиць, атаки притягання й відштовхування (підрозділ 2.4).

Карти буфера (P-OP). У потоковому мовленні вузол неправдиво повідомляє про наявні фрагменти, щоб менше віддавати; споріднені прояви — пропуск, хибні звіти, фіктивні блоки [390].

Sybil та eclipse (P-OP, P-DS). Див. підрозділи 2.3, 2.4 і формули (2.2), (2.4); CyBOK розрізняє локалізовані (LEA), топологічно обізнані (taLEA) та вихідні (OEA) eclipse-атаки [390].

Зберігання (P-DS). Відповідальний вузол заперечує наявність даних, повертає застарілі чи підроблені значення, не реплікує їх [371].

Free-riding (P-OP). Споживання без внеску [350]; раціональна поведінка, яку стримують стимулами.

На відміну від клієнт-серверних аналогів, порушник мусить масштабувати частку своїх вузлів разом із мережею, а за непрямого доступу — спершу коректно приєднатися [390]. Зведення подано в табл. 3.3.

Таблиця 3.3 — Атаки на P2P-системи: цільові властивості, найвразливіші класи й ознаки виявлення (за [390] з доповненнями)

Атака	CIA	Найвразливіший клас	Ознаки виявлення
DoS/DDoS	A	гібридні (індекс, трекер); неструктуровані	сплеск запитів на вузол, зростання частки RPC без відповіді
Змова	C, I, A	системи з репутацією; ієрархічні	щільні кластери взаємних високих оцінок
Забруднення, отруєння індексу	I	неструктуровані, ієрархічні	невідповідність гешів, багато версій одного імені
Whitewashing, цензурування	I, A	структуровані; системи з репутацією	короткоживучі ID з тих самих префіксів; вміст недоступний попри анонси
Маршрутизація	I, A	структуровані	кроки не наближають до ключа, пошуки не збігаються
Карти буфера	I, A	неструктуровані потокові	розрив між заявленими й відданими фрагментами
Sybil	C, A	структуровані з вільним ID	аномальна щільність ID біля ключів, багато ID на підмережу
Eclipse	C, I, A	структуровані, мережі реєстрів	таблиця сусідів з однієї автономної системи чи префікса, асиметрія ступенів
Зберігання	I, A	структуровані	розбіжність відповідей реплік, невдалі перевірки читанням
Free-riding	A	неструктуровані без стимулів	низьке відношення віддачі до завантаження

3.6 Напади та їх пом'якшення

3.6.1 Ідентичність і допуск

Базові механізми захисту — автентифікація, захищене зберігання й захищена маршрутизація — діють лише до досягнення критичної маси змовників і можуть конфліктувати з анонімністю, неоднорідністю та ощадливістю ресурсів [390], тож кожен слід оцінювати разом з його *ціною*.

Криптографічно зв'язані ідентифікатори. В S/Kademlia NodeID $= H(pk)$, а повідомлення підписуються; статична головоломка вимагає c_1 нульових старших бітів у $H(\text{NodeID})$ і забороняє вільний вибір позиції, динамічна — c_2 нульових бітів у $H(\text{NodeID} \oplus X)$; перевірка має складність $O(1)$, розв'язання — $O(2^{c_1} + 2^{c_2})$ [93]. Щоб захопити всі k позицій реплік ключа в мережі з N чесних вузлів, потрібно k ідентифікаторів, ближчих до ключа, ніж найближчий чесний вузол; випадковий допустимий ідентифікатор має цю властивість з імовірністю $\approx 1/(N+1)$. Очікувані витрати на при-

цільне розміщення та на приєднання чесного вузла

$$W_{\text{target}} \approx k\big((N+1)\,2^{c_1} + 2^{c_2}\big), \qquad W_{\text{join}} \approx 2^{c_1} + 2^{c_2} \tag{3.7}$$

операцій генерування ключа чи гешування. Для $N = 10^6$, $k = 8$, $c_1 = 16$, $c_2 = 0$ маємо $W_{\text{target}} \approx 5{,}2 \cdot 10^{11}$, тобто за умовної швидкості 10^5 операцій на секунду близько 60 ядро-діб, тоді як чесний вузол витрачає $\approx 0{,}7$ с. Прив'язка до ключа дає множник $\approx kN$, а головоломка масштабує обидві вартості: за $c_1 = 24$ порушникові потрібно $\approx 15\,500$ ядро-діб, а чесному вузлу — майже три хвилини, що неприйнятно для мобільних і IoT-пристроїв. Проти *неприцільних* Sybil-вузлів діє лише W_{join}, а без прив'язки ідентифікатора (DHT BitTorrent до BEP 42) $W_{\text{target}} = k$ [309].

Доказ ресурсу. Періодичне підтвердження витрат перетворює разову вартість c у формулі (2.2) на поточну. Українські дослідники запропонували механізм випадкових часових челендж-токенів (RTCT): вузли в непередбачувані моменти відповідають на криптографічні виклики зі спалюванням токенів, що здорожчує утримання численних ідентичностей [39]; ціна — навантаження на чесних учасників.

Соціальні графи. SybilGuard [422] і SybilLimit [421] спираються на те, що порушник має мало *атакувальних ребер* g до чесної частини швидко перемішуваного соціального графа. SybilLimit обмежує кількість прийнятих Sybil-вузлів величиною $O(\log n)$ на ребро (проти $O(\sqrt{n}\log n)$ у SybilGuard): з точністю до сталих для $n = 10^6$ і $g = 500$ це $\approx 10^4$ вузлів (1 %) проти $\approx 10^7$, тобто відсутності обмеження. Ціна — потреба в реальному соціальному графі.

3.6.2 Маршрутизація, таблиці й eclipse

Castro та співавт. поєднали засвідчене призначення ідентифікаторів, *обмежені* таблиці та тест відмови маршрутизації з переходом до *надлишкової* маршрутизації [115]. S/Kademlia шукає через d неперетинних шляхів, використовує списки «сиблінгів» для надійної реплікації й приймає лише підписані контакти [93]. Ефект d описує формула (2.3): для $f = 0{,}1$ і довжини шляху 10 чотири шляхи підвищують успіх з $0{,}35$ до $0{,}82$ ціною чотирикратного трафіку. Перевірки Сіта й Морріса дешеві й мають бути обов'язковими [371], а в BEP 42 вузли з ідентифікаторами, що не відповідають IP-адресам, не можуть бути цілями зберігання й не враховуються в умові завершення пошуку [309].

Після роботи Хейлмана та співавт. [197] частину контрзаходів упроваджено в Bitcoin Core, а згодом додано *різноманітність мережевих префіксів* і *якірні з'єднання*. Параметр `-asmap` (версія 0.20.0) відображає IP-адреси на номери автономних систем і обмежує кількість з'єднань з однією автономною системою замість групування за префіксом /16 [100]. Файл `anchors.dat`

(версія 0.21.0) зберігає два вихідні з'єднання лише для ретрансляції блоків, до яких вузол повертається після перезапуску, щоб порушник не міг використати перезапуск для повної заміни сусідів [101]. У термінах формули (2.4) перше зменшує f_{eff} порушника, зосередженого в кількох автономних системах, друге не дає f_{eff} стрибнути до одиниці під час перезапуску; від перехоплення BGP [80] це захищає лише частково. Для IPFS показано, що довільний вузол можна ізолювати помірними ресурсами, а атака масштабується на всю публічну мережу; уразливість CVE-2020-10937 після розкриття разом із Protocol Labs пом'якшено [326]. Грищук О. і Грищук Р. запропонували диференціально-ігрові моделі на основі марковських ланцюгів для оцінювання захищеності блокчейн-вузла від eclipse-атак і троянського програмного забезпечення та вибору оптимальних стратегій захисту [7].

3.6.3 Репутація, змова, цілісність вмісту

EigenTrust обчислює глобальну довіру як власний вектор матриці нормованих локальних оцінок [242]:

$$c_{ij} = \frac{\max(s_{ij}, 0)}{\sum_{l} \max(s_{il}, 0)}, \qquad \mathbf{t}^{(n+1)} = (1-a)\, C^{\mathsf{T}} \mathbf{t}^{(n)} + a\, \mathbf{p}, \tag{3.8}$$

де s_{ij} — різниця задовільних і незадовільних взаємодій i з j, $\mathbf{p}$ — розподіл початкової довіри на заздалегідь довірених вузлах, $a \in (0,1)$ — вага повернення до $\mathbf{p}$. У спрощеній двоблоковій моделі змовники M віддають усю локальну довіру один одному, чесні вузли — частку ε змовникам, а $\mathbf{p}$ зосереджено на чесних. Тоді стаціонарна частка довіри змовників

$$t_M = \frac{(1-a)\,\varepsilon}{a + (1-a)\,\varepsilon}. \tag{3.9}$$

Для $a = 0{,}15$, $\varepsilon = 0{,}05$ маємо $t_M \approx 0{,}22$, за $\varepsilon = 0{,}01$ — $\approx 0{,}054$, а за $a \to 0$ $t_M \to 1$: замкнена клика поглинає всю довіру. Збільшення a до $0{,}5$ знижує t_M до $\approx 0{,}048$, але робить систему залежною від заздалегідь довірених вузлів, повертаючи елемент централізації. Проти free-riding діє взаємність «око за око» в BitTorrent [135].

Найдешевший захист від забруднення — *адресація за вмістом*: ключ є гешем даних, тож підміну виявляє сам отримувач. BitTorrent перевіряє кожен фрагмент за гешем із метаінформації [135], а змінювані записи DHT захищають підписом власника [371]. Проте геш підтверджує відповідність *ідентифікатору*, а не якість вмісту, тож отруєння індексу (прив'язка хибних гешів до популярних назв) лишається можливим [264]; вибір геш-функцій — за розділом 9.

3.6.4 Кейс: P2P-ботнети та протидія їм

P2P-ботнети демонструють дуальність атак: техніки порушників стають інструментами захисників. Ботнет Storm керувався через оверлей Overnet на основі Kademlia; Holz та співавт. проникли в нього, оцінили кількість заражених машин і дослідили зрив каналу керування: eclipse вмісту Sybil-вузлами біля гешів команд виявився в Overnet нездійсненним, а забруднення (масова публікація під тими самими ключами) перетворилося на «перегони» з ботами [201]. Rossow та співавт. побудували графову модель P2P-ботнетів, оцінили розміри одинадцяти активних ботнетів (деякі перевищували мільйон ботів) і прототипували протидію на основі переліку вузлів і отруєння, зокрема **sinkholing** — перенаправлення ботів на вузол захисників [344]. Gameover Zeus запозичив механізми живучості: трирівнева архітектура, автоматичне блокування IP-адрес, що надто часто звертаються до бота, і резервний канал генерування доменних імен роблять довготривале отруєння й sinkholing дуже складними [78]. 30 травня 2014 р. операція під керівництвом ФБР за підтримки Європолу порушила роботу Gameover Zeus (від 500 тис. до 1 млн заражених комп'ютерів) і вилучила сервери CryptoLocker; серед учасників були слідчі України [222]. Уроки для легітимних оверлеїв: перелік вузлів і Sybil-сенсори загрожують приватності, обмеження частоти запитів і резервні канали підвищують живучість, а стійкість ботнету до sinkholing — це та сама стійкість до eclipse, якої бракує багатьом DHT. Для операторів критичної інфраструктури P2P-трафік є важливим індикатором компрометації (розділ 14).

Висновки до розділу

Чотири класи протоколів P2P реалізують різні компроміси між ефективністю, гарантіями й стійкістю. Неструктуровані мережі плавно деградують, але дають лише ймовірнісне знаходження, а затоплення є вбудованим підсилювачем DoS (формули (3.1)–(3.3)). Структуровані DHT гарантують пошук за $O(\log N)$ кроків, проте позиція визначає відповідальність, тож призначення ідентифікаторів, передбачуваність маршрутів і заповнення таблиць стають головними об'єктами атак. Гібридні схеми концентрують технічний, приватнісний і юридичний ризики в індексі, трекері та сідах, ієрархічні — у суперпірах: модель (3.6) показує, що оверлей, який витримує відмову $99\,\%$ випадкових вузлів, розпадається після виведення з ладу $1\,\%$ вузлів найвищого ступеня.

Класифікація CyBOK за об'єктами P-OP і P-DS (табл. 3.3) пов'язує атаки з властивостями CIA, найвразливішими класами та ознаками виявлення. Пом'якшення мають вимірну ціну: прив'язка ідентифікатора до ключа здорожчує прицільне розміщення в $\approx kN$ разів, але головоломки однаково навантажують чесних учасників (3.7); EigenTrust стримує змову лише ці-

ною заздалегідь довірених вузлів (3.9); якірні з'єднання й різноманітність автономних систем зменшують ефективну частку порушника. Відкритими проблемами лишаються оцінювання стійкості за корельованих компрометацій, поєднання захисту від Sybil з анонімністю та ощадливістю ресурсів і формальна верифікація протоколів стабілізації.

Питання для самоперевірки

1. Порівняйте пошук затопленням і випадковими блуканнями за кількістю повідомлень, затримкою та гарантіями знаходження.
2. За формулами (3.1) і (3.2) обчисліть R_τ, M_τ і P_{find} для $k = 5$, $\tau = 5$, $\rho = 5 \cdot 10^{-4}$. Який коефіцієнт підсилення отримує порушник?
3. Використовуючи (3.3), оцініть кількість раундів до охоплення $99\,\%$ вузлів мережі з $N = 10^5$ за $\beta = 0{,}8$ і частки мовчазних вузлів $f = 0{,}2$.
4. Побудуйте finger-таблицю вузла N7 для кільця рис. 3.2 і визначте шлях пошуку ключа K3.
5. Чому однонаправленість XOR-метрики Kademlia є водночас перевагою для кешування і вразливістю щодо прицільного розміщення Sybil-вузлів?
6. Поясніть, чому заповнення таблиць Pastry за мережевою близькістю відкриває можливість їх отруєння та як це усувають обмежені таблиці Castro та співавт.
7. Які централізовані компоненти гібридних P2P-систем є пріоритетними цілями атак? Проаналізуйте технічний і юридичний аспекти їхньої вразливості.
8. Опишіть атаки на початкове підключення вузла та заходи протидії.
9. За формулою (3.6) знайдіть p_c для дворівневого оверлею з $2\,\%$ суперпірів ступеня 100 і листових вузлів ступеня 3. Як зміниться висновок за цілеспрямованої атаки?
10. Співвіднесіть атаки забруднення, отруєння індексу, шахрайства з картами буфера й free-riding з об'єктами P-OP і P-DS та властивостями CIA.
11. За формулою (3.7) визначте, яке значення c_1 забезпечить $W_{\text{target}} \geq 10^{15}$ для $N = 10^7$ і $k = 8$, і оцініть час приєднання чесного IoT-пристрою зі швидкістю 10^3 операцій на секунду.
12. За формулою (3.9) знайдіть мінімальне a, за якого частка довіри кліки не перевищує $5\,\%$ при $\varepsilon = 0{,}03$. Які недоліки має таке значення a?
13. Як контрзаходи `-asmap` і `anchors.dat` у Bitcoin Core впливають на параметри моделі eclipse з розділу 2? Від яких атак вони не захищають?

14. Дослідницьке: порівняйте стійкість P2P-ботнетів до sinkholing і стійкість легітимних DHT до eclipse. Які механізми живучості ботнетів доцільно запозичити для оверлеїв критичної інфраструктури і які етичні та правові обмеження має активна протидія ботнетам?
15. Дослідницьке: запропонуйте модель оцінювання частки Sybil-вузлів у DHT за спостережуваною щільністю ідентифікаторів біля ключів і перевірте її на відкритих даних вимірювань.

РОЗДІЛ 4

Розподілені системи: скоординована кластеризація ресурсів

Розділ відповідає змістовому модулю III «Розподілені системи: скоординована кластеризація ресурсів» (тема 3) робочої програми дисципліни. Якщо в розділі 2 скоординовані системи виокремлено як клас, а в розділі 3 розглянуто однорангові мережі, то тут предметом аналізу є самі *механізми координації*: стилі, групова комунікація, координаційні властивості та схеми реплікації, завдяки яким розосереджені вузли створюють ілюзію одного логічно централізованого ресурсу. Структуру узгоджено з CyBOK [390] і поглиблено першоджерелами, формальними визначеннями й кількісними моделями. Наскрізна теза: кожна координаційна гарантія спирається на припущення про час, відмови й членство, порушник атакує саме ці припущення, а схема реплікації визначає, які з таких атак пом'якшуються.

4.1 Стилі координації систем

4.1.1 Кластеризація ресурсів і віртуальна централізація

Скоординована система об'єднує вузли так, щоб клієнт бачив одну службу з єдиним станом, а розподіленість, реплікація й відмови залишалися прихованими [390]. **Кластер** — тісно зв'язані вузли одного адміністративного домену зі спільною площиною керування (HPC, Kubernetes, СКБД). **Ґрід** об'єднує ресурси кількох організацій у віртуальну організацію з федеративною автентифікацією, тож довіра розподілена між доменами. **Хмара** надає еластичні ресурси через інтерфейс провайдера, а її площина керування сама є реплікованою логічно централізованою службою. У термінах моделі $\langle V, E, R, S, \Gamma \rangle$ (підрозділ 2.1) усі три форми реалізують координацію ресурсів Γ_R, що спирається на координацію послуг Γ_S. Чим досконаліша ілюзія централізації, тим цінніша для порушника площина керування: доступ до сховища стану кластера рівнозначний правам суперкористувача [317].

4.1.2 Моделі синхронності й відмов як параметри стилю

Стиль координації задамо кортежем $\Sigma = \langle \mathcal{T}, \mathcal{M}_t, \mathcal{M}_f, \mathcal{M}_m \rangle$: топологія ухвалення рішень, модель синхронності, модель відмов і модель членства. У **синхронній** моделі відомі межі затримки повідомлень Δ і відносної швидкості процесів Φ, тож обчислення ведуть раундами, як у бортових системах керування польотом. В **асинхронній** моделі меж немає, і детермінований консенсус за однієї аварійної відмови неможливий (FLP, розділ 1).

Частково синхронну модель Дворк, Лінч і Стокмейєра [154] запишемо через невідомий момент **глобальної стабілізації** GST:

$$\forall m: \quad t_{\text{recv}}(m) \le \max\bigl(t_{\text{send}}(m),\ \text{GST}\bigr) + \Delta, \tag{4.1}$$

де межа Δ існує, але протоколу невідомі ні вона, ні GST. Тут консенсус досяжний за $n \ge 2f+1$ для аварійних і за $n \ge 3f+1$ для візантійських відмов, причому безпечність (safety) зберігається за будь-якої поведінки мережі, а живучість (liveness) гарантується лише після GST [154]. Порушник, що контролює затримки, фактично *керує моментом GST*: він відкладає прогрес, але не повинен мати змоги порушити узгодженість. Якщо тайм-аут раунду $\tau_0 = 100$ мс, а порушник тримає затримку службових повідомлень 120 мс, жоден раунд не завершується; протокол, що подвоює тайм-аут ($\tau_r = 2^r\tau_0$), відновлює прогрес уже за $\tau_1 = 200$ мс, тож порушник мусить нарощувати затримку експоненційно, і атака стає помітною.

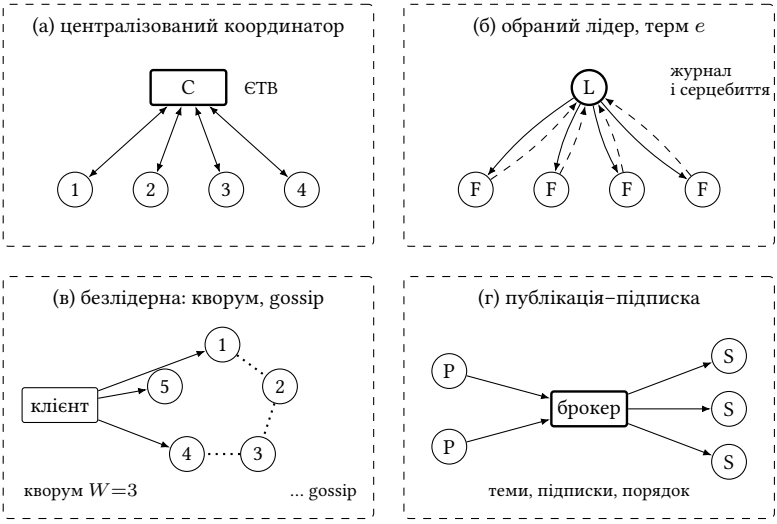


Рис. 4.1 — Базові стилі координації: ЄТВ — єдина точка відмови; F — послідовники; P, S — видавці та підписники. Оркестрація структурно відповідає схемі (а), хореографія — схемі (г) без брокера

4.1.3 Основні стилі координації

Централізований координатор (координатор двофазної фіксації, планувальник, сервер каталогу) простий і лінеаризований, але є єдиною точкою відмови й концентрації довіри. **Координація з обраним лідером** (Multi-Paxos, Raft, ZAB) усуває статичну точку відмови: лідера обирає більшість

на один терм, а його відмову виявляють за пропущеними серцебиттями; проте лідер лишається *динамічною* ціллю DoS-атак (підрозділ 2.5). **Безлідерна** координація буває кворумною, коли клієнт звертається до W або R реплік (розділ 13), та епідемічною (3.3). **Подієва координація** (публікація–підписка) розв'язує виробників і споживачів через брокер, який знає всі теми й підписки і тому є природною ціллю розвідки. На рівні сервісів розрізняють **оркестрацію** з центральним рушієм робочих процесів і **хореографію**, де сервіси реагують на події один одного; хореографія стійкіша до відмов, але глобальний стан процесу не спостерігається, що ускладнює аудит (розділ 14). Схеми стилів подано на рис. 4.1, порівняння — у табл. 4.1.

Таблиця 4.1 — Порівняння стилів координації

Стиль	Узгодженість	Доступність за поділу	ЄТВ	Візантійські вузли
Координатор (2PC, планувальник)	сильна; блокування за відмови координатора	лише зі сторони координатора	координатор	не витримує
Обраний лідер (Raft, Paxos)	лінеаризованість через журнал лідера	у частині з більшістю, $n \geq 2f+1$	лідер до переобрання	не витримує
Лідер і BFT-кворум (PBFT)	лінеаризованість за $\leq f$ зловмисних реплік	у частині з $\geq 2f+1$ реплік	немає	витримує за $n \geq 3f+1$
Безлідерний кворум	налаштовувана ($W+R>N$), часто кінцева	висока	немає	слабка: отруєння злиття
Епідемічний (gossip)	кінцева, імовірнісна	дуже висока	немає	лише з автентифікацією
Публікація–підписка	порядок у межах теми	визначає кластер брокерів	брокер (логічно)	не витримує
Оркестрація	задає рушій (Saga)	визначає рушій	рушій	не витримує
Хореографія	кінцева, без глобального стану	висока	немає	слабка; складний аудит

Зі зменшенням концентрації рішень зростає доступність, але слабшають узгодженість і спостережуваність; стійкість до візантійських вузлів дають лише кворуми $3f+1$ або автентифікація повідомлень.

4.2 Надійне та безпечне групове спілкування

4.2.1 Членство, групові подання й віртуальна синхронність

Групова комунікація надає процесам абстракцію «надіслати групі» з гарантіями доставки й порядку [390]. Її основою є **служба членства**, що видає

послідовність **групових подань** (views) $V_i = \langle i, M_i\rangle$ — номер і множину членів, які вважаються працездатними та з'єднаними. Членство буває *первинного компонента* (прогрес лише в частині з більшістю) і *розділюваним* (кожна частина мережі працює у власному поданні) [127]. **Віртуальна синхронність** Бірмана й Джозефа [99] вимагає, щоб процеси, які разом переходять з V_i до V_{i+1}, доставили в V_i однакову множину повідомлень. Відмова тоді виглядає як атомарна подія «процес вийшов із групи», а стан можна безпечно переносити на нових членів. Для безпеки служба членства стає *кореневим авторитетом*: за поданнями розподіляють групові ключі й формують кворуми, тож порушник, який нав'язав подання без чесних або з власними вузлами, контролює все, що спирається на групу. Тому зміна членства має сама проходити автентифікований кворумний протокол [335].

4.2.2 Надійна та впорядкована розсилка

За Хадзілакосом і Туегом [193] **надійна розсилка** в моделі аварійних відмов має три властивості: *дійсність* (коректний відправник доставляє власне повідомлення), *узгодженість* (якщо коректний процес доставив m, то всі коректні доставлять m) і *цілісність* (кожне m доставляється не більше одного разу й лише якщо його надіслав зазначений відправник). Впорядковані різновиди додають властивості порядку. Позначимо $m \prec_q m'$ доставку процесом q повідомлення m раніше за m', $D_q(m)$ — доставку m процесом q, $D_{p,q}(m)$ — доставку обома процесами, $s(m)$ — відправника, $m <_s m'$ — надсилання m раніше за m', $m \to m'$ — причинне передування:

$$\begin{aligned}
\text{FIFO:}\quad & s(m){=}s(m') \wedge m <_s m' \Rightarrow \big(D_q(m') \Rightarrow m \prec_q m'\big);\\
\text{причинний:}\quad & m \to m' \Rightarrow \big(D_q(m') \Rightarrow m \prec_q m'\big);\\
\text{повний:}\quad & D_{p,q}(m) \wedge D_{p,q}(m') \Rightarrow \big(m \prec_p m' \Leftrightarrow m \prec_q m'\big).
\end{aligned} \tag{4.2}$$

Причинний порядок включає FIFO, а повний не випливає з жодного з них. **Атомарна** розсилка (надійна з повним порядком) в асинхронній моделі еквівалентна консенсусу [119] і потребує детекторів відмов або часткової синхронності (4.1). Якщо операції «відкликати право r» і «записати з правом r» надіслали різні адміністратори, за FIFO одна репліка може виконати запис, а інша відхилити; лише повний порядок робить рішення авторизації однаковим.

Дефаго, Шипер і Урбан класифікують алгоритми повного порядку за тим, хто його будує: фіксований чи змінний секвенсор, передавання привілею, історія комунікації, узгодження адресатами [156]. Це водночас класифікація *влади над порядком*: секвенсор дешевий, але сам вирішує, чиї операції підуть першими, і може вибірково їх затримувати; узгодження адресатами розподіляє цю владу ціною додаткових раундів.

4.2.3 Візантійська надійна розсилка

Візантійський відправник може надіслати різним процесам різні повідомлення (**двозначність**). Протокол Брахи [104] для $n \geq 3f+1$ додає фази ECHO і READY: отримавши $\langle \text{SEND}, m \rangle$, процес розсилає ECHO; зібравши досить ECHO або READY, розсилає READY; доставляє m після кворуму READY. Пороги й кількість повідомлень:

$$q_E = \left\lceil \frac{n+f+1}{2} \right\rceil, \qquad q_R = f+1, \qquad q_D = 2f+1, \qquad M(n) \approx n + 2n^2, \tag{4.3}$$

де q_E — кворум ECHO; q_R — кількість READY, що змушує процес приєднатися до них; q_D — кворум доставки; $M(n)$ — повідомлення на одну розсилку. Два кворуми ECHO перетинаються щонайменше в $2q_E - n \geq f+1$ процесах, тобто хоча б в одному коректному, тому два різні повідомлення не зберуть кворуму одночасно. Серед $f+1$ відправників READY є коректний, а $2f+1$ гарантує, що READY отримають усі коректні процеси. Для $n=4$, $f=1$ маємо $q_E=3$, $q_R=2$, $q_D=3$, $M \approx 36$; для $n=31$, $f=10$ — $q_E=21$, $q_R=11$, $q_D=21$, $M \approx 1953$. Квадратична складність — ціна стійкості без підписів; система Rampart поєднала візантійську надійну й атомарну розсилку зі службою членства на основі підписів [334], а порогові підписи замінюють $2f+1$ підтверджень одним сертифікатом (підрозділ 4.4).

4.2.4 Безпечна групова комунікація та групові ключі

До групового каналу висувають вимоги [390, 109]: автентифікацію й контроль допуску членів (розділ 10); конфіденційність під груповим ключем K_G; автентичність джерела (груповий MAC її не дає, бо будь-який член може підробити повідомлення іншого); **зворотну секретність** — новий член не читає минулого трафіку; **пряму секретність** у значенні групових протоколів — вилучений член не читає майбутнього трафіку (не плутати з PFS, розділ 9); стійкість до змови вилучених членів. Отже, *кожна зміна подання потребує зміни ключа*, і керування ключами стає задачею координації.

Логічна ієрархія ключів (LKH) [417, 411] розміщує членів у листках d-арного дерева: член знає ключі на шляху до кореня, кореневий ключ є груповим. Під час виходу члена сервер замінює ключі на цьому шляху й шифрує кожен новий ключ ключами дочірніх вузлів. Для групи з n членів

$$L = \lceil \log_d n \rceil, \qquad S_{\text{член}} = L+1, \qquad C_{\text{join}} = 2L, \qquad C_{\text{leave}} \leq dL, \tag{4.4}$$

де L — глибина дерева; $S_{\text{член}}$ — кількість ключів у члена; $C_{\text{join}}, C_{\text{leave}}$ — кількість шифрувань під час приєднання й виходу (їх вміщують в одне групове повідомлення). Плоска схема з попарними ключами вимагає $n-1$ шифрувань. Для $n = 10^6$ і $d=2$ маємо $L=20$, $C_{\text{leave}} \leq 40$; за $d=4$ — $L=10$, $C_{\text{join}}=20$, $C_{\text{leave}} \leq 40$ проти 999 999 у плоскій схемі. Оскільки

$dL \approx (d/\ln d)\ln n$, оптимум досягається за $d = 3$. Приклад наведено на рис. 4.2. Слабке місце LKH — сервер ключів, що знає всі ключі й є централізованим координатором (табл. 4.1).

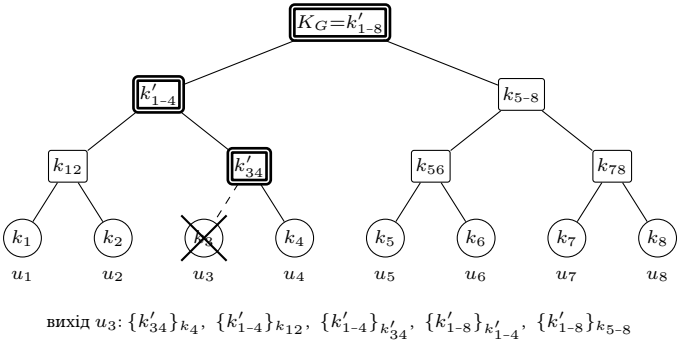


Рис. 4.2 — Дерево ключів LKH ($n = 8$, $d = 2$, $L = 3$): після виходу u_3 замінюються ключі на шляху до кореня (подвійна рамка), а групове повідомлення містить $dL - 1 = 5$ шифрувань (за [417])

Контрибутивні протоколи усувають довірений сервер. У TGDH [249] кожен вузол дерева має секретний ключ k_v і «засліплений» ключ $BK_v = g^{k_v} \bmod p$, а ключ внутрішнього вузла $k_v = g^{k_l k_r} \bmod p$ обчислюють із ключів нащадків, тож кореневий ключ є спільним ключем Діффі–Геллмана групи; зміна членства коштує $O(\log n)$ піднесень до степеня. Протокол вимагає однакового дерева в усіх членів, тобто узгоджених подань і впорядкованої доставки.

Сучасний стандарт — MLS (RFC 9420) [91]. Члени тримають пари ключів у листках *дерева з храповиком*, а груповий секрет змінюється *епохами*: повідомлення Commit застосовує пропозиції додавання, вилучення й оновлення, причому шифрування для всіх, крім одного члена, потребує $\log N$ шифрувань замість $N - 1$. MLS забезпечує пряму секретність і **безпеку після компрометації**: коли скомпрометований член оновить листковий ключ і групи оброблять відповідний Commit, порушник утрачає доступ. Службі доставки (DS) не довіряють конфіденційність, але вона може затримувати чи відкидати повідомлення. RFC 9420 визнає координаційну природу проблеми: застосунок *мусить* розв'язувати конфлікт кількох Commit однієї епохи, і якщо вибір делеговано DS, скомпрометована служба може блокувати оновлення члена й звести нанівець безпеку після компрометації, а зловмисний член — сформувати шлях оновлення, який відхилять лише деякі члени, і «фрагментувати» групу [91]. Груповий протокол успадковує вразливості впорядкування й двозначності.

4.3 Координаційні властивості

4.3.1 Безпечність та живучість

Координацію описують властивостями консенсусу, членства й узгодженості [390], які зводяться до двох типів. Нехай виконання — послідовність станів $\sigma = s_0 s_1 \ldots \in S^\omega$, властивість P — множина допустимих виконань, $\sigma_{..i}$ — префікс довжини i, S^* — скінченні послідовності. За Алперном і Шнайдером [76]

$$\begin{aligned} P - \text{безпечність} &\iff \forall \sigma \notin P \; \exists i \geq 0 \; \forall \beta \in S^\omega : \; \sigma_{..i} \, \beta \notin P, \\ P - \text{живучість} &\iff \forall \alpha \in S^* \; \exists \beta \in S^\omega : \; \alpha \, \beta \in P, \end{aligned} \tag{4.5}$$

і кожна властивість є перетином властивостей безпечності й живучості. У консенсусі узгодженість і дійсність — безпечність, завершення — живучість; «не більше одного лідера на терм» — безпечність, «кожен запит зрештою виконано» — живучість.

Порушення безпечності має *скінченного свідка* (поганий префікс), тому його можна довести за захищеним журналом аудиту (розділ 14), але не можна «виправити». Порушення живучості скінченного свідка не має: про нього лише *підозрюють* за тайм-аутами, які самі є припущенням про синхронність. Звідси принцип систем, стійких до вторгнень: безпечність має зберігатися за будь-яких затримок, а живучість може залежати від часткової синхронності (4.1). Конфіденційність не є властивістю окремого виконання: витік визначається співвідношенням кількох виконань, тобто є гіпервластивістю [133].

4.3.2 Упорядкування, логічний час і моделі узгодженості

Логічні годинники Лемпорта (розділ 1) гарантують лише $e \to e' \Rightarrow C(e) < C(e')$, а векторні точно характеризують причинність: $e \to e'$ тоді й лише тоді, коли $V(e) < V(e')$ покомпонентно [394]. Обидва механізми довіряють значенням, які повідомляє вузол. Візантійський вузол завищує компоненти вектора, і його оновлення «домінують» за стратегією «останній запис перемагає», або оголошує залежність від неіснуючого повідомлення, і причинна розсилка (4.2) безстроково чекає на «дірку» в історії. Захист — прив'язка залежностей до гешів повідомлень-попередників, обмеження приросту й підписування міток. Атаки на фізичний час розглянуто в підрозділі 2.5.

Моделі узгодженості — лінеаризованість [198], послідовна, причинна й кінцева [390] — також є координаційними властивостями: перші дві потребують повного порядку, а отже, консенсусу, останні досяжні без нього (розділи 1, 13). Модель визначає, *що може приховати зловмисна репліка*: за кінцевої узгодженості вона безкарно показує клієнтам різні історії, а за лінеа-

ризованості підписані квитанції мають вкладатися в одну історію, і розбіжність стає доказом для аудиту.

4.3.3 Відмовостійкість і детектори відмов

Відмовостійкість складається з *виявлення*, *маскування* (голосування реплік) і *відновлення* [86]. Виявлення формалізують **ненадійні детектори відмов** Чандри й Туега [119]: модуль процесу видає множину підозрюваних, а клас детектора задають *повнота* (зрештою кожен процес, що відмовив, постійно підозрюється) і *точність* (коректні процеси не підозрюються; у кінцевих варіантах — починаючи з деякого моменту). Консенсус розв'язний з детектором $\Diamond\mathcal{S}$ за $f < n/2$ [119], а $\Diamond\mathcal{W}$ є найслабшим придатним детектором [118]. На практиці детектор будують на серцебиттях і тайм-аутах, а кінцева точність досягається лише за часткової синхронності.

4.3.4 Атаки на детектор відмов і членство

Порушникові досить змусити детектор помилятися. Нехай лідер надсилає серцебиття з періодом η, послідовник починає вибори, якщо за $T = k\eta$ не отримав жодного, а порушник (вибірковим відкиданням пакетів, перевантаженням каналу чи процесора) спричиняє незалежну втрату кожного серцебиття з імовірністю p. Тоді

$$P_{\text{fs}} = p^k, \qquad \bar{T}_{\text{fs}} \approx \frac{\eta}{p^k}, \qquad T_D \approx T + \eta, \tag{4.6}$$

де P_{fs} — імовірність хибної підозри у вікні; $\bar{T}_{\text{fs}}$ — середній час між хибними підозрами, що провокують переобрання; T_D — час виявлення справжньої відмови. Для типових налаштувань etcd $\eta = 100$ мс і $T = 1000$ мс [401], тобто $k = 10$. За природних втрат $p = 0{,}05$ маємо $\bar{T}_{\text{fs}} \approx 10^{12}$ с, за $p = 0{,}5$ — близько 102 с, за $p = 0{,}7$ — близько $3{,}5$ с: кластер постійно перебуває у виборах і не приймає записів, хоча жоден вузол не відмовив. Подвоєння T ($k = 20$) за $p = 0{,}5$ дає $\bar{T}_{\text{fs}} \approx 29$ год, але вдвічі збільшує T_D: точність і швидкість виявлення конкурують, а порушник на шляху передавання може відкидати *всі* серцебиття, і криптографія тут не допомагає.

Інший вектор — *дестабілізація виборів*: у Raft ізольований вузол збільшує номер терму й після повернення змушує лідера скласти повноваження. Фаза **попереднього голосування** (Pre-Vote) і правило ігнорувати запити на голосування, поки надходять серцебиття чинного лідера, усувають такі збурення [312]. Протилежний випадок — *сіра відмова*: вузол відповідає на серцебиття, але не обробляє запитів, тож потрібні перевірки *прогресу* на рівні застосунку, а не лише досяжності.

Атаки на членство спрямовані на службу подань. *Примусові зміни подання* виснажують систему: за (4.4) при $n = 10^6$, $d = 4$ і 100 виходах на секунду сервер виконує до 4000 шифрувань на секунду. *Sybil-вузли* (підрозділ 2.3)

збільшують частку порушника понад f. *Атака реконфігурації* домагається хибними звинуваченнями вилучення чесних членів: якщо в BFT-групі з $n = 7$ ($f = 2$) порушник контролює дві репліки й домігся вилучення двох чесних, то для $n = 5$ допустимо лише $f = 1$, і безпеку порушено без нової компрометації. Захист — реконфігурація лише рішенням кворуму *старої* конфігурації, обмеження частоти змін і нижня межа n (табл. 4.2).

Таблиця 4.2 — Координаційні властивості, атаки на них і механізми захисту

Властивість	Атака	Механізм захисту
Узгодженість консенсусу	двозначність візантійського лідера чи відправника	перетин кворумів, розсилка Брахи (4.3), підписи
Повний порядок	вибіркова затримка чи випередження операцій секвенсором	узгодження адресатами, ротація лідера, фіксація порядку до розкриття вмісту
Причинний порядок	завищення лічильників, фіктивні залежності	геш-зв'язані історії, межі приросту, підписані мітки
Лінеаризованість читань	читання в колишнього лідера з простроченою орендою	кворумне підтвердження читань, fencing-токени епох
Завершення (живучість)	затримки понад тайм-аут, керування GST	експоненційні тайм-аути, ротація лідера, моніторинг виборів
Точність детектора	хибні підозри, штормові вибори (4.6)	Pre-Vote, адаптивні тайм-аути, кілька шляхів серцебиття
Повнота детектора	сіра відмова «напівживого» вузла	перевірки прогресу застосунку
Членство й подання	Sybil-вузли, вилучення чесних, часті зміни подання	контроль допуску, реконфігурація кворумом старої конфігурації, мінімальне n
Групова секретність	придушення оновлень ключів службою доставки, фрагментація групи	підтвердження Commit, моніторинг епох

4.4 Схема керування та координації реплікації: основа пом'якшення атак

4.4.1 Активна, пасивна й напівактивна реплікація

Підхід **скінченного автомата** Шнайдера [355] подає службу детермінованим автоматом, вихід якого визначено послідовністю команд. Координація реплік зводиться до *узгодженості* (кожна коректна репліка отримує кожен запит) і *порядку* (усі обробляють запити в однаковій послідовності), тобто до атомарної розсилки (4.2). Для t відмов типу «зупинка» достатньо $t + 1$ реплік, для t візантійських — $2t + 1$ з голосуванням за виходами [355], хоча саме впорядкування за візантійських учасників потребує порогу $3t + 1$ (розділ 13). Вимога детермінізму — окрема поверхня атаки: якщо команда залежить від локального годинника чи планування потоків, вплив на

середовище однієї репліки робить чесну репліку «візантійською» і може спричинити її хибне вилучення.

У **активній** реплікації команди виконують усі репліки, а виходи голосуються. У **пасивній** (primary–backup) виконує лише первинна репліка й передає резервним оновлення стану; недетермінізм дозволено, але відмову первинної треба виявляти, тож схема вразлива до хибних підозр (4.6) і «розщепленого мозку» з двома первинними. Від нього захищають монотонні номери епох (fencing-токени), які сховище перевіряє під час запису; візантійську первинну репліку пасивна схема не виявляє. У **напівактивній** виконують усі, а недетерміновані рішення ухвалює лідер. **Лінива** реплікація поширює оновлення асинхронно й має вікно втрати підтверджених записів [390]. Схеми зображено на рис. 4.3.

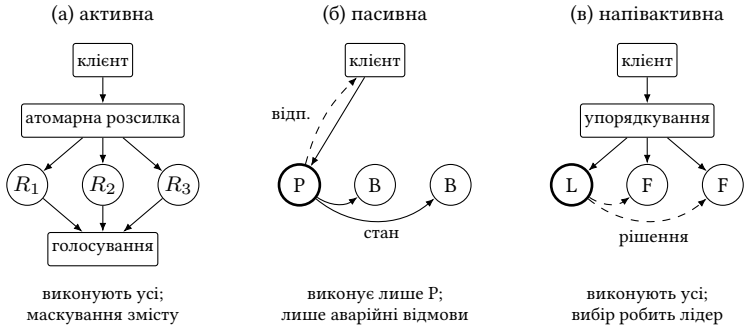


Рис. 4.3 — Схеми керування репліками: P — первинна, B — резервні, L — лідер, F — послідовники (за [355, 390])

4.4.2 Аварійні та візантійські моделі й вікно вразливості

Реплікація з аварійними відмовами ($n \geq 2f + 1$) не захищає від зловмисної репліки, а BFT-реплікація ($n \geq 3f + 1$) маскує довільну поведінку f реплік ціною квадратичного обміну на кшталт (4.3) (розділ 13). Спільна слабкість: межа f має виконуватися протягом *усього* життя системи. **Проактивне відновлення** Кастро й Ліскова [116] періодично перезавантажує репліки з чистого образу й оновлює їхні ключі, тож поріг f стосується лише *вікна вразливості* T_w. За середнього часу компрометації репліки $\tau_c = 30$ діб і $T_w = 15$ год імовірність компрометації у вікні $q = 1 - e^{-T_w/\tau_c} \approx 0{,}02$; це значення використано нижче.

4.4.3 Порогова криптографія та проактивне оновлення часток

Реплікація погіршує конфіденційність: копія закритого ключа на кожній з n реплік підвищує ймовірність його викрадення до $1 - (1 - q)^n$. За схемою

Шаміра [360] секрет $s = F(0)$ задає многочлен F степеня f, репліка i отримує частку $s_i = F(i)$, будь-які $f+1$ часток відновлюють секрет, а f часток нічого не розкривають. Порогові підписи Шоупа [367] дають змогу $f+1$ реплікам сформувати звичайний підпис RSA під одним відкритим ключем, не збираючи закритого ключа. Проти *мобільного* порушника **проактивне розділення секрету** [199] оновлює частки на початку кожного періоду τ:

$$s_i^{(\tau+1)} = s_i^{(\tau)} + \sum_{j=1}^{n} \delta_j^{(\tau)}(i), \qquad \deg \delta_j^{(\tau)} = f, \quad \delta_j^{(\tau)}(0) = 0, \tag{4.7}$$

де $\delta_j^{(\tau)}$ — випадковий многочлен репліки j з нульовим вільним членом. Секрет не змінюється, частки різних періодів не поєднуються, тож порушник мусить отримати $f+1$ часток *в одному періоді*. Для $n=4$, $f=1$, $q=0{,}02$ на період це $2{,}34\cdot 10^{-3}$, а за 30 періодів — $0{,}068$. Без оновлення частки накопичуються: за 30 періодів репліка скомпрометована з імовірністю $1-0{,}98^{30}\approx 0{,}45$, і секрет розкривається з імовірністю $0{,}62$ — у дев'ять разів частіше.

4.4.4 Різноманітність реплік і модель спільної причини

Пороги припускають *незалежну* компрометацію, але ідентичні репліки мають однакові вразливості [390]. Ідею N-версійного програмування [85] перевірили Найт і Левесон: для 27 незалежно розроблених версій програми гіпотезу про незалежність відмов статистично відхилено [252]. Ретельно дібрані комбінації ОС мають значно менше спільних уразливостей, ніж однорідні [178], а система Lazarus автоматично керує різноманітністю BFT-реплік за відкритими даними про вразливості [179].

Застосуємо β-модель відмов зі спільною причиною з функційної безпеки [209]: імовірність компрометації репліки q поділяють на незалежну складову $q_I = (1-\beta)q$ і спільну $q_C = \beta q$, що одночасно вражає всі репліки однієї версії. Для однорідної BFT-групи

$$P_{\text{одн}}(n,f) \approx \beta q + (1-\beta q)\sum_{j=f+1}^{n} \binom{n}{j} q_I^{\,j}(1-q_I)^{n-j}, \tag{4.8}$$

де перший доданок описує спільну вразливість, що дає порушникові всі $n > f$ реплік, а сума — незалежне захоплення понад f реплік (пор. (2.5)). Отже, βq — *нижня межа* ризику, яку не зменшує збільшення n. Якщо жодна з m версій не має більше f реплік, одна спільна вразливість безпеки не порушує, і доданок βq замінюється членами порядку $(\beta q)^2$ та змішаними подіями. Точний розрахунок для $q=0{,}02$ наведено в табл. 4.3.

Таблиця 4.3 — Імовірність порушення безпеки BFT-групи ($q = 0{,}02$)

n (f), версії	β=0	β=0,1 одн.	β=0,1 різн.	β=0,3 одн.	β=0,3 різн.
4 (1), 1+1+1+1	$2{,}34 \cdot 10^{-3}$	$3{,}89 \cdot 10^{-3}$	$2{,}33 \cdot 10^{-3}$	$7{,}15 \cdot 10^{-3}$	$2{,}32 \cdot 10^{-3}$
7 (2), 2+2+2+1	$2{,}6 \cdot 10^{-4}$	$2{,}19 \cdot 10^{-3}$	$7{,}4 \cdot 10^{-4}$	$6{,}09 \cdot 10^{-3}$	$1{,}52 \cdot 10^{-3}$
10 (3), 3+3+2+2	$3{,}1 \cdot 10^{-5}$	$2{,}02 \cdot 10^{-3}$	$5{,}5 \cdot 10^{-4}$	$6{,}01 \cdot 10^{-3}$	$1{,}39 \cdot 10^{-3}$

За незалежних компрометацій перехід від $n = 4$ до $n = 10$ знижує ризик у 75 разів, а за $\beta = 0{,}1$ в однорідній групі — лише в 1,9 раза, бо ризик упирається в межу $\beta q = 0{,}002$. Група з $n = 7$ реплік чотирьох версій майже втричі надійніша за однорідну з $n = 10$, а за $\beta = 0{,}3$ різноманітна група з чотирьох реплік у 2,6 раза надійніша за однорідну з десяти: різноманітність дешевша за нарощування кількості реплік. Проте спільні адміністратори й ланцюг постачання корелюють компрометації незалежно від програмної різноманітності.

4.4.5 Як схема реплікації пом'якшує класи атак

Відповідно до табл. 4.2 жоден механізм не закриває всіх класів збурень: *часові* атаки (затримки, пропуски, DoS) маскує кворумна реплікація до f недоступних реплік; *змістові* (підробка, двозначність) — лише активна BFT-реплікація; *тривалі вторгнення* — проактивне відновлення; *спільні вразливості* — різноманітність версій (4.8); *викрадення секретів* — порогова криптографія з оновленням (4.7); *розщеплений мозок* — кворум більшості, fencing-токени й заборона перемикання між регіонами без кворуму.

4.4.6 Кейс: координаційна служба Kubernetes під атакою

Kubernetes зберігає весь стан кластера в etcd — реплікованій на основі Raft службі «ключ–значення». Доступ до etcd рівнозначний правам суперкористувача, тому звертатися до нього має лише API-сервер через TLS з автентифікацією клієнтів за сертифікатами, а в разі втрати кворуму кластер не змінює стан і нові поди не плануються [317, 399]. Рекомендовано п'ять членів: кластери з 3, 5 і 7 членів витримують 1, 2 і 3 відмови, а понад сім членів знижують продуктивність запису [175]; тайм-аут виборів має щонайменше вдесятеро перевищувати час обертання пакета [401].

Нехай оператор критичної інфраструктури в Україні розміщує п'ять членів etcd. Під час воєнного стану державні інформаційні ресурси дозволено розміщувати на хмарних ресурсах за межами України [11], тож третім майданчиком може бути хмарний регіон в ЄС. За доступності члена $a = 0{,}995$ і майданчика (з урахуванням знеструмлень) $a_s = 0{,}98$ формула (2.5), до-

повнена відмовами майданчиків, дає: усі члени на одному майданчику — $A \approx 0{,}9800$; розподіл $3{+}2$ — $A \approx 0{,}9797$, тобто *гірше*, бо втрата більшого майданчика знищує кворум; розподіл $2{+}2{+}1$ між трьома майданчиками — $A \approx 0{,}9982$, що скорочує річний простій із 175 до 15 год. Міжмайданчиковий канал при цьому стає поверхнею атаки: за часу обертання 40 мс тайм-аут виборів має бути не меншим за 400 мс, а вибіркова затримка серцебиття провокує хибні вибори (4.6). Звідси конфігурація: $2{+}2{+}1$, тайм-аут із запасом, Pre-Vote, взаємна TLS-автентифікація, доступ до etcd лише з API-серверів, моніторинг змін лідера й терму (розділ 14).

У жовтні 2018 р. втрата зв'язності в мережі GitHub тривала 43 с, але система керування кластерами MySQL на основі Raft встигла перемкнути первинні бази на інше узбережжя США; у кожному дата-центрі лишилися відсутні в іншому записи (на одному кластері — близько 954), і деградація тривала 24 год 11 хв [414]. У листопаді 2020 р. в Cloudflare частково несправний комутатор створив асиметричний поділ: члени etcd бачили різні підмножини вузлів, вибори завершувалися нічиєю, кластер перейшов у режим лише читання, а деградація API тривала 6 год 33 хв [265]. За механізмом це була відмова типу «пропуск» (сам звіт Cloudflare називає її візантійською, бо різні вузли спостерігали суперечливий стан мережі), але детектор відмов опинився в стані, який порушник може створити цілеспрямовано.

Суміжні українські дослідження стосуються аудиту легковагових кластерів Kubernetes із довірою на базі MultiChain [2] і шардингу стану мультичейн-систем зі збереженням консенсусу [25]. Відкриті проблеми — емпірична оцінка β, безпечна реконфігурація BFT-груп і детектори відмов, стійкі до сірих відмов.

Висновки до розділу

Скоординована кластеризація створює ілюзію централізованої служби, що тримається на припущеннях про синхронність, відмови й членство. Стиль координації визначає, де зосереджено довіру (табл. 4.1), а модель часткової синхронності (4.1) показує, що порушник, який керує затримками, атакує насамперед живучість. Групова комунікація поєднує членство, віртуальну синхронність і впорядковану розсилку (4.2); двозначність нейтралізують кворуми Брахи (4.3), а кожна зміна подання вимагає зміни ключів, яку LKH здешевлює до $O(d \log_d n)$ (4.4), тоді як TGDH і MLS усувають довірений сервер, але залежать від порядку змін стану групи.

Розмежування безпечності й живучості (4.5) дає метод аналізу атак (табл. 4.2): хибні підозри детектора (4.6), дестабілізація виборів і реконфігурація порушують гарантії без злому криптографії. Активна BFT-реплікація маскує змістові атаки, проактивне оновлення (4.7) — тривалі, різноманітність версій — спільні вразливості, що за β-моделлю (4.8) задають нижню

межу ризику (табл. 4.3). Кейс etcd та інциденти з розщепленням мозку показують, що розміщення реплік і налаштування детекторів відмов є рішеннями безпеки.

Питання для самоперевірки

1. Порівняйте централізований, лідерний, безлідерний і подієвий стилі координації за розташуванням довіри, єдиними точками відмови та стійкістю до візантійських вузлів.
2. Поясніть модель часткової синхронності (4.1). Чому протокол цієї моделі може втратити живучість під час атаки, але не повинен втрачати безпеку?
3. Сформулюйте властивість віртуальної синхронності. Які наслідки для безпеки групи має компрометація служби членства?
4. Наведіть приклад, коли FIFO-розсилка дає різні рішення авторизації на різних репліках, а повний порядок — однакові. Чи випливає з повного порядку FIFO-порядок?
5. За формулою (4.3) обчисліть пороги q_E, q_R, q_D і кількість повідомлень для $n = 13$, $f = 4$. Доведіть, що два кворуми ЄСНО перетинаються щонайменше в одному коректному процесі.
6. Для групи з $n = 50\,000$ членів обчисліть за (4.4) глибину дерева, кількість ключів у члена й вартість виходу для $d = 2$, $d = 3$ і $d = 8$. Порівняйте з плоскою схемою.
7. Чим пряма й зворотна секретність групових протоколів відрізняються від безпеки після компрометації в MLS? Які атаки на службу доставки MLS порушують ці властивості?
8. Класифікуйте як властивості безпечності чи живучості: «не більше одного лідера на терм», «кожен запис зрештою реплікується», «вилучений член не розшифровує нових повідомлень». Чому конфіденційність не є властивістю окремого виконання?
9. За моделлю (4.6) знайдіть мінімальне k, за якого середній час між хибними підозрами перевищує добу при $\eta = 50$ мс і $p = 0{,}6$. Який час виявлення справжньої відмови дістанемо?
10. Опишіть атаку реконфігурації на BFT-групу з $n = 10$. Скільки чесних реплік має вилучити порушник, що контролює три репліки, щоб порушити безпеку? Запропонуйте захист.
11. Порівняйте активну, пасивну й напівактивну реплікацію за стійкістю до змістових атак, вимогою детермінізму та ризиком розщепленого мозку.

12. За (4.7) поясніть, чому частки різних періодів неможливо поєднати. Оцініть імовірність розкриття секрету за рік при $n = 7$, $f = 2$, $q = 0{,}01$ на добу з щоденним оновленням і без нього.
13. Використовуючи (4.8), знайдіть β, за якого однорідна група з $n = 10$ стає менш надійною, ніж повністю різноманітна група з $n = 4$ при $q = 0{,}02$.
14. Розрахуйте доступність кластера etcd із семи членів за розміщень $4{+}3$, $3{+}2{+}2$ і $3{+}3{+}1$ при $a = 0{,}995$, $a_s = 0{,}98$. Яке розміщення обрали б для об'єкта критичної інфраструктури і чому?
15. *Дослідницьке.* На основі інцидентів GitHub (2018) і Cloudflare (2020) запропонуйте метрики та методику виявлення атак на детектор відмов координаційної служби й оцініть їхню здатність відрізняти атаку від сірої відмови.

РОЗДІЛ 5

Розподілені системи: координаційні класи та напади

Розділ відповідає змістовому модулю IV «Розподілені системи: координаційні класи та напади» (тема 4) робочої програми дисципліни й завершує модульну частину посібника. Класи координації введено в розділі 2, P2P-системи розглянуто в розділі 3, механізми логічної централізації — у розділі 4; тут ці механізми аналізуються з погляду порушника: як атакують системи кожного координаційного класу на рівнях інфраструктури та програм і чому атака на нижчий шар часто вражає не ресурс, а службу, що на ньому виконується. Структуру узгоджено з CyBOK [390] і поглиблено моделями поширення компрометації, кількісними оцінками атак, першоджерелами та українським контекстом.

5.1 Координаційні класи та атакованість: узагальнена модель

5.1.1 Два подання однієї системи

Нагадаємо (підрозділ 2.1), що скоординовані системи поділяють на клас координації ресурсів Γ_R і клас координації послуг Γ_S. Для Γ_R характерне **інфраструктурне подання**: користувач задає операційні вимоги (обчислювальні ресурси, кількість віртуальних машин, сховище, затримку, ціну), але не знає, як ресурси розміщено й репліковано. Домінантними властивостями є доступність і надійність доступу до ресурсів, а цілісність важлива настільки, наскільки її вимагає специфікація служби, наприклад ізоляція ВМ без витоку інформації [390]. Для Γ_S характерне **подання програм**: схему координації визначає специфікація служби — база даних вимагає ACID, сховище «ключ–значення» — лінеаризованості, пошукова служба задовольняється слабкою узгодженістю, а реєстр вимагає сильної узгодженості ціною затримки. Тому першою мішенню атак на Γ_S є цілісність (разом із конфіденційністю), а доступність страждає як наслідок.

Функціональні блоки хмари (автентифікація, допуск, брокери, планувальники, монітори, балансувальники, комунікації, інтерфейси, сховища) разом із фізичними ресурсами й інтерфейсами між ними утворюють поверхню атаки [390]. Для аналізу зручно впорядкувати ці блоки в чотири шари: **ресурс** (апаратне забезпечення, гіпервізор, фізична мережа, носії), **платформа** (площина керування, API оркестратора, планувальник, служба метаданих, розподілене сховище), **сервіс** (бази даних, черги, реєстри служб, шини, API) і **застосунок** (бізнес-логіка, композиції сервісів, вебінтерфейси). Перші два шари належать переважно до Γ_R, два останні — до Γ_S (рис. 5.1).

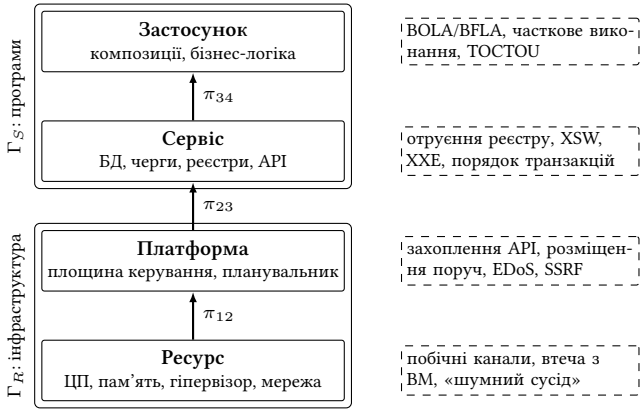


Рис. 5.1 — Шари координаційних класів, типові атаки на кожному шарі та коефіцієнти поширення компрометації $\pi_{\ell-1,\ell}$ (авторське узагальнення за [390])

5.1.2 Модель поширення компрометації між шарами

Шари пов'язані *координаційними залежностями*: гіпервізор розподіляє пам'ять і процесорний час між ВМ, площина керування видає облікові дані й конфігурацію, сервіс довіряє платформі розміщення своїх реплік, застосунок — сервісам. Тому ресурсна атака, як зауважено в CyBOK, найчастіше шкодить не ресурсу *per se*, а службі, що на ньому виконується [390]. Нехай p_ℓ — імовірність прямої компрометації шару $\ell \in \{1,2,3,4\}$ через його власну поверхню атаки за період спостереження, а $\pi_{\ell-1,\ell}$ — умовна ймовірність того, що компрометація шару $\ell-1$ дає порушникові контроль над шаром ℓ (сила координаційної залежності; $\pi = 1$ означає повну довіру, $\pi \to 0$ — ефективну ізоляцію чи атестацію). За припущення незалежності подій імовірність компрометації шару

$$P_1 = p_1, \qquad P_\ell = 1 - (1 - p_\ell)\bigl(1 - \pi_{\ell-1,\ell}\, P_{\ell-1}\bigr), \quad \ell = 2,3,4, \tag{5.1}$$

а *радіус ураження* компонента шару ℓ, від якого залежать N_ℓ орендарів, характеризується математичним сподіванням кількості одночасно скомпрометованих застосунків $\mathbb{E}[D_\ell] = p_\ell\, N_\ell \prod_{j=\ell}^{3} \pi_{j,j+1}$.

Числовий приклад. Нехай $p_1 = 0{,}01$ (гіпервізор, апаратне забезпечення), $p_2 = 0{,}03$ (площина керування), $p_3 = 0{,}05$ (сервіс), $p_4 = 0{,}10$ (застосунок), $\pi_{12} = 0{,}9$, $\pi_{23} = 0{,}8$, $\pi_{34} = 0{,}9$. Тоді $P_2 \approx 0{,}0387$, $P_3 \approx 0{,}0794$, $P_4 \approx 0{,}164$: нижчі шари додають до власного ризику застосунку 64%, тобто близько 39% підсумкового ризику спричинено координаційними залежностями. Посилення захисту самого застосунку ($p_4 = 0{,}05$) дає $P_4 \approx 0{,}118$;

якщо натомість запровадити конфіденційні обчислення ($\pi_{12} = 0{,}3$) і захистити площину керування ($p_2 = 0{,}01$), то $P_4 \approx 0{,}148$, а обидва заходи разом — $P_4 \approx 0{,}101$. Окремому орендареві захист нижчих шарів дає менше, але для гіпервізора з $N_1 = 40$ орендарями $\mathbb{E}[D_1] = 0{,}01 \cdot 40 \cdot 0{,}648 \approx 0{,}26$, і ця величина реалізується як рідкісна подія, що одночасно вражає близько 26 застосунків. Такий корельований ризик не диверсифікується в межах одного провайдера, тож орендареві варто розподіляти репліки між доменами відмов (підрозділ 4.4).

Модель ігнорує зворотні шляхи (від застосунку до площини керування, як у SSRF) і кореляцію p_ℓ; її узагальнення — ймовірнісний граф атак із вагами ребер π (розділи 7 і 8).

5.2 Клас координації ресурсів: розгляд інфраструктури

5.2.1 Об'єкти координації ресурсів

Типовим представником класу Γ_R є хмара моделі IaaS [279]: планувальник і брокер відображають запити орендарів на фізичні хости, запускають і мігрують ВМ, стежать за станом ресурсів і відпрацьовують відмови відповідно до угоди про рівень обслуговування (SLA) [390]. Ізоляцію орендарів забезпечує **гіпервізор** (тип 1 — на апаратному забезпеченні, тип 2 — поверх хостової ОС); NIST SP 800-125 вимагає мінімізувати, оновлювати й ізолювати гіпервізор та його інтерфейс керування як найпривілейованіші компоненти [354]. До класу належать також кластери й ґрід із менеджерами задач, розподілені файлові системи й об'єктні сховища із серверами метаданих, програмно-визначені мережі ЦОД із логічно централізованим контролером (розділ 11), реплікована інфраструктура клієнт–сервер [390] і периферійні обчислення (розділ 16). Контейнерні оркестратори й модель спільної відповідальності розглянуто в розділі 12.

5.2.2 Класи атак на координацію ресурсів

5.2.2.1 Побічні та приховані канали між орендарями

ВМ різних орендарів ділять кеш процесора, шину пам'яті й планувальник гіпервізора. На прикладі Amazon EC2 Ристенпарт і співавтори показали, що можна картографувати внутрішню мережу хмари, визначити ймовірний хост жертви й запускати ВМ, доки одна з них не опиниться на тому самому хості, а потім застосувати побічні канали [340]. Згодом у лабораторних умовах із сусідньої ВМ на гіпервізорі Xen було видобуто ключ розшифрування ElGamal бібліотеки libgcrypt [426]. Spectre змушує процесор спекулятивно виконувати інструкції й розкривати дані жертви через стан кешу, долаючи межі програмних пісочниць [254], а Meltdown дає змогу читати пам'ять

ядра з непривілейованого процесу [267]. Отже, ізоляція в Γ_R залежить від мікроархітектурних припущень, які неможливо перевірити програмно.

Атака починається з координаційного кроку — *розміщення*. Нехай планувальник розміщує кожну з k ВМ порушника рівноймовірно й незалежно на одному з H придатних хостів. Імовірність хоча б одного спільного розміщення з жертвою та очікувана вартість спроби

$$P_{\text{со}}(k, H) = 1 - \left(1 - \frac{1}{H}\right)^{k} \approx 1 - e^{-k/H}, \qquad C_{\text{со}} = k\, c_{\text{ВМ}}\, t, \tag{5.2}$$

де $c_{\text{ВМ}}$ — ціна години роботи ВМ, t — тривалість спроби в годинах. Для $H = 1000$ і $k = 100$ маємо $P_{\text{со}} \approx 0{,}095$. Проте планувальник не є рівномірним: він групує ВМ за зоною доступності, типом екземпляра й часом запуску. Якщо порушник, запускаючи ВМ одразу після жертви, зменшує ефективну множину хостів до $H_{\text{еф}} = 50$, то вже $k = 20$ ВМ дають $P_{\text{со}} \approx 0{,}33$, а $k = 100$ — $P_{\text{со}} \approx 0{,}87$. Отже, передбачуваність планувальника підсилює атаку на порядок, а рандомізація розміщення, виділені хости й обмеження частоти створення ВМ є заходами саме координаційного рівня.

5.2.2.2 Втеча з віртуальної машини

Помилка в емульованому пристрої або гіпервізорі дає гостьовому коду виконання на рівні хоста, тобто одночасну компрометацію всіх орендарів ($\pi_{12} \to 1$ у (5.1)). Показовий приклад — уразливість VENOM у віртуальному контролері гнучких дисків QEMU, який використовували Xen і KVM: команди контролера з гостьової системи спричиняли запис за межами буфера з можливістю виконання довільного коду [142]: поверхнею атаки є навіть застарілі пристрої, що емулюються за замовчуванням.

5.2.2.3 «Шумний сусід», вичерпання ресурсів і EDoS

Спільні ресурси, які гіпервізор не розподіляє жорстко (кеш, пропускна здатність пам’яті й дисків), дають змогу орендареві погіршувати продуктивність сусідів. Варадараджан і співавтори описали **атаки звільнення ресурсів**: порушник спрямовує на застосунок жертви запити, які змінюють характер її навантаження, і так звільняє спільний ресурс для власної ВМ. У лабораторії продуктивність кеш-чутливого тесту через сусідню ВМ падала більш ніж на 80%, атака покращувала результати до 60%, а в Amazon EC2 — до 13% [410]. Еластичність хмари породжує окремий клас — **економічну відмову в обслуговуванні** (Economic Denial of Sustainability, EDoS): служба не падає, бо автомасштабування додає екземпляри, але рахунок жертви зростає до неприйнятного рівня [384]. Додаткові витрати жертви за час T

оцінимо як

$$\Delta C(T) = T\,c_h \left\lceil \frac{\lambda_a}{\rho\,\mu} \right\rceil + 3600\,T\,\lambda_a\,b\,c_e, \qquad n \le n_{\max}, \tag{5.3}$$

де λ_a — інтенсивність шкідливих запитів, запит/с; μ — продуктивність одного екземпляра, запит/с; ρ — цільове завантаження автомасштабування; c_h — ціна екземпляра за годину; b — обсяг відповіді, ГБ; c_e — ціна вихідного трафіку за ГБ; T — у годинах; $n = \lceil \lambda_a/(\rho\mu) \rceil$ — кількість додаткових екземплярів, $n_{\max}$ — стеля масштабування. Для $\lambda_a = 2000$, $\mu = 100$, $\rho = 0{,}6$, $c_h = 0{,}2$ ум. од., $b = 5{\cdot}10^{-5}$ ГБ (50 КБ), $c_e = 0{,}05$ ум. од. і $T = 720$ год (місяць) отримуємо 34 додаткові екземпляри вартістю 4896 ум. од. і $259\,200$ ГБ трафіку вартістю $12\,960$ ум. од., разом близько $17\,900$ ум. од. Витрати на трафік перевищують обчислювальні, а стеля $n_{\max}$ перетворює EDoS на звичайну відмову в обслуговуванні: параметр координації ресурсів задає компроміс між доступністю й фінансовою стійкістю.

5.2.2.4 Компрометація площини керування та служби метаданих

Інтерфейс керування хмарою — «найкоротший шлях» до всіх ресурсів орендаря: через нього змінюють образи, запускають і зупиняють екземпляри, тож успішна атака дає повний контроль над обліковим записом жертви з усіма даними [375]. Технічні проблеми безпеки хмарних вебсервісів, серед них атаки обгортання XML-підпису (підрозділ 5.3), систематизовано ще 2009 р. [239]. У 2011 р. частина тих самих авторів повідомила, що на час дослідження інтерфейси керування публічної хмари Amazon (EC2, S3) і приватної хмарної платформи Eucalyptus вдавалося скомпрометувати обгортанням підпису та міжсайтовим скриптингом [375]. Інший вектор — **підробка запитів на боці сервера** (SSRF) до служби метаданих екземпляра, яка видає тимчасові облікові дані ролі ВМ. Саме так у 2019 р. неправильно налаштований вебекран застосунків Capital One було змушено переслати запити до служби метаданих AWS; отримані облікові дані мали надмірні права на читання об'єктних сховищ [256], а витік торкнувся понад 100 млн осіб; збої контролю охопили всі рівні — від налаштувань до керівництва й регуляторів [248]. У термінах моделі (5.1) це *зворотний* шлях: від застосунку (шар 4) через платформу (шар 2) до даних інших сервісів. Протидія — сесійний режим служби метаданих IMDSv2, у якому запит має містити токен, отриманий окремим запитом `PUT` [405], найменші привілеї ролей екземплярів і заборона вихідних з'єднань застосунків до службових адрес.

5.2.2.5 Атаки на планувальник, брокер, міграцію і сховище

Аномальний розподіл задач, спричинений атакою на планувальник, виявляють засобами керування доступом; за зловмисного захоплення планувальника порушуються доступність і цілісність, але не конфіденційність, а компрометація брокера ресурсів вражає насамперед доступність і без резервних брокерів веде до зупинки системи [390]. Спотворення даних моніторингу й обліку порушує всі властивості CIA, бо рішення про масштабування й міграцію ухвалюються на хибному поданні стану. *Жива міграція* передає пам'ять ВМ мережею, тож неавтентифікований канал дає змогу читати й змінювати її стан, а спровокована міграція — впливати на розміщення. Образи й знімки ВМ потребують такого самого захисту, як і працюючі системи [354]. У розподілених сховищах мішенями є сервер метаданих, політика розміщення реплік і залишкові дані на спільних носіях.

5.2.3 Заходи захисту

Ізоляцію забезпечують апаратна віртуалізація з мінімальною довіреною обчислювальною базою й засоби проти спекулятивного виконання. Конфіденційні обчислення (AMD SEV-SNP, Intel TDX) шифрують пам'ять ВМ ключами, недоступними гіпервізору, і дають віддалену атестацію, тож зменшують π_{12}, хоча побічних каналів повністю не усувають. Площину керування захищають багатофакторна автентифікація, короткоживучі облікові дані, окремі мережі керування, журналювання викликів API з виявленням аномалій (розділ 14) і перевірка узгодженості стану планувальника з дозволеними розподілами [390]. Решту заходів узагальнено в табл. 5.1.

Таблиця 5.1 — Атаки на клас координації ресурсів

Атака	Шар	Порушувана властивість	Заходи
Побічні канали між орендарями	1	ізоляція, конфіденційність	виділені хости, заборона спільних ядер, SEV-SNP/TDX, оновлення мікрокоду
Втеча з ВМ	1	ізоляція, цілісність усіх орендарів	мінімізація гіпервізора, вимкнення зайвих пристроїв, оновлення
Розміщення поруч із жертвою	2	непередбачуваність розміщення	рандомізація, обмеження частоти запусків, anti-affinity
Шумний сусід, звільнення ресурсів	1–2	справедливий розподіл, доступність	квоти, cgroups, резервування, моніторинг продуктивності
EDoS	2	еластичність, фінансова стійкість	стеля $n_{\max}$, кешування, обмеження швидкості, бюджетні сповіщення
Захоплення API, SSRF до метаданих	2	автентичність керувальних команд	MFA, IMDSv2, найменші привілеї, журналювання API
Захоплення планувальника чи брокера	2	узгодженість прив'язок «задача–ресурс»	перевірка узгодженості, резервні брокери
Атаки на міграцію й образи	2	конфіденційність і цілісність стану ВМ	шифрований автентифікований канал, захист знімків
Атаки на розподілене сховище	2	цілісність і доступність даних у спокої	захист сервера метаданих, домени відмов, шифрування

5.2.4 Кейси: від дослідження до кампаній проти провайдерів

Три епізоди ілюструють різні шляхи поширення компрометації в Γ_R. *Через розміщення*: у роботі [340] легітимний API створення ВМ став першим кроком атаки на ізоляцію, а згодом цей ризик перетворився на викрадення ключів [426]. *Через постачальника керованих послуг*: у 2017 р. CISA повідомила про кампанію проти постачальників керованих IT-послуг (MSP), у якій викрадені адміністративні облікові дані й сертифікати провайдерів давали доступ до мереж клієнтів, а спільна, лише логічно розділена інфраструктура MSP ставала точкою входу до всіх них; у редакції 2018 р. кампанію пов'язано з діями кібергрупи, яку уряд США пов'язує з Міністерством державної безпеки КНР (APT10) [223]. Координаційною залежністю тут є делегована довіра «провайдер $\rightarrow$ клієнт» з $\pi \approx 1$. *Через застосунок*: кейс Capital One — зворотний шлях «застосунок $\rightarrow$ служба метаданих $\rightarrow$ сховище» [256, 248]. В усіх трьох випадках порушник не зламує криптографію, а використовує легітимні координаційні механізми з надмірною довірою.

5.3 Клас координації послуг: розгляд програм

5.3.1 Об'єкти координації послуг

CyBOK відносить до класу Γ_S вебсервіси, служби розподілу ключів (розділи 9, 10), сховища «ключ–значення», транзакційні служби й блокчейни та поділяє транзакції на *короткі* (потрібні узгодженість і мала затримка), *великі* (реєстри, головне — цілісність журналу) і *змішані* [390].

Сервісно-орієнтована архітектура (SOA) спершу спиралася на SOAP-повідомлення, опис інтерфейсів WSDL і реєстри UDDI, згодом — на REST-інтерфейси, реєстри служб і шлюзи API. **Композицію** сервісів будують двома способами. За **оркестрації** (WS-BPEL, рушії робочих процесів) центральний рушій викликає учасників і тримає глобальний стан процесу — це точка концентрації довіри. За **хореографії** координатора немає: кожен учасник бачить лише локальне подання, тож коректність залежить від порядку й автентичності подій (підрозділ 4.1). Атомарність між сервісами забезпечують протокол WS-AtomicTransaction, що координує двофазну фіксацію [415], або шаблон Saga з компенсувальними діями [180] (розділ 13). Сучасні застосунки залежать також від *ланцюга постачання сервісів*: сторонніх API, платіжних шлюзів, постачальників ідентичності.

5.3.2 Атаки на повідомлення та реєстри сервісів

Атака обгортання XML-підпису (XML Signature Wrapping, XSW) використовує розбіжність між тим, що перевіряє модуль підпису, і тим, що обробляє застосунок. Посилання `Reference` у підписі вказує на елемент за ідентифікатором; порушник переносить підписаний елемент в інше місце документа (наприклад, у довільний елемент заголовка) і вставляє на його звичне місце власне тіло з новим ідентифікатором. Криптографічна перевірка успішна, бо підписаний фрагмент не змінено, а бізнес-логіка виконує підкладену операцію (рис. 5.2). Мак-Інтош і Остел показали, що наївне використання XML Signature для захисту SOAP-повідомлень лишає їх уразливими до непомітної модифікації, а ефективні контрзаходи потребують ретельної специфікації політики безпеки й коректної реалізації з обох боків [278].

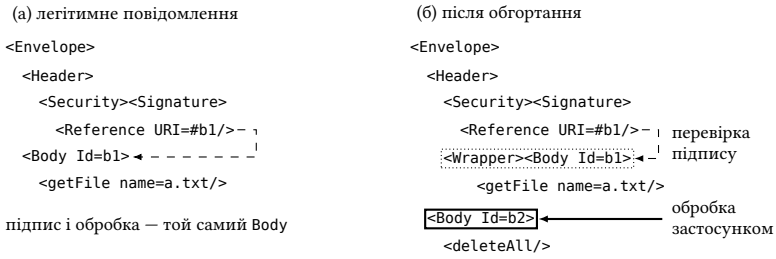


Рис. 5.2 — Атака обгортання XML-підпису: підписаний елемент перенесено в заголовок, на місці тіла — підкладена операція (за [278])

Контрзаходи XSW полягають у тому, щоб застосунок обробляв *саме той* вузол, який було перевірено: модуль перевірки повертає посилання на підписані вузли, а не «так/ні»; структуру повідомлення (що саме підписано й де розташовано підпис) перевіряють за схемою та політикою; повідомлення з дубльованими ідентифікаторами відкидають. Практики безпечного використання XML Signature зведено в настановах W3C [419], захист SOAP-повідомлень визначає стандарт WS-Security [416], а архітектуру захисту вебсервісів описано в NIST SP 800-95 [370].

Той самий розрив між «перевіреним» і «обробленим» лежить в основі атак на XML-парсери. **Зовнішні сутності** (XXE) змушують парсер, що обробляє DTD, читати локальні файли або звертатися до внутрішніх адрес (різновид SSRF); у рейтингу OWASP Top 10:2021 XXE віднесено до категорії неправильної конфігурації безпеки [320]. **XML-бомба** («мільярд сміхів») складається з k рівнів сутностей, кожна з яких посилається на попередню десять разів, тож документ менше кілобайта за $k = 9$ розгортається в гігабайти. Захист — заборона DTD і зовнішніх сутностей, ліміти глибини й розгортань, валідація за схемою до бізнес-обробки.

Реєстри сервісів — метадані координації Γ_S (підрозділ 2.5). Порушник, що змінив запис (WSDL-опис, адресу кінцевої точки, запис у Consul чи Eureka), перенаправляє виклики на підконтрольний сервіс разом з обліковими даними й токенами. Протидія — автентифікована реєстрація, підписані описи служб і взаємна автентифікація сервісів за ідентичностями навантажень (розділ 12) зі звіркою очікуваної ідентичності, а не лише чинності сертифіката.

5.3.3 Атаки на композицію та транзакційну координацію

Композиція з k сервісів переходить через проміжні стани, видимі назовні. Нехай крок i успішно фіксується з імовірністю s_i, а після відмови на кроці j кожен із $j-1$ уже зафіксованих кроків треба компенсувати, і компенсація успішна з імовірністю c (незалежно). Тоді ймовірність потрапляння в неузгоджений стан, коли частину дій зафіксовано, а частину — ні,

$$P_{\text{неузг}}(k) = \sum_{j=2}^{k} \Big(\prod_{i=1}^{j-1} s_i \Big) (1 - s_j) \big(1 - c^{\,j-1}\big). \tag{5.4}$$

Для $k = 5$, $s_i = 0{,}98$, $c = 0{,}995$ маємо $P_{\text{неузг}} \approx 9{,}4 \cdot 10^{-4}$, а для $k = 10$ — $3{,}9 \cdot 10^{-3}$. Порушник, однак, не чекає випадкових відмов: відмова в обслуговуванні останнього кроку ($s_k \to 0$) дає $P_{\text{неузг}} = s^{k-1}(1 - c^{k-1}) \approx 0{,}018$, тобто у 20 разів більше, а одночасна атака на службу компенсацій ($c = 0{,}9$)

— $\approx 0{,}32$. Мішенню є *координаційна* ланка — останній крок і механізм компенсації, тож компенсації мають бути ідемпотентними, повторюваними, автентифікованими й захищеними від відтворення, а незавершені саги — під моніторингом.

Стани гонитви й TOCTOU («перевірка в один момент, використання — в інший») виникають, коли один сервіс перевіряє умову (залишок коштів, квоту), а інший діє на підставі вже застарілого результату: паралельні запити вичерпують ліміт кілька разів, а в хореографії повідомлення не в тому порядку переводять учасників у несумісні стани. Протидія — ключі ідемпотентності, умовні оновлення з перевіркою версії та явна машина станів процесу, що відкидає недопустимі переходи.

5.3.4 Атаки на API та делегування довіри

Більшість позицій OWASP API Security Top 10 2023 [319] стосується авторизації, споживання ресурсів і довіри, а не криптографії. *Порушена авторизація на рівні об'єкта* (BOLA, API1): сервіс перевіряє автентифікацію клієнта, але не те, що запитаний об'єкт належить йому. *Порушена авторизація на рівні функцій* (BFLA, API5): доступ звичайного користувача до адміністративних операцій. *Необмежене споживання ресурсів* (API4) поєднує DoS і EDoS (5.3); SSRF (API7) відкриває зворотний шлях до платформи; *небезпечне споживання API* (API10) — надмірна довіра до відповідей сторонніх сервісів. Делегування довіри породжує проблему «збентеженого заступника» (confused deputy): сервіс із широкими правами діє від імені клієнта, не звужуючи повноважень до його прав. Протоколи OAuth 2.0 і JWT [194, 240] розглянуто в розділі 10; у композиціях аудиторію й область дії токена слід звужувати на кожному виклику, а не пересилати початковий токен ланцюгом.

5.3.5 Розподілені реєстри як координація послуг

Для «великих» транзакцій цілісність забезпечують два механізми — незмінний геш-ланцюг і стійкий до атак консенсус, тож атаки спрямовані на консенсус і порядок, а не на геш-функцію [390]. *Атака 51%* дає порушникові змогу переписати нещодавню історію й здійснити подвійне витрачання; її вартість залежить від параметрів конкретного PoW-ланцюга, і для відгалужень Bitcoin з іншими параметрами висновки щодо безпеки Bitcoin не переносяться автоматично [183]. Eclipse-атаки на однорангову мережу (розділ 3) дають змогу марнувати обчислення жертви або подавати їй хибне подання ланцюга [197, 390].

Егоїстичний майнінг показує, що більшості недостатньо: пул із часткою обчислювальної потужності α приховує знайдені блоки й оприлюднює їх вибірково, змушуючи чесних майнерів працювати над застарілою

гілкою [166]. Якщо γ — частка чесних майнерів, що в разі рівних гілок продовжують гілку пулу, то відносний дохід пулу за стратегією Еяля–Сірера

$$R_{\text{пул}}(\alpha,\gamma)=\frac{\alpha(1-\alpha)^2\bigl(4\alpha+\gamma(1-2\alpha)\bigr)-\alpha^3}{1-\alpha\bigl(1+(2-\alpha)\alpha\bigr)},\qquad R_{\text{пул}}>\alpha \iff \alpha>\frac{1-\gamma}{3-2\gamma}. \tag{5.5}$$

Поріг вигідності дорівнює $1/3$ за $\gamma=0$, $1/4$ за $\gamma=1/2$ і прямує до нуля за $\gamma\to 1$. Для $\alpha=0{,}3$ і $\gamma=0{,}5$ маємо $R_{\text{пул}}\approx 0{,}327$ (на 9% більше за чесну частку), а для $\alpha=0{,}4-R_{\text{пул}}\approx 0{,}526$: пул отримує більшість доходу, маючи меншість потужності, і раціональні майнери мають стимул до нього приєднатися. Модифікація авторів — випадковий вибір гілки за рівності — дає $\gamma=1/2$ і поріг $1/4$ [166]; оптимальні стратегії знижують поріг, а з урахуванням мережевих затримок він зникає [349]. Параметр γ суто координаційний: його визначають швидкість поширення блоків і топологія мережі, тож атака на мережеву координацію посилює економічну атаку на консенсус.

Випередження (front-running) і **видобувна цінність майнера** (MEV) атакують *порядок* транзакцій. Боти децентралізованих бірж конкурентно підвищують комісію (аукціони пріоритетного газу), щоб отримати ранню позицію в блоці, а високі винагороди за впорядкування створюють системний ризик для консенсусного рівня [144]. Властивість повного порядку (підрозділ 4.2), що в реплікованих автоматах була технічною вимогою, у реєстрах набула економічної ціни; залежність смартконтрактів від порядку транзакцій розглянуто в розділі 13 [84].

5.3.6 Заходи захисту та узагальнення

Базою пом'якшення, як і для Γ_R, є схеми реплікації й координації, що запобігають компрометації до порогу, на який розраховано схему (підрозділ 4.4) [390]; прикладні заходи узагальнено в табл. 5.2.

Таблиця 5.2 — Атаки на клас координації послуг

Атака	Елемент	Порушувана властивість	Заходи
XSW	повідомлення	цілісність команди	обробка перевірених вузлів, схема, WS-Security
XXE, XML-бомба	парсер	конфіденційність, доступність	заборона DTD, ліміти розгортання
Отруєння реєстру	реєстр служб	автентичність кінцевої точки	підписані описи, mTLS, звірка ідентичності
Порушення порядку в хореографії	композиція	повний порядок, машина станів	явні стани, послідовні номери, відкидання переходів
Часткове виконання	транзакція	атомарність	саги, ідемпотентні компенсації, моніторинг
Гонитва, TOCTOU	транзакція	ізоляція	ключі ідемпотентності, умовні оновлення
BOLA, BFLA	API	авторизація	перевірка власника об'єкта й ролі на кожен виклик
Необмежене споживання	API	доступність, вартість	обмеження швидкості, квоти, стеля масштабування
Збентежений заступник	делегування	найменші привілеї	звуження токенів, обмеження аудиторії
51%, егоїстичний майнінг	консенсус	цілісність журналу, стимули	підтвердження, $\gamma = 1/2$, децентралізація
Front-running, MEV	порядок транзакцій	справедливий порядок	приватне подання, справедливе впорядкування

5.4 Порівняльний аналіз атакованості координаційних класів

5.4.1 Узагальнення за класами координації

Модульна частина посібника розглянула три типи координації: децентралізовану (P2P, розділ 3), скоординовані ресурси та скоординовані послуги. Вони відрізняються тим, *де* зосереджено довіру і *яку* властивість насамперед атакує порушник (табл. 5.3). Спільна закономірність полягає в тому, що в усіх класах найефективніші атаки спрямовано не на криптографічні примітиви, а на припущення координації: про частку чесних учасників, передбачуваність розміщення, порядок повідомлень і межі делегованої довіри.

Таблиця 5.3 — Порівняльна атакованість координаційних класів

Критерій	Децентралізовані (P2P)	Координація ресурсів Γ_R	Координація послуг Γ_S
Розташування довіри	розподілена між рівноправними вузлами	площина керування, гіпервізор, планувальник	рушій композиції, реєстр служб, консенсус
Домінантні вектори	Sybil, eclipse, отруєння маршрутизації й вмісту, змова	побічні канали, втеча з ВМ, захоплення API, EDoS, розміщення поруч	XSW/XXE, отруєння реєстру, часткове виконання, BOLA, MEV, егоїстичний майнінг
Властивість-мішень	цілісність маршрутизації, доступність вмісту	доступність та ізоляція ресурсів	цілісність (узгодженість, порядок, атомарність)
Базові механізми пом'якшення	обмеження ідентичностей, надлишкові маршрути, репутація	ізоляція, контроль розміщення, квоти, BFT-реплікація площини керування (підрозділ 4.4)	захист повідомлень, авторизація об'єктів, компенсації, кворумні й BFT-схеми з порогом f
Відкриті проблеми	Sybil-стійкість без центру, приватність маршрутизації	ізоляція від мікроархітектурних каналів, атестація площини керування	справедливий порядок, верифікація композицій, стимулосумісність консенсусу

5.4.2 Методика оцінювання атакованості за класом координації

Для дисертаційних досліджень і аудиту пропонується така послідовність.

1. *Класифікація.* Визначити клас координації кожної підсистеми (підрозділ 2.1), гібридні системи декомпонувати.
2. *Граф залежностей.* Побудувати шари й компоненти (рис. 5.1), оцінити силу залежностей π і кількість залежних орендарів N_ℓ.
3. *Інваріанти.* Сформулювати властивості безпечності й живучості кожного механізму (підрозділ 4.3), допущені класи збурень і поріг f схеми реплікації.
4. *Кількісна оцінка.* Оцінити p_ℓ за даними про вразливості чи експертно, розрахувати P_ℓ (5.1) і радіус ураження, а для специфічних механізмів — (5.2), (5.3), (5.4) чи (5.5); корельовані компрометації врахувати за β-моделлю (4.8).
5. *Вибір заходів.* Ранжувати заходи за ефективністю

$$\eta_m = \frac{\sum_a V_a \big(P_a^{(0)} - P_a^{(m)}\big)}{C_m}, \tag{5.6}$$

де V_a — цінність активу (застосунку орендаря) a, $P_a^{(0)}$ і $P_a^{(m)}$ — ймовірності його компрометації до і після заходу m, C_m — вартість заходу.

6. *Перевірка.* Підтвердити оцінки тестуванням на проникнення, інжекцією збурень у координаційні механізми (затримки, поділи мережі, відмова компенсацій) і моніторингом інваріантів (розділ 14).

Повернімося до прикладу з підрозділу 5.1. Захист одного застосунку ($p_4 \colon 0{,}10 \to 0{,}05$) зменшує його ризик на $0{,}046$, тобто $\sum_a V_a \Delta P_a = 0{,}046\,V$. Ізоляція й захист площини керування знижують ризик кожного з 40 орендарів на $0{,}016$, що дає $0{,}64\,V$ — у 14 разів більше. За (5.6) захід на нижньому шарі вигідніший, доки він дорожчий менш ніж у 14 разів: інвестиції провайдера в ізоляцію мають мультиплікативний ефект.

5.4.3 Український контекст

Російська агресія зробила провайдерів телекомунікацій і хостингу пріоритетною мішенню саме як платформи класу Γ_R з великим радіусом ураження. За даними CERT-UA, з 11.05.2023 по 27.09.2023 угруповання UAC-0165 (у заголовку звіту атаки віднесено до Sandworm) втрутилося в інформаційно-комунікаційні системи щонайменше 11 провайдерів телекомунікацій України, що призвело до перебоїв у наданні послуг. Ланцюг атаки охоплював підбір паролів до необмежених інтерфейсів керування (SSH, RDP) з заздалегідь скомпрометованих серверів в українському сегменті Інтернету, бекдор у модулі автентифікації PAM, штатні облікові записи VPN без багатофакторної автентифікації, пошук комп'ютерів адміністраторів і зміну списків контролю доступу, а на завершення — виведення з ладу мережевого, серверного обладнання й систем зберігання, чому сприяли однакові паролі та відсутність резервних копій конфігурацій [36]. У термінах моделі (5.1) площина керування провайдера мала $\pi \approx 1$ щодо обладнання, N_ℓ — це всі абоненти, а скомпрометовані сервери слугували плацдармом для подальших атак, тобто компрометація поширювалася й горизонтально між платформами.

Протилежний бік — хмари як засіб стійкості. Постанова Кабінету Міністрів № 263 дозволила в умовах воєнного стану розміщувати державні інформаційні ресурси на хмарних ресурсах, зокрема за межами України [11], правову основу визначив Закон «Про хмарні послуги» [62], а практику міграції реєстрів розглянуто в розділі 12. У термінах цього розділу міграція переносить залежність реєстрів (Γ_S) на платформу іноземного провайдера (Γ_R): загрозу кінетичного знищення ЦОД замінено ризиками компрометації площини керування, SSRF, EDoS і залежності від міжнародних каналів. Звідси заходи: захищене керування ключами, розподіл реплік між регіонами, передавання журналів API площини керування до національного мо-

ніторингу й план відновлення на випадок втрати доступу до провайдера (розділ 15).

Висновки до розділу

Атакованість розподіленої системи визначається її класом координації. У класі координації ресурсів домінують атаки на доступність та ізоляцію, а першим кроком часто є легітимна координаційна операція — створення ВМ, виклик API, масштабування. Модель (5.1) показує, що нижчі шари додають суттєву частку ризику застосунку й корельовано вражають усіх орендарів компонента; передбачуваність планувальника підсилює атаки розміщення (5.2), еластичність породжує EDoS (5.3), а служба метаданих та інтерфейси керування відкривають зворотні шляхи від застосунку до платформи (табл. 5.1).

У класі координації послуг першою мішенню є цілісність: обгортання підпису й отруєння реєстрів експлуатують розрив між перевіреним і обробленим, атаки на композицію — проміжні стани (5.4), атаки на реєстри — стимули й порядок транзакцій (5.5) (табл. 5.2). Порівняльний аналіз (табл. 5.3), критерій ефективності (5.6) і досвід атак на українських провайдерів показують мультиплікативний ефект заходів на нижніх шарах.

Модульна частина (розділи 2–5) пройшла шлях від таксономії до аналізу нападів: класи систем і функціональні елементи (розділ 2), ідентичність і маршрутизація як головні поверхні атаки P2P-систем (розділ 3), механізми логічної централізації та схеми реплікації (розділ 4) і, нарешті, атакованість інфраструктурного й прикладного подань. Разом вони дають цілісну методологію: визначити схему координації, сформулювати її інваріанти, з'ясувати, які припущення може порушити порушник, і кількісно обґрунтувати заходи.

Питання для самоперевірки

1. Чим інфраструктурне подання класу координації ресурсів відрізняється від подання програм класу координації послуг? Чому для першого домінантною властивістю є доступність, а для другого — цілісність?
2. Поясніть, чому ресурсна атака часто шкодить не ресурсу, а службі, що на ньому виконується. Наведіть приклади для кожного з чотирьох шарів.
3. За моделлю (5.1) обчисліть P_4 для $p_1 = 0{,}02$, $p_2 = 0{,}05$, $p_3 = 0{,}03$, $p_4 = 0{,}08$, $\pi_{12} = 1$, $\pi_{23} = 0{,}7$, $\pi_{34} = 0{,}9$. Який захід — зниження p_2 удвічі чи π_{12} до $0{,}2$ — ефективніший?

4. Які обмеження моделі (5.1)? Запропонуйте її узагальнення на граф залежностей зі зворотними шляхами на кшталт SSRF.
5. Скільки ВМ має запустити порушник, щоб за (5.2) досягти $P_{\text{со}} \geq 0{,}5$ при $H = 2000$ і при $H_{\text{еф}} = 80$? Оцініть вартість спроби за ціни $0{,}1$ ум. од. за годину й $t = 2$ год.
6. Опишіть ланцюг атаки Ристенпарта та ін. Які заходи на рівні планувальника перешкоджають кожному його етапу?
7. За (5.3) визначте стелю $n_{\max}$, за якої місячні витрати на екземпляри не перевищать 1000 ум. од., і оцініть, яку частку атакувального трафіку тоді буде відкинуто. Як обрати компроміс між EDoS і DoS?
8. Поясніть механізм SSRF до служби метаданих у кейсі Capital One. Як сесійний режим IMDSv2 і найменші привілеї ролей розривають цей ланцюг?
9. Чому атака обгортання XML-підпису не порушує криптографічної перевірки? Сформулюйте вимоги до інтерфейсу між модулем перевірки підпису та бізнес-логікою, що унеможливлюють XSW.
10. За (5.4) обчисліть $P_{\text{неузг}}$ для композиції з $k = 8$ сервісів при $s = 0{,}99$, $c = 0{,}98$ і для випадку DoS на останній крок. Які архітектурні рішення зменшують обидві величини?
11. Порівняйте BOLA і BFLA за OWASP API Security Top 10 2023. Чому ці вразливості є порушеннями координації авторизації в композиції сервісів?
12. За (5.5) знайдіть поріг вигідності егоїстичного майнінгу при $\gamma = 0{,}25$ і дохід пулу з $\alpha = 0{,}3$. Чому γ є координаційним, а не криптографічним параметром?
13. Поясніть, як MEV і випередження перетворюють властивість повного порядку розсилки на об'єкт економічної атаки. Які підходи до справедливого впорядкування вам відомі?
14. За даними CERT-UA про атаки на українських провайдерів 2023 р. побудуйте граф поширення компрометації, оцініть π для його ребер і запропонуйте три заходи з найвищим η_m (5.6).
15. *Дослідницьке.* Розробіть методику кількісного порівняння атакованості гібридної системи (державний реєстр, розміщений у публічній хмарі з P2P-розподілом оновлень) за трьома класами координації: визначте інваріанти, метрики, джерела даних для оцінки p_ℓ і π та спосіб перевірки моделі.

РОЗДІЛ 6

Нормативно-правове та стандартизаційне забезпечення захисту розподілених інформаційних ресурсів

Розділ 1 показав, що розподілений інформаційний ресурс не має єдиної точки контролю: його компоненти розміщені в різних доменах адміністрування, а іноді й у різних юрисдикціях. Саме тому проєктування захисту такого ресурсу починається не з вибору механізмів, а з встановлення того, *чиї* вимоги на нього поширюються, *які* з них є юридично обов'язковими, а які — рекомендаційними, і *як* довести їх виконання. Цей розділ формує в аспіранта здатність будувати повний реєстр застосовних вимог, узгоджувати вітчизняну модель комплексної системи захисту інформації (КСЗІ) з міжнародною моделлю системи управління інформаційною безпекою (СУІБ), кількісно оцінювати повноту відповідності та коректно обирати доказову базу для аудиту. Викладені тут конструкції використовуються далі скрізь: моделі ризиків (розділ 8) спираються на нормативне визначення активу, архітектура нульової довіри (розділ 12) — на каталоги заходів, а процеси реагування (розділ 15) — на законодавчі обов'язки щодо повідомлення про інциденти.

6.1 Ієрархія джерел вимог до захисту розподілених ресурсів

Нормативно-правове забезпечення захисту інформації — це впорядкована сукупність приписів різної юридичної сили, які визначають обов'язкові властивості інформації, обов'язки суб'єктів та процедури підтвердження відповідності. Для розподіленої системи ця сукупність принципово багатошарова: один і той самий кластер може одночасно підпадати під режим державного інформаційного ресурсу, режим персональних даних і галузеві вимоги регулятора.

Структурно джерела вимог утворюють ієрархію за юридичною силою (рис. 6.1). Конституція України закріплює базові засади (право на інформацію, право на приватність, обмеження втручання), закони конкретизують правові режими інформації, акти Президента України та Кабінету Міністрів України встановлюють організаційні механізми, нормативні документи системи технічного захисту інформації (НД ТЗІ) і національні стандарти (ДСТУ) задають технічні критерії, а галузеві й відомчі акти — специфічні вимоги для банків, операторів електронних комунікацій, енергетики тощо. Міжнародні стандарти та найкращі практики розташовані в основі піраміди: вони мають найменшу юридичну силу (за винятком випадків

прямої імплементації), але найбільшу деталізацію і найширше покриття технологічних сценаріїв.



Рис. 6.1 — Ієрархія джерел вимог до захисту інформації

Практичний наслідок ієрархії такий: суперечність між приписами різного рівня розв'язується на користь акта вищої сили, а прогалина нижнього рівня не звільняє від обов'язку, встановленого вищим. Для розподілених ресурсів це означає, що відсутність спеціального НД ТЗІ для, скажімо, контейнерних платформ не скасовує загального обов'язку захищати державний інформаційний ресурс, установленого законом [52].

6.2 Законодавство України: правові режими інформації та розподілені ресурси

Базовий закон [54] поділяє інформацію за порядком доступу на відкриту та інформацію з обмеженим доступом, а остання охоплює конфіденційну, таємну і службову. Закон [52] встановлює, що захист інформації в інформаційно-комунікаційних системах (ІКС) забезпечує власник системи, а для державних інформаційних ресурсів і для інформації з обмеженим доступом, вимога щодо захисту якої встановлена законом, обов'язковим є створення комплексної системи захисту інформації з підтвердженою відповідністю. Закон [43] формує окремий, найсуворіший режим державної таємниці, який фактично унеможливлює використання публічних хмарних середовищ для відповідних ресурсів.

Закон [58] вводить поняття кіберзахисту, кіберпростору, об'єктів критичної інформаційної інфраструктури та національної системи кібербезпеки; його чинна редакція розширює обов'язки суб'єктів щодо повідомлення про кіберінциденти. Закон [55] закріплює категоризацію об'єктів критичної інфраструктури, паспортизацію та секторальний підхід. Закон [45] покладає на постачальників електронних комунікаційних послуг обов'язки

щодо безпеки та цілісності мереж і послуг, зокрема тих сегментів, що використовують **безпроводові** технології доступу і радіочастотний спектр. Закон [44] визначає правовий статус електронних підписів і печаток, кваліфікованих надавачів електронних довірчих послуг та засобів кваліфікованого електронного підпису — це юридичний фундамент цілісності та невідмовності транзакцій у розподілених системах. Закон [53] регулює обробку персональних даних, а закон про публічні електронні реєстри [59] — вимоги до державних реєстрів, які за архітектурою є типовими розподіленими ресурсами.

Для проєктувальника ключовим є не перелік законів, а *процедура віднесення*: кожен інформаційний об'єкт, що обробляється системою, має бути класифікований за правовим режимом, оскільки саме режим визначає обов'язковий мінімум захисту, допустиму географію оброблення й перелік дозволених криптографічних засобів. У розподіленому середовищі один сервіс часто обробляє суміш режимів; тоді або застосовують найсуворіший режим до всього сервісу, або виконують **сегментацію за режимами** з криптографічним і мережевим розмежуванням — підхід, докладніше розглянутий у розділах 11 і 12.

6.3 Стратегія кібербезпеки та система суб'єктів забезпечення кібербезпеки

Стратегічний рівень задає Стратегія кібербезпеки України, введена в дію Указом Президента України № 447/2021 [60]. Вона визначає принципи стримування, кіберстійкості та взаємодії, а також орієнтує національну систему на впровадження ризик-орієнтованого управління і міжнародних стандартів. Закон [58] разом із законом про національну безпеку [57] розподіляє повноваження між основними суб'єктами: Державна служба спеціального зв'язку та захисту інформації України формує й реалізує державну політику у сферах криптографічного і технічного захисту інформації, кіберзахисту державних ресурсів та об'єктів критичної інформаційної інфраструктури [8]; Служба безпеки України протидіє кібертероризму і кібершпигунству; Національна поліція (Кіберполіція) розслідує кіберзлочини; Національний банк України регулює кіберзахист банківської системи [48]; Міністерство оборони і Генеральний штаб відповідають за кібероборону. Оперативний рівень реагування забезпечує урядова команда CERT-UA [117], яка акумулює індикатори компрометації та координує усунення наслідків інцидентів.

Ця конструкція є децентралізованою: для розподіленого ресурсу, що охоплює кілька секторів (наприклад, хмарний сервіс, який обслуговує і державний реєстр, і банківські процеси), одночасно виникають зобов'язання перед кількома регуляторами з різними формами й строками звітування.

Побудова єдиної **матриці регуляторних зобов'язань** — обов'язковий елемент проєкту захисту такої системи.

6.4 Підзаконне регулювання: правила, кіберзахист критичної інфраструктури, експертиза й ліцензування

Правила забезпечення захисту інформації в інформаційних, електронних комунікаційних та інформаційно-комунікаційних системах, затверджені постановою Кабінету Міністрів України № 373 [42], конкретизують закон [52]: вони визначають обов'язки власника системи, вимоги до служби захисту інформації, до розмежування доступу, до обліку носіїв та до підтвердження відповідності КСЗІ. Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури, затверджені постановою № 518 [22], натомість побудовані вже за ризик-орієнтованою логікою: вони вимагають визначення переліку критичних процесів, оцінювання ризиків, впровадження заходів, безперервного моніторингу та періодичного аудиту інформаційної безпеки.

Порядок віднесення об'єктів до критичної інфраструктури та ведення відповідних переліків врегульовано постановою Кабінету Міністрів України № 1109 від 09.10.2020 [14], а питання об'єктів критичної *інформаційної* інфраструктури — постановою № 943 від тієї самої дати [13]. Ці акти запроваджують критерії й методику категоризації, за якими власник розподіленого ресурсу з'ясовує, чи поширюються на нього посилені вимоги.

Підтвердження відповідності КСЗІ здійснюється у формі державної експертизи у сфері технічного захисту інформації відповідно до Положення, затвердженого наказом Адміністрації Держспецзв'язку від 16.05.2007 № 93 [46]; результатом є атестат відповідності. Господарська діяльність із надання послуг у галузі криптографічного і технічного захисту інформації підлягає ліцензуванню [56], а ліцензійні умови встановлено постановою Кабінету Міністрів України № 821 [12]. Правові засади застосування національних та гармонізованих міжнародних стандартів визначає закон про стандартизацію [61]: за загальним правилом стандарти є добровільними для застосування, але набувають обов'язковості, якщо на них посилається нормативно-правовий акт або договір.

6.5 Система НД ТЗІ та функціональні профілі захищеності

Ядро вітчизняної технічної моделі становлять чотири документи. НД ТЗІ 1.1-002-99 [31] формулює загальні положення захисту від несанкціонованого доступу, вводить поняття комплексу засобів захисту (КЗЗ) і політики безпеки. НД ТЗІ 2.5-004-99 [33] задає **критерії захищеності** у вигляді набору функціональних послуг безпеки, згрупованих у чотири родини: конфіденційність (К), цілісність (Ц), доступність (Д) і спостережність (Н). Кожна

послуга має впорядковані рівні; наприклад, довірча (КД) і адміністративна (КА) конфіденційність, довірча (ЦД) і адміністративна (ЦА) цілісність, використання ресурсів (ДР), стійкість до відмов (ДС), відновлення після збоїв (ДВ), реєстрація (НР), ідентифікація та автентифікація (НИ), цілісність КЗЗ (НЦ). Окремо визначаються рівні гарантій, що характеризують суворість процесу розроблення й оцінювання.

НД ТЗІ 2.5-005-99 [32] класифікує автоматизовані системи (АС) і встановлює стандартні **функціональні профілі захищеності** — узгоджені набори послуг із зазначеними рівнями. Профіль позначають у форматі ⟨клас АС⟩.⟨види захищеності⟩.⟨номер⟩, що прямо пов'язує клас системи з обов'язковим мінімумом послуг. Порядок створення КСЗІ регламентує НД ТЗІ 3.7-003-05 [34], а вимоги до служби захисту інформації — НД ТЗІ 1.4-001-2000 [35].

Таблиця 6.1 — Класи АС і розподілені конфігурації

Клас	Характеристика	Типові розподілені конфігурації
1	Одномашинний однокористувацький комплекс	практично не трапляється; окремі автономні АРМ у складі системи
2	Локалізований багатомашинний багатокористувацький комплекс	кластер у межах одного контрольованого периметра, приватна хмара організації
3	Розподілений багатомашинний багатокористувацький комплекс із каналами поза контрольованою зоною	геореплікація між майданчиками, гібридна та публічна хмара, мобільний і безпроводовий доступ

Для розподілених ресурсів релевантними є класи 2 і 3, причому клас 3 вимагає додаткових послуг захисту під час обміну через неконтрольовані канали та посилених механізмів спостереженості. Водночас модель НД ТЗІ має відомі обмеження щодо сучасних архітектур: вона побудована навколо стабільного периметра й фіксованого переліку компонентів, тоді як хмарні та контейнерні середовища характеризуються ефемерністю ресурсів, автоматичним масштабуванням і розподілом відповідальності між замовником та провайдером [279]. Профіль захищеності, зафіксований на момент експертизи, погано узгоджується з практикою безперервного постачання змін, а поняття «контрольована зона» втрачає операційний зміст у мультиорендному середовищі. Це — відкрита наукова проблема: розроблення динамічних профілів захищеності та процедур *безперервної* атестації є актуальним напрямом досліджень (див. також розділи 12 і 17).

6.6 КСЗІ і СУІБ: порівняння та сценарії інтеграції

КСЗІ — це сукупність організаційних і технічних заходів та засобів, спрямованих на забезпечення визначених властивостей інформації у конкретній

ІКС. **СУІБ** — це частина загальної системи управління організацією, побудована на оцінюванні ризиків і призначена для встановлення, впровадження, підтримання та постійного поліпшення інформаційної безпеки [20]. Обидві моделі описують той самий предметний простір, але різними мовами й з різною логікою доказування (табл. 6.2).

Таблиця 6.2 — Порівняння КСЗІ та СУІБ

Ознака	КСЗІ (НД ТЗІ)	СУІБ (ДСТУ EN ISO/IEC 27001)
Правова основа	обов'язкова за [52] і [42] для державних ресурсів	добровільна; обов'язковість — через галузеві акти й договори
Мета	забезпечити задані властивості інформації в системі	керовано зменшувати ризики до прийнятного рівня
Об'єкт	ІКС разом із її середовищами	організація в межах визначеної сфери застосування
Модель вимог	функціональний профіль захищеності	заходи Додатка А плюс власні, обґрунтовані ризиком
Роль ризику	опосередкована, через модель загроз і порушника	центральна, з окремим процесом за [231]
Життєвий цикл	проєктний: створення → атестація → супроводження	циклічний, із внутрішнім аудитом і аналізом з боку керівництва
Доказова база	проєктна й експлуатаційна документація, протоколи випробувань	документована інформація, записи, результати аудитів
Підтвердження	атестат відповідності за результатами держекспертизи [46]	сертифікат акредитованого органу з сертифікації

Життєвий цикл КСЗІ за [34] подано на рис. 6.2. Принципово, що він завершується не атестацією, а етапом супроводження, який повертає систему до перегляду вихідних вимог у разі зміни середовищ, технологій або моделі загроз.

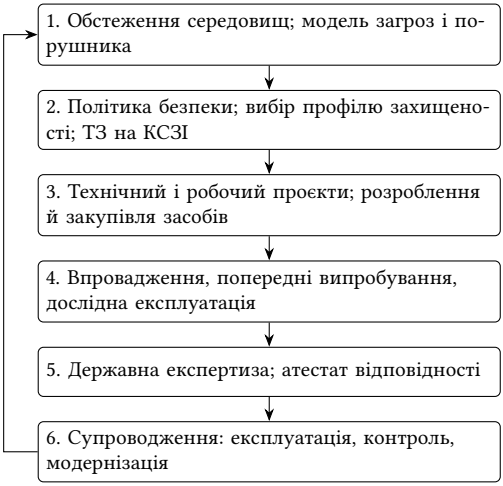


Рис. 6.2 — Життєвий цикл КСЗІ (за [34])

Практично значущими є три сценарії інтеграції. *Перший* — «СУІБ як оболонка»: організація впроваджує СУІБ на рівні всієї організації, а КСЗІ створює для тих ІКС, де це вимагає закон; тоді сфера застосування СУІБ охоплює КСЗІ, а атестат стає одним із записів системи управління. *Другий* — «спільна модель ризиків»: єдиний реєстр активів і ризиків живить і модель загроз КСЗІ, і оцінювання ризиків за [231], що усуває дублювання обстежень. *Третій* — «спільна доказова база»: журнали, звіти сканувань, результати тестів на проникнення та записи внутрішніх аудитів оформлюються так, щоб одночасно задовольняти вимоги держекспертизи й сертифікаційного аудиту. Найпоширенішою помилкою є паралельне ведення двох незалежних систем документації, що подвоює витрати й породжує суперечності між деклараціями.

6.7 Родина ISO/IEC 27000 і критерії оцінювання IT-безпеки

Національними гармонізованими версіями базових стандартів родини є ДСТУ EN ISO/IEC 27001:2023 [20] (вимоги до СУІБ) і ДСТУ EN ISO/IEC 27002:2023 [21] (каталог із 93 заходів, згрупованих у чотири теми: організаційні, людські, фізичні, технологічні, з наскрізними атрибутами). Для розподілених ресурсів критично важливі супутні документи: ISO/IEC 27005 [231] — управління ризиками; ISO/IEC 27017 [233] — заходи для хмарних послуг із чітким розмежуванням ролей постачальника й замовника; ISO/IEC 27018 [234] — захист персональних даних у публічних хмарах;

ISO/IEC 27035 [236] — управління інцидентами; ISO 22301 [226] — системи управління неперервністю діяльності; ISO 31000 [227] — загальні засади ризик-менеджменту. Готовність інформаційно-комунікаційних технологій до забезпечення неперервності діяльності описує окремий стандарт ISO/IEC 27031 [235], що є містком між СУІБ та системою управління неперервністю (докладніше — у розділі 15).

Окремою гілкою є ISO/IEC 15408 (Common Criteria) [229], який задає мову профілів захисту (PP) і завдань з безпеки (ST) та рівнів довіри до оцінювання (EAL). Взаємне визнання сертифікатів у межах відповідних міжнародних угод дає змогу скоротити витрати на повторне оцінювання засобів захисту, однак для розподілених систем сертифікується, як правило, лише окремий компонент (криптомодуль, міжмережевий екран, гіпервізор), тоді як властивості *композиції* компонентів залишаються поза межами сертифіката. Це підводить до фундаментального обмеження: захищеність розподіленої системи не є простою кон'юнкцією захищеності її частин, а формальні методи композиційного оцінювання досі розвинені недостатньо (розділ 7).

6.8 Право ЄС та євроінтеграційні зобов'язання України

Угода про асоціацію між Україною та ЄС [65] зобов'язує до поступового наближення законодавства, зокрема у сферах електронних комунікацій, електронної ідентифікації та захисту даних. Ключові акти права ЄС такі: Директива (ЄС) 2022/2555 (NIS2) [149] — вимоги до управління кіберризиками, звітування про значні інциденти та відповідальність керівництва для суб'єктів секторів високої критичності; Регламент (ЄС) 2016/679 (GDPR) [328] — захист персональних даних, зокрема принципи мінімізації, підзвітності та повідомлення про порушення; Регламент (ЄС) 2022/2554 (DORA) [329] — цифрова операційна стійкість фінансового сектору, включно з керуванням ризиками сторонніх постачальників ІКТ; Регламент (ЄС) 2024/2847 (Cyber Resilience Act) [332] — горизонтальні вимоги кібербезпеки до продуктів із цифровими елементами протягом усього життєвого циклу; Регламент (ЄС) № 910/2014 (eIDAS) [333] і Регламент (ЄС) 2024/1183 [330], що запроваджує Європейську рамку цифрової ідентичності та гаманці EUDI.

Порівняння NIS2 з українським регулюванням критичної інфраструктури виявляє як збіги, так і суттєві розриви. Спільним є секторальний підхід, вимога ризик-орієнтованих заходів і обов'язок повідомляти про інциденти. Відмінності стосуються насамперед: (а) строків звітування — NIS2 встановлює багатоетапну схему з раннім попередженням протягом 24 годин, повідомленням протягом 72 годин і підсумковим звітом протягом місяця, тоді як вітчизняні строки визначаються підзаконними актами й галузевими регуляторами окремо; (б) персональної відповідальності органів управління

суб'єкта; (в) явних вимог до безпеки ланцюга постачання, які в українських актах поки що виражені слабше [22]; (г) механізму нагляду з дієвими адміністративними санкціями. Регуляторна карта зрілості секторів ЄС [160] показує, що навіть у межах Союзу рівень готовності секторів суттєво різниться, тож формальна транспозиція норм не гарантує фактичної стійкості.

6.9 Каталоги заходів як мова проєктування та таблиці відповідності

Для інженерного проєктування захисту розподілених ресурсів нормативні вимоги зручно перекладати мовою каталогів заходів. NIST CSF 2.0 [307] задає шість функцій — GOVERN (GV), IDENTIFY (ID), PROTECT (PR), DETECT (DE), RESPOND (RS), RECOVER (RC) — і слугує «верхньою» рамкою для узгодження бізнес-цілей із заходами. NIST SP 800-53 Rev. 5 [304] містить деталізований каталог заходів безпеки й приватності з можливістю формування базових наборів. CIS Controls v8.1 [129] пропонує пріоритезовану послідовність заходів із групами впровадження, зручну для організацій з обмеженими ресурсами. Для хмарних розподілених ресурсів застосовують Cloud Controls Matrix [134] та Security Guidance [358].

Таблиця 6.3 — Відповідність (mapping) вимог

NIST CSF 2.0	ДСТУ EN ISO/IEC 27001 (розділи, Додаток A)	НД ТЗІ (послуги, документи)
GV	4–6, 9.3; A.5.1, A.5.31	політика безпеки за 1.1-002-99; служба ЗІ за 1.4-001-2000
ID	6.1.2; A.5.9, A.5.12, A.5.21	обстеження середовищ, модель загроз і порушника (3.7-003-05)
PR	A.5.15–A.5.18; A.8.2–A.8.5, A.8.24	послуги КА, КД, ЦА, ЦД, НИ; розмежування доступу за [42]
DE	A.8.15, A.8.16	НР (реєстрація), НЦ, НТ (самотестування КЗЗ)
RS	A.5.24–A.5.28	регламенти служби ЗІ; звітування за [22]
RC	A.5.29, A.5.30	послуги ДС, ДВ, ДР; плани відновлення

Такі таблиці не є взаємно однозначними: одному заходу CSF може відповідати кілька послуг НД ТЗІ і навпаки, а частина понять (наприклад, управління ланцюгом постачання за [103]) не має прямого відповідника у вітчизняній моделі. Методологічну основу для машинозчитуваних відповідностей створює програма NIST OLIR [243], яка вводить типізовані відношення між елементами документів (еквівалентність, підмножина, надмножина, перетин), що дає змогу коректно агрегувати покриття замість наївного зіставлення «один до одного».

6.10 Оцінювання відповідності, аудит і юридична відповідальність

Нехай $R = \{r_1, \dots, r_n\}$ — реєстр застосовних вимог, $w_i > 0$ — вага вимоги (визначена критичністю процесу або рівнем ризику), а s_i — ступінь виконання, оцінений за трибальною шкалою: 0 — не виконано, $0{,}5$ — виконано частково, 1 — виконано з доказами. Тоді **індекс відповідності** обчислюється як

$$I_{\mathrm{c}} = \frac{\sum_{i=1}^{n} w_i s_i}{\sum_{i=1}^{n} w_i}, \qquad I_{\mathrm{c}} \in [0;1], \tag{6.1}$$

а зважений нормативний розрив — як $G = \sum_i w_i\,(1 - s_i)$. Величина G безпосередньо використовується для пріоритезації плану усунення невідповідностей: усувають ті вимоги, які дають найбільший приріст I_{c} на одиницю витрат.

Другою кількісною характеристикою є **коефіцієнт покриття** одного набору вимог іншим. Нехай A і B — множини елементів двох каталогів, а $M \subseteq A \times B$ — відношення відповідності. Тоді

$$\kappa(A \to B) = \frac{\bigl|\{\, b \in B : \exists\, a \in A,\ (a,b) \in M \,\}\bigr|}{|B|}. \tag{6.2}$$

Значення $\kappa < 1$ означає наявність вимог B, не покритих каталогом A; саме ці елементи формують перелік додаткових заходів під час переходу, наприклад, від відповідності НД ТЗІ до відповідності ДСТУ ISO/IEC 27001. Обидві метрики є грубими: вони не враховують кореляції між вимогами й не є мірою фактичної захищеності, а лише мірою *документованої* відповідності. Побудова метрик, чутливих до реальної результативності заходів, — предмет розділів 7 і 14.

Формами оцінювання відповідності є державна експертиза у сфері ТЗІ [46], сертифікація СУІБ акредитованим органом [20], внутрішній аудит, незалежний аудит інформаційної безпеки об'єктів критичної інфраструктури [22] та тестування на проникнення. Юридична відповідальність за порушення вимог захисту інформації настає в адміністративному, цивільному та кримінальному порядку; Кримінальний кодекс України [27] містить окремий розділ про кримінальні правопорушення у сфері використання електронно-обчислювальних машин (комп'ютерів), систем та комп'ютерних мереж і мереж електрозв'язку.

Типові помилки правозастосування: ототожнення атестата відповідності з фактичною захищеністю; створення КСЗІ «під експертизу» без подаль-

шого супроводження; ігнорування зміни правового режиму інформації після інтеграції нових джерел даних; перенесення оброблення до хмари без перегляду моделі загроз і розподілу відповідальності; відсутність договірного закріплення вимог безпеки для субпідрядників, унаслідок чого зобов'язання формально є, а важелів впливу немає.

6.10.1 Кейс: збій оператора електронних комунікацій та регуляторні наслідки

У грудні 2023 р. масштабна кібератака на найбільшого українського мобільного оператора спричинила тривалу недоступність послуг мобільного зв'язку й мобільного інтернету для мільйонів абонентів, а також вторинні відмови у сервісах, що залежали від цих каналів (платіжні термінали, окремі системи оповіщення). Реагування координували CERT-UA та СБУ [117].

Регуляторний аналіз кейсу є повчальним. По-перше, оператор одночасно перебуває у сфері дії закону про електронні комунікації [45] (обов'язки щодо безпеки та цілісності мереж і послуг), закону про критичну інфраструктуру [55] і загальних вимог до кіберзахисту [22]. По-друге, інцидент продемонстрував, що ризик концентрації є системним: відмова одного розподіленого ресурсу поширюється на суміжні сектори через залежності, які формально не належать жодному з операторів. По-третє, у логіці NIS2 [149] такий випадок кваліфікувався б як значний інцидент із багатоетапним звітуванням і подальшим наглядовим провадженням, тоді як вітчизняна модель на момент подій не мала настільки формалізованої процедури. Нарешті, відновлення показало практичну цінність вимог до резервування та планів неперервності [226]: організації, які мали альтернативні канали й офлайн-процедури, зазнали значно менших втрат. Кейс підтверджує тезу розділу: нормативні вимоги слід трактувати не як формальність, а як мінімальний інженерний контракт стійкості.

Висновки до розділу

Нормативно-правове та стандартизаційне забезпечення захисту розподілених інформаційних ресурсів є багаторівневою системою, у якій обов'язкові приписи національного права поєднуються з добровільними, але детальнішими міжнародними стандартами. Для розподіленої системи характерна множинність застосовних режимів: один ресурс може одночасно підпадати під вимоги щодо державних інформаційних ресурсів, персональних даних, критичної інфраструктури та галузевого регулювання, тому першим кроком проєктування є побудова матриці регуляторних зобов'язань.

Вітчизняна модель КСЗІ забезпечує чітку, перевірювану інженерну конструкцію — функціональний профіль захищеності — але базується на припущенні про стабільний периметр і фіксований склад системи, що погано

узгоджується з хмарними та контейнерними архітектурами. Модель СУІБ за ДСТУ EN ISO/IEC 27001, навпаки, є ризик-орієнтованою й циклічною, проте не задає технічного мінімуму. Раціональною стратегією є не заміна однієї моделі іншою, а їх інтеграція через спільний реєстр активів і ризиків та спільну доказову базу.

Євроінтеграційні зобов'язання України роблять наближення до NIS2, GDPR, DORA, CRA та eIDAS 2 не теоретичним, а практичним завданням; найбільші розриви стосуються строків звітування про інциденти, відповідальності керівництва, безпеки ланцюга постачання та дієвості нагляду. Каталоги заходів (NIST CSF 2.0, SP 800-53, CIS Controls, CSA CCM) виконують роль спільної інженерної мови, а формалізовані таблиці відповідності з типізованими відношеннями дають змогу кількісно оцінювати покриття. Запропоновані індекс відповідності та коефіцієнт покриття є простими, але операційно корисними інструментами пріоритезації, які, однак, вимірюють документовану, а не фактичну захищеність — усунення цього розриву є окремим науковим завданням, до якого посібник повертається в розділах 7, 14 і 17.

Питання для самоперевірки

1. Побудуйте ієрархію джерел вимог до захисту інформації та поясніть, як розв'язується колізія між актами різного рівня.
2. Які правові режими інформації встановлює законодавство України і як вибір режиму впливає на допустиму архітектуру розподіленого ресурсу?
3. За яких умов створення КСЗІ з підтвердженою відповідністю є обов'язковим?
4. Назвіть основних суб'єктів національної системи кібербезпеки та їхні повноваження. Які проблеми породжує розподіл повноважень для мультисекторного хмарного сервісу?
5. Чим ризик-орієнтована логіка постанови № 518 відрізняється від логіки Правил, затверджених постановою № 373?
6. Опишіть чотири родини функціональних послуг безпеки за НД ТЗІ 2.5-004-99 і наведіть приклади послуг у кожній.
7. Як співвідносяться клас АС за НД ТЗІ 2.5-005-99 і типова конфігурація розподіленої системи? Чому клас 3 потребує додаткових послуг?
8. Сформулюйте не менше трьох обмежень моделі функціональних профілів захищеності для хмарних і контейнерних середовищ.
9. Порівняйте КСЗІ і СУІБ за метою, об'єктом, роллю ризику, доказовою базою та формою підтвердження відповідності.

10. Запропонуйте для конкретної організації сценарій інтеграції КСЗІ і СУІБ та обґрунтуйте, які саме документи стануть спільними.
11. Які стандарти родини ISO/IEC 27000 є найважливішими для захисту хмарних розподілених ресурсів і чому?
12. У чому полягає обмеження сертифікації за ISO/IEC 15408 щодо розподілених систем?
13. Виконайте порівняння вимог NIS2 із чинним українським регулюванням критичної інфраструктури за чотирма критеріями та визначте найсуттєвіші розриви.
14. Побудуйте таблицю відповідності між функціями NIST CSF 2.0, розділами ДСТУ EN ISO/IEC 27001 і послугами НД ТЗІ для системи, яку ви досліджуєте.
15. Обчисліть індекс відповідності та зважений нормативний розрив для набору з десяти вимог із різними вагами; поясніть, чому високе значення індексу не доводить фактичної захищеності.

РОЗДІЛ 7

Математичні та системно-аналітичні основи оцінювання захищеності розподілених систем

Попередні розділи (1–6) окреслили архітектурний, координаційний і нормативний контекст захисту розподілених інформаційних ресурсів. Проте ані перелік загроз, ані перелік вимог нормативних документів самі собою не дають відповіді на ключове інженерне запитання: *наскільки* захищена конкретна система і *який* із можливих варіантів її захисту раціональний за наявних обмежень. Відповідь потребує формального апарату — моделей політик безпеки, теоретико-графових конструкцій, ймовірнісних і теоретико-ігрових моделей, багатокритеріального оцінювання та коректно побудованих метрик. Цей розділ систематизує такий апарат і завершується розгорнутим числовим прикладом наскрізного розрахунку захищеності гіпотетичної розподіленої системи. Матеріал розділу є математичним ядром посібника і безпосередньо забезпечує формування компетентності КФ-2.

7.1 Системний аналіз розподіленої системи захисту

7.1.1 Декомпозиція та ієрархія цілей

Систему захисту розподілених інформаційних ресурсів доцільно розглядати як складну систему в сенсі системного аналізу [425]: вона має ієрархічну структуру, множину різнорідних елементів, нелінійні зв'язки та функціонує в умовах концептуальної невизначеності (невідомі наміри та ресурси порушника) і структурної невизначеності (динамічна топологія, міграція навантажень).

Системний аналіз системи захисту передбачає послідовне виконання чотирьох процедур:

1. *цільова декомпозиція* — побудова дерева цілей від глобальної мети (забезпечення конфіденційності, цілісності, доступності та підзвітності ресурсів) до елементарних підцілей, що піддаються вимірюванню;
2. *структурна декомпозиція* — розбиття системи на підсистеми, домени безпеки та зони довіри, встановлення інтерфейсів між ними;
3. *структурний синтез* — вибір складу механізмів захисту та схеми їх розміщення в архітектурі;
4. *параметричний синтез* — вибір числових значень параметрів обраних механізмів (довжини ключів, періоду ротації облікових даних, кратності реплікації, порогів спрацювання правил моніторингу).

7.1.2 Постановка задачі оптимального синтезу

Нехай $\Omega = \{x_1, \dots, x_m\}$ — множина доступних заходів (контролів) захисту, а $X \subseteq \Omega$ — варіант системи захисту. Позначимо через $R(X)$ залишковий ризик за умови впровадження X, через $C(X)$ — сумарні витрати життєвого циклу, через $D(X)$ — деградацію цільових показників функціонування (затримки, зниження продуктивності). Задача оптимального синтезу формулюється як задача умовної оптимізації

$$X^{*} = \arg\min_{X \subseteq \Omega} R(X) \quad \text{за умов} \quad C(X) \le C_0,\;\; D(X) \le D_0,\;\; X \models \mathcal{N}, \tag{7.1}$$

де C_0 — бюджетне обмеження; D_0 — допустима деградація сервісу; $\mathcal{N}$ — множина обов'язкових нормативних вимог (для України — відповідні НД ТЗІ [33, 32] і загальні вимоги до кіберзахисту об'єктів критичної інфраструктури [22]), яким варіант X мусить задовольняти беззастережно.

Двоїста постановка — мінімізація витрат за обмеження на залишковий ризик $R(X) \le R_0$ — відповідає логіці ISO/IEC 27005 [231] і NIST SP 800-30 [300], де ризик-апетит задається керівництвом організації. Обидві постановки належать до класу задач булевого програмування і в загальному випадку NP-складні, тому на практиці застосовують жадібні алгоритми за критерієм «зниження ризику на одиницю витрат», лагранжеву релаксацію або еволюційні методи.

Залишковий ризик обчислюють як математичне сподівання втрат:

$$R(X) = \sum_{i=1}^{n} p_i(X)\, L_i(X), \tag{7.2}$$

де $p_i(X)$ — ймовірність реалізації i-го сценарію загрози за наявності заходів X; $L_i(X)$ — умовні втрати за цим сценарієм; n — кількість розглянутих сценаріїв. Докладніше методики оцінювання p_i та L_i розглянуто в розділі 8.

7.2 Формальні моделі політик безпеки

Формальна модель політики безпеки — це математичний об'єкт, що визначає множину станів системи, множину дозволених переходів і предикат безпечності стану. Її призначення — дати можливість *довести* властивості системи, а не лише перевірити їх емпірично.

7.2.1 Дискреційні моделі: HRU і Take-Grant

Модель **HRU** (Харрісона–Руззо–Ульмана) [196] описує систему як трійку (S, O, M), де S — множина суб'єктів, $O \supseteq S$ — множина об'єктів, M — ма-

триця доступів, $M[s, o] \subseteq \mathcal{R}$ — набір прав. Стан змінюється командами, побудованими з шести примітивних операцій (`enter`, `delete`, `create subject`, `create object`, `destroy subject`, `destroy object`).

Задача безпеки (safety problem) полягає у перевірці: чи може право r колись потрапити в комірку $M[s, o]$, де його спочатку не було. Центральний результат HRU: у загальному випадку ця задача *алгоритмічно нерозв'язна* (зводиться до проблеми зупинки машини Тюрінга); для моноопераційних систем вона розв'язна, але NP-повна [196]. Практичний висновок для розподілених систем принциповий: неможливо побудувати універсальний аналізатор, який для довільної дискреційної політики доведе відсутність небажаного поширення прав. Звідси — необхідність обмежувати виразність моделі доступу (RBAC, ABAC із скінченними правилами), що детально розглянуто в розділі 10.

Модель **Take-Grant** обмежує виразність до графа, дуги якого позначені правами `take`, `grant`, `read`, `write`. Для неї задача безпеки розв'язується за *лінійний* час від розміру графа [268]. Це класичний приклад компромісу «виразність — аналізовність», що безпосередньо стосується проєктування систем керування доступом у мікросервісних середовищах.

7.2.2 Мандатні моделі: Белла–ЛаПадули та Біба

Модель **Белла–ЛаПадули** (BLP) [94] формалізує захист конфіденційності через ґратку рівнів секретності $(L, \leq)$ і три властивості: *ss-property* («немає читання вгору»: суб'єкт із рівнем $\ell(s)$ може читати об'єкт лише за $\ell(o) \leq \ell(s)$); *⋆-property* («немає запису вниз»: запис дозволено лише за $\ell(o) \geq \ell(s)$); *ds-property* (додаткове дискреційне обмеження). Основна теорема безпеки стверджує: якщо початковий стан безпечний і кожен перехід зберігає ці властивості, то система залишається безпечною.

Модель **Біба** [98] є дуальною до BLP і захищає цілісність: «немає читання знизу» та «немає запису вгору» за ґраткою рівнів цілісності. Спільне застосування BLP і Біба на одній ґратці призводить до виродження (доступ можливий лише в межах одного рівня), тому на практиці використовують дві незалежні ґратки.

7.2.3 Моделі цілісності та конфлікту інтересів

Модель **Кларка–Вілсона** [132] орієнтована на комерційні системи й оперує поняттями обмежених даних (CDI), процедур перевірки цілісності (IVP) і трансформаційних процедур (TP). Ключові механізми — *коректно сформовані транзакції* та *розподіл обов'язків*. Для розподілених систем ця модель є теоретичною основою вимог до незмінності журналів аудиту та до багатоособового підтвердження критичних операцій.

Модель **Брюера–Неша** («китайська стіна») [106] формалізує динамічний конфлікт інтересів: доступ суб'єкта до набору даних компанії A автоматично забороняє доступ до даних конкурентів A у тому самому класі конфлікту. Права визначаються не статично, а історією звернень. Модель безпосередньо застосовна до мультиорендних хмарних платформ і сервісів керованої безпеки (MSSP).

7.2.4 Моделі невтручання

Моделі **невтручання** (non-interference) [188] формулюють безпеку як властивість потоків інформації, а не прав доступу. Система $\mathcal{S}$ є невтручальною щодо групи високого рівня H стосовно групи низького рівня L, якщо для будь-якої послідовності дій α

$$\mathrm{out}_L\big(\mathcal{S}, \alpha\big) = \mathrm{out}_L\big(\mathcal{S}, \mathrm{purge}_H(\alpha)\big), \tag{7.3}$$

де out_L — спостережувані виходи для L; $\mathrm{purge}_H(\alpha)$ — послідовність, з якої вилучено всі дії суб'єктів рівня H. Тобто дії високого рівня не змінюють нічого з того, що спостерігає низький рівень. Ця властивість покриває приховані канали, які моделі доступу не помічають. У розподілених системах строге невтручання практично недосяжне через спільні ресурси (кеш, мережа, планувальник), тому використовують ослаблені варіанти — невтручання з умовним розсекреченням і кількісний аналіз витоку через ентропію (підрозділ 7.9).

Таблиця 7.1 — Порівняння формальних моделей політик безпеки

Модель	Захищає	Обчислювальна складність і застосовність
HRU	дискреційний доступ	задача безпеки нерозв'язна; монооперaційний випадок — NP-повний
Take-Grant	дискреційний доступ	лінійний час; обмежена виразність
BLP	конфіденційність	перевірка інваріантів за поліноміальний час; ґратка рівнів
Біба	цілісність	дуальна до BLP; основа для контролю джерел даних
Кларка–Вілсона	цілісність транзакцій	неформальна перевірка; розподіл обов'язків
Брюера–Неша	конфлікт інтересів	права залежать від історії; мультиорендність
Невтручання	потоки інформації	верифікація трас; приховані канали

7.3 Теоретико-графові методи

7.3.1 Графи та дерева атак

Дерево атак [356] — це «І/АБО»-дерево, корінь якого позначає мету порушника, а листя — елементарні дії. Атрибути листя (вартість, потрібна кваліфікація, ймовірність) поширюються до кореня: для вузла типу «АБО» вартість дорівнює мінімуму вартостей нащадків, для «І» — сумі.

Граф атак [364] — орієнтований граф $G = (V, E)$, вершини якого відповідають станам системи (або досягнутим привілеям), а дуги — застосуванню конкретної уразливості чи техніки. Масштабовані генератори графів атак на основі логічного виведення (наприклад, підхід MulVAL [318]) будують граф за описом топології, конфігурацій і бази уразливостей за поліноміальний час, що робить метод придатним для мереж із тисячами вузлів. Техніки в дугах доцільно позначати ідентифікаторами MITRE ATT&CK [288], що забезпечує узгодженість із засобами моніторингу (розділ 14).

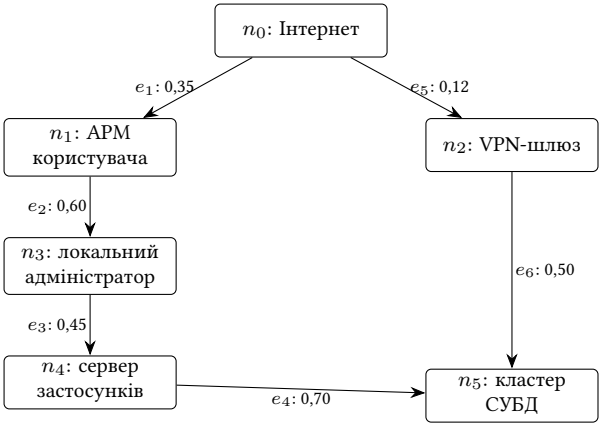


Рис. 7.1 — Ймовірнісний граф атак гіпотетичної розподіленої системи

7.3.2 Метрики на графах атак

Для зваженого графа атак із ймовірностями успіху p_e на дугах імовірність успішного проходження шляху π за припущення незалежності подій дорівнює

$$P(\pi) = \prod_{e \in \pi} p_e, \qquad w(e) = -\ln p_e, \qquad \pi^* = \arg\min_{\pi \in \Pi} \sum_{e \in \pi} w(e). \tag{7.4}$$

Логарифмічне перетворення ваг зводить задачу пошуку *найімовірнішого* шляху компрометації до класичної задачі про найкоротший шлях (алгоритм Дейкстри, $O(|E| + |V| \log |V|)$).

Метрика **k-нульових днів** (k-zero-day safety) [412] визначає мінімальну кількість *різних невідомих* уразливостей, потрібних порушникові для досягнення мети. Її перевага — незалежність від суб'єктивних оцінок ймовірності: значення $k = 1$ означає, що одна вдало використана вразливість «нульового дня» руйнує захист, тоді як $k \geq 3$ свідчить про глибоку ешелонованість.

7.3.3 Граф довіри та мінімальний розріз

Задачу сегментації мережі формалізують на графі допустимих взаємодій $G = (V, E, c)$, де $c(u, v)$ — «вартість» розриву зв'язку (втрата функційності). Ізоляція множини критичних вузлів T від зони підвищеного ризику S зводиться до задачі мінімального розрізу

$$\text{cut}^{*} = \min_{(A,\bar{A}):\, S\subseteq A,\ T\subseteq \bar{A}} \ \sum_{u\in A,\ v\in \bar{A}} c(u,v), \tag{7.5}$$

яка за теоремою Форда–Фалкерсона про максимальний потік і мінімальний розріз зводиться до задачі про максимальний потік і розв'язується за поліноміальний час (наприклад, алгоритмом Едмондса–Карпа). Отриманий розріз задає мінімальну за втратами функційності множину точок, де слід розмістити міжмережеві екрани або політики мікросегментації. Цей апарат є формальним обґрунтуванням проєктних рішень архітектури нульової довіри (розділ 12).

7.4 Ймовірнісні та стохастичні моделі

7.4.1 Показники надійності й готовності

Базові показники теорії надійності переносяться на безпеку з поправкою на те, що «відмова» спричинена не випадковим збоєм, а цілеспрямованою дією:

$$A = \frac{\text{MTTF}}{\text{MTTF} + \text{MTTR}}, \qquad \text{MTBF} = \text{MTTF} + \text{MTTR}, \tag{7.6}$$

де A — стаціонарний коефіцієнт готовності; MTTF — середнє напрацювання до відмови; MTTR — середній час відновлення; MTBF — середнє напрацювання між відмовами. Для реплікованої системи з n вузлів і кворумом k (наприклад, $k = \lfloor n/2 \rfloor + 1$ для протоколів консенсусу) готовність обчислюють за біноміальною схемою (та сама модель кворумної доступності, що й у розділі 1)

$$A_{\text{сис}} = \sum_{i=k}^{n} \binom{n}{i} A^{\,i}\,(1-A)^{\,n-i}. \tag{7.7}$$

Формула (7.7) припускає незалежність відмов. Реальні розподілені системи мають **відмови зі спільної причини** (спільне живлення, спільний гіпервізор, спільна помилка конфігурації, масований обстріл енергетичної інфраструктури). Їх ураховують β-фактором:

$$U_{\text{сис}} = (1-\beta)\,U_{\text{незал}} + \beta\,U_{\text{вузла}}, \qquad U = 1 - A, \tag{7.8}$$

де $\beta \in [0;1]$ — частка відмов, спричинених спільним чинником. Досвід забезпечення стійкості української інфраструктури у 2022–2024 рр. — зокрема, перенесення державних реєстрів до хмарних середовищ за рішенням Уряду й координації Держспецзв'язку [8] — підтверджує, що саме β-складова визначає реальну доступність, і що географічне та юрисдикційне рознесення реплік є не надлишковістю, а необхідністю.

7.4.2 Марковські моделі станів безпеки

Життєвий цикл вузла щодо безпеки моделюють ланцюгом Маркова з неперервним часом і скінченною множиною станів. Стаціонарний розподіл $\boldsymbol{\pi}$ знаходять із системи

$$\boldsymbol{\pi}\,\mathbf{Q} = \mathbf{0}, \qquad \sum_{i} \pi_i = 1, \tag{7.9}$$

де $\mathbf{Q}$ — інфінітезимальна матриця (генератор) із елементами $q_{ij} \geq 0$ $(i \neq j)$ — інтенсивностями переходів, і $q_{ii} = -\sum_{j \neq i} q_{ij}$. Якщо тривалості перебування у станах не є експоненційними (типово для часу виявлення інциденту, що має «важкий хвіст»), застосовують напівмарковські процеси, у яких стаціонарні ймовірності визначаються добутком імовірностей вкладеного ланцюга на середні часи перебування.

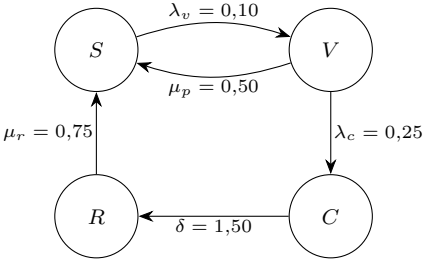


Рис. 7.2 — Граф станів марковської моделі безпеки вузла (інтенсивності — у доба$^{-1}$): S — захищений, V — уразливий, C — скомпрометований невиявлено, R — відновлення

7.4.3 Ймовірність компрометації ланцюга

Для послідовності незалежних етапів атаки (ланцюга ураження) сумарна ймовірність успіху дорівнює добутку (7.4). Якщо мети можна досягти кількома незалежними шляхами $\pi_1, \dots, \pi_r$, то

$$P_{\text{комп}} = 1 - \prod_{j=1}^{r} \bigl(1 - P(\pi_j)\bigr). \tag{7.10}$$

Ця оцінка є верхньою межею для випадку позитивно корельованих шляхів (спільні дуги) і застосовується як консервативна.

7.5 Моделі масового обслуговування та стійкість до DDoS

Стійкість сервісу до атак на відмову в обслуговуванні природно описується апаратом теорії масового обслуговування. Для одноканальної системи M/M/1 з інтенсивністю надходження λ і обслуговування μ середній час

перебування заявки становить $T = 1/(\mu - \lambda)$, і система стійка лише за $\rho = \lambda/\mu < 1$.

Для кластера з c ідентичних обслуговувальних вузлів (M/M/c) із коефіцієнтом завантаження $\rho = \lambda/(c\mu)$ і запропонованим навантаженням $a = \lambda/\mu$ ймовірність очікування визначає формула Ерланга C:

$$C(c,a) = \frac{\dfrac{a^c}{c!\,(1-\rho)}}{\displaystyle\sum_{k=0}^{c-1} \frac{a^k}{k!} + \frac{a^c}{c!\,(1-\rho)}}, \qquad W_q = \frac{C(c,a)}{c\mu - \lambda}. \tag{7.11}$$

Тут W_q — середній час очікування в черзі. Модель дає змогу кількісно відповісти на проєктні запитання: яка мінімальна кількість вузлів c забезпечує виконання SLO за затримкою під час атаки заданої інтенсивності; за якого λ система переходить у режим $\rho \geq 1$ і черга зростає необмежено; який виграш дає фільтрація, що зменшує ефективне λ. Важливо, що для DDoS-атак потік заявок зазвичай не є пуасонівським (пачковість, самоподібність), тому результат M/M/c слід трактувати як оптимістичну оцінку, а перевіряти — імітаційним моделюванням.

7.6 Теоретико-ігрові моделі протистояння

7.6.1 Ігри з нульовою сумою

Найпростіша модель протистояння «захисник— атакувальник» — матрична гра з нульовою сумою. Захисник обирає рядок (розподіл обмеженого ресурсу моніторингу), атакувальник — стовпець (ціль). За матриці втрат $\mathbf{M}$ ціна гри в змішаних стратегіях

$$v = \min_{\mathbf{x}\in\Delta_D} \max_{\mathbf{y}\in\Delta_A} \mathbf{x}^{\top}\mathbf{M}\,\mathbf{y}, \tag{7.12}$$

де Δ_D, Δ_A — симплекси змішаних стратегій сторін. За теоремою про мінімакс розв'язок існує завжди і знаходиться лінійним програмуванням. Практичний наслідок: *рандомізація* захисних дій (непередбачувані маршрути перевірок, змінні вікна ротації) строго домінує над будь-якою детермінованою стратегією.

7.6.2 Ігри Штакельберга

Реалістичнішою є **гра Штакельберга**: захисник як лідер першим фіксує (можливо, змішану) стратегію, атакувальник як послідовник спостерігає її та обирає найкращу відповідь. Сильна рівновага Штакельберга (SSE) — розв'язок, у якому лідер максимізує виграш за умови, що послідовник грає

найкращу відповідь. Такі моделі успішно застосовано для планування патрулювання і розподілу ресурсів безпеки [393]; для кіберзахисту вони описують розміщення сенсорів, приманок (honeypot) і графіків аудиту.

7.6.3 Модель FlipIt

Модель **FlipIt** [407] описує приховане протистояння за контроль над ресурсом: обидва гравці можуть у будь-який момент «перехопити» ресурс, сплативши вартість ходу, але не бачать ходів супротивника. Модель адекватно відображає компрометацію криптографічних ключів і облікових даних, коли факт компрометації тривалий час невідомий.

Якщо захисник грає періодично з періодом δ_D, а атакувальник — періодично з періодом $\delta_A \geq \delta_D$ і випадковою фазою, середній виграш атакувальника дорівнює

$$\beta_A = \frac{\delta_D}{2\delta_A} - \frac{c_A}{\delta_A} = \frac{1}{\delta_A}\Big(\frac{\delta_D}{2} - c_A\Big), \tag{7.13}$$

де c_A — вартість одного ходу атакувальника у тих самих одиницях, що й виграш від володіння ресурсом за одиницю часу. З (7.13) випливає *умова стримування*: якщо $\delta_D < 2c_A$, то $\beta_A < 0$ за будь-якого δ_A, і раціональний атакувальник не грає взагалі. Це дає кількісне обґрунтування періоду ротації ключів і облікових даних: він має бути меншим за подвоєну вартість проникнення.

7.7 Багатокритеріальне оцінювання захищеності

7.7.1 Метод аналізу ієрархій

Метод аналізу ієрархій (AHP) [346] будує ієрархію «мета — критерії — альтернативи» та отримує ваги критеріїв із матриці попарних порівнянь $\mathbf{A} = [a_{ij}]$, $a_{ji} = 1/a_{ij}$, за дев'ятибальною шкалою. Ваги обчислюють методом середнього геометричного рядка з подальшим нормуванням, а узгодженість суджень контролюють показниками

$$\mathrm{CI} = \frac{\lambda_{\max} - n}{n - 1}, \qquad \mathrm{CR} = \frac{\mathrm{CI}}{\mathrm{RI}(n)}, \tag{7.14}$$

де $\lambda_{\max}$ — максимальне власне число матриці; n — порядок матриці; $\mathrm{RI}(n)$ — середнє значення індексу для випадкових матриць ($\mathrm{RI}(3) = 0{,}58$; $\mathrm{RI}(4) = 0{,}90$; $\mathrm{RI}(5) = 1{,}12$). Судження вважають прийнятними за $\mathrm{CR} \leq 0{,}10$.

7.7.2 TOPSIS, згортки та нечіткі оцінки

Метод **TOPSIS** [208] ранжує альтернативи за близькістю до ідеального розв'язку: після нормування та зважування матриці рішень визначають

ідеальну $\mathbf{v}^+$ і антиідеальну $\mathbf{v}^-$ точки, обчислюють евклідові відстані d_i^+, d_i^- і відносну близькість

$$\mathrm{CC}_i = \frac{d_i^-}{d_i^+ + d_i^-}, \qquad \mathrm{CC}_i \in [0;1]. \tag{7.15}$$

Адитивна згортка $S_i = \sum_j w_j r_{ij}$ проста, але компенсаторна: високе значення за одним критерієм маскує провал за іншим. Для безпеки, де відмова одного механізму може бути фатальною, доцільніші мультиплікативна згортка $S_i = \prod_j r_{ij}^{w_j}$ або згортка за найгіршим критерієм $S_i = \min_j r_{ij}$.

Оскільки експертні судження щодо загроз лінгвістично невизначені, застосовують апарат **нечітких множин** [423]: оцінки подають трикутними нечіткими числами, агрегують за правилами нечіткої арифметики, а результат дефазифікують (метод центра ваги). Це дає змогу коректно працювати з формулюваннями «висока ймовірність», «помірний вплив», не підмінюючи їх фіктивною точністю.

7.8 Метрики захищеності

Метрика захищеності — це вимірна характеристика, що відображає стан або якість захисту. Коректна метрика має бути: вимірною (об'єктивно й повторювано), релевантною до рішення, недорогою у зборі, чутливою до змін і стійкою до маніпуляцій. Настанови щодо побудови програми вимірювань подано в NIST SP 800-55 [357].

Таблиця 7.2 — Основні класи метрик захищеності

Метрика	Зміст, шкала та обмеження
CVSS v4.0 [138]	базові, загрозні, середовищні та додаткові метрики; оцінка 0–10; характеризує *властивість уразливості*, а не ризик організації
EPSS [164]	емпірична ймовірність експлуатації CVE протягом 30 діб, шкала $[0;1]$; доповнює CVSS для пріоритизації усунення
Поверхня атаки [275]	зважена сума точок входу/виходу, каналів і елементів даних; порівняльна, а не абсолютна
Покриття заходів	частка активів, охоплених заходом (наприклад, MFA, EDR, шифрування); шкала $[0;1]$
k-нульових днів [412]	мінімальна кількість невідомих уразливостей до мети; ціле $k \geq 1$
SLO безпеки	MTTD, MTTR, RTO/RPO, частка інцидентів, оброблених у межах нормативу

Важливо не змішувати рівні: CVSS оцінює технічну серйозність уразливості, EPSS — ймовірність її експлуатації, і лише їх поєднання з вартістю активу дає ризик у сенсі (7.2). Показники MTTD і MTTR прямо входять до вимог щодо повідомлення про інциденти за Директивою NIS 2 [149] та Ре-

гламентом DORA [329], а в Україні — до порядку взаємодії з CERT-UA [117] відповідно до Закону про основні засади забезпечення кібербезпеки [58].

7.9 Ентропійні та інформаційно-теоретичні підходи

Кількісною мірою невизначеності порушника щодо секрету $\mathcal{X}$ з розподілом $\{p_1, \dots, p_N\}$ є ентропія Шеннона та мін-ентропія:

$$H(\mathcal{X}) = -\sum_{i=1}^{N} p_i \log_2 p_i, \qquad H_\infty(\mathcal{X}) = -\log_2 \max_i p_i. \tag{7.16}$$

Для оцінювання стійкості автентифікації релевантна саме H_∞, бо раціональний порушник перебирає найімовірніші варіанти першими. Ймовірність успіху інтерактивної (онлайн) атаки підбором за q спроб обмежена зверху

$$P_{\text{підбір}}(q) \le q \cdot 2^{-H_\infty}. \tag{7.17}$$

Класичний результат Шеннона [361] про досконалу секретність визначає нижню межу: ентропія ключа має бути не меншою за ентропію повідомлення. У прикладному вимірі ентропійний підхід дає змогу оцінити *залишкову* невизначеність після часткового витоку — наприклад, скільки бітів секрету залишається після компрометації підмножини часток у схемі порогового розділення секрету (розділ 9), або наскільки зменшується невизначеність місцезнаходження вузла після аналізу метаданих безпроводового сегмента (розділ 11).

7.10 Розгорнутий приклад комплексного розрахунку

Розглянемо гіпотетичну розподілену систему «РІР-Д»: три географічно рознесені майданчики, кворумна реплікація СУБД ($n = 3$, $k = 2$), фронтальний кластер із $c = 8$ вузлів ($\mu = 200$ запитів/с на вузол), 5000 облікових записів, доступ співробітників через VPN та безпроводові сегменти філій.

7.10.1 Крок 1. Готовність кворумної реплікації

Нехай для одного вузла СУБД MTTF $= 4000$ год, MTTR $= 5$ год. За (7.6) $A = 4000/4005 = 0{,}998752$, тобто простій одного вузла — $8760 \cdot (1 - A) \approx 10{,}9$ год/рік. За (7.7) для схеми «2 з 3»

$$A_{\text{сис}} = 3A^2 - 2A^3 = 2{,}992514 - 1{,}992519 = 0{,}999995,$$

що відповідає простою $\approx$ 2,5 хв/рік. Проте за $\beta = 0{,}05$ формула (7.8) дає $U_{\text{сис}} = 0{,}95 \cdot 4{,}67 \cdot 10^{-6} + 0{,}05 \cdot 1{,}248 \cdot 10^{-3} = 6{,}68 \cdot 10^{-5}$, тобто $\approx$ 35 хв/рік. Висновок: реальну доступність визначає не кратність реплікації,

а частка відмов зі спільної причини; інвестиції в незалежність майданчиків (живлення, канали, юрисдикції) дають більший ефект, ніж збільшення n з 3 до 5.

7.10.2 Крок 2. Марковська модель станів вузла

Для моделі на рис. 7.2 з інтенсивностями $\lambda_v = 0{,}10$, $\mu_p = 0{,}50$, $\lambda_c = 0{,}25$, $\delta = 1{,}50$, $\mu_r = 0{,}75$ доба$^{-1}$ рівняння балансу (7.9) дають $\pi_V = \frac{0{,}10}{0{,}75}\pi_S = 0{,}1333\pi_S$, $\pi_C = \frac{0{,}25}{1{,}50}\pi_V = 0{,}0222\pi_S$, $\pi_R = 2\pi_C = 0{,}0444\pi_S$. З умови нормування $1{,}2\pi_S = 1$ маємо

$$\pi_S = 0{,}8333, \quad \pi_V = 0{,}1111, \quad \pi_C = 0{,}0185, \quad \pi_R = 0{,}0370.$$

Отже, вузол перебуває у стані невиявленої компрометації $1{,}85\,\%$ часу — приблизно 6,8 доби на рік. Підвищення інтенсивності виявлення вдвічі ($\delta = 3{,}0$) знижує π_C до $0{,}93\,\%$, тоді як удвічі швидше усунення уразливостей ($\mu_p = 1{,}0$) дає лише $\pi_C \approx 1{,}19\,\%$. Кількісний висновок: інвестиція у швидкість *виявлення* ефективніша за інвестицію в темп усунення уразливостей — це формальне обґрунтування пріоритету систем моніторингу (розділ 14).

7.10.3 Крок 3. Аналіз графа атак

За графом на рис. 7.1 маємо два шляхи до кластера СУБД: $\pi_1 = \langle e_1, e_2, e_3, e_4\rangle$ з $P(\pi_1) = 0{,}35 \cdot 0{,}60 \cdot 0{,}45 \cdot 0{,}70 = 0{,}0662$ та $\pi_2 = \langle e_5, e_6\rangle$ з $P(\pi_2) = 0{,}12 \cdot 0{,}50 = 0{,}0600$. За (7.10) $P_{\text{комп}} = 1 - (1 - 0{,}0662)(1 - 0{,}0600) = 0{,}1222$.

Оцінимо ефект заходів (табл. 7.3). Багатофакторна автентифікація знижує p_{e_1} з $0{,}35$ до $0{,}06$; мікросегментація знижує p_{e_3} з $0{,}45$ до $0{,}10$; своєчасне оновлення VPN-шлюзу знижує p_{e_5} з $0{,}12$ до $0{,}02$.

Таблиця 7.3 — Вплив заходів захисту на ймовірність компрометації

Сценарій	$P(\pi_1)$	$P(\pi_2)$	$P_{\text{комп}}$
Базовий	0,0662	0,0600	0,1222
+ MFA	0,0113	0,0600	0,0707
+ MFA + мікросегментація	0,0025	0,0600	0,0624
+ MFA + сегм. + оновлення VPN	0,0025	0,0100	0,0125

Показовим є перехід від другого до третього рядка: мікросегментація сама собою знижує сумарну ймовірність лише на $12\,\%$ відносно попереднього стану, бо «вузьке місце» вже перемістилося на шлях π_2. Це ілюструє фундаментальний принцип: ефективність заходу визначається не його якістю, а положенням у структурі найкоротших шляхів компрометації; оптимізувати треба *розріз* графа, а не окремі дуги.

7.10.4 Крок 4. Стійкість фронтального кластера до DDoS

За штатного навантаження $\lambda = 1000$ зап./с маємо $a = 5$, $\rho = 0{,}625$; за (7.11) $C(8;5) = 0{,}167$ і $W_q = 0{,}167/(1600 - 1000) = 0{,}28$ мс. Під час атаки, що додає 480 зап./с, $\lambda = 1480$, $a = 7{,}4$, $\rho = 0{,}925$, звідки $C(8;7{,}4) = 0{,}771$ і $W_q = 0{,}771/120 = 6{,}43$ мс — зростання у 23 рази за незмінної кількості вузлів. За $\lambda = 1700$ зап./с маємо $\rho = 1{,}0625 > 1$: система нестійка, черга зростає необмежено. Розрахунок для $c = 9$ дає $\rho = 0{,}944$, $C(9;8{,}5) = 0{,}817$, $W_q = 8{,}17$ мс, що ще задовольняє SLO «не більш ніж 10 мс». Отже, для витримування атаки заданої інтенсивності потрібен щонайменше дев'ятий вузол або фільтрація, що знижує ефективне λ нижче 1600 зап./с.

7.10.5 Крок 5. Ротація облікових даних за моделлю FlipIt

Нехай вартість одного успішного прихованого проникнення для порушника еквівалентна $c_A = 15$ добам володіння ресурсом. За умовою стримування $\delta_D < 2c_A = 30$ діб. Обравши $\delta_D = 28$ діб і врахувавши власні витрати захисника $c_D = 0{,}2$ доби на цикл ротації, дістаємо виграш захисника $1 - c_D/\delta_D = 0{,}993$ за від'ємного очікуваного виграшу атакувальника. Модель дає кількісне, а не «традиційне» обґрунтування періоду ротації.

7.10.6 Крок 6. Оцінювання стійкості автентифікації

Емпіричний розподіл паролів користувачів дає мін-ентропію $H_\infty \approx 20$ біт. За обмеження $q = 100$ спроб на обліковий запис за добу з (7.17) $P \le 100/2^{20} = 9{,}5 \cdot 10^{-5}$ на запис за добу. Для 5000 записів очікувана кількість компрометацій становить $0{,}48$ за добу, або близько 174 за рік — неприйнятно. Додавання незалежного другого фактора (TOTP, 6 цифр, $H_\infty = 19{,}9$ біт) підвищує сумарну мін-ентропію до 39,9 біт, і очікувана кількість успішних підборів падає до $1{,}7 \cdot 10^{-4}$ на рік. Обмеження частоти спроб само собою не розв'язує задачі за великої кількості облікових записів — потрібне саме збільшення ентропії.

7.10.7 Крок 7. Багатокритеріальний вибір архітектури

Критерії: K_1 — конфіденційність, K_2 — цілісність, K_3 — доступність, K_4 — сукупна вартість володіння. Матриця попарних порівнянь наведена в табл. 7.4.

Таблиця 7.4 — Матриця попарних порівнянь критеріїв (AHP)

	K_1	K_2	K_3	K_4	w_j
K_1	1	1	1/3	3	0,207
K_2	1	1	1/2	3	0,229
K_3	3	2	1	5	0,484
K_4	1/3	1/3	1/5	1	0,080

Метод середнього геометричного дає ваги $w = (0{,}207;\ 0{,}229;\ 0{,}484;\ 0{,}080)$. Перевірка узгодженості: $\lambda_{\max} = 4{,}034$, звідки за (7.14) $\mathrm{CI} = 0{,}0114$ і $\mathrm{CR} = 0{,}0114/0{,}90 = 0{,}013 < 0{,}10$ — судження узгоджені.

Для трьох варіантів архітектури — A_1 (базовий периметровий захист), A_2 (сегментація + MFA), A_3 (повна архітектура нульової довіри) — з нормованими оцінками $A_1 = (0{,}40;\ 0{,}45;\ 0{,}55;\ 1{,}00)$, $A_2 = (0{,}75;\ 0{,}70;\ 0{,}80;\ 0{,}60)$, $A_3 = (0{,}95;\ 0{,}90;\ 0{,}90;\ 0{,}30)$ адитивна згортка дає $S(A_1) = 0{,}532$, $S(A_2) = 0{,}751$, $S(A_3) = 0{,}862$. Ранжування $A_3 \succ A_2 \succ A_1$ зберігається і за TOPSIS (7.15). Водночас за мультиплікативної згортки розрив між A_2 і A_3 зменшується ($0{,}748$ проти $0{,}834$), бо низька оцінка A_3 за вартістю більше не компенсується; це нагадує, що вибір виду згортки є самостійним методологічним рішенням, яке слід документувати.

7.10.8 Крок 8. Зведення результатів

Комплексний розрахунок дав узгоджену картину: залишкова ймовірність компрометації СУБД знижується з $0{,}122$ до $0{,}0125$ (у 9,8 раза) за рахунок трьох заходів, з яких лише один — мікросегментація — був очевидним «за здоровим глуздом»; критичним параметром доступності виявився β-фактор, а не кратність реплікації; найбільшу чутливість показника невиявленої компрометації забезпечує інтенсивність виявлення δ; для витримування DDoS потрібен дев'ятий фронтальний вузол; період ротації облікових даних має не перевищувати 30 діб. Саме така форма подання результатів — з явними припущеннями, чутливістю та межами застосовності моделей — відповідає вимогам до наукового обґрунтування рішень із захисту інформації.

Висновки до розділу

Оцінювання захищеності розподілених систем є багаторівневою задачею, що не зводиться до жодного окремого методу. Системний аналіз дає рамку декомпозиції та формалізує задачу оптимального синтезу (7.1) як умовну оптимізацію за критерієм залишкового ризику. Формальні моделі політик безпеки визначають межу принципової аналізовності: нерозв'язність задачі безпеки в HRU і лінійна розв'язність у Take-Grant окреслюють простір

компромісу між виразністю моделі доступу та можливістю її верифікації. Теоретико-графові методи — графи й дерева атак, метрика k-нульових днів, задача мінімального розрізу — переводять якісні міркування про «глибину оборони» у обчислювані величини й показують, що ефективність заходу визначається його положенням у структурі шляхів компрометації. Ймовірнісні моделі (марковські та напівмарковські ланцюги, біноміальні схеми кворуму, β-фактор) дають змогу відокремити ефект надлишковості від ефекту незалежності відмов, а моделі масового обслуговування — перевести стійкість до DDoS у площину проєктних рішень щодо потужності кластера. Теоретико-ігрові моделі, зокрема FlipIt, обґрунтовують необхідність рандомізації та задають кількісні межі для періодів ротації секретів. Багатокритеріальні методи (AHP, TOPSIS, нечіткі оцінки) забезпечують прозорість і перевірюваність експертних суджень через контроль узгодженості. Нарешті, коректно визначені метрики — CVSS v4.0, EPSS, поверхня атаки, показники MTTD/MTTR — пов'язують результати моделювання з операційною практикою та з вимогами NIS 2, DORA і національного законодавства. Головний методологічний висновок: жодна модель не є «правильною» сама собою; наукова цінність оцінювання визначається явністю припущень, аналізом чутливості та узгодженістю висновків, отриманих різними незалежними методами.

Питання для самоперевірки

1. Сформулюйте задачу оптимального синтезу системи захисту в прямій та двоїстій постановках. Які обмеження є нормативними й не підлягають оптимізації?
2. У чому полягає задача безпеки в моделі HRU і який її статус щодо алгоритмічної розв'язності? Які практичні наслідки це має для систем керування доступом у мікросервісних архітектурах?
3. Чому спільне застосування моделей Белла–ЛаПадули та Біба на одній ґратці рівнів призводить до виродження політики доступу?
4. Порівняйте моделі Кларка–Вілсона та Брюера–Неша за об'єктом захисту, механізмом і сферою застосування в розподілених системах.
5. Чому строге невтручання практично недосяжне в розподілених системах? Які ослаблені варіанти застосовують і як їх кількісно оцінюють?
6. Обґрунтуйте, чому заміна ваг дуг графа атак на $-\ln p_e$ зводить пошук найімовірнішого шляху компрометації до задачі про найкоротший шлях.

7. Граф атак містить три незалежні шляхи з імовірностями 0,08; 0,05 і 0,03. Обчисліть сумарну ймовірність компрометації. Як зміниться результат, якщо шляхи мають спільну початкову дугу?
8. Для вузла з $\mathrm{MTTF} = 6000$ год і $\mathrm{MTTR} = 8$ год обчисліть коефіцієнт готовності та готовність кворумної схеми «3 з 5». Порівняйте результат зі схемою «2 з 3».
9. У марковській моделі рис. 7.2 змініть δ з 1,50 до 2,50 доба$^{-1}$ і перерахуйте стаціонарний розподіл. На скільки відсотків зменшиться частка часу невиявленої компрометації?
10. Кластер має $c = 6$ вузлів із $\mu = 250$ зап./с. Визначте максимальну інтенсивність запитів, за якої система залишається стійкою, та обчисліть W_q за $\lambda = 1350$ зап./с.
11. Вартість прихованого проникнення для порушника оцінено у 20 діб еквівалентного володіння ресурсом. Який максимальний період ротації облікових даних забезпечує стримування за моделлю FlipIt? Обґрунтуйте.
12. Мін-ентропія PIN-коду з чотирьох цифр становить 13,3 біт. Обчисліть верхню межу ймовірності успішного підбору за 50 спроб і очікувану кількість компрометацій для 20 000 карток за рік.
13. Побудуйте матрицю попарних порівнянь для трьох критеріїв оцінювання захищеності, обчисліть ваги методом середнього геометричного та перевірте узгодженість за CR.
14. Порівняйте адитивну, мультиплікативну та мінімаксну згортки як інструмент агрегації часткових показників захищеності. Для яких класів систем компенсаторність згортки є неприйнятною?
15. Чому CVSS не є мірою ризику організації? Запропонуйте схему поєднання CVSS v4.0, EPSS і вартості активу для пріоритизації усунення уразливостей та обґрунтуйте її відповідність формулі (7.2).

РОЗДІЛ 8

Моделювання загроз і управління ризиками розподілених інформаційних ресурсів

Попередні розділи сформували уявлення про архітектури розподілених систем, чинне нормативно-правове поле та математичний апарат оцінювання захищеності. Цей розділ поєднує ці три складники в єдиному інженерному процесі: від структурованого опису системи — через побудову моделі порушника й моделі загроз — до кількісно обґрунтованого рішення про те, які саме захисні заходи слід упровадити за обмеженого бюджету. Управління ризиками розглядається тут не як формальна процедура для отримання атестата відповідності, а як науково-практичний інструмент прийняття рішень в умовах неповної інформації, притаманних розподіленому середовищу з динамічним периметром, зовнішніми провайдерами та довгими ланцюгами постачання програмного забезпечення. Матеріал розділу є методологічною основою для розділів 14–17, де розглядаються моніторинг, реагування та управління безпекою.

8.1 Понятійний апарат ризик-менеджменту інформаційної безпеки

Термінологічне ядро дисципліни закріплене в ISO 31000 [227], ISO/IEC 27005 [231], NIST SP 800-30 [300] та RFC 4949 [365]; в українському нормативному полі відповідні поняття унормовано ДСТУ EN ISO/IEC 27001:2023 [20] і НД ТЗІ 1.1-002-99 [31].

Актив — будь-що, що має цінність для організації: дані, програмне забезпечення, обчислювальні та комунікаційні ресурси, персонал, репутація, а в розподілених системах ще й довіра зовнішніх учасників до вузла. **Загроза** — потенційна причина небажаного інциденту; **вразливість** — властивість активу або заходу захисту, що може бути використана загрозою. **Вплив** (impact) — масштаб негативних наслідків реалізації загрози, **ймовірність** — міра очікуваності такої реалізації в заданому часовому горизонті. **Ризик** у формулюванні ISO 31000 — це вплив невизначеності на цілі; в операційній практиці інформаційної безпеки він виражається функцією

$$R = f(P,\, I) \quad \text{і в найпростішому вигляді} \quad R = P \cdot I, \tag{8.1}$$

де $P \in [0, 1]$ — ймовірність реалізації сценарію протягом року, I — вплив у грошовому чи бальному вимірі. Ця мультиплікативна згортка є грубим наближенням: вона неявно припускає незалежність подій, лінійність корисності та однорідність шкал. Для розподілених систем із каскадними відмо-

вами таке припущення часто хибне, тому в розділі 7 розглянуто складніші моделі агрегування.

Внутрішній (inherent) ризик — ризик до впровадження заходів; **залишковий ризик** — те, що залишається після їх упровадження:

$$R_{\text{зал}} = R_{\text{вн}} \cdot \prod_{k=1}^{m} \bigl(1 - e_k\bigr), \tag{8.2}$$

де $e_k \in [0, 1)$ — коефіцієнт результативності k-го незалежного заходу. Мультиплікативна форма відображає ідею ешелонованого захисту: два заходи з результативністю 0,6 і 0,5 знижують ризик не на 110 %, а на 80 %. **Апетит до ризику** — рівень ризику, який власник свідомо готовий утримувати задля досягнення цілей; **толерантність** — допустимий діапазон відхилень навколо цього рівня. Критично важливо, що апетит визначає не служба захисту інформації, а керівництво організації: це управлінське, а не технічне рішення.

Процес управління ризиком за ISO/IEC 27005 [231] і NIST SP 800-37 [303] є ітеративним і супроводжується наскрізними діяльностями — комунікацією та моніторингом (рис. 8.1).

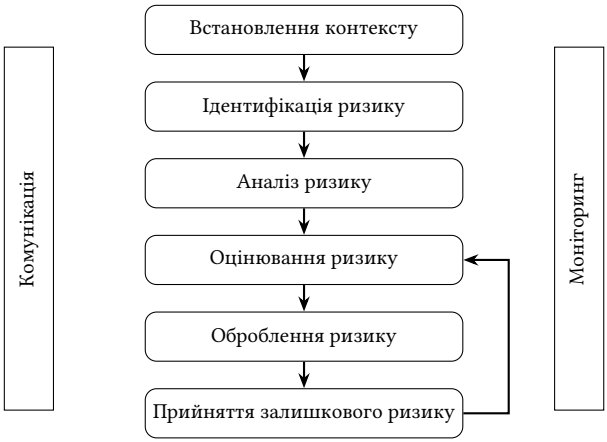


Рис. 8.1 — Процес управління ризиком інформаційної безпеки (за [231, 227])

8.2 Інвентаризація та категоризація розподілених активів

Жодна модель загроз не буває повнішою за реєстр активів, на якому вона побудована. Захід A.5.9 ДСТУ EN ISO/IEC 27002:2023 [21] та контроль 1

CIS Controls v8.1 [129] вимагають ведення актуального інвентарю з призначеним власником для кожної позиції. Мінімальний набір атрибутів запису реєстру: ідентифікатор, тип, власник (роль, а не прізвище), розпорядник, місце оброблення (юрисдикція), правовий режим (відкрита інформація, персональні дані [53], службова інформація, державна таємниця [43]), клас критичності за тріадою конфіденційність–цілісність–доступність, допустимий час простою (RTO) і допустима втрата даних (RPO), залежності від інших активів.

Категоризація в українській практиці має подвійну природу. З одного боку, НД ТЗІ 2.5-005-99 [32] класифікує автоматизовані системи за класами 1–3 та задає стандартні функціональні профілі захищеності; з іншого — Закон України «Про критичну інфраструктуру» [55] та постанова КМУ № 1109 [14] вводять категорії критичності об'єктів (I–IV), а постанова КМУ № 518 [22] — загальні вимоги до їх кіберзахисту. Для розподіленого ресурсу ці дві класифікації застосовуються одночасно: перша — до конкретної системи як об'єкта інформаційної діяльності, друга — до її ролі в наданні життєво важливої послуги.

Розподілене й хмарне середовище створює три специфічні труднощі обліку.

- *Динамічність і ефемерність.* Контейнер живе хвилини, автомасштабована група змінює склад щохвилини, тому статичний реєстр у вигляді таблиці застаріває швидше, ніж заповнюється. Розв'язок — перехід від обліку екземплярів до обліку *шаблонів* (образи, маніфести, модулі інфраструктури як коду) з автоматичним виявленням розбіжностей; NIST SP 800-190 [376] прямо вимагає контролю життєвого циклу образів.
- *Тіньові ІТ і тіньові дані.* Самостійно розгорнуті командами SaaS-сервіси, тестові копії продуктивних баз, експорти в електронні таблиці утворюють активи поза периметром управління. Виявлення потребує аналізу DNS- і проксі-журналів, інвентаризації хмарних облікових записів та періодичного сканування сховищ.
- *Розмитість власності.* У моделі спільної відповідальності [358, 279] частина контролів належить провайдерові, і реєстр має фіксувати межу відповідальності для кожного активу, інакше певні ризики не отримають власника взагалі.

Окремої уваги потребують **безпроводові** сегменти доступу до розподілених ресурсів: точки доступу, промислові безпроводові шлюзи, канали мобільного зв'язку резервування. Безпроводові активи часто випадають із реєстру, хоча саме вони формують найдоступніший для порушника фізичний вектор (докладніше — у розділі 11).

8.3 Модель порушника та модель загроз

НД ТЗІ 1.1-002-99 [31] і НД ТЗІ 2.5-004-99 [33] закріплюють обов'язковість побудови **моделі порушника** як передумови формування вимог до комплексної системи захисту інформації; НД ТЗІ 3.7-003-05 [34] визначає її місце в порядку створення КСЗІ. Класична вітчизняна схема класифікує порушника за чотирма ознаками: рівень можливостей (від запуску наявних програм до створення власних засобів і втручання в апаратуру), місце дії (поза контрольованою зоною, у контрольованій зоні, безпосередньо на об'єкті), рівень повноважень (стороння особа, користувач, адміністратор, розробник) і мотивація (необережність, цікавість, корисливість, примус, ідеологія).

Сучасний розподілений ландшафт вимагає розширення цієї схеми (табл. 8.1). Ключова відмінність — поява порушників, які не мають жодного стосунку до контрольованої зони: вони діють через ланцюг постачання, через скомпрометованого провайдера або повністю автоматизовано.

Таблиця 8.1 — Розширена класифікація порушників для розподілених систем

Категорія	Ресурс і стійкість	Характерні вектори
Автоматизований (боти, сканери)	Низький, безперервна дія	Масове сканування, підбір облікових даних, експлуатація свіжих CVE
Кіберзлочинна група	Середній, орієнтація на прибуток	Здирницьке ПЗ, компрометація ділового листування, викрадення даних
Інсайдер	Легітимний доступ, знання процесів	Зловживання повноваженнями, вивантаження даних, саботаж
Постачальник / підрядник	Довірений канал, віддалений доступ	Компрометація оновлень, зловживання сервісним акаунтом
APT-угруповання	Високий, роками присутнє в системі	Цілеспрямований фішинг, 0-day, компрометація ланцюга постачання, руйнівні операції

Досвід України 2014–2025 рр. показав, що для критичних розподілених ресурсів визначальним є саме останній профіль: звіти CERT-UA [117] і Держспецзв'язку [8] фіксують тривалі кампанії з поєднанням шпигунства й деструктивних дій, а ENISA [161] відносить державні реєстри та телекомунікації до найбільш атакованих секторів. Тому модель порушника для державного розподіленого ресурсу має за замовчуванням припускати наявність вмотивованого супротивника з ресурсами державного рівня, а не «середньостатистичного хакера».

Модель загроз — це структурований опис множини сценаріїв $\{(a_j, v_k, t_l)\}$, де a_j — актив, v_k — вразливість, t_l — дія порушника. Практична вимога до моделі: вона має бути *перевіркоздатною* (кожен сценарій формулюється так, щоб можна було спроєктувати тест) і *простежуваною*

(кожному сценарію відповідає щонайменше один захід та щонайменше одне джерело подій для виявлення).

8.4 Методології моделювання загроз

Маніфест моделювання загроз [105] зводить процес до чотирьох питань: над чим ми працюємо; що може піти не так; що ми з цим робимо; чи достатньо добре ми це зробили. Методології різняться передусім способом відповіді на друге питання.

8.4.1 STRIDE та її варіанти

STRIDE [283, 366] — мнемоніка шести класів загроз, кожен з яких є запереченням певної властивості безпеки (табл. 8.2). Метод застосовується до діаграми потоків даних (DFD): система декомпозується на зовнішні сутності, процеси, сховища та потоки, між якими проводяться **межі довіри**. У варіанті *STRIDE-per-element* кожному типу елемента приписується підмножина застосовних категорій (сховище не може «підмінюватися», але може «фальсифікуватися»); у варіанті *STRIDE-per-interaction* аналізується трійка «джерело–потік–приймач», що дає точніший, але значно більший перелік. Для розподілених систем практично виправданим є гібрид: per-element для внутрішніх компонентів і per-interaction для всіх потоків, що перетинають межу довіри.

Таблиця 8.2 — Відповідність STRIDE, властивостей безпеки і контрзаходів

Категорія	Порушувана властивість	Типові контрзаходи
Spoofing (підміна)	Автентичність	Взаємна автентифікація mTLS, MFA, підписані маркери [240]
Tampering (фальсифікація)	Цілісність	Імітовставки, підпис за ДСТУ 4145 [16], TLS 1.3 [336]
Repudiation (відмова від дій)	Невідмовність	Незмінні журнали, кваліфікований е-підпис [44]
Information disclosure	Конфіденційність	Шифрування у спокої та в русі, мінімізація даних
Denial of service	Доступність	Обмеження темпу, квоти, георезервування, CDN
Elevation of privilege	Авторизація	Найменші привілеї, ізоляція, контроль політик доступу

8.4.2 LINDDUN, PASTA, OCTAVE, дерева атак

LINDDUN [266, 147] переносить логіку STRIDE у площину приватності: linking, identifying, non-repudiation, detecting, data disclosure, unawareness, non-compliance. Для розподілених реєстрів персональних даних LINDDUN є необхідним доповненням, оскільки STRIDE не виявляє загроз, що виника-

ють із *легітимного* оброблення — надмірного зв'язування записів, повторної ідентифікації знеособлених наборів, невиконання вимог GDPR [328] щодо прав суб'єкта.

PASTA [403] — семиетапний ризик-орієнтований процес (від визначення бізнес-цілей до аналізу залишкового ризику), який від початку пов'язує технічний аналіз із вартісними показниками. OCTAVE Allegro [114] орієнтована на активи й на самостійне проведення оцінювання силами організації без залучення зовнішніх аналітиків, що робить її придатною для установ із обмеженим бюджетом. Проєкт NIST SP 800-154 [377] (остаточної редакції не видано) пропонує даноцентричний підхід, за якого модель будується навколо конкретного набору даних, а не навколо системи, — це зручно саме для розподілених ресурсів, де одні й ті самі дані існують у кількох системах одночасно.

Дерева атак [356] формалізують декомпозицію мети порушника через вузли «І»/«АБО» і дають змогу поширювати знизу вгору числові атрибути — вартість атаки, потрібну кваліфікацію, ймовірність успіху. Для вузла типу «АБО» ймовірність успіху $p = 1 - \prod_i (1 - p_i)$, для вузла «І» — $p = \prod_i p_i$. Фрагмент дерева для державного реєстру наведено на рис. 8.2.

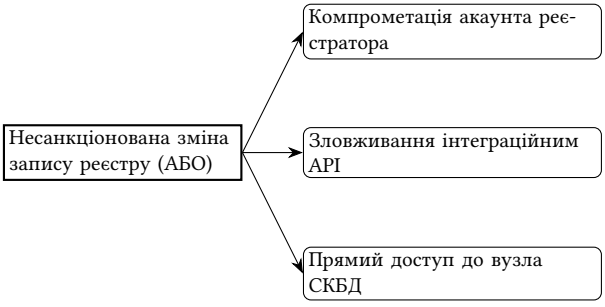


Рис. 8.2 — Фрагмент дерева атак на розподілений державний реєстр

8.4.3 Практика моделювання за DFD

Робочий цикл для розподіленої системи: (1) побудова DFD рівня 1 з явними межами довіри; (2) перелічення загроз за STRIDE для кожного елемента й потоку; (3) ранжування за попередньою оцінкою ризику; (4) зіставлення з наявними заходами; (5) фіксація виявлених прогалин у реєстрі ризиків. Настанови OWASP [398] наголошують, що DFD має відображати *фактичну*, а не проєктну архітектуру, — у мікросервісних середовищах розбіжність між ними є типовою причиною пропущених загроз. Приклад DFD із STRIDE-мітками наведено далі, у кейсі (рис. 8.3).

8.5 Kill chain, MITRE ATT&CK і матриця покриття

Модель *Cyber Kill Chain* [207] описує цілеспрямоване вторгнення як послідовність із семи фаз: розвідка, озброєння, доставляння, експлуатація, встановлення, управління (C2), дії щодо цілей. Її головна практична цінність — ідея, що зрив атаки на будь-якій ранній фазі знецінює всю подальшу підготовку порушника. Обмеження моделі — лінійність і зовнішньоцентричність: вона погано описує дії інсайдера та бічне переміщення всередині розподіленого середовища.

MITRE ATT&CK [288, 389] усуває це обмеження, подаючи знання про поведінку супротивника у вигляді матриці тактик (навіщо) і технік та субтехнік (як), доповнених процедурами (конкретні реалізації, задокументовані для відомих угруповань). Для розподілених ресурсів принципово важливими є доменні матриці ATT&CK for Cloud (техніки зловживання ідентичностями та API хмарного провайдера), ATT&CK for Containers (втеча з контейнера, зловживання оркестратором) та ATT&CK for ICS (докладніше — у розділі 16). Каталог CAPEC [112] описує узагальнені шаблони атак і слугує містком між технікою ATT&CK і конкретною вразливістю в коді, а MITRE D3FEND [289] подає граф контрзаходів із категоріями Model, Harden, Detect, Isolate, Deceive, Evict, Restore.

Матриця покриття (coverage map) будується як бінарне або градуйоване відображення $\mathrm{cov} : T \times C \to \{0, 1, 2\}$ множини релевантних технік T на множину впроваджених заходів і засобів моніторингу C, де 0 — відсутність покриття, 1 — часткове (є телеметрія, немає правила виявлення), 2 — повне (є заходи запобігання й виявлення). Інтегральний показник покриття

$$K = \frac{1}{2\,|T_{\text{рел}}|} \sum_{t \in T_{\text{рел}}} \max_{c \in C} \mathrm{cov}(t, c), \tag{8.3}$$

де $T_{\text{рел}}$ — підмножина технік, застосовних до фактичного технологічного стека. Практична порада: $|T_{\text{рел}}|$ для типового розподіленого державного сервісу становить 60–90 технік із понад 600 наявних у матриці, і саме коректне відсіювання нерелевантних технік визначає корисність показника. Побудова матриці покриття природно зв'язує моделювання загроз із розділами 14 (моніторинг) і 15 (реагування): нульове покриття техніки означає одночасно і прогалину в захисті, і «сліпу пляму» для SOC.

8.6 Оцінювання ризиків: якісні та кількісні підходи

8.6.1 Якісні шкали й матриця ризиків

Якісне оцінювання оперує порядковими шкалами ймовірності та впливу (табл. 8.3). Його перевага — швидкість і придатність за відсутності статистики, недолік — ілюзія точності: порядкові рівні не можна ані додавати,

ані множити, а поширена практика перемноження «балів» математично некоректна. Матриця ризиків прийнятна як інструмент *комунікації* і первинного сортування, але не як основа для розрахунку окупності заходів.

Таблиця 8.3 — Матриця ризиків (рівні: Н — низький, П — помірний, В — високий, К — критичний)

Ймовірність \ Вплив	І1	І2	І3	І4	І5
Р5 (майже певна)	П	В	К	К	К
Р4 (ймовірна)	П	П	В	К	К
Р3 (можлива)	Н	П	В	В	К
Р2 (малоймовірна)	Н	Н	П	В	В
Р1 (рідкісна)	Н	Н	Н	П	В

8.6.2 Кількісні підходи: SLE, ARO, ALE

Класична кількісна модель оперує трьома величинами: вартістю активу AV, коефіцієнтом ураження $EF \in [0,1]$ та річною частотою реалізації ARO. Одноразові та річні очікувані втрати визначаються як

$$SLE = AV \cdot EF, \qquad ALE = SLE \cdot ARO = AV \cdot EF \cdot ARO. \tag{8.4}$$

Числовий приклад. Нехай для розподіленого державного реєстру вартість інформаційного активу (сукупні витрати на відновлення даних, юридичні наслідки, компенсації та репутаційні втрати) оцінено як $AV = 40{,}0$ млн грн. Сценарій «шифрування здирницьким ПЗ реплік реєстру у двох із трьох центрів оброблення» уражує 15 % вартості: $EF = 0{,}15$, звідки $SLE = 40{,}0 \cdot 0{,}15 = 6{,}0$ млн грн. Експертна оцінка частоти — одна подія на 2,5 року, тобто $ARO = 0{,}4$. Тоді $ALE = 6{,}0 \cdot 0{,}4 = 2{,}4$ млн грн на рік. Якщо впровадження ізольованих незмінних резервних копій знижує EF до 0,04, а сегментація зменшує ARO до 0,25, новий $ALE' = 40{,}0 \cdot 0{,}04 \cdot 0{,}25 = 0{,}40$ млн грн; відвернені втрати $\Delta ALE = 2{,}0$ млн грн на рік.

8.6.3 FAIR, Монте-Карло та аналіз чутливості

Модель FAIR [339, 177] декомпозує ризик на частоту подій втрат LEF (яка, своєю чергою, розкладається на частоту контактів, ймовірність дії порушника, вразливість) і величину втрат LM (первинні та вторинні). Замість точкових значень FAIR оперує розподілами, а результат отримується імітаційним моделюванням: для N реалізацій ($N = 10^4 \dots 10^6$) генеруються LEF_i і LM_i, обчислюється $\text{Loss}_i = \sum_{j=1}^{n_i} LM_{ij}$, де $n_i \sim \text{Poisson}(LEF_i)$, і будується емпіричний розподіл річних втрат. Замість єдиного числа керівництво отримує криву перевищення втрат: медіану, 90-й процентиль, «хвіст». Для наведеного вище прикладу лог-нормальний розподіл LM із

медіаною 6 млн грн і 95-м процентилем 25 млн грн дає очікуване значення, суттєво більше за детерміноване SLE, — саме асиметрія хвоста, а не середнє, визначає потребу в кіберстрахуванні.

Аналіз чутливості (наприклад, за допомогою торнадо-діаграм або кореляції рангів Спірмена між входами й виходом) показує, які саме вхідні оцінки найбільше впливають на результат; уточнювати доцільно лише їх. Це має і науково-методологічне значення: воно перетворює експертне оцінювання з разової процедури на кероване зменшення невизначеності.

8.6.4 Похибки експертного оцінювання

Типові систематичні викривлення: *надмірна впевненість* (заявлені 90 % довірчі інтервали фактично покривають істину в 40–60 % випадків); *ефект прив'язки* до першого названого числа; *доступність* — переоцінка загроз, про які нещодавно писали ЗМІ, і недооцінка «тихих» ризиків на кшталт помилок конфігурації; *груповий тиск* під час колективного оцінювання. Контрзаходи — калібрувальне тренування експертів, незалежне анонімне оцінювання з подальшим обговоренням розбіжностей (модифікований метод Дельфі), використання опорних частот (base rates) із галузевої статистики, розділення оцінювання частоти й величини втрат між різними групами фахівців. Українські дослідження [38, 37] демонструють перспективність доповнення експертних оцінок машинним навчанням на телеметрії розподілених систем, а методика [63] пропонує формалізований підхід до оцінювання комплексних збитків від інциденту з урахуванням взаємозалежності компонентів.

8.7 Ризики ланцюга постачання програмного забезпечення

Розподілена система успадковує ризики всіх своїх залежностей. NIST SP 800-161 [103] визначає кіберризик ланцюга постачання як окрему категорію, що потребує власних процесів: оцінювання постачальників, договірних вимог, перевірки цілісності артефактів і планування на випадок компрометації довіреного каналу.

Три інциденти сформували сучасне розуміння проблеми. Компрометація процесу складання SolarWinds Orion [74] показала, що підписаний легітимним ключем постачальника оновлення може містити закладку, — отже, довіра до підпису не замінює контролю цілісності самого процесу складання. Log4Shell [285] продемонстрував, що критична вразливість у транзитивній залежності, про наявність якої більшість організацій не знала, уражує тисячі систем одночасно; ключовою проблемою була не так вразливість, як неспроможність швидко відповісти на питання «де саме в нас використовується Log4j». Спроба вбудувати закладку в XZ Utils [176] виявила ризик

соціальної інженерії щодо супроводжувачів відкритого коду: зловмисник роками вибудовував репутацію, щоб отримати права запису.

Практична відповідь ґрунтується на трьох механізмах:

SBOM — специфікація складу ПЗ
Машиночитний перелік компонентів і залежностей у форматі SPDX (ISO/IEC 5962:2021) [238] або CycloneDX (ECMA-424) [157]; мінімальні елементи та практики поширення визначені настановами CISA [373]. SBOM перетворює питання «чи вразливі ми» з дослідницької задачі на запит до бази даних.

Верифікація артефактів
Криптографічний підпис артефактів і, головне, підписані *свідчення про походження* (provenance): хто, з якого коду, на якому складальнику й за якими параметрами зібрав артефакт.

SLSA
Рамка [372] задає рівні гарантій цілісності: від наявності провенансу до повністю ізольованого, відтворюваного складання з дворецензійним внесенням змін. Рівень SLSA є вимірюваною метрикою зрілості, придатною для внесення в договір із постачальником.

Для державних розподілених систем України ця тематика набуває нормативного виміру: вимоги NIS 2 [149] і DORA [329] щодо управління ризиками постачальників ІКТ стають орієнтиром для гармонізації національного законодавства, адже ні Закон «Про основні засади забезпечення кібербезпеки України» [58], ні Стратегія кібербезпеки [60] не містять окремих положень про безпеку ланцюгів постачання.

8.8 Оброблення ризику та оптимальний розподіл бюджету

ISO/IEC 27005 [231] визначає чотири стратегії: *уникнення* (відмова від діяльності або технології, що породжує ризик), *зниження* (впровадження заходів), *перенесення* (страхування, аутсорсинг із договірною відповідальністю) і *прийняття* (свідоме утримання ризику в межах апетиту). Важливо, що перенесення ніколи не є повним: репутаційні та регуляторні наслідки залишаються з власником даних незалежно від умов договору.

Критерієм вибору заходів слугує показник окупності інвестицій у безпеку

$$ROSI = \frac{\Delta ALE - C_{\text{річ}}}{C_{\text{річ}}}, \tag{8.5}$$

де $C_{\text{річ}}$ — зведені до року витрати на захід (амортизація капітальних витрат плюс операційні). Для прикладу з підрозділу 8.6: якщо $\Delta ALE =$

2,0 млн грн, а річні витрати на незмінні резервні копії та сегментацію становлять $C_{\text{річ}} = 0{,}7$ млн грн, то $ROSI = (2{,}0 - 0{,}7)/0{,}7 \approx 1{,}86$, тобто 186 %.

За обмеженого бюджету B вибір набору заходів формалізується як задача про рюкзак:

$$\max_{x \in \{0,1\}^n} \sum_{i=1}^{n} \Delta ALE_i \, x_i \quad \text{за умови} \quad \sum_{i=1}^{n} c_i x_i \le B, \tag{8.6}$$

де $x_i = 1$ означає ухвалення i-го заходу. Задача NP-складна, проте для практичних розмірностей ($n < 50$) розв'язується точно динамічним програмуванням; жадібна евристика за спаданням питомої ефективності $\rho_i = \Delta ALE_i / c_i$ дає добре наближення, але не гарантує оптимуму.

Числовий приклад. Нехай $B = 2000$ тис. грн і розглядаються п'ять заходів (табл. 8.4).

Таблиця 8.4 — Вихідні дані задачі розподілу бюджету безпеки

Захід	c_i, тис. грн	ΔALE_i, тис. грн	ρ_i
З1. MFA для адміністраторів	350	1450	4,14
З2. Мікросегментація мережі	900	1800	2,00
З3. SIEM та SOC 24/7	1600	2600	1,63
З4. WAF для порталу	400	600	1,50
З5. Незмінні резервні копії	500	1900	3,80

Жадібний вибір у порядку спадання ρ_i дає З1 (350), З5 (500), З2 (900) — сумарна вартість 1750 тис. грн, сумарний ефект 5150 тис. грн; залишку 250 тис. грн не вистачає на жоден із решти заходів. Повний перебір $2^5 = 32$ комбінацій підтверджує, що цей набір є оптимальним: найближча альтернатива З1+З5+З3 коштує 2450 тис. грн і виходить за межі бюджету, а З5+З2+З4 дає лише 4300 тис. грн. Загальний $ROSI$ портфеля становить $(5150 - 1750)/1750 \approx 1{,}94$. Слід підкреслити, що збіг жадібного й точного розв'язків тут випадковий: достатньо змінити c_2 на 1700, щоб жадібний алгоритм утратив оптимальність.

Обмеження моделі очевидні й повинні проговорюватися: заходи не є незалежними (SIEM без сегментації менш дієвий), ΔALE_i оцінені з похибкою, порівнянною з відмінностями між варіантами, а частина ефектів (відповідність вимогам, довіра громадян) не має грошового виміру. Тому задачу доцільно розв'язувати як багатокритеріальну або в постановці робастної оптимізації — це один із відкритих напрямів досліджень.

Кіберстрахування як механізм перенесення ризику в Україні перебуває на етапі становлення. Ключові методологічні питання — визначення страхової події для розподіленої системи (де саме стався інцидент, якщо дані оброблялися в трьох юрисдикціях), виключення щодо «воєнних дій»,

актуарна оцінка за відсутності національної статистики інцидентів. Для об'єктів критичної інфраструктури страхування не заміщує обов'язкових вимог [22], а лише покриває залишковий фінансовий ризик.

8.9 Комунікація ризику, ризик-реєстр та інтеграція із СУІБ

Реєстр ризиків — центральний артефакт процесу. Мінімальний набір полів: ідентифікатор; опис сценарію у форматі «джерело загрози – вразливість – актив – наслідок»; власник ризику (керівник, а не виконавець); оцінки ймовірності й впливу; внутрішній та залишковий рівні; обрана стратегія оброблення; перелік заходів із термінами й відповідальними; дата перегляду; посилання на техніки ATT&CK і на пункти вимог, що покриваються. Останні два поля забезпечують простежуваність в обидва боки — до моделі загроз і до нормативних вимог [20].

Комунікація ризику вимагає різних мов для різних аудиторій: технічній команді потрібні техніки й індикатори, керівництву — грошові величини та ймовірність перевищення порогу, регуляторові — відповідність вимогам. Хибою є подання керівництву «теплової карти» без указання, які саме управлінські рішення від нього очікуються; ефективнішим є формат «три сценарії з найбільшим внеском у ризик, вартість зниження кожного, залишковий ризик після зниження».

Інтеграція із СУІБ за ДСТУ EN ISO/IEC 27001:2023 [20] відбувається через пункти 6.1 (дії щодо ризиків), 8.2–8.3 (оцінювання й оброблення), 9.3 (аналіз з боку керівництва) і формується у вигляді Декларації про застосовність. Зв'язок із управлінням безперервністю за ISO 22301 [226] двобічний: аналіз впливу на діяльність (BIA) постачає ризик-менеджментові значення AV, RTO і RPO, а реєстр ризиків визначає сценарії, для яких треба розробляти плани відновлення (докладніше — у розділі 15). Керування інцидентами за ISO/IEC 27035 [236] і NIST SP 800-61 [128] замикає цикл: фактичні інциденти є емпіричним джерелом для перегляду ARO, тобто перетворюють оцінювання ризиків із апріорного на байєсівське.

8.10 Кейс: моделювання загроз розподіленого державного реєстру

Розглянемо гіпотетичний, але типовий для української практики об'єкт: державний публічний електронний реєстр [59], розгорнутий у трьох географічно рознесених центрах оброблення даних із синхронною реплікацією, доступний громадянам через вебпортал, а іншим органам влади — через систему електронної взаємодії. Реєстр містить персональні дані [53] і належить до об'єктів критичної інфраструктури [55].

Крок 1. Модель системи. Побудовано DFD рівня 1 з трьома межами довіри: Інтернет, демілітаризована зона, внутрішня зона оброблення (рис. 8.3). Позначки біля потоків указують застосовні категорії STRIDE.

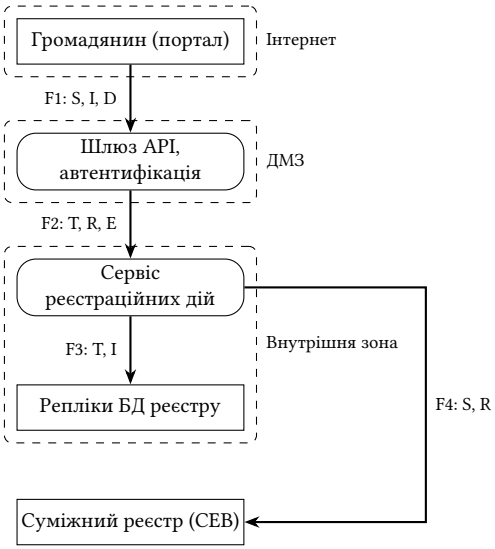


Рис. 8.3 — DFD розподіленого державного реєстру з межами довіри та STRIDE-мітками

Крок 2. Модель порушника. Основними визнано три профілі з табл. 8.1: APT-угруповання з ресурсами державного рівня; інсайдер-реєстратор із легітимними повноваженнями на внесення змін; підрядник, що супроводжує прикладне ПЗ і має віддалений привілейований доступ.

Крок 3. Перелічення загроз. Для потоку F1 виявлено підміну особи через викрадені засоби автентифікації (S) і відмову в обслуговуванні через розподілену атаку (D); для F2 — підвищення привілеїв через недосконалу перевірку маркерів доступу (E) і відсутність невідмовності дій адміністратора (R); для F3 — фальсифікацію записів в обхід прикладного рівня (T); для F4 — підміну суміжної системи та відмову від факту передавання (S, R). Додатково LINDDUN виявив загрозу надмірного зв'язування даних під час аналітичного вивантаження, яку STRIDE не фіксує, оскільки формально доступ є легітимним.

Крок 4. Оцінювання. Для сценарію «інсайдер вносить неправомірні зміни до 200 записів» прийнято $AV = 40$ млн грн, $EF = 0{,}05$, $ARO = 0{,}6$, звідки $ALE = 40 \cdot 0{,}05 \cdot 0{,}6 = 1{,}2$ млн грн. Для сценарію здирницького ПЗ — розрахунок із підрозділу 8.6 ($ALE = 2{,}4$ млн грн).

Крок 5. Оброблення. Обрано портфель із табл. 8.4 (З1, З2, З5). Додатково для інсайдерського сценарію впроваджено правило «чотирьох очей» для масових операцій і незмінне журналювання з кваліфікованою електронною позначкою часу [44], що знижує EF до 0,015 і дає $ALE' = 0{,}36$ млн грн.

Крок 6. Матриця покриття. З 74 релевантних технік ATT&CK повне покриття мали 31, часткове — 26, нульове — 17; показник $K = (2{\cdot}31{+}1{\cdot}26)/(2{\cdot}74) \approx 0{,}59$. Виявлені прогалини (переважно техніки бічного переміщення та зловживання довіреними відносинами) стали вхідними даними для наступного циклу планування й для розроблення правил кореляції в SOC.

Крок 7. Перегляд. Реєстр ризиків переглядається щоквартально та позапланово — після кожного значного інциденту, зміни архітектури або публікації CERT-UA [117] про нову кампанію проти державних ресурсів. Такий режим відповідає вимогам постанови КМУ № 518 [22] та підходу CSF 2.0 [307], де функція Govern охоплює зокрема управління ризиками ланцюга постачання.

Висновки до розділу

Управління ризиками розподілених інформаційних ресурсів є містком між нормативними вимогами й інженерними рішеннями. Понятійний апарат ISO 31000, ISO/IEC 27005 і NIST SP 800-30 дає спільну мову, проте його механічне застосування до розподіленого середовища дає хибні результати: реєстр активів застаріває швидше, ніж укладається, межа відповідальності розмита між організацією та провайдерами, а класична модель порушника з НД ТЗІ потребує розширення профілями APT, підрядника й автоматизованого супротивника.

Моделювання загроз доцільно будувати на комбінації методологій: STRIDE над DFD — для систематичного перелічення технічних загроз, LINDDUN — для загроз приватності, дерева атак — для аналізу конкретних високоризикових сценаріїв, MITRE ATT&CK — для зв'язку моделі із фактичною поведінкою супротивника й для побудови матриці покриття, яка одночасно є картою прогалин захисту й «сліпих плям» моніторингу.

Кількісне оцінювання (SLE, ARO, ALE, FAIR, імітаційне моделювання) не усуває невизначеності, але робить її явною й керованою; аналіз чутливості вказує, які саме оцінки варто уточнювати. Матриця ризиків залишається інструментом комунікації, а не обчислень. Розподіл обмеженого бюджету безпеки коректно формулюється як оптимізаційна задача, розв'язок якої слід супроводжувати чесним переліком припущень щодо незалежності заходів і точності оцінок.

Ризики ланцюга постачання (SolarWinds, Log4Shell, XZ Utils) вимагають окремого контуру управління з SBOM, верифікацією провенансу та рівнями SLSA. Нарешті, увесь процес має бути замкнений: інциденти оновлюють оцінки частот, а реєстр ризиків залишається живим документом, інтегрованим із СУІБ і системою управління безперервністю діяльності. Відкритими науковими проблемами залишаються агрегування взаємозалежних ризиків у розподілених системах, робастна оптимізація портфеля заходів

за суттєвої невизначеності вхідних даних та автоматизоване формування й супровід моделей загроз для середовищ, що змінюються швидше за темп ручного аналізу.

Питання для самоперевірки

1. Розмежуйте поняття «загроза», «вразливість», «ризик» і «вплив» за ISO/IEC 27005 та RFC 4949. Наведіть приклад, коли вразливість існує, а ризик є прийнятним.
2. Чому мультиплікативна згортка $R = P \cdot I$ є грубим наближенням саме для розподілених систем? Які припущення вона порушує?
3. Що таке апетит до ризику й толерантність до ризику? Хто в організації уповноважений їх визначати і чому це не служба захисту інформації?
4. Які атрибути повинен містити запис реєстру активів розподіленої системи? Як вести облік ефемерних контейнерних активів?
5. Порівняйте класифікацію автоматизованих систем за НД ТЗІ 2.5-005-99 і категоризацію об'єктів критичної інфраструктури за Законом України «Про критичну інфраструктуру». Чи взаємозамінні вони?
6. Розширте класичну модель порушника з НД ТЗІ 1.1-002-99 профілями, актуальними для хмарного середовища. Обґрунтуйте кожне доповнення.
7. У чому різниця між STRIDE-per-element і STRIDE-per-interaction? Для яких елементів розподіленої системи виправданий другий варіант?
8. Які загрози виявляє LINDDUN і принципово не виявляє STRIDE? Наведіть приклад для реєстру персональних даних.
9. Побудуйте фрагмент дерева атак для мети «отримання копії бази даних розподіленого реєстру» і обчисліть ймовірність успіху для вузлів «І» та «АБО».
10. Чим ATT&CK відрізняється від Cyber Kill Chain за структурою та за призначенням? Які обмеження має кожна модель?
11. Як побудувати матрицю покриття захисних заходів і що означає нульове покриття техніки з погляду SOC?
12. Обчисліть ALE для сценарію з $AV = 25$ млн грн, $EF = 0{,}2$, $ARO = 0{,}5$. Визначте ROSI заходу вартістю 1,2 млн грн на рік, який знижує EF до 0,06.
13. Сформулюйте задачу розподілу бюджету безпеки як задачу про рюкзак. Побудуйте приклад вхідних даних, для якого жадібний алгоритм не дає оптимального розв'язку.

14. Які систематичні викривлення експертного оцінювання найнебезпечніші для оцінки ARO і якими процедурами їх зменшують?
15. Яку роль відіграють SBOM і рівні SLSA у зниженні ризиків ланцюга постачання? Який із трьох інцидентів — SolarWinds, Log4Shell, XZ Utils — найгірше піддається пом'якшенню через SBOM і чому?

РОЗДІЛ 9

Криптографічні механізми та інфраструктура відкритих ключів у розподілених системах

Розподілена система за визначенням не має спільного фізичного периметра: її вузли обмінюються повідомленнями через канали, які контролюються третіми сторонами, а дані зберігаються на носіях, доступ до яких адміністративно розділений між різними операторами. За таких умов криптографія перестає бути одним із багатьох механізмів захисту й стає основним засобом, що дозволяє переносити довіру між доменами безпеки. Розділ систематизує криптографічні примітиви, протоколи захищених каналів та інфраструктуру відкритих ключів (PKI) саме в аспекті розподіленості: як узгоджуються ключі між вузлами, що не мають попередньої спільної таємниці; як перевіряється статус сертифіката, коли центр сертифікації недоступний; як керувати ключами, коли жоден адміністратор не має права одноосібно ними розпоряджатися. Матеріал спирається на національні стандарти України (ДСТУ 7624:2014, ДСТУ 7564:2014, ДСТУ 8845:2019, ДСТУ 4145-2002) та на чинні міжнародні специфікації, а також готує до розділів 10 (ідентифікація й керування доступом) і 13 (захист розподілених реєстрів), де криптографічні механізми виступають будівельним матеріалом.

9.1 Роль криптографії в розподілених системах і поняття криптографічного протоколу

Криптографічні механізми забезпечують чотири базові властивості з переліку сервісів безпеки ISO 7498-2 [228]: конфіденційність, цілісність, автентичність джерела та невідмовність. Для розподілених систем принципово важливо, що всі ці властивості криптографія забезпечує *незалежно від довіри до транспортного середовища* — саме тому вона є основою моделі нульової довіри (розділ 12) і дозволяє будувати захищену взаємодію поверх недовіреної мережі, включно з безпроводовими сегментами та каналами супутникового зв'язку.

Не менш важливо чітко окреслити те, чого криптографія *не* забезпечує. Вона не гарантує доступності: зашифрований канал так само вразливий до відмови в обслуговуванні, а втрата ключа перетворює конфіденційність на незворотну втрату даних. Вона не захищає від компрометації кінцевої точки: якщо вузол контролюється зловмисником, він оперує відкритим текстом і легітимними ключами. Вона не приховує метаданих — розмірів, частоти та напряму повідомлень, за якими аналіз трафіку відновлює структу-

ру взаємодії. Нарешті, вона не усуває помилок авторизації: коректно перевірений підпис засвідчує, *хто* підписав, але не те, чи мав він на це право.

Криптографічний протокол — це розподілений алгоритм, у якому дві чи більше сторін виконують послідовність криптографічних перетворень і обміну повідомленнями для досягнення визначеної мети безпеки за наявності активного супротивника [365, 280]. Типові помилки застосування протоколів у розподілених системах повторюються десятиліттями: використання шифрування без автентифікації (класична вразливість до атак на доповнення); повторне використання лічильника (nonce) у режимі GCM, що призводить до розкриття ключа автентифікації; відсутність прив'язки сеансових ключів до ідентичності сторін, що уможливлює атаки з віддзеркаленням і «людина посередині»; перевірка підпису сертифіката без перевірки його статусу відкликання та відповідності імені; використання одного ключа для різних призначень (підпис і шифрування), що руйнує формальні доведення стійкості. Окремий клас становлять помилки реалізації — атаки за побічними каналами, для протидії яким потрібні операції зі сталим часом виконання [298].

9.2 Симетричні примітиви, режими роботи та автентифіковане шифрування

Симетричні примітиви забезпечують основний обсяг криптографічних перетворень у розподілених системах: саме вони захищають масовий трафік і дані у сховищах, тоді як асиметричні механізми використовуються лише для встановлення й підтвердження ключів. **Блокові шифри** перетворюють блоки фіксованої довжини під керуванням ключа; безпечність конструкції визначається стійкістю до диференціального й лінійного криптоаналізу, а також запасом раундів. **Потокові шифри** формують гаму, що додається до відкритого тексту, і дають перевагу за швидкодією на платформах без апаратної підтримки блокових перетворень.

Самі по собі блокові шифри не є засобом шифрування повідомлень — потрібен **режим роботи**. Режими CBC, CTR, OFB забезпечують лише конфіденційність, і їх застосування без окремого коду автентичності є типовою проєктною помилкою. Сучасна практика вимагає **автентифікованого шифрування з асоційованими даними** (AEAD): режим GCM [155], режим CCM, а також конструкція ChaCha20-Poly1305 [298]. AEAD одночасно забезпечує конфіденційність корисного навантаження та цілісність і автентичність як навантаження, так і незашифрованих асоційованих даних (заголовків маршрутизації, ідентифікаторів сеансу). Для розподілених систем критичною є вимога унікальності nonce у межах ключа: за швидкості обміну між вузлами лічильники вичерпуються, тому необхідні або детермінова-

ні схеми нумерації в межах з'єднання, або конструкції з розширеним простором nonce.

Функції гешування забезпечують стиснення повідомлення до значення фіксованої довжини зі стійкістю до знаходження прообразу та колізій. Коди автентичності повідомлень будуються на їх основі: HMAC — як вкладена конструкція з двома викликами геш-функції, KMAC — як нативний режим губчастої конструкції. Геш-функції також є основою функцій вироблення ключів: HKDF реалізує парадигму «видобути й розширити» (extract-then-expand), що дозволяє з одного спільного секрету отримати незалежні ключі для різних напрямів і призначень [255]. Саме ця схема застосована в TLS 1.3 для формування ієрархії секретів рукостискання.

9.3 Національні криптографічні стандарти України

Україна має власний комплект симетричних і асиметричних криптографічних стандартів, розроблених переважно науковою школою Харкова за участю І. Д. Горбенка [5]. Їх застосування є обов'язковим у державних інформаційно-комунікаційних системах і під час надання кваліфікованих електронних довірчих послуг.

ДСТУ 7624:2014 («Калина») [17] — блоковий шифр SPN-структури з розміром блоку 128, 256 або 512 бітів і довжиною ключа 128, 256 або 512 бітів, причому довжина ключа може дорівнювати розміру блоку або вдвічі його перевищувати. Кількість раундів — від 10 до 18 залежно від параметрів. Порівняно з AES «Калина» використовує чотири різні S-блоки, лінійне перетворення на основі MDS-матриці 8×8 над полем $GF(2^8)$ та додавання підключів за модулем 2^{64} поряд із XOR, що ускладнює побудову диференціальних характеристик [310]. Стандарт визначає також режими роботи, зокрема режими з автентифікацією.

ДСТУ 7564:2014 («Купина») [18] — функція гешування, побудована за схемою Даві—Меєра з двома різними перестановками типу AES-подібного SPN, зі значеннями геша 256, 384 і 512 бітів [311]. Конструкція споріднена з Grøstl, використовує ті самі S-блоки, що й «Калина», що дає економію апаратних ресурсів при спільній реалізації. Стандарт визначає також режим коду автентичності повідомлень на базі «Купини».

ДСТУ 8845:2019 («Струмок») [19] — потоковий шифр із ключем 256 або 512 бітів, побудований на основі регістра зсуву над скінченним полем із нелінійним автоматом і використанням S-блоків «Калини». Орієнтований на високошвидкісне шифрування каналів, зокрема магістральних.

ДСТУ 4145-2002 [16] — цифровий підпис на еліптичних кривих над двійковими полями $GF(2^m)$ (m від 163 до 431). Формально близький до схеми ECDSA, але використовує криві над полями характеристики 2 у поліноміальному або оптимальному нормальному базисі й інший спосіб формува-

ння підпису. Саме цей стандарт лежить в основі кваліфікованого електронного підпису в Україні.

Таблиця 9.1 — Національні та міжнародні криптографічні алгоритми

Призначення	Стандарт України	Міжнародний аналог	Ключ / вихід, біти
Блокове шифрування	ДСТУ 7624:2014 «Калина»	AES (FIPS 197)	128/256/512 проти 128/192/256
Гешування	ДСТУ 7564:2014 «Купина»	SHA-2, SHA-3	256/384/512
Потокове шифрування	ДСТУ 8845:2019 «Струмок»	ChaCha20	256/512 проти 256
Цифровий підпис	ДСТУ 4145-2002	ECDSA, EdDSA	$m = 163 \dots 431$

Питання продуктивності в розподілених середовищах є практично значущим. Сучасні процесори містять апаратні інструкції прискорення AES і SHA, тоді як для «Калини» та «Купини» такої підтримки немає, і програмні реалізації поступаються за пропускною здатністю в кілька разів. Це створює архітектурний конфлікт: вимога нормативної відповідності диктує національні алгоритми, а вимога продуктивності міжвузлового обміну — апаратно прискорені міжнародні. Типове проєктне рішення полягає в гібридній схемі: національні алгоритми застосовуються там, де цього вимагає закон (підпис юридично значущих документів, захист державних інформаційних ресурсів), а масовий транспортний трафік захищається стандартизованими AEAD-конструкціями протоколу TLS 1.3, за умови що ключі цього каналу автентифіковано сертифікатами ДСТУ 4145-2002. Напрям подальших досліджень — оптимізація реалізацій «Калини» та «Струмка» з використанням векторних інструкцій і оцінювання їх стійкості до атак за побічними каналами.

9.4 Асиметрична криптографія та узгодження ключів

Асиметричні механізми розв’язують дві задачі, нерозв’язні симетричними засобами в розподіленому середовищі: встановлення спільного ключа між сторонами без попередньої таємниці та невідмовність. RSA ґрунтується на складності факторизації, криптосистеми на еліптичних кривих — на складності дискретного логарифмування в групі точок кривої. Перевага ECC полягає в значно менших розмірах ключів за еквівалентного рівня стійкості, що критично для протоколів із обмеженою довжиною повідомлень і для пристроїв з обмеженими ресурсами.

Оцінювання стійкості зручно виражати через **рівень стійкості** λ — логарифм обчислювальної складності найкращої відомої атаки:

$$\lambda_{\text{sym}} = k, \qquad \lambda_{\text{ECC}} \approx \frac{n}{2}, \qquad \lambda_{\text{RSA}} \approx \frac{1}{\ln 2}\sqrt[3]{\frac{64}{9}\,(b\ln 2)\left(\ln(b\ln 2)\right)^2},$$

де k — довжина симетричного ключа, n — порядок групи точок у бітах, b — довжина модуля RSA у бітах (тож $\ln N \approx b\ln 2$). Третій вираз відповідає складності загального решета числового поля без урахування доданка $o(1)$, тому дає дещо завищені значення (близько 117 бітів для $b = 2048$ і 139 бітів для $b = 3072$); консервативні значення рівнів стійкості, прийняті в настановах NIST, наведено в табл. 9.2 [88].

Таблиця 9.2 — Довжини ключів і рівні стійкості

Рівень λ, біт	Симетричний	ECC	RSA / DH	Постквантовий (FIPS 203/204)
112	3TDEA	224–255	2048	—
128	AES-128, Калина-128	256–383	3072	ML-KEM-512
192	AES-192	384–511	7680	ML-KEM-768
256	AES-256, Калина-256	512+	15360	ML-KEM-1024

Узгодження ключів за протоколом Діффі—Геллмана, зокрема в еліптичній формі (ECDH), дозволяє двом вузлам отримати спільний секрет $Z = d_A Q_B = d_B Q_A$ без його передавання каналом [89]. Використання **ефемерних** ключів (ECDHE), які генеруються для кожного сеансу й знищуються після нього, забезпечує **пряму секретність** (forward secrecy): компрометація довготривалого ключа автентифікації в майбутньому не дозволяє розшифрувати раніше перехоплені сеанси. Для розподілених систем із тривалим життєвим циклом і високою ймовірністю компрометації окремих вузлів пряма секретність є не опцією, а базовою вимогою.

Цифровий підпис забезпечує автентичність і невідмовність: перевіряч може довести третій стороні, що повідомлення підписане власником приватного ключа. Схема EdDSA [241] усуває класичну вразливість ECDSA, пов'язану з повторним використанням або передбачуваністю випадкового параметра, застосовуючи детерміноване формування цього параметра з ключа й повідомлення. Юридична невідмовність, однак, є не криптографічною, а нормативною властивістю: вона потребує доведеного одноосібного контролю підписувача над засобом підпису й довіреної позначки часу.

9.5 Захищені канали: TLS 1.3, mTLS та IPsec

Протокол TLS 1.3 [336] радикально спростив і зміцнив рукостискання порівняно з попередніми версіями: вилучено статичний обмін RSA й усі шифри без AEAD, скорочено кількість циклів обміну до одного, а всі повідомлення після ServerHello шифруються. Клієнт надсилає припущення про групу й ефемерний відкритий ключ уже в першому повідомленні, що дозволяє серверу відразу обчислити спільний секрет і перейти до захищеного обміну (рис. 9.1).

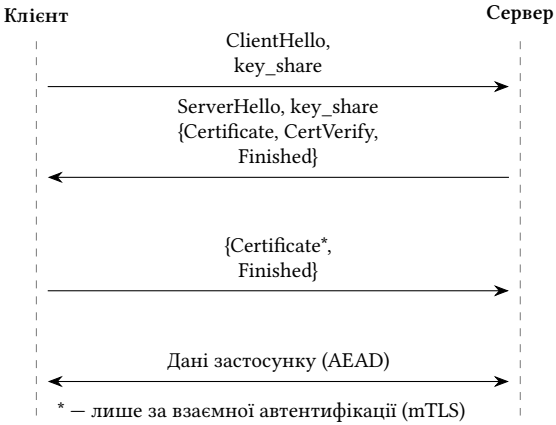


Рис. 9.1 — Спрощена схема рукостискання TLS 1.3 (за [336])

Режим 0-RTT дозволяє клієнтові надіслати дані застосунку разом із першим повідомленням, використовуючи ключ, похідний від попереднього сеансу. Плата за це — втрата захисту від повторного відтворення: перехоплені 0-RTT дані можуть бути надіслані повторно, і протокол цього не виявляє. Тому 0-RTT припустимий лише для ідемпотентних операцій; у розподілених системах, де запит може ініціювати транзакцію в реєстрі, його слід вимикати або обмежувати на рівні шлюзу.

Взаємна автентифікація (mTLS) — обов'язковий елемент захисту міжсервісної взаємодії: кожен вузол пред'являє власний сертифікат, і жоден із них не вважається довіреним лише за фактом перебування в мережі. Складність mTLS у великих системах полягає не в криптографії, а в керуванні життєвим циклом сотень короткоживучих сертифікатів вузлів, що потребує автоматизованого внутрішнього ЦС.

IPsec [247] захищає трафік на мережевому рівні, прозоро для застосунків, і застосовується передусім для з'єднання сегментів мережі (site-to-site)

та захисту інфраструктурного трафіку. Відмінність моделей довіри суттєва: TLS автентифікує *сервіс* за іменем у сертифікаті й будує довіру від публічних або відомчих ЦС, тоді як IPsec автентифікує *вузол* (шлюз) і часто спирається на попередньо розподілені ключі або відомчу PKI. У розподіленій системі ці рівні доповнюють один одного: IPsec захищає інфраструктурний периметр між майданчиками, TLS/mTLS — взаємодію застосунків, і саме останній рівень зберігає захист у разі компрометації мережевого сегмента.

9.6 Інфраструктура відкритих ключів

PKI розв'язує задачу зв'язування відкритого ключа з ідентичністю. Основним об'єктом є **сертифікат** формату X.509, профіль якого для Інтернету визначено RFC 5280 [140]: підписана центром сертифікації структура, що містить відкритий ключ, ім'я суб'єкта, період чинності, призначення ключа, точки розповсюдження інформації про відкликання та інші розширення. Перевірка сертифіката — це побудова й валідація **ланцюжка** до довіреного кореня з контролем підписів, періодів чинності, обмежень імен і політик, а також статусу відкликання кожної ланки.

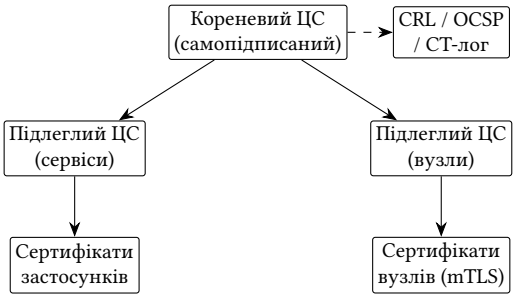


Рис. 9.2 — Ієрархічна модель довіри PKI та служби статусу (за [140, 348])

Розрізняють **ієрархічну** модель довіри (єдиний корінь, суворе підпорядкування, проста побудова ланцюжка) і **мережеву** (кілька рівноправних коренів, пов'язаних крос-сертифікатами). Крос-сертифікація дозволяє двом організаціям взаємно визнати свої ЦС без спільного кореня, але суттєво ускладнює побудову шляху: кількість потенційних шляхів зростає, і валідатор має вміти обирати серед них. Проміжна модель — «мостовий» ЦС, що пов'язує відомчі ієрархії.

Відкликання є найслабшим місцем PKI. Списки відкликаних сертифікатів (CRL) зростають до мегабайтів і оновлюються з затримкою; протокол

OCSP [348] дає відповідь про статус конкретного сертифіката в режимі запиту, але створює залежність доступності сервісу від доступності відповідача та розкриває йому інформацію про те, які ресурси відвідує клієнт. **OCSP stapling** усуває обидві проблеми, переносячи отримання підписаної відповіді на сервер, який додає її до рукостискання. **Прозорість сертифікатів** (Certificate Transparency) [261] доповнює цю картину: усі видані сертифікати публікуються в криптографічно верифікованих журналах на основі дерев Меркла, що дозволяє власникові домену виявити неправомірно виданий сертифікат, навіть якщо ЦС діяв недобросовісно або був скомпрометований.

PKI сама є розподіленою системою і має власні точки відмови: компрометація кореневого ключа знецінює всю ієрархію; недоступність OCSP-відповідача або репозиторію CRL блокує перевірку; неузгодженість годинників вузлів спричиняє хибне відхилення чинних сертифікатів; помилка в процедурі перевірки заявника призводить до видачі сертифіката зловмиснику. Тому проєктування PKI — це передусім проєктування відмовостійкості й процедур, а не вибір алгоритмів. Життєвий цикл сертифіката (генерація ключової пари, заявка, перевірка, видача, публікація, використання, поновлення, відкликання, архівування) має бути автоматизований: у системах із сотнями вузлів ручні процедури неминуче призводять до простоїв через прострочення.

9.7 Електронні довірчі послуги в Україні

Закон України «Про електронну ідентифікацію та електронні довірчі послуги» [44] встановлює правові засади надання ЕДП і визначає **кваліфікований електронний підпис** (КЕП) як підпис, створений із використанням засобу кваліфікованого електронного підпису й кваліфікованого сертифіката. КЕП має презумпцію рівнозначності власноручному підпису. Аналогом для юридичних осіб є **кваліфікована електронна печатка**. Криптографічною основою КЕП в Україні є ДСТУ 4145-2002 разом із «Купиною» [16, 18].

Систему утворюють кваліфіковані надавачі ЕДП, відомості про яких публікуються в **Довірчому списку**, що формується Центральним засвідчувальним органом [66]; вимоги до надавачів і порядок електронної ідентифікації визначено постановою Кабінету Міністрів України № 764 [10], а порядок використання ЕДП в органах державної влади — постановою № 798 [50]. **Кваліфікована електронна позначка часу** [73] засвідчує існування даних у визначений момент і є обов'язковою для довготривалого зберігання підписаних документів: без неї після завершення строку дії сертифіката неможливо довести, що підпис створено в період його чинності.

Українська модель побудована як наближення до європейської: Регламент (ЄС) № 910/2014 (eIDAS) [333] визначає аналогічні рівні підпису, довір-

чі списки держав-членів і принцип взаємного визнання. Ключова відмінність полягає в переліку допустимих криптографічних алгоритмів: eIDAS спирається на алгоритми, визначені європейськими специфікаціями, тоді як в Україні обов'язковими є національні ДСТУ. Це створює практичну проблему транскордонного визнання: підпис за ДСТУ 4145-2002 технічно не перевіряється типовим європейським застосунком без спеціального модуля. Розв'язання цієї проблеми — через взаємне визнання довірчих списків і підтримку національних алгоритмів у валідаторах — є актуальним завданням у контексті євроінтеграції.

9.8 Керування ключами: HSM, KMS, розділення секрету та порогові схеми

Стійкість системи визначається не алгоритмом, а керуванням ключами [88]. **Апаратний модуль безпеки** (HSM) — спеціалізований пристрій, що генерує й зберігає ключі так, що приватний ключ ніколи не залишає межі криптографічного модуля у відкритому вигляді; вимоги до таких модулів і чотири рівні їх безпеки визначає FIPS 140-3 [305]. Хмарні сервіси KMS переносять цю функцію в сервісну модель, залишаючи відкритим питання довіри до оператора; часткову відповідь дають схеми з ключами, що керуються клієнтом.

Якість ключів визначається джерелом ентропії. Детермінований генератор псевдовипадкових бітів придатний лише за умови ініціалізації достатньою кількістю справжньої ентропії; вимоги до джерел і методи їх валідації визначено в [402]. Для віртуалізованих і контейнерних вузлів це нетривіальна проблема: щойно створений екземпляр може мати мало ентропії, а клоновані образи — однаковий стан генератора, що вже призводило до масової появи однакових ключів.

Політика керування має визначати генерацію, розподіл, зберігання, ротацію, депонування та знищення ключів. **Криптоперіод** обмежує обсяг даних, зашифрованих одним ключем, і час, протягом якого його компрометація завдає шкоди. Депонування ключів шифрування даних необхідне для відновлюваності, але ключі підпису депонувати не можна — це руйнує невідмовність.

У розподіленому середовищі ключова вимога — відсутність одноосібного контролю. Її реалізує **схема розділення секрету Шаміра** [360]. Дилер обирає просте p, секрет $s < p$ і випадкові коефіцієнти $a_1, \dots, a_{t-1}$, будуючи многочлен

$$f(x) = s + a_1 x + a_2 x^2 + \cdots + a_{t-1} x^{t-1} \pmod{p},$$

і роздає n учасникам частки $s_i = f(i)$, $i = 1, \dots, n$. Будь-які t часток відновлюють секрет інтерполяцією Лагранжа:

$$s = f(0) = \sum_{i \in S} s_i \prod_{\substack{j \in S \\ j \neq i}} \frac{j}{j - i} \pmod{p}, \qquad |S| = t,$$

тоді як будь-які $t - 1$ часток не дають про s жодної інформації (досконала стійкість). Схема безпосередньо застосовна до захисту кореневого ключа ЦС: його відновлення потребує присутності кворуму довірених осіб.

Розвитком цієї ідеї є **порогові підписи** та **розподілена генерація ключів** (DKG), де приватний ключ узагалі ніколи не існує цілісно в жодній точці. У пороговій схемі на еліптичній кривій кожен з n учасників володіє часткою d_i такою, що

$$d = \sum_{i \in S} \lambda_i^S d_i, \qquad \lambda_i^S = \prod_{\substack{j \in S \\ j \neq i}} \frac{j}{j - i}, \qquad Q = dG,$$

де Q — спільний відкритий ключ, G — твірна точка. Підпис формується інтерактивним протоколом за участю щонайменше t сторін; компрометація до $t - 1$ вузлів не дозволяє ані підробити підпис, ані відновити d. Для розподілених реєстрів і систем із кількома операторами це дає технічну реалізацію принципу колективного контролю, а також підвищує доступність: відмова окремих вузлів не блокує підписання.

9.9 Криптографія для обчислень над захищеними даними

Класична криптографія захищає дані у стані передавання та зберігання, але не під час обробки. Для розподілених інформаційних ресурсів, які обробляються на недовірених обчислювальних потужностях, розвиваються чотири напрями.

Гомоморфне шифрування дозволяє виконувати операції безпосередньо над шифротекстами так, що результат розшифрування збігається з результатом операції над відкритими текстами. Частково гомоморфні схеми підтримують одну операцію, повністю гомоморфні — довільні обчислення, але ціною уповільнення на кілька порядків, що поки обмежує застосування вузькими сценаріями (приватний пошук, агрегування статистики).

Багатостороннє захищене обчислення (MPC) дозволяє кільком сторонам обчислити функцію від їхніх приватних входів, не розкриваючи входи одна одній. Практичні застосування — спільна аналітика реєстрів різних відомств без об'єднання масивів персональних даних, що узгоджується з принципом мінімізації [328].

Докази з нульовим розголошенням дозволяють довести істинність твердження, не розкриваючи підстав. Неінтерактивні конструкції застосовуються для підтвердження атрибутів особи (наприклад, повноліття) без розкриття самої дати народження та для перевірки коректності обчислень, виконаних недовіреним вузлом.

Довірені середовища виконання (TEE) розв'язують задачу апаратно: обчислення виконуються в ізольованому анклаві, вміст пам'яті якого недоступний навіть операційній системі, а віддалена атестація дозволяє переконатися в цілісності коду. Обмеження TEE суттєві: довіра переноситься на виробника процесора, а низка атак за побічними каналами показала практичну вразливість анклавів. Тому TEE доцільно розглядати як засіб зменшення, а не усунення ризику, і поєднувати з криптографічним захистом.

9.10 Постквантовий перехід і криптоаджилність

Квантовий комп'ютер достатнього масштабу зруйнує криптосистеми, стійкість яких ґрунтується на факторизації й дискретному логарифмуванні (RSA, DH, ECDSA, ДСТУ 4145-2002); симетричні алгоритми та геш-функції втрачають приблизно половину рівня стійкості [95]. Практичну актуальність надає стратегія «зібрати зараз — розшифрувати потім»: перехоплений сьогодні трафік може бути розшифрований через десятиліття, тому дані з тривалим строком конфіденційності перебувають під загрозою вже зараз.

У 2024 р. NIST стандартизував три постквантові механізми: ML-KEM — інкапсуляцію ключів на модульних ґратках [302], ML-DSA — підпис на ґратках [301] і SLH-DSA — підпис на основі геш-функцій [306], а також визначив схеми зі станом для спеціальних застосувань [141]. Рекомендованим підходом перехідного періоду є **гібридні схеми**, у яких спільний секрет обчислюється з класичного й постквантового компонентів одночасно: система залишається стійкою, доки стійкий хоча б один із них. Загальний план міграції [308] передбачає інвентаризацію криптографічних активів (де, який алгоритм, який строк конфіденційності даних), пріоритезацію за критерієм тривалості захисту, заміну спочатку механізмів узгодження ключів, потім підписів.

Криптоаджилність — властивість системи змінювати криптографічні алгоритми без перепроєктування архітектури — стає окремою вимогою до розподілених систем. Вона передбачає узгодження алгоритмів у протоколі замість жорсткого кодування, версіонування форматів із запасом на довші ключі й підписи, абстрагування криптографічних операцій за інтерфейсом та інвентар алгоритмів як частину керування конфігурацією. В Україні постквантовий перехід ускладнюється тим, що національні стандарти підпису потребують власного постквантового наступника; відповідні дослідження

ведуться, і формування національного постквантового стандарту є одним із пріоритетних наукових завдань у сфері криптографічного захисту.

9.11 Кейс: захист обміну між вузлами розподіленого державного реєстру

Розглянемо ілюстративну конфігурацію системи електронної взаємодії державних електронних інформаційних ресурсів, побудованої за федеративною моделлю: кожен володілець ресурсу експлуатує власний шлюз безпеки, а обмін відбувається безпосередньо між шлюзами за єдиними правилами [15]. Криптографічний захист будується у три шари.

Шар каналу. Між шлюзами встановлюється взаємно автентифікований TLS-канал: кожен шлюз має сертифікат вузла, виданий підлеглим ЦС системи, і перевіряє сертифікат контрагента, включно зі статусом відкликання. Використовуються ефемерні ключі ECDHE, режим 0-RTT вимкнено, оскільки запити змінюють стан реєстрів.

Шар повідомлення. Кожне повідомлення підписується кваліфікованим сертифікатом організації-відправника за ДСТУ 4145-2002 і супроводжується кваліфікованою позначкою часу. Це забезпечує невідмовність незалежно від каналу: навіть якщо канал завершено, а шлюз згодом скомпрометовано, факт і час запиту залишаються доказовими. Журнал підписаних повідомлень утворює доказову базу для розслідування інцидентів (розділ 14).

Шар ключів. Ключі шлюзів зберігаються в HSM класу FIPS 140-3 рівня 3 і ротуються за визначеним криптоперіодом; кореневий ключ ЦС системи розділено за схемою Шаміра з порогом $t = 3$ із $n = 5$ носіїв, що зберігаються в різних організаціях, а операції з ним виконуються лише в присутності кворуму.

Типові проблеми експлуатації подібних систем: масові відмови взаємодії через одночасне прострочення сертифікатів вузлів (усунення — автоматизоване поновлення завчасно, з моніторингом строків); блокування обміну через недоступність OCSP-відповідача (усунення — stapling і кешування відповідей із контрольованим часом життя); розбіжність системного часу вузлів, що спричиняє відхилення позначок часу (усунення — автентифікована синхронізація часу). Показово, що всі три проблеми належать не до криптографії, а до її експлуатаційного оточення, — це підтверджує загальне спостереження: у зрілих системах криптографічні механізми відмовляють переважно через помилки керування життєвим циклом.

Висновки до розділу

Криптографія в розподілених системах виконує роль механізму перенесення довіри між доменами, які не мають спільного адміністративного контролю. Вона забезпечує конфіденційність, цілісність, автентичність і невід-

мовність, але принципово не забезпечує доступності, не захищає скомпрометовану кінцеву точку, не приховує метаданих і не замінює авторизації; проєктні рішення мають виходити саме з цього розмежування.

Сучасна практика вимагає автентифікованого шифрування (AEAD) для будь-якого обміну, ефемерного узгодження ключів для забезпечення прямої секретності та взаємної автентифікації вузлів як заміни довірі до мережевого периметра. Україна має власний комплект криптографічних стандартів — «Калина», «Купина», «Струмок» і ДСТУ 4145-2002, — застосування яких обов'язкове для державних ресурсів; практичне проєктування потребує зваженого поєднання нормативної відповідності з вимогами продуктивності міжвузлового обміну.

Інфраструктура відкритих ключів є повноцінною розподіленою системою з власними точками відмови, зосередженими не в алгоритмах, а в процедурах відкликання, доступності служб статусу й автоматизації життєвого циклу сертифікатів. Українська система електронних довірчих послуг структурно узгоджена з eIDAS, але транскордонне визнання потребує підтримки національних алгоритмів у валідаторах.

Керування ключами — визначальний чинник реальної стійкості. Схема розділення секрету Шаміра, порогові підписи й розподілена генерація ключів дають математично обґрунтований засіб усунення одноосібного контролю над критичними ключами, що особливо важливо для багатооператорних розподілених реєстрів. Нарешті, постквантовий перехід перетворює криптоаджилність з бажаної якості на архітектурну вимогу: система, спроєктована сьогодні, має передбачати заміну алгоритмів протягом свого життєвого циклу без перепроєктування.

Питання для самоперевірки

1. Які властивості безпеки забезпечує криптографія в розподілених системах і які принципово не забезпечує? Наведіть приклад системи, де саме друга група властивостей виявилася критичною.
2. Чому шифрування без автентифікації вважається проєктною помилкою? Наведіть механізм атаки.
3. Поясніть вимогу унікальності nonce у режимі GCM. Які наслідки її порушення й як їх уникають у високошвидкісному міжвузловому обміні?
4. Порівняйте структуру алгоритму «Калина» з AES за розміром блоку, довжинами ключів і використаними перетвореннями.
5. У чому полягає відмінність ДСТУ 4145-2002 від ECDSA і чому вона ускладнює транскордонне визнання підпису?

6. Обґрунтуйте, чому ключ ECC завдовжки 256 бітів вважають еквівалентним симетричному ключу 128 бітів.
7. Що таке пряма секретність і за яких умов вона досягається? Чому вона є базовою вимогою для розподілених систем із тривалим життєвим циклом?
8. Опишіть послідовність рукостискання TLS 1.3. Які ризики несе режим 0-RTT і в яких сценаріях він припустимий?
9. Порівняйте моделі довіри TLS та IPsec. Як ці протоколи доповнюють один одного в захисті міжвузлового обміну, зокрема в безпроводових сегментах?
10. Які переваги й недоліки мають CRL, OCSP та OCSP stapling? Яку задачу додатково розв'язує прозорість сертифікатів?
11. Перелічіть точки відмови PKI як розподіленої системи та запропонуйте заходи їх усунення.
12. Побудуйте схему Шаміра з параметрами $t = 3$, $n = 5$ для умовного секрету й покажіть відновлення за трьома частками.
13. Чим порогова схема підпису відрізняється від розділення секрету за Шаміром за рівнем захищеності приватного ключа?
14. Оцініть, які дані вашої предметної області перебувають під загрозою стратегії «зібрати зараз — розшифрувати потім», і складіть чернетку плану криптографічної міграції.
15. Які архітектурні рішення забезпечують криптоаджилність розподіленої системи? Наведіть приклад системи, у якій її брак унеможливив швидку заміну алгоритму.

РОЗДІЛ 10

Ідентифікація, автентифікація та керування доступом у розподілених системах

Керування доступом є тим механізмом, через який абстрактна політика безпеки організації перетворюється на конкретні рішення «дозволити — заборонити», що ухвалюються мільйони разів на добу в кожному вузлі розподіленої системи. У монолітних системах ці рішення приймалися одним монітором звертань; у розподіленому середовищі — десятками незалежних точок примусового виконання політики, розділених мережею, часовими затримками й адміністративними межами. Саме тут виникає центральна для розділу наукова проблема: як забезпечити узгодженість, повноту й підзвітність рішень щодо доступу, коли ані носій ідентичності, ані сховище політик, ані ресурс не перебувають під єдиним контролем. Розділ послідовно розглядає понятійний апарат, механізми й протоколи автентифікації, формальні моделі авторизації, архітектури централізованого й децентралізованого адміністрування, а також українську нормативну і технологічну практику. Матеріал безпосередньо забезпечує програмний результат навчання ПРН 7 і спирається на криптографічні механізми, викладені в розділі 9.

10.1 Понятійний апарат: ідентифікація, автентифікація, авторизація, підзвітність

Термінологічну основу задає RFC 4949 [365] та ISO 7498-2 [228]. **Ідентифікація** — це подання системі ідентифікатора сутності, тобто твердження «я є X». **Автентифікація** — перевірка істинності цього твердження шляхом демонстрації володіння певним автентифікатором. **Авторизація** — визначення множини операцій, які автентифікована (або, у деяких моделях, анонімна) сутність має право виконати над ресурсом. **Підзвітність** (accountability) — здатність однозначно пов'язати виконану дію з конкретною сутністю, що є передумовою аудиту й розслідування інцидентів (розділ 14).

Ці чотири функції часто зливають у побутове поняття «логін», проте для розподілених систем їх розділення є принциповим: автентифікація може відбуватися в одному домені (постачальник ідентичності), авторизація — в іншому (власник ресурсу), а підзвітність вимагає кореляції журналів обох. НД ТЗІ 1.1-002-99 [31] і НД ТЗІ 2.5-004-99 [33] формалізують ці функції як окремі *послуги безпеки* — ідентифікації та автентифікації (НИ), достовірного каналу (НК), розмежування доступу (КД, КА), реєстрації (НР).

Цифрова ідентичність — це сукупність *атрибутів*, які в конкретному контексті достатньо однозначно описують сутність. Сутністю може бути людина, організація, пристрій, програмний робочий процес (workload) або сервіс. **Облікові дані** (credentials) — об'єкт, що зв'язує ідентифікатор з автентифікатором (сертифікат X.509 [140], запис у каталозі, посвідчення).

Життєвий цикл ідентичності описують моделлю **JML** (joiner — mover — leaver): створення облікового запису й первинне надання прав; зміна ролі, підрозділу чи повноважень; припинення доступу. Кожен перехід — джерело специфічних ризиків: неповне видалення прав при переміщенні породжує **розростання привілеїв** (privilege creep), а незакритий запис звільненого працівника — **сирітський обліковий запис** (orphaned account), який є одним з найчастіше експлуатованих векторів первинного доступу за класифікацією MITRE ATT&CK (техніка T1078 «Valid Accounts») [288].

10.2 Автентифікація: фактори, рівні достовірності, стійкі до фішингу методи

Класичну таксономію факторів автентифікації (знання, володіння, невід'ємна характеристика) сучасні настанови доповнюють вимогами до *якості реалізації*. NIST SP 800-63 у редакції 2025 року (SP 800-63-4, що замінила редакцію 2017 року [192]) [396, 397] розділяє три незалежні шкали достовірності:

- **IAL** (Identity Assurance Level) — рівень достовірності первинної перевірки особи під час реєстрації (IAL1–IAL3);
- **AAL** (Authenticator Assurance Level) — рівень стійкості процесу автентифікації (AAL1–AAL3);
- **FAL** (Federation Assurance Level) — рівень захищеності передавання тверджень між постачальником ідентичності та довірчою стороною (FAL1–FAL3).

Розділення шкал має практичне значення: система може вимагати високої AAL3 (апаратний криптографічний автентифікатор) за помірної IAL1, і навпаки. Помилкою проєктування є «склеювання» рівнів у єдиний показник «сили автентифікації».

Багатофакторна автентифікація (БФА) знижує ризик компрометації, але не всі її реалізації рівноцінні. Одноразові коди, надіслані SMS або згенеровані TOTP-застосунком, залишаються вразливими до реального фішингу з проксіюванням (adversary-in-the-middle) та до підміни SIM-картки. **Стійкими до фішингу** вважають методи, у яких автентифікатор криптографічно прив'язує відповідь до походження (origin) довірчої сторони й не передає жодного секрету, придатного для відтворення. Такими є FIDO2/WebAuthn [113] з апаратними ключами або платформними автенти-

фікаторами, а також автентифікація на основі сертифікатів у режимі mTLS. Ключова властивість WebAuthn — пара ключів генерується для конкретного `rpId`, тому підроблений домен не може отримати валідний підпис.

Оцінюючи парольні механізми, слід виходити з ентропії пароля. Для пароля довжиною L символів, обраних рівноймовірно з алфавіту потужністю N, ентропія становить

$$H = L \log_2 N \quad [\text{біт}], \tag{10.1}$$

а очікувана кількість спроб при повному переборі — 2^{H-1}. Однак реальні паролі, обрані людиною, мають ентропію, значно нижчу за цю верхню межу, тому сучасні рекомендації [396] відмовляються від примусової композиційної складності й періодичної зміни паролів на користь збільшення мінімальної довжини, перевірки за списками скомпрометованих паролів та обмеження швидкості спроб. Якщо зловмисник здійснює v спроб за секунду, а система обмежує їх до v', то час зламу зростає у v/v' разів — це найдешевший захід, що дає найбільший приріст стійкості.

Біометрія в розподілених системах має принципові обмеження: біометричні ознаки не є секретом, їх неможливо відкликати після компрометації, а показники FAR/FRR залежать від умов зчитування. Тому NIST розглядає біометрію лише як фактор, що *доповнює* володіння пристроєм, і лише за наявності перевірки живості та захищеного каналу від сенсора. Обробка біометричних даних додатково підпадає під ст. 9 GDPR [328] та Закон України «Про захист персональних даних» [53] як особлива категорія даних.

Окремої уваги потребує автентифікація машин і сервісів. У мікросервісних середовищах кількість не-людських ідентичностей на порядок перевищує кількість користувацьких. Практика вбудовування довготривалих статичних секретів у конфігурацію є основним джерелом витоків. Альтернативою є **workload identity**: специфікація SPIFFE [381] визначає універсальний ідентифікатор `spiffe://довіра/шлях` та короткоживучі посвідчення SVID (X.509 або JWT), які видає агент SPIRE після *атестації* робочого процесу за властивостями платформи (вузол, простір імен, службовий обліковий запис). Тим самим статичний секрет замінюється на процедуру, що спирається на властивості середовища виконання.

10.3 Протоколи автентифікації в розподілених середовищах

10.3.1 Kerberos, каталоги та AAA-протоколи

Kerberos V5 [297] лишається основою автентифікації в корпоративних доменах. Протокол реалізує автентифікацію через довірену третю сторону на симетричній криптографії: центр видачі ключів (KDC) у складі сервера автентифікації (AS) і сервера видачі квитків (TGS) видає *квиток на отримання*

квитків (TGT), а потім — сервісні квитки. Властивості протоколу: взаємна автентифікація, відсутність передавання пароля мережею, наскрізний єдиний вхід у межах області (realm), можливість крос-областевої довіри.

Разом з тим Kerberos має відомі слабкі місця, які активно експлуатуються: *Kerberoasting* (офлайновий підбір пароля службового облікового запису за сервісним квитком, зашифрованим на його ключі), *AS-REP roasting* для облікових записів без попередньої автентифікації, атаки «золотого» та «срібного» квитка при компрометації ключа `krbtgt` або сервісного облікового запису, а також залежність від синхронізації часу. Компрометація KDC означає повну компрометацію області — це класичний приклад єдиної точки довіри, що суперечить принципам архітектури нульової довіри (розділ 12) [342].

LDAP [359] виконує роль протоколу доступу до каталогу ідентичностей; у складі Active Directory він поєднується з Kerberos. Слід розрізняти LDAP як *транспорт* довідкових запитів і LDAP bind як *механізм* автентифікації: простий bind передає пароль і без TLS є неприйнятним. RADIUS [337] історично забезпечує AAA для мережевого доступу, зокрема для 802.1X у бездротових сегментах (детально — у розділі 11); його обмеження — слабкий захист атрибутів застарілим механізмом на основі MD5, що спонукає до застосування RADIUS поверх TLS. Diameter [169] усуває ці недоліки, вимагаючи TLS/DTLS та підтримуючи однорангову модель, і застосовується переважно в мережах мобільного зв'язку.

10.3.2 Федеративні протоколи: SAML, OAuth 2.0, OpenID Connect

SAML 2.0 [111] побудовано на обміні XML-твердженнями (assertions) між постачальником ідентичності (IdP) та постачальником послуг (SP) із підписом XML-DSig. Це зріла технологія міжорганізаційного єдиного входу, поширена в академічних федераціях та державних системах, проте важка для мобільних клієнтів.

Принципово важливо розрізняти призначення OAuth 2.0 та OpenID Connect. OAuth 2.0 [194] є фреймворком *делегованої авторизації*: він дозволяє клієнтському застосунку отримати обмежений доступ до ресурсу від імені власника ресурсу, не отримуючи його облікових даних. OAuth 2.0 сам по собі *не є* протоколом автентифікації користувача. OpenID Connect [347] додає над ним шар ідентичності: `id_token` у форматі JWT, кінцеву точку `userinfo` та стандартизовані твердження. Змішування цих рівнів — поширена архітектурна помилка, що призводить до вразливостей типу підміни токена.

Сучасна безпечна практика зафіксована в BCP 240 [269]: обов'язкове застосування PKCE навіть для конфіденційних клієнтів, точне (а не шаблонне) звіряння `redirect_uri`, відмова від неявного потоку (implicit) та потоку

з паролем власника ресурсу, застосування токенів, прив'язаних до відправника (sender-constrained), зокрема через mTLS [110].

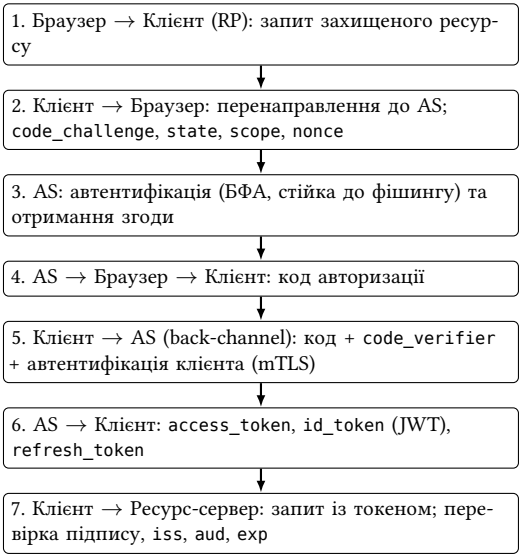


Рис. 10.1 — Потік Authorization Code + PKCE в OAuth 2.0/OIDC (за [194, 347, 269])

10.3.3 JWT і типові помилки перевірки

JWT [240] став де-факто форматом передавання тверджень. Практика показує стійкий набір помилок реалізації, кожна з яких зводить нанівець криптографічний захист:

1. прийняття заголовка `alg` зі значенням `none` або довіра до `alg`, зазначеного самим токеном, замість алгоритму, зафіксованого політикою;
2. сплутування алгоритмів (RS256 → HS256), коли відкритий ключ використовується як секрет HMAC;
3. довіра до посилання `jku`/`x5u` на зовнішнє джерело ключів без обмеження переліку допустимих джерел;
4. відсутність перевірки `aud` (токен, виданий для одного сервісу, приймається іншим) та `iss`;
5. ігнорування `exp`/`nbf` або надмірний строк життя токена;
6. відсутність механізму відкликання: JWT є самодостатнім, тому дострокове припинення прав вимагає або короткого строку життя, або звернення до кінцевої точки інтроспекції.

Таблиця 10.1 — Порівняння протоколів автентифікації та федерації

Протокол	Крипто-основа	Призначення й сфера	Основні ризики
Kerberos	симетрична	SSO в межах домену/області	компрометація KDC, Kerberoasting, час
LDAP	TLS + bind	доступ до каталогу, перевірка пароля	простий bind без TLS, ін'єкції фільтрів
RADIUS	спільний секрет	AAA мережевого доступу, 802.1X	слабкий захист атрибутів, потреба в RadSec
SAML 2.0	XML-DSig	міжорганізаційний SSO для веб	складність XML, обхід підпису, XSW
OAuth 2.0	TLS + токени	делегована авторизація	підміна `redirect_uri`, витік токена
OIDC	JWT/JWS	федеративна автентифікація	помилки перевірки `id_token`
mTLS	X.509	автентифікація сервісів, proof-of-possession	керування життєвим циклом сертифікатів
SPIFFE	X.509/JWT	ідентичність робочих процесів	довіра до атестації платформи

10.4 Моделі керування доступом та їх формалізація

10.4.1 DAC, MAC, RBAC

Дискреційне керування доступом (DAC) залишає рішення власникові об'єкта; формально описується матрицею доступу Лемпсона. Його вада — нетранзитивність контролю: власник може передати права далі, тому політика не є системно керованою. **Мандатне керування доступом** (MAC) прив'язує рішення до міток конфіденційності та формальних правил (модель Белла–ЛаПадули для конфіденційності, Біби — для цілісності, розділ 7); мандатний принцип реалізують, зокрема, послуги адміністративної конфіденційності (КА) й адміністративної цілісності (ЦА), що входять до функціональних профілів захищеності НД ТЗІ 2.5-005-99 [32] для систем, які обробляють інформацію з обмеженим доступом.

Рольова модель (RBAC), стандартизована як INCITS 359 [221, 170], вводить проміжний рівень абстракції — роль. Базову модель формалізуємо як кортеж

$$\mathcal{R} = \langle U, R, P, S, UA, PA \rangle, \quad UA \subseteq U \times R, \quad PA \subseteq P \times R, \tag{10.2}$$

де U — користувачі, R — ролі, P — дозволи (пари «операція—об'єкт»), S — сеанси. Множина дозволів користувача u визначається як

$$\mathrm{perms}(u) = \bigcup_{r\,:\,(u,r)\in UA} \{\, p \mid (p,r) \in PA \,\}. \tag{10.3}$$

Ієрархія ролей задається частковим порядком $RH \subseteq R \times R$: якщо $r_1 \succeq r_2$, то r_1 успадковує всі дозволи r_2. Розділення обов'язків (SoD) виражається обмеженнями на UA: для взаємно виключних наборів ролей $RS \subseteq R$ і порогу k вимагається $|\{r \in RS : (u,r) \in UA\}| < k$ (статичне SoD) або аналогічна умова на активовані в сеансі ролі (динамічне SoD).

Кількісний ефект RBAC оцінюється порівнянням числа адміністративних призначень. За безпосереднього призначення дозволів потрібно до $|U| \cdot |P|$ зв'язків, тоді як за рольового — $|UA| + |PA| \approx |U| \cdot \bar{a} + |R| \cdot \bar{b}$, де $\bar{a}$ — середня кількість ролей на користувача, $\bar{b}$ — середня кількість дозволів на роль. Для $|U| = 5000$, $|P| = 2000$, $|R| = 120$, $\bar{a} = 3$, $\bar{b} = 25$ маємо $15{,}0 \cdot 10^3 + 3{,}0 \cdot 10^3 = 1{,}8 \cdot 10^4$ проти $1{,}0 \cdot 10^7$ — скорочення обсягу адміністрування більш ніж на два порядки. Це і є кількісне обґрунтування рольового підходу.



Рис. 10.2 — Ієрархія ролей RBAC з обмеженням розділення обов'язків

10.4.2 ABAC, ReBAC, PBAC і контроль з урахуванням ризику

Атрибутивна модель (ABAC) [203] узагальнює попередні: рішення є значенням функції

$$d = f(A_S, A_O, A_A, A_E) \in \{\textit{permit}, \textit{deny}, \textit{indeterminate}\}, \tag{10.4}$$

де A_S — атрибути суб'єкта, A_O — об'єкта, A_A — дії, A_E — середовища (час, місце, стан пристрою, рівень загрози). ABAC забезпечує тонку деталізацію й динамічність, але ускладнює аналіз: задача перевірки «хто має доступ до об'єкта o» стає обчислювально складною, а політики важко піддаються ручному аудиту.

Реляційна модель (ReBAC) визначає доступ через граф відношень між сутностями; рішення — це перевірка досяжності у графі. Промисловим орієнтиром є система Zanzibar [321], що зберігає трильйони кортежів відношень і забезпечує причинну узгодженість рішень через мітки *zookie*, розв'язуючи характерну для розподілених систем проблему «нового ворога» (new enemy problem), коли зміну прав ще не поширено, а зміну вмісту — уже.

Політико-орієнтований підхід (PBAC), або policy-as-code, виносить логіку рішень у декларативні політики, що зберігаються, версіонуються й тестуються як програмний код. Найпоширенішими є мова Rego в складі Open Policy Agent [315] та мова Cedar. Це дає змогу застосовувати до політик практики DevSecOps (розділ 17): статичний аналіз, модульні тести, канаркові розгортання.

Контроль доступу з урахуванням ризику (risk-adaptive, RAdAC; у термінології галузевих аналітиків — CARTA) робить рішення функцією неперервно оцінюваного ризику сеансу. Практичну реалізацію можна описати адитивною згорткою

$$\rho = \sum_{i=1}^{n} w_i x_i, \qquad d = \begin{cases} \textit{permit}, & \rho < \theta_1, \\ \textit{step-up}, & \theta_1 \le \rho < \theta_2, \\ \textit{deny}, & \rho \ge \theta_2, \end{cases} \tag{10.5}$$

де x_i — нормовані показники (незвичне місцеперебування, невідповідність пристрою політиці, час доби, репутація IP, аномальність поведінки), w_i — вагові коефіцієнти. Науковою проблемою залишається обґрунтоване калібрування w_i, θ_1, θ_2: надто низькі пороги породжують хибні спрацювання й блокування легітимної діяльності, а надто високі — пропуски атак і формальний характер механізму.

Таблиця 10.2 — Порівняння моделей керування доступом

Модель	Носій рішення	Переваги	Обмеження
DAC	власник об'єкта	простота, гнучкість	неконтрольоване поширення прав
MAC	мітки та правила системи	формальна доказовість, відповідність НД ТЗІ	жорсткість, низька придатність до бізнес-процесів
RBAC	роль	керованість, аудитованість, SoD	«вибух ролей», статичність
ABAC	атрибути	тонка деталізація, динамічність	складність аналізу й аудиту політик
ReBAC	граф відношень	природність для спільного доступу до даних	потреба у спеціалізованому сховищі, узгодженість
PBAC	політика-як-код	версіонування, тестування, переносність	потреба у кваліфікації розробників політик
RAdAC	оцінка ризику	адаптивність, реакція на аномалії	калібрування порогів, хибні спрацювання

10.5 Централізоване й децентралізоване адміністрування доступом

Архітектура систем керування ідентичністю та доступом (IAM) традиційно описується чотирма логічними компонентами, запозиченими з моделі монітора звертань: PEP (точка примусового виконання), PDP (точка ухвалення рішення), PAP (точка адміністрування політик) і PIP (точка отримання інформації про атрибути). Розподіленість системи означає, що PEP розмножуються, тоді як PDP і PAP можуть бути централізованими або також розподіленими — і саме цей вибір становить сутність дилеми ПРН 7.

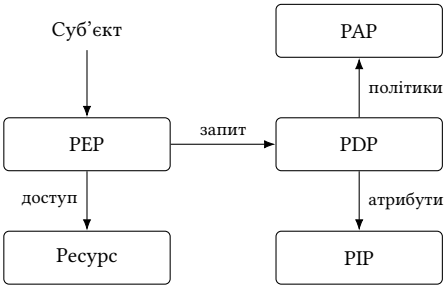


Рис. 10.3 — Логічні компоненти системи керування доступом (за [342, 203])

Централізоване адміністрування передбачає єдиний каталог ідентичностей, єдине сховище політик і єдину точку ухвалення рішень. Переваги: узгодженість політики, повнота аудиту, простота рецертифікації, швидке відкликання прав. Недоліки: єдина точка відмови й компрометації, мережева залежність (недосяжність PDP паралізує систему), масштабованість, а також невідповідність адміністративній структурі багатовідомчих систем.

Децентралізоване адміністрування делегує ухвалення рішень і адміністрування власникам доменів. Це підвищує автономність і живучість — критично важливу властивість для української інфраструктури в умовах воєнного стану, коли зв'язність між сегментами може порушуватися. Плата — дрейф політик, розбіжності в трактуванні ролей, неповний зведений аудит.

Федерація ідентичності є компромісом: автентифікація лишається в домені суб'єкта, авторизація — у домені ресурсу, а між ними встановлюється **коло довіри** (circle of trust) — формалізований набір угод, метаданих і криптографічних довірчих зв'язків [397]. **Брокер ідентичності** (identity broker) зменшує кількість двосторонніх зв'язків з $O(n^2)$ до $O(n)$, нормалізує твердження й протоколи, однак сам стає критичним активом і потенційним місцем концентрації ризику.

Гібридна схема, яку доцільно рекомендувати для великих відомчих систем, полягає в централізації *джерела істини* про ідентичності та *політик верхнього рівня* за одночасної децентралізації примусового виконання: політики розповсюджуються як підписані артефакти, а локальні PDP здатні працювати автономно з останнім відомим станом протягом визначеного інтервалу. Це переносить у сферу керування доступом добре відомий компроміс теореми CAP (розділ 1) [251]: за поділу мережі система обирає між доступністю (дозволяти доступ за застарілою політикою) та узгодженістю (відмовляти). Безпечним усталеним значенням є «fail closed» для операцій високого ризику й «fail open з посиленим журналюванням» — для операцій, критичних до неперервності.

10.6 Керування привілейованим доступом

Привілейовані облікові записи є основною метою зловмисника. **PAM** (Privileged Access Management) охоплює: сховище й ротацію привілейованих облікових даних; **брокер сесій**, через який адміністратор підключається до цільової системи, не отримуючи пароля; запис сесій; контроль команд. Ключовим принципом є **just-in-time доступ**: постійні привілеї замінюються тимчасовим підвищенням прав на визначений інтервал за наявності обґрунтування й, за потреби, схвалення другою особою.

Формально ефект JIT-підходу оцінюється скороченням сукупного «вікна привілеїв»: якщо m адміністраторів мають постійні права, сумарна експозиція за період T дорівнює $m \cdot T$; за JIT-моделі вона зменшується до $\sum_j \tau_j$, де τ_j — тривалості фактичних сеансів. За типових значень (10 адміністраторів, кожен має 4 сеанси на тиждень по 2 години: 80 проти $10 \cdot 168 = 1680$ людино-годин експозиції на тиждень) скорочення перевищує 95 %.

Керування секретами (ключі API, паролі сервісів, сертифікати) підпорядковується тим самим принципам: динамічна генерація короткоживучих облікових даних замість статичних, шифрування сховища з використанням апаратних модулів (FIPS 140-3 [305]), повний аудит звертань. Заборона на зберігання секретів у репозиторіях коду й образах контейнерів [376] має підкріплюватися автоматизованим скануванням.

Протидія розростанню привілеїв потребує поєднання технічних і організаційних заходів: автоматичного відкликання прав, наданих у зв'язку з попередньою посадою, під час події «mover»; вимоги строку дії для кожного призначення; регулярної рецертифікації (підрозділ 10.10). Відповідні вимоги містять заходи 5 і 6 CIS Controls [129] та заходи 5.15–5.18 ДСТУ EN ISO/IEC 27002:2023 [21].

10.7 Керування доступом до хмарних і мікросервісних ресурсів

У хмарних середовищах політика доступу є декларативним документом, який оцінюється службою провайдера. Особливості, що вимагають окремої уваги: різна семантика поєднання дозвільних і заборонних тверджень, успадкування політик за ієрархією організації, а також механізми *тимчасових облікових даних* — прийняття ролі (role assumption) з видачею короткоживучого токена. Останнє слід вважати основним засобом уникнення статичних ключів доступу [358, 233].

Найпоширенішим класом помилок є надмірно широкі політики (символ узагальнення в полі дій або ресурсів) та можливість **ескалації через передавання ролі**, коли право змінювати політики або призначати ролі фактично еквівалентне правам адміністратора. Тому аналіз політик має проводитися не за текстом, а за *обчисленою досяжністю* привілеїв — це окремий напрям досліджень (формальна верифікація хмарних політик).

У мікросервісних архітектурах авторизація виноситься на рівень сервісної сітки: sidecar-проксі виконує роль PEP, перевіряючи mTLS-ідентичність виклику (SPIFFE-ідентифікатор) та звертаючись до локального PDP. Це забезпечує єдину точку примусу без модифікації коду сервісів і дає змогу реалізувати мікросегментацію (розділ 12). Окремою задачею є **делегування**: коли сервіс A викликає сервіс B від імені користувача, потрібен потік «on-behalf-of» з обміном токена, який зберігає як ідентичність кори-

стувача, так і ідентичність сервісу-посередника; інакше втрачається підзвітність, а привілеї сервісу «поглинають» обмеження користувача (проблема заплутаного заступника, confused deputy).

10.8 Децентралізована ідентичність: DID та верифіковані посвідчення

Модель **самокерованої ідентичності** (SSI) пропонує перенести контроль над ідентичністю до самого суб'єкта. Її технічну основу становлять **децентралізовані ідентифікатори** (DID) [382] — ідентифікатори виду `did:метод:значення`, що розв'язуються у DID-документ з відкритими ключами й точками доступу, — та **верифіковані посвідчення** (W3C VC) [383], що утворюють трикутник довіри «емітент — утримувач — перевіряч». Криптографічні механізми селективного розкриття дають змогу довести окремий атрибут (наприклад, повноліття) без розкриття решти даних, що узгоджується з принципом мінімізації даних GDPR [328].

Критичний аналіз має бути тверезим. По-перше, децентралізується *ідентифікатор*, але не *довіра*: перевіряч усе одно мусить довіряти емітентові, тобто реєстр довірених емітентів відтворює централізацію на іншому рівні. По-друге, відповідальність за збереження ключів переноситься на суб'єкта, а надійне відновлення після втрати пристрою залишається невирішеною практичною проблемою. По-третє, відкликання посвідчень у децентралізованій моделі є нетривіальним і потенційно порушує приватність. По-четверте, регуляторна база лише формується: європейська рамка цифрової ідентичності (eIDAS 2) [330] впроваджує гаманець цифрової ідентичності ЄС, задаючи орієнтир і для України в контексті євроінтеграції. Отже, SSI слід розглядати як перспективний напрям, що потребує подальших досліджень щодо відкликання, відновлення й правових наслідків, а не як готову заміну федеративним схемам.

10.9 Українська практика електронної ідентифікації

Правовою основою є Закон України «Про електронну ідентифікацію та електронні довірчі послуги» (до перейменування — «Про електронні довірчі послуги») [44], який визначає електронну ідентифікацію, схеми електронної ідентифікації та рівні довіри до засобів (низький, середній, високий), а також статус кваліфікованого електронного підпису (КЕП). КЕП, створений засобом кваліфікованого електронного підпису, є одночасно засобом автентифікації високого рівня довіри, оскільки спирається на апаратно захищений особистий ключ і кваліфікований сертифікат за ДСТУ 4145-2002 [16].

Інтегрована система електронної ідентифікації (ICEI, id.gov.ua) виконує роль національного брокера ідентичності: вона з'єднує постачальників

електронної ідентифікації (кваліфіковані надавачі електронних довірчих послуг, банки) з надавачами електронних послуг, звільняючи останніх від потреби інтегруватися з кожним постачальником окремо. Положення про ІСЕІ затверджено постановою Кабінету Міністрів України [47]. Архітектурно це класичне коло довіри з брокером, розглянуте в підрозділі 10.5.

Система BankID Національного банку України [49] реалізує електронну ідентифікацію через банки-ідентифікатори, використовуючи вже проведену ними процедуру належної перевірки клієнта. У термінах NIST це відповідає високому IAL за помірного AAL, що ілюструє практичну цінність розділення шкал достовірності. **«Дія.Підпис»** доповнює екосистему мобільним засобом підпису й автентифікації з біометричною перевіркою на пристрої.

Вимоги до реалізації послуг ідентифікації та автентифікації в захищених системах визначає НД ТЗІ 2.5-004-99 [33]: послуга «ідентифікація та автентифікація» (НИ-1 — НИ-3) вимагає, щоб комплекс засобів захисту до початку будь-якої взаємодії однозначно ідентифікував користувача й перевірив його автентичність, зберігав атрибути автентифікації захищено та забезпечував послугу «достовірний канал» (НК). Разом із послугами розмежування доступу (КД, КА) і реєстрації (НР) вони формують функціональний профіль захищеності системи за НД ТЗІ 2.5-005-99 [32]. Практичне узгодження цих вимог із сучасними федеративними механізмами (OIDC, WebAuthn) є актуальною прикладною задачею, оскільки нормативні документи 1999 року не оперують поняттями федерації, і відповідність доводиться обґрунтовувати через еквівалентність функцій.

10.10 Аудит прав доступу та аналітика ідентичності

Рецертифікація доступу (access review) — періодична процедура підтвердження власником ресурсу або керівником підрозділу актуальності наданих прав. Її ефективність визначається не частотою, а якістю подання: рецензент має бачити не технічні ідентифікатори дозволів, а бізнес-зрозумілий опис і ознаки ризику (незвичність права для посади, давність останнього використання, конфлікт SoD).

Виявлення надлишкових прав спирається на зіставлення *наданих* і *фактично використаних* привілеїв. Кількісною мірою є коефіцієнт надлишковості

$$\kappa(u) = 1 - \frac{|P_{\text{use}}(u)|}{|P_{\text{grant}}(u)|}, \tag{10.6}$$

де $P_{\text{use}}(u)$ — множина дозволів, використаних суб'єктом за спостережний період. Значення κ, близькі до одиниці, вказують на кандидатів для скорочення прав; систематичне зниження середнього κ по організації є ви-

мірюваним показником зрілості керування доступом і придатне як метрика для СУІБ за ДСТУ EN ISO/IEC 27001:2023 [20].

Аналітика ідентичності застосовує методи виявлення аномалій до подій автентифікації й авторизації: рольова кластеризація (role mining) для побудови обґрунтованих ролей із фактичних призначень, виявлення відхилень від однорангової групи (peer group analysis), кореляція з подіями SIEM (розділ 14). Дослідницьким напрямом залишається поєднання розвідки ідентичності з графовим аналізом шляхів атак: обчислення досяжності привілеїв у графі «користувач — роль — ресурс — обліковий запис» дає змогу виявляти неочевидні ланцюги ескалації, які не видно з жодної окремої політики.

10.11 Кейс: схема керування доступом для розподіленої відомчої ІКС

Розглянемо відомчу інформаційно-комунікаційну систему з центральним апаратом і 25 територіальними підрозділами, 6 тис. користувачів, підсистемами документообігу, галузевого реєстру й аналітики; частина сервісів розміщена у хмарі, частина — у власному центрі оброблення даних; підрозділи мають нестабільну зв'язність. Система обробляє персональні дані та службову інформацію, є об'єктом критичної інфраструктури [55, 22].

Проєктні рішення:

Джерело істини
Кадрова система — єдине авторитетне джерело подій JML; синхронізація до центрального каталогу з автоматичним створенням, зміною та блокуванням записів; сирітські записи виявляються звірянням щодоби.

Автентифікація
AAL3 для адміністраторів і доступу до реєстру (апаратні ключі FIDO2 або КЕП на захищеному носії), AAL2 для решти; для зовнішніх взаємодій — федерація через ICEI та BankID.

Модель доступу
Гібридна RBAC+ABAC: близько 90 ролей, побудованих за посадовою структурою (керованість, SoD), доповнених атрибутивними умовами (територіальна належність, гриф документа, стан пристрою, робочий час).

Адміністрування
Централізовані PAP і каталог; PDP реплікуються в кожному територіальному підрозділі й у хмарному сегменті; політики розповсюджуються як підписані артефакти з версією та строком дії; за втрати зв'язності локальний PDP працює автономно до 72 год з обов'язковим локальним журналюванням і подальшою вивантаженням журналів.

Привілейований доступ
Постійні адміністративні права відсутні; підвищення — через JIT-запит зі схваленням другою особою, сесії проходять через брокер із записом.

Сервіси
Взаємна автентифікація за mTLS з ідентичністю SPIFFE; сервісна сітка виконує роль PEP; делегування — через потік on-behalf-of зі збереженням ідентичності користувача в токені.

Аудит
Щоквартальна рецертифікація прав до реєстру, щорічна — для решти; розрахунок $\kappa(u)$; кореляція подій автентифікації в SIEM; обов'язкове інформування CERT-UA про інциденти [117, 58].

Очікуваний ефект: скорочення сукупного вікна привілеїв, збереження працездатності підрозділів за порушення зв'язності, забезпечення повноти доказової бази для розслідування інцидентів і виконання вимог НД ТЗІ до послуг НИ, НК, КД і НР.

Висновки до розділу

Ідентифікація, автентифікація та керування доступом утворюють механізм, через який політика безпеки набуває виконуваної форми. У розподіленому середовищі ці функції обов'язково розділяються між доменами, тому їх проєктування зводиться до узгодження трьох незалежних вимірів достовірності — IAL, AAL і FAL — та до свідомого вибору місця ухвалення рішень.

Автентифікація рухається від секретів, які можна перехопити, до криптографічних доказів володіння, прив'язаних до походження запиту; стійкі до фішингу методи (FIDO2/WebAuthn, mTLS, КЕП) слід вважати цільовим станом, а одноразові коди — перехідним. Для не-людських ідентичностей еквівалентом є короткоживучі посвідчення, видані за результатами атестації робочого процесу.

Моделі керування доступом утворюють шкалу від керованості до виразності: RBAC дає аудитованість і кількісно обґрунтоване скорочення адміністративних зусиль, ABAC і ReBAC — деталізацію й динамічність ціною складності аналізу, PBAC — інженерну дисципліну роботи з політиками, RAdAC — адаптивність за умови коректного калібрування. На практиці доцільною є гібридизація, а не вибір однієї моделі.

Дилема централізованого й децентралізованого адміністрування не має універсального розв'язку: централізація дає узгодженість і повноту аудиту, децентралізація — живучість і автономність. Гібридна схема з централізованим джерелом істини, підписаними політиками та автономними локальними PDP є практично обґрунтованим компромісом, особливо для української відомчої інфраструктури в умовах можливого порушення зв'язності.

Нарешті, керування доступом не є одноразовим проєктним рішенням: без рецертифікації, аналітики надлишкових прав і суворої дисципліни життєвого циклу ідентичності будь-яка коректно спроєктована модель за кілька років вироджується у сукупність накопичених винятків. Відкритими науковими проблемами залишаються формальна верифікація узгодженості політик у розподіленому середовищі, калібрування ризик-адаптивних механізмів та вирішення питань відкликання й відновлення в моделях децентралізованої ідентичності.

Питання для самоперевірки

1. У чому полягає різниця між ідентифікацією, автентифікацією, авторизацією та підзвітністю? Наведіть приклад системи, у якій ці функції реалізовано в різних адміністративних доменах.
2. Що таке життєвий цикл ідентичності JML і які ризики безпеки пов'язані з кожним його переходом?
3. Поясніть призначення шкал IAL, AAL і FAL. Чому їх недоцільно зводити до єдиного показника?
4. Які властивості роблять метод автентифікації стійким до фішингу? Чому TOTP цією властивістю не володіє?
5. Обчисліть ентропію пароля довжиною 12 символів з алфавіту потужністю 62 та оцініть час повного перебору за швидкості 10^9 спроб на секунду. Як зміниться результат за обмеження до 10 спроб на хвилину?
6. Опишіть обмін повідомленнями в Kerberos V5 та поясніть механізм атак Kerberoasting і «золотого квитка».
7. Чому OAuth 2.0 не є протоколом автентифікації користувача? Що саме додає OpenID Connect?
8. Перелічіть щонайменше п'ять типових помилок перевірки JWT і вкажіть, який захід усуває кожну з них.
9. Наведіть формальне визначення базової моделі RBAC. Як у ній виражається статичне та динамічне розділення обов'язків?
10. Порівняйте ABAC і ReBAC за виразністю, складністю аудиту та придатністю до масштабування. У яких задачах підхід Zanzibar є доцільнішим за атрибутивний?
11. Які переваги й недоліки має централізоване адміністрування доступом? За яких умов слід обирати автономну роботу локальних PDP?
12. Що таке коло довіри у федерації ідентичності і яку роль виконує брокер ідентичності? Як він змінює структуру ризику?

13. Як реалізується just-in-time доступ і як кількісно оцінити ефект від відмови від постійних привілеїв?
14. Проаналізуйте роль ІСЕІ (id.gov.ua) та Системи BankID НБУ в архітектурі національної електронної ідентифікації. Яким рівням IAL і AAL вони відповідають?
15. Як довести відповідність федеративної схеми на основі OIDC вимогам послуги НИ за НД ТЗІ 2.5-004-99?
16. Запропонуйте методику виявлення надлишкових прав із використанням коефіцієнта $\kappa(u)$ та вкажіть обмеження такого підходу.

РОЗДІЛ 11

Захист мережевої інфраструктури розподілених систем, зокрема безпроводових сегментів

Мережа є тим середовищем, що перетворює множину автономних вузлів на розподілену систему, а отже, саме вона стає першою й найбільш доступною для порушника поверхнею атаки. Якщо в розділах 9 і 10 розглянуто криптографічні та ідентифікаційні механізми, які захищають дані й суб'єктів, то цей розділ присвячено захисту самого транспортного середовища: його архітектурі, сегментації, засобам фільтрації, захищеним каналам, безпеці службових протоколів і стійкості до атак на доступність. Окрему й найбільшу увагу приділено безпроводовим сегментам, які в розподілених системах формують найвразливіший периметр, оскільки фізичне середовище передавання тут принципово неконтрольоване. Матеріал розділу є підґрунтям для розділу 12 (архітектура нульової довіри, хмарні та контейнерні середовища) і розділу 14 (моніторинг і виявлення вторгнень).

11.1 Мережева архітектура розподіленої системи як об'єкт захисту

Класична модель захисту спиралася на поняття периметра — замкненої межі, усередині якої трафік вважався довіреним. Для розподіленої системи це припущення хибне за побудовою: вузли розміщено на різних майданчиках, частина сервісів винесена до хмарних провайдерів, користувачі підключаються з некерованих мереж, а міжсайтові канали орендуються в операторів електронних комунікацій. Відбувається **розмивання периметра**: межа довіри перестає збігатися з фізичною межею мережі й переноситься на рівень окремого потоку та окремого запиту [342, 186].

Для систематичного аналізу мережу розподіленої системи доцільно розглядати як сукупність трьох логічно відокремлених площин.

- **Площина даних** (data plane) — пересилання користувацьких пакетів; характеризується високою інтенсивністю та жорсткими вимогами до затримки.
- **Площина керування** (control plane) — протоколи, що формують стан пересилання: маршрутизація (BGP, OSPF), розв'язання імен (DNS), розподіл адрес (DHCP), синхронізація часу (NTP), автентифікація доступу (RADIUS). Компрометація цієї площини дає порушникові контроль над усією площиною даних без потреби зламувати кінцеві вузли.

- **Площина менеджменту** (management plane) — адміністративний доступ до мережевих пристроїв, телеметрія, резервне копіювання конфігурацій, системи керування. Її винесення в окремий, фізично або логічно ізольований контур (out-of-band) є базовою вимогою CIS Controls [129] і НД ТЗІ щодо розмежування функцій адміністрування [31].

Критичними точками архітектури є магістральні й міжсайтові канали та точки взаємодії з провайдерами. Для них характерні специфічні ризики: залежність від одного оператора, спільне використання фізичної інфраструктури, можливість пасивного перехоплення на ділянці «останньої милі», а також ризик відмови каналу внаслідок фізичного пошкодження. Досвід функціонування української мережевої інфраструктури засвідчив, що саме резервування каналів різних операторів і різних середовищ передавання (оптика, радіорелейний зв'язок, супутниковий доступ) є визначальним чинником збереження зв'язності [8].

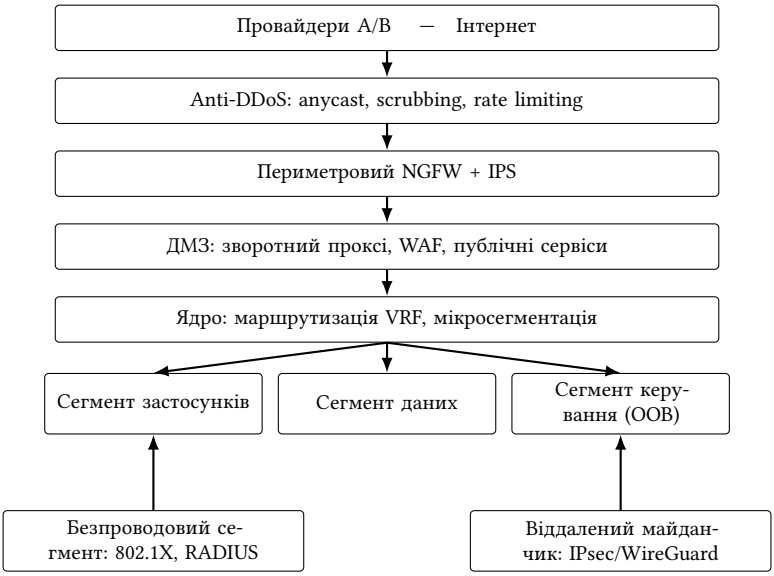


Рис. 11.1 — Еталонна сегментована архітектура розподіленої системи

11.2 Сегментація та мікросегментація

Сегментація — це поділ мережі на зони, між якими трафік проходить лише через контрольовані точки із заданою політикою. Мета — обмеження

бічного переміщення (lateral movement) порушника після компрометації окремого вузла, зменшення області дії інциденту та спрощення доведення відповідності вимогам [129, 21].

Технологічний інструментарій сегментації охоплює: VLAN (IEEE 802.1Q) — поділ на канальному рівні; VRF — незалежні таблиці маршрутизації на одному пристрої, що дає ізоляцію на мережевому рівні; приватні підмережі та трансляцію адрес; зони довіри й **демілітаризовані зони** (ДМЗ), у яких розміщують сервіси, доступні ззовні.

Принципово важливим є розрізнення двох напрямів трафіку. Потоки «**північ–південь**» перетинають периметр (клієнт — сервіс), потоки «**схід–захід**» циркулюють між вузлами всередині системи. У розподілених системах на мікросервісній архітектурі частка трафіку «схід–захід» переважає, а класичний периметровий екран його не бачить узагалі. Саме тому центр ваги переноситься на **мікросегментацію** — застосування політики на рівні окремого робочого навантаження.

Кількісний аргумент на користь сегментації дає оцінка потенційної зв'язності. У пласкій мережі з n вузлів кількість потенційно допустимих односпрямованих пар дорівнює $n(n-1)$. Якщо мережу поділено на k рівнопотужних сегментів із забороною міжсегментного трафіку за замовчуванням, кількість дозволених пар усередині сегментів становить

$$N_k = k \cdot \frac{n}{k}\left(\frac{n}{k} - 1\right) = \frac{n^2}{k} - n,$$

тобто коефіцієнт скорочення поверхні бічного переміщення $\rho = N_k / N_1 \approx 1/k$ при $n \gg k$. Для $n = 2000$ і $k = 20$ кількість пар зменшується з $3{,}998 \cdot 10^6$ до $1{,}98 \cdot 10^5$ — приблизно у 20 разів. Ця оцінка є верхньою межею; реальний виграш залежить від кількості дозволених міжсегментних правил, тому метрику доцільно уточнювати як частку фактично дозволених пар у матриці політики.

11.2.1 Методика проєктування сегментації розподіленої системи

Проєктування сегментації доцільно виконувати як послідовність кроків, узгоджену з процесом створення КСЗІ [34].

1. Інвентаризація активів і побудова матриці потоків: які вузли, з якими вузлами, за якими протоколами і з якою інтенсивністю обмінюються даними.
2. Класифікація активів за критичністю та категорією інформації (зокрема виокремлення персональних даних [53] і ресурсів об'єктів критичної інфраструктури [22]).

3. Формування зон довіри: групування активів з однаковими вимогами до конфіденційності, цілісності й доступності та однаковим профілем загроз.
4. Визначення політики міжзонної взаємодії за принципом «заборонено все, що не дозволено явно», з фіксацією власника кожного правила.
5. Вибір механізму примусового виконання політики (апаратний екран, розподілений екран гіпервізора, мережеві політики оркестратора, ідентифікаційний проксі).
6. Верифікація: моделювання досяжності, тестування на проникнення, безперервний контроль дрейфу конфігурацій.

11.2.2 Програмно визначена сегментація

Статичні VLAN погано масштабуються в динамічних середовищах, де адреси вузлів змінюються щохвилини. **Програмно визначена сегментація** відв'язує політику від топології: правило формулюється в термінах міток (tag, label), ролей або ідентичності робочого навантаження, а контролер транслює його в конкретні списки доступу на всіх точках примусового виконання. Це створює міст до архітектури нульової довіри, де рішення про доступ ухвалюється для кожного з'єднання окремо на підставі ідентичності та контексту [342]; докладніше — у розділі 12.

11.3 Засоби мережевого захисту та їх розміщення в топології

Міжмережеві екрани пройшли шлях від пакетних фільтрів, що ухвалюють рішення за полями заголовка окремого пакета, через екрани зі збереженням стану (stateful), які відстежують стан з'єднань, до NGFW — систем, що поєднують ідентифікацію застосунку незалежно від номера порту, прив'язку правил до облікових записів користувачів, інспекцію TLS і вбудовані модулі запобігання вторгненням [351]. Проксі-сервери та шлюзи прикладного рівня розривають з'єднання, аналізуючи семантику протоколу; **WAF** спеціалізується на захисті вебзастосунків від класів вразливостей, систематизованих у OWASP Top 10 [320].

Системи виявлення й запобігання вторгненням (IDS/IPS) поділяють за розміщенням (мережеві та хостові) і за методом (сигнатурні, аномальні, на основі аналізу протоколів) [352]. Зростання частки зашифрованого трафіку зменшило ефективність сигнатурного аналізу корисного навантаження, що спричинило появу класу **NDR** (Network Detection and Response), який спирається на поведінкові ознаки потоків, метадані сеансів і фінгерпринти криптографічних рукостискань.

Розміщення засобів у розподіленій топології підпорядковується правилу: точка примусового виконання політики має бути якнайближче до захи-

щуваного активу, а точка спостереження — якнайближче до джерела трафіку. Практично це означає багаторівневу схему: периметровий NGFW на стику з провайдером, екран перед ДМЗ, внутрішній екран між зонами, розподілені мікросегментаційні політики на рівні гіпервізора чи вузла кластера, а також сенсори NDR у точках агрегації трафіку кожного майданчика.

11.4 Захищені канали між сегментами

Оскільки міжсайтові й міжхмарні канали проходять через некеровану інфраструктуру, конфіденційність і цілісність трафіку мають забезпечуватися криптографічно, незалежно від довіри до оператора.

IPsec [247] реалізує захист на мережевому рівні: база політик безпеки (SPD) визначає, який трафік захищати, база асоціацій (SAD) зберігає параметри, а протокол ESP забезпечує шифрування й автентифікацію. Ключі узгоджуються протоколом IKEv2. IPsec застосовують у двох режимах розгортання — site-to-site (тунель між шлюзами майданчиків) і remote-access (тунель від клієнта до шлюзу). Настанови щодо проєктування й параметризації подано в NIST SP 800-77 Rev. 1 [90].

WireGuard [151] реалізує принципово простішу модель: фіксований криптонабір (Noise IK, X25519, ChaCha20-Poly1305, BLAKE2s), відсутність узгодження алгоритмів, прив'язка відкритого ключа до дозволених IP-адрес, ядерна реалізація обсягом близько чотирьох тисяч рядків коду. Наслідком є менша поверхня атаки та вища пропускна здатність, платою — відсутність криптографічної гнучкості й обмежені можливості інтеграції з наявними PKI.

TLS-тунелі (зокрема TLS 1.3 [336]) працюють на транспортному рівні, добре проходять крізь трансляцію адрес і фільтри, але захищають лише сеанси застосунків. **MACsec** (IEEE 802.1AE) [219] діє на канальному рівні між суміжними пристроями, забезпечуючи шифрування «від порту до порту» на швидкостях аж до сотень гігабіт за секунду з апаратним прискоренням; він доречний для магістральних ділянок і каналів між приміщеннями в межах об'єкта.

Таблиця 11.1 — Порівняння технологій захищених каналів

Технологія	Рівень	Криптонабір	Сфера застосування	Накладні витрати
IPsec/IKEv2	мережевий	узгоджуваний (AES-GCM, ChaCha20)	site-to-site, remote-access, сумісність із PKI	50–80 байт на пакет
WireGuard	мережевий	фіксований (X25519, ChaCha20-Poly1305)	міжсайтові й адміністративні тунелі	32–60 байт на пакет
TLS-тунель	транспортний	узгоджуваний (TLS 1.3)	прикладні сеанси, обхід фільтрів	20–40 байт + рукостискання
MACsec	канальний	GCM-AES-128/256	магістраль, суміжні пристрої	32–40 байт на кадр

Ефективна пропускна здатність тунелю оцінюється з урахуванням інкапсуляції та втрат:

$$R_{\text{eff}} = R_0 \cdot \frac{L}{L + h} \cdot (1 - p)\,,$$

де R_0 — швидкість каналу, L — корисне навантаження пакета, h — сумарний обсяг службових заголовків тунелю, p — імовірність втрати пакета. Для $R_0 = 1$ Гбіт/с, $L = 1360$ байт, $h = 60$ байт і $p = 0{,}001$ отримуємо $R_{\text{eff}} \approx 956$ Мбіт/с. Сумарна затримка міжсайтового обміну складається з поширення, серіалізації, черг і криптографічного оброблення: $T = \sum_i (d_i + L/R_i + q_i) + 2T_{\text{crypt}}$; на практиці саме доданок q_i (черги в перевантажених ділянках) домінує й визначає якість роботи синхронних розподілених протоколів.

11.5 Безпека протоколів мережевої інфраструктури

Розподілена система довіряє службовим протоколам неявно: вузол, який отримав відповідь DNS, приймає її як істину; маршрутизатор, який отримав анонс BGP, змінює шлях; сервер, що синхронізував годинник, приймає рішення про чинність сертифіката й строк дії токена. Тому компрометація цих протоколів еквівалентна компрометації самої системи.

DNSSEC [81, 82] додає до відповідей DNS цифрові підписи, що дає змогу валідувальному резолверу перевірити походження й цілісність даних, спираючись на ланцюг довіри від кореневої зони. DNSSEC не забезпечує конфіденційності — її розв'язують DoT [205] і DoH [200], які інкапсулюють запити в TLS чи HTTPS. Для розподіленої установи важливо, що DoH одночасно ускладнює корпоративний контроль резолюції, тому політика має явно визначати перелік довірених резолверів і блокувати обхідні.

Безпека **BGP** спирається на RPKI: власник адресного простору публікує підписаний об'єкт ROA, який засвідчує, яка автономна система має право анонсувати префікс; маршрутизатор виконує валідацію походження й позначає маршрут як Valid, Invalid або NotFound [290]. Це унеможливлює найпоширеніший клас перехоплень трафіку через хибні анонси, хоч і не захищає від підроблення повного шляху.

NTP [284] потребує захисту, бо зсув часу руйнує перевірку сертифікатів, чинність квитків Kerberos і кореляцію журналів. Мінімальні заходи — кілька незалежних джерел стратуму 1, автентифікація (симетричним ключем або, у сучасних розгортаннях, протоколом NTS [173]), обмеження режимів, заборона зовнішніх запитів на клієнтських пристроях.

На канальному рівні застосовують DHCP snooping (відсіювання відповідей від несанкціонованих серверів), динамічну інспекцію ARP і захист портів, що протидіють ARP-спуфінгу — класичному механізму атаки «людина посередині» всередині сегмента. Ці засоби особливо важливі там, де в одному широкомовному домені співіснують керовані й некеровані пристрої.

11.6 Захист безпроводових сегментів розподілених систем

Безпроводовий сегмент відрізняється від проводового однією принциповою властивістю: середовище передавання є спільним і фізично неконтрольованим, тому порушник може пасивно приймати кадри й активно передавати їх, не долаючи жодного фізичного бар'єра. Це робить безпроводові сегменти найчастішою точкою початкового доступу до розподіленої системи.

11.6.1 Еволюція механізмів захисту IEEE 802.11

Стандарт IEEE 802.11 [218] консолідує механізми захисту безпроводових мереж, які зазнали кількох поколінь змін.

Таблиця 11.2 — Еволюція механізмів захисту безпроводових мереж IEEE 802.11

Механізм	Рік	Шифрування й цілісність	Автентифікація	Стан
WEP	1997	RC4, CRC-32	спільний ключ	зламаний
WPA (TKIP)	2003	RC4 + TKIP, MIC	PSK або 802.1X	застарілий
WPA2	2004	AES-CCMP	PSK або 802.1X/EAP	вразливий до KRACK без виправлень
WPA3-SAE	2018	AES-CCMP/GCMP, PMF	SAE (Dragonfly)	чинний
Enhanced Open (OWE)	2017	AES-GCMP	без автентифікації, DH-обмін	для відкритих мереж

Ключовою відмінністю WPA3-SAE є заміна попереднього спільного ключа на протокол одночасної автентифікації рівних (SAE, «Dragonfly»), що є формою автентифікованого обміну Діффі–Гелмана, стійкою до офлайнового перебору пароля: перехоплення рукостискання більше не дає змоги атакувати пароль поза мережею. Додатково обов'язковим стає захист кадрів керування (PMF), що усуває тривіальні атаки деавтентифікації. Механізм OWE [195] застосовує неавтентифікований обмін Діффі–Гелмана у відкритих мережах, забезпечуючи конфіденційність від пасивного прослуховування без роздавання пароля, але не захищаючи від активного порушника.

Слід наголосити, що NIST SP 800-97, який десятиліттями був базовою настановою з побудови мереж RSN, вилучено з обігу як технологічно застарілий із відсиланням до чинної редакції IEEE 802.11 [174]; настанови щодо організаційного забезпечення безпеки безпроводових локальних мереж подано в NIST SP 800-153 [379].

11.6.2 Автентифікація 802.1X/EAP і RADIUS-інтеграція

Корпоративний режим захисту безпроводового доступу будується на портовому контролі доступу IEEE 802.1X [220]. Учасниками є заявник (supplicant) на пристрої користувача, автентифікатор (точка доступу чи комутатор) і сервер автентифікації. Автентифікатор до успішного завершення процедури пропускає лише кадри EAPOL, блокуючи решту трафіку. Транспортом облікових даних є розширюваний протокол автентифікації EAP [72], а взаємодія автентифікатора із сервером здійснюється протоколом RADIUS [337].

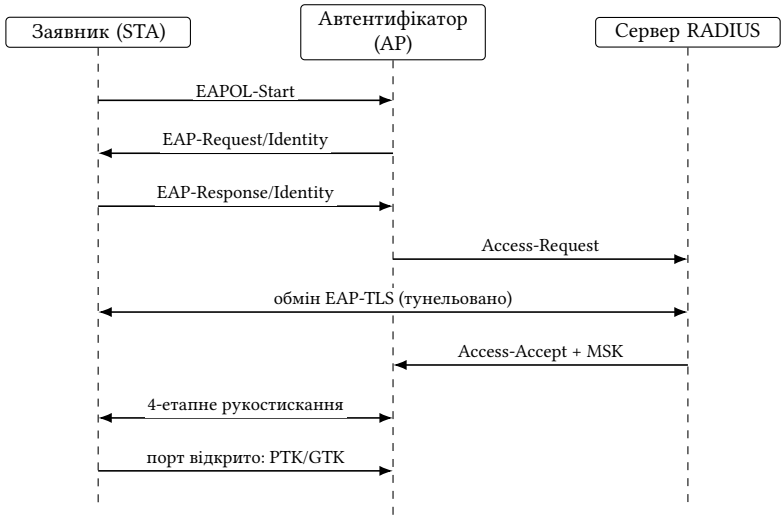


Рис. 11.2 — Послідовність автентифікації 802.1X/EAP із сервером RADIUS (за [220, 72])

Практично значущими є такі вимоги: використання методів із взаємною автентифікацією (EAP-TLS або тунельовані EAP-TTLS/PEAP), обов'язкова перевірка заявником сертифіката сервера RADIUS із закріпленням довіреного центру сертифікації (інакше можлива підміна сервера), захист транспорту RADIUS (RadSec поверх TLS або IPsec) на міжмайданчикових ділянках, а також резервування серверів автентифікації, оскільки їх відмова блокує доступ усього безпроводового сегмента.

11.6.3 Атаки на безпроводові мережі та контрзаходи

Практика виявляє такі основні класи атак.

Несанкціонована точка доступу (rogue AP). Пристрій, підключений до проводової мережі без дозволу, створює шлях в обхід усіх периметрових засобів. Контрзаходи — 802.1X на проводових портах, контроль MAC-таблиць, радіосканування.

Двійник (evil twin). Точка доступу з тим самим SSID і сильнішим сигналом перехоплює з'єднання клієнтів. Дослідження умов щільної забудови показують, що виявлення потребує сукупного аналізу радіочастотних ознак, часових характеристик маяків і топології сусідніх мереж [3]. Контрзаходи — 802.1X із перевіркою сертифіката сервера, PMF, WIPS.

KRACK. Атака повторного встановлення ключа примушує сторону 4-етапного рукостискання повторно встановити вже використаний ключ, що спричиняє повторне використання лічильника й порушення конфіденційності [408]. Усувається виправленнями заявників і точок доступу.

Деавтентифікація. Підроблені кадри керування розривають сеанси; використовується як передумова для перехоплення рукостискання чи як атака на доступність. Усувається обов'язковим PMF.

Атака на PMKID. Дає змогу отримати матеріал для офлайнового перебору пароля з одного кадру, без очікування підключення клієнта. Контрзахід — перехід на SAE або на 802.1X.

Атаки на реалізації SAE. Дослідження Dragonblood виявили побічні канали й вразливості зниження версії в ранніх реалізаціях WPA3, що підтверджує потребу перевіряти не лише специфікацію, а й конкретну реалізацію [409].

Розвідка радіоефіру («war driving»). Натурні експерименти в Україні засвідчують, що значна частка мереж і досі не використовує стійкого шифрування або зберігає застарілі режими сумісності [24].

11.6.4 Безпроводові системи виявлення та запобігання вторгненням

WIDS/WIPS — це підсистема з розподілених радіосенсорів і аналітичного ядра, яка інвентаризує радіооточення, класифікує точки доступу (санкціонована, чужа сусідня, несанкціонована в мережі), виявляє аномальні кадри керування, спроби деавтентифікації й нетипову поведінку клієнтів, а в режимі запобігання — активно розриває неавторизовані асоціації. Під час проєктування слід ураховувати правові межі активної протидії: примусове відключення сторонніх мереж може виходити за межі повноважень оператора та порушувати вимоги законодавства про електронні комунікації [45]. Організаційні аспекти розгортання й супроводу таких систем описано в NIST SP 800-153 [379].

11.6.5 Суміжні безпроводові технології та мобільні мережі

Розподілені системи використовують не лише 802.11. Bluetooth і BLE застосовують у периферії та системах контролю доступу; їх ризики пов'язані з режимами спарювання без автентифікації та з можливістю відстеження за адресою пристрою. Zigbee поширений в автоматизації будівель, де критичною є безпека процедури приєднання до мережі й керування мережевим ключем. LoRaWAN забезпечує далекий зв'язок для телеметрії й спирається на дворівневу схему ключів (мережевий і прикладний), що дає змогу відокремити оператора мережі від власника даних. NB-IoT і мобільні мережі 4G/5G переносять частину відповідальності на оператора; архітектуру безпеки 5G визначає 3GPP TS 33.501 [70], що вводить приховування постійного ідентифікатора абонента (SUCI), взаємну автентифікацію та захист міжмережевої взаємодії. Механізм **мережевих зрізів** (network slicing) дає розподіленій установі логічно виділений сегмент мобільної мережі з власними параметрами якості й безпеки, проте створює й нову поверхню атаки — ізоляція зрізів залежить від коректності конфігурації спільної інфраструктури оператора; систематизацію відповідних загроз наведено в аналітиці ENISA [162].

11.6.6 Екранування та вимоги ТЗІ до безпроводових каналів на ОІД

На об'єктах інформаційної діяльності, де обробляється інформація з обмеженим доступом, безпроводові технології потрапляють під окремий режим. Правила забезпечення захисту інформації в інформаційно-комунікаційних системах [42] і нормативні документи системи ТЗІ [31, 34] вимагають, щоб усі канали передавання інформації були описані в моделі загроз та охоплені комплексною системою захисту інформації з підтвердженою відповідністю. Практичними наслідками є: заборона або суворе обмеження безпроводового доступу в контурах, де циркулює інформація, що становить державну таємницю [43]; контроль зони можливого

перехоплення радіосигналу та її співвіднесення з контрольованою зоною об'єкта; застосування архітектурного й конструктивного екранування приміщень для зменшення рівня випромінювання за межами контрольованої зони; урахування побічних електромагнітних випромінювань і наведень від активного мережевого обладнання; окремий облік і контроль усіх радіопередавальних пристроїв, унесених на об'єкт. Безпроводовий сегмент на ОІД доцільно проєктувати як принципово недовірений: він завершується на виділеному шлюзі, за яким трафік проходить повноцінну автентифікацію та фільтрацію нарівні з трафіком із зовнішніх мереж.

11.7 Стійкість до відмов і атак на доступність

Атаки на доступність поділяють на об'ємні (вичерпання смуги пропускання підсиленими потоками UDP), протокольні (вичерпання станів — SYN flood, атаки на таблиці з'єднань екранів) і прикладні (повільні або ресурсомісткі HTTP-запити, атаки на пошукові й авторизаційні кінцеві точки). Розподілена система вразлива до всіх трьох класів, причому найслабшою ланкою зазвичай є не смуга каналу, а стан проміжних пристроїв.

Архітектурні контрзаходи охоплюють: anycast-розподіл точок входу, що розсіює атаку між майданчиками; винесення очищення трафіку до **scrubbing**-центрів провайдера; обмеження інтенсивності (rate limiting) за джерелом, сеансом і типом запиту; резервування каналів різних операторів; резервування маршрутів і автономність сегментів, коли віддалений майданчик зберігає працездатність локальних сервісів за відсутності зв'язку з ядром.

Ефективність очищення зручно описувати через залишкове навантаження. Нехай λ_m — інтенсивність шкідливого трафіку, λ_l — легітимного, η — частка шкідливого трафіку, що відсіюється, φ — частка легітимного трафіку, помилково відкинутого. Тоді залишкове навантаження на захищуваний сервіс і показник якості фільтрації становлять

$$\lambda_r = (1-\eta)\lambda_m + (1-\varphi)\lambda_l, \tag{11.1}$$

$$Q = \eta - \varphi \cdot \frac{\lambda_l}{\lambda_m}. \tag{11.2}$$

Умовою збереження працездатності є $\lambda_r < \mu$, де μ — обслуговувальна здатність сервісу. Із виразу видно, що за великого співвідношення λ_m/λ_l припустиме навіть помітне φ, тоді як у режимі «мирного часу» помилкове відкидання легітимних запитів коштує дорожче за пропуск шкідливих. Це обґрунтовує потребу в адаптивних порогах фільтрації, що перемикаються за фактом виявлення атаки.

Досвід української інфраструктури під час повномасштабної війни підтвердив вирішальну роль розподіленості: перенесення державних реєстрів у резервні майданчики, використання кількох незалежних операторів і супутникового доступу, а також координація реагування через CERT-UA [117, 8] дали змогу зберегти доступність критичних сервісів попри поєднання кібератак із фізичним ураженням об'єктів електроживлення та зв'язку.

11.8 Програмно визначені мережі та віртуалізація мережевих функцій

SDN відокремлює площину керування від площини даних, зосереджуючи логіку в контролері. Це дає гнучкість, але створює нові поверхні атаки: сам **контролер** як єдина точка відмови й точка максимальних привілеїв; **південний інтерфейс** (контролер–комутатор), де підміна повідомлень дає змогу довільно змінювати правила пересилання; **північний інтерфейс** (застосунки–контролер), де недостатня авторизація застосунків керування призводить до ескалації. Захист контролера передбачає взаємну автентифікацію TLS на обох інтерфейсах, рольове розмежування доступу застосунків, кластеризацію з кворумом, ізоляцію площини керування в окремому контурі та контроль цілісності правил, що встановлюються.

NFV переносить мережеві функції (екрани, балансувальники, шлюзи) у віртуальні машини та контейнери, унаслідок чого безпека мережевої функції стає похідною від безпеки платформи віртуалізації: ізоляції гіпервізора, цілісності образів, керування секретами. Мережеві політики в контейнерних середовищах і відповідні механізми сервісної сітки докладно розглянуто в розділі 12 [376].

11.9 Моніторинг мережевого трафіку

Основою мережевої видимості є експорт метаданих потоків. NetFlow та його стандартизований наступник **IPFIX** [131] передають на колектор записи про потоки (адреси, порти, протокол, обсяг, тривалість, прапорці), що дає змогу відновлювати картину взаємодій без збереження корисного навантаження. Дзеркалювання портів (SPAN) і мережеві відгалужувачі (TAP) забезпечують повнокадровий доступ там, де потрібен глибокий аналіз.

Інспекція зашифрованого трафіку з розривом TLS дає найповнішу видимість, але створює правові та етичні проблеми: вона передбачає доступ до змісту приватного листування працівників, підпадає під вимоги щодо обробки персональних даних [53, 328] і потребує явного інформування користувачів та обмеження категорій трафіку, що інспектується (зокрема виключення банківських і медичних ресурсів). Технічно вона також знижує безпеку, замінюючи наскрізне шифрування на довіру до проксі.

Альтернативою є аналіз без розшифрування. **Фінгерпринтинг** JA3 і його наступник JA4+ формують компактний відбиток клієнтського рукостискання TLS (перелік і порядок шифронаборів, розширень, груп), що дає змогу ідентифікувати застосунок або шкідливе програмне забезпечення за характерним профілем, не торкаючись змісту сеансу [77]. Такий підхід узгоджується з принципом мінімізації даних і добре масштабується в розподілених середовищах, проте вразливий до навмисної нормалізації відбитків з боку порушника. Побудову повноцінної системи моніторингу безпеки розглянуто в розділі 14.

11.10 Кейс: захищена мережева архітектура розподіленої установи

Розглянемо установу з центральним офісом у Києві, двома віддаленими майданчиками, резервним центром обробки даних та потребою безпроводового доступу для працівників і відвідувачів. Проєктне рішення охоплює такі елементи.

1. *Підключення.* Два незалежні оператори на кожному майданчику, у центральному офісі — додатково супутниковий резерв; публічні сервіси опубліковано через anycast-точки з можливістю переведення трафіку на scrubbing-центр.
2. *Периметр.* NGFW з IPS на стику, ДМЗ із зворотним проксі та WAF; уся вхідна взаємодія з реєстрами — лише через шлюз API з автентифікацією.
3. *Міжсайтові канали.* Основний тунель IPsec/IKEv2 із сертифікатною автентифікацією шлюзів; резервний — WireGuard через другого оператора; на магістральних ділянках у межах об'єкта — MACsec.
4. *Сегментація.* VRF для трьох контурів: службового, технологічного (інженерні системи) і гостьового; мікросегментація серверного контуру за ролями; площина менеджменту — в окремому OOB-контурі з доступом лише з привілейованих робочих станцій.
5. *Безпроводовий доступ.* Два логічні безпроводові сегменти: службовий — WPA3-Enterprise з 802.1X/EAP-TLS, сертифікатами пристроїв і перевіркою сертифіката сервера RADIUS; гостьовий — Enhanced Open з ізоляцією клієнтів, обмеженням смуги й виходом лише в Інтернет через окремий VRF. Розгорнуто WIDS/WIPS із сенсорами на кожному поверсі; заборонено режими сумісності WPA2-PSK.
6. *Службові протоколи.* Внутрішні валідувальні резолвери з DNSSEC і примусовим перенаправленням усього DNS-трафіку; блокування зовнішніх DoH-резолверів; ROA для власного адресного простору; три джерела NTP з автентифікацією.

7. *Моніторинг.* Експорт IPFIX з усіх маршрутизаторів, сенсори NDR у точках агрегації, збирання журналів RADIUS і WIPS, фінгерпринтинг JA4 без розриву TLS.
8. *Стійкість.* Кожен майданчик зберігає автономність локальних сервісів на 72 години; щоквартальні навчання з відпрацювання втрати основного каналу та відмови центрального майданчика [226].

Оцінка ефекту: за $n \approx 1200$ вузлів і $k = 15$ сегментів верхня межа кількості дозволених пар зменшується приблизно на порядок; час виявлення несанкціонованої точки доступу скорочується з тижнів (за результатами періодичних обстежень) до хвилин завдяки безперервному радіомоніторингу.

Висновки до розділу

Мережева інфраструктура розподіленої системи є не пасивним транспортом, а активним об'єктом захисту з власною моделлю загроз. Розмивання периметра означає, що захист має спиратися не на межу, а на сегментацію, криптографічний захист кожного каналу та безперервну перевірку ідентичності й контексту. Сегментація й мікросегментація дають вимірюваний ефект: скорочення поверхні бічного переміщення приблизно обернено пропорційне кількості сегментів, що робить її однією з найбільш економічно ефективних мір.

Засоби мережевого захисту доцільно розміщувати багаторівнево, зважаючи на переважання трафіку «схід–захід» у сучасних архітектурах. Захищені канали між сегментами обираються за критеріями рівня моделі, накладних витрат і потреби в криптографічній гнучкості: IPsec залишається стандартом для гетерогенних середовищ, WireGuard — раціональним вибором за пріоритету простоти й швидкодії, MACsec — для магістральних ділянок.

Особливої уваги потребує довіра до службових протоколів: DNSSEC, RPKI, автентифікований NTP і засоби канального рівня перетворюють неявні припущення на перевірювані твердження. Безпроводові сегменти залишаються найдоступнішою точкою входу; сучасний рівень захисту визначається поєднанням WPA3-SAE або 802.1X/EAP-TLS із обов'язковим захистом кадрів керування, безперервним радіомоніторингом і суворим режимом для об'єктів інформаційної діяльності. Стійкість до атак на доступність досягається не окремим засобом, а архітектурою — розподіленістю точок входу, резервуванням каналів і автономністю сегментів, що підтверджено практикою функціонування української інфраструктури в умовах війни. Нарешті, перехід до SDN/NFV і зростання частки зашифрованого трафіку зміщують дослідницький фронт до захисту площини керування та до мето-

дів аналізу без розшифрування, які поєднують ефективність виявлення з дотриманням приватності.

Питання для самоперевірки

1. У чому полягає розмивання периметра розподіленої системи і які архітектурні наслідки воно має?
2. Назвіть три площини мережевої архітектури та поясніть, чому компрометація площини керування є критичнішою за компрометацію окремого вузла.
3. Чим відрізняються потоки «північ–південь» від потоків «схід–захід» і як це впливає на вибір засобів захисту?
4. Виведіть залежність кількості потенційно дозволених пар вузлів від кількості сегментів. За яких припущень ця оцінка є верхньою межею?
5. Порівняйте VLAN, VRF і програмно визначену сегментацію за критеріями масштабованості, прив'язки до топології та придатності для динамічних середовищ.
6. Які відмінності між пакетним фільтром, екраном зі збереженням стану та NGFW є суттєвими для розподіленої системи?
7. Порівняйте IPsec, WireGuard, TLS-тунель і MACsec за рівнем моделі, накладними витратами та криптографічною гнучкістю. Для яких ділянок мережі установи ви обрали б кожну з технологій?
8. Чому DNSSEC не забезпечує конфіденційності запитів і які механізми її забезпечують? Які ризики для корпоративного контролю створює DoH?
9. Поясніть, що засвідчує об'єкт ROA і від якого класу атак на BGP захищає валідація походження маршруту.
10. Опишіть послідовність автентифікації 802.1X/EAP. Яку роль відіграє ключ MSK і що станеться, якщо заявник не перевіряє сертифікат сервера RADIUS?
11. Чим WPA3-SAE принципово стійкіший за WPA2-PSK до офлайнового відновлення пароля? Що додає обов'язковий захист кадрів керування?
12. Порівняйте атаки rogue AP, evil twin, KRACK і атаку на PMKID за передумовами, наслідками та контрзаходами.
13. Які правові обмеження слід урахувати під час розгортання WIPS в активному режимі та під час інспекції зашифрованого трафіку?
14. Використовуючи модель залишкового навантаження, поясніть, чому пороги фільтрації DDoS доцільно робити адаптивними. За яких співвідношень λ_m/λ_l припустиме зростання φ?

15. Які нові поверхні атаки виникають у SDN порівняно з традиційною мережею і які заходи захисту контролера ви вважаєте мінімально необхідними?
16. Запропонуйте програму експериментального дослідження ефективності виявлення несанкціонованих точок доступу в умовах щільної забудови: які метрики, які базові рішення для порівняння, як формувати вибірку?

РОЗДІЛ 12

Архітектура нульової довіри та захист хмарних і контейнерних розподілених ресурсів

Розділ присвячено зміні базової парадигми захисту розподілених інформаційних ресурсів — переходу від периметрової моделі, успадкованої від епохи корпоративних локальних мереж, до архітектури нульової довіри (Zero Trust Architecture, ZTA) та до специфічних механізмів захисту хмарних, контейнерних і безсерверних середовищ. Матеріал спирається на механізми ідентифікації та керування доступом (розділ 10) і на засоби захисту мережевої інфраструктури, зокрема безпроводових сегментів (розділ 11), і поширює їх на середовища, у яких мережевий периметр як конструкція втрачає сенс. Виклад побудовано навколо нормативної основи — NIST SP 800-207, NIST SP 800-190, NIST SP 800-145, ISO/IEC 27017 та 27018 — із кількісними моделями довірчого оцінювання й аналізом української практики розміщення державних інформаційних ресурсів у хмарних інфраструктурах.

12.1 Криза периметрової моделі захисту

Класична модель захисту, яку часто називають моделлю «фортеці з ровом», ґрунтується на припущенні, що мережу можна поділити на довірену внутрішню зону та недовірене зовнішнє середовище, а безпеку забезпечує контроль трафіку на межі між ними. Це припущення було коректним, поки виконувалися три умови: усі активи розміщені у контрольованих приміщеннях, усі користувачі працюють із корпоративних робочих станцій, а всі застосунки виконуються на власних серверах організації. Жодна з цих умов у сучасних розподілених системах не виконується.

Емпіричні свідчення кризи периметрової моделі мають кілька вимірів. По-перше, домінантним сценарієм компрометації став не «пробій» периметра, а зловживання легітимними обліковими даними: зловмисник, який отримав дійсні реєстраційні дані через фішинг або витік, для периметрового засобу є нерозрізненним від легітимного працівника. По-друге, після початкового доступу вирішальним етапом атаки стає латеральне переміщення — набір технік, систематизованих у тактиці *Lateral Movement* матриці MITRE ATT&CK [288]; у пласкій внутрішній мережі витрати зловмисника на переміщення між вузлами близькі до нуля. По-третє, аналітичні огляди ландшафту загроз фіксують стійке зростання частки інцидентів, пов'язаних із помилковими конфігураціями хмарних сервісів і компрометацією ланцюга постачання програмного забезпечення [161], тобто з векторами, для яких периметровий контроль структурно нерелевантний.

Три технологічні зсуви остаточно зруйнували периметр. **Віддалена й гібридна робота** перемістила значну частину робочих місць за межі контрольованої мережі; масштабування VPN-концентраторів під час пандемії та, в українських умовах, під час широкомасштабного вторгнення, перетворило VPN на критичну точку відмови й одночасно на привабливу ціль атаки. **Хмарні обчислення** перенесли застосунки й дані до інфраструктури, якою організація не володіє: керуюча площина хмарного провайдера доступна з будь-якої точки Інтернету, і жодний прикордонний міжмережевий екран її не захищає. **Мобільні та особисті пристрої** (BYOD), а також безпроводові сегменти доступу, зробили межу мережі динамічною й нечіткою; докладніше про захист безпроводових сегментів — у розділі 11.

Наслідком є фундаментальна асиметрія: периметрова модель забезпечує сильну автентифікацію одноразово, на вході, після чого надає широкі неявні повноваження всередині. Нульова довіра змінює саме цю логіку — усуває поняття «неявно довіреної зони» й переносить рішення про доступ до кожного окремого запиту.

12.2 Архітектура нульової довіри за NIST SP 800-207

12.2.1 Засадничі принципи

Документ NIST SP 800-207 [342] формулює нульову довіру не як технологію, а як **сукупність засадничих принципів** проєктування, які визначають, що вважати ресурсом, як приймати рішення про доступ і як контролювати його наслідки. Сім принципів такі:

1. Усі джерела даних і обчислювальні сервіси розглядаються як ресурси, що підлягають захисту, незалежно від їх розміщення й типу.
2. Уся комунікація захищається незалежно від розташування у мережі; мережеве розташування не породжує довіри.
3. Доступ до окремого ресурсу надається на основі сесії, тобто на обмежений час і в обмеженому обсязі.
4. Рішення про доступ визначається динамічною політикою, що враховує ідентичність клієнта, стан пристрою, характеристики застосунку, поведінкові й контекстні атрибути.
5. Організація здійснює моніторинг і вимірювання цілісності та безпекового стану всіх активів, які їй належать або з якими вона взаємодіє.
6. Автентифікація та авторизація є динамічними та строго примусовими; вони виконуються до надання доступу й переоцінюються протягом сесії.

7. Організація збирає якнайбільше даних про стан активів, мережевої інфраструктури й комунікацій і використовує ці дані для вдосконалення безпекового стану.

Принципово важливим є те, що ці положення не приписують конкретних продуктів. ZTA — це властивість архітектури, а не найменування класу засобів; будь-яке твердження про «купівлю нульової довіри» є категоріальною помилкою, до якої окремо повертаємось у підрозділі 12.3.

12.2.2 Логічні компоненти, площини керування й даних

Абстрактна модель ZTA виокремлює три ключові логічні компоненти. **Механізм політики** (Policy Engine, PE) — компонент, який приймає рішення про надання доступу суб'єкта до ресурсу на основі політики організації та даних із зовнішніх джерел; саме тут реалізується довірчий алгоритм. **Адміністратор політики** (Policy Administrator, PA) — компонент, який виконує рішення PE: встановлює або розриває комунікаційний шлях, видає сесійні реєстраційні дані чи маркери доступу. **Точка примусового застосування політики** (Policy Enforcement Point, PEP) — компонент, що фізично вмикає, контролює й припиняє з'єднання між суб'єктом і ресурсом. PE і PA утворюють **площину керування**, PEP і потік «суб'єкт — ресурс» — **площину даних**. Логічну структуру наведено на рис. 12.1.

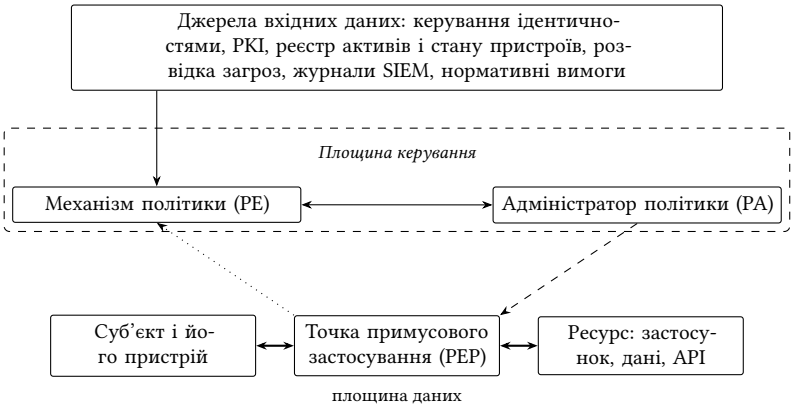


Рис. 12.1 — Логічні компоненти архітектури нульової довіри (за [342])

Джерелами вхідних даних для рішень слугують: система керування ідентичностями та привілеями, інфраструктура відкритих ключів (розділ 9), система безперервної діагностики й пом'якшення, що надає відомості про стан і рівень оновленості пристроїв, реєстри активів, канали роз-

відки загроз, журнали активності та системи SIEM (розділ 14), а також галузеві нормативні вимоги. Чим ширший і достовірніший цей набір, тим точнішим є рішення PE.

12.2.3 Довірчий алгоритм

Довірчий алгоритм (trust algorithm) — це процедура, за якою PE перетворює сукупність вхідних сигналів на рішення. Розрізняють **критеріальний** варіант, за якого запит задовольняється лише за одночасного виконання всіх обов'язкових умов, і **ваговий** (score/based) варіант, за якого обчислюється агрегований довірчий бал і порівнюється з порогом.

Формалізуємо ваговий варіант. Нехай сесія s характеризується вектором нормованих часткових оцінок $f_i(s) \in [0,1]$, $i = \overline{1,n}$ (сила автентифікації, відповідність пристрою політиці, репутація мережі й геолокація, відхилення поведінки від базового профілю, свіжість оновлень тощо), а w_i — ваги, що відображають внесок кожного чинника. Тоді довірчий бал сесії

$$T(s) = \sum_{i=1}^{n} w_i\, f_i(s), \qquad w_i > 0, \quad \sum_{i=1}^{n} w_i = 1, \quad T(s) \in [0,1]. \tag{12.1}$$

Рішення про доступ до ресурсу r ухвалюється за двопороговим правилом із трьома варіантами рішення

$$d(s,r) = \begin{cases} \text{дозволити}, & T(s) \geq \tau_1(r), \\ \text{дозволити з обмеженнями}, & \tau_0(r) \leq T(s) < \tau_1(r), \\ \text{відмовити}, & T(s) < \tau_0(r), \end{cases} \tag{12.2}$$

де пороги $\tau_0(r) \leq \tau_1(r)$ зростають зі зростанням критичності ресурсу. Проміжний стан «дозволити з обмеженнями» реалізує так звану *ступінчасту* реакцію: додаткова автентифікація, доступ лише для читання, скорочений час життя маркера, посилене журналювання.

Довірчий бал природно пов'язується з оцінкою ризику сесії. Якщо $P_e(r)$ — ймовірність експлуатації ресурсу за умови надання доступу недобросовісному суб'єктові, а $L(r)$ — очікувані втрати, то очікуваний ризик сесії

$$R(s,r) = \big(1 - T(s)\big) \cdot P_e(r) \cdot L(r), \tag{12.3}$$

що дозволяє інтегрувати ZTA у загальну систему управління ризиками (розділ 8) і задавати пороги τ_0, τ_1 з умови $R(s,r) \leq R_{\text{доп}}$. Слід усвідомлювати обмеження такої моделі: вона припускає адитивність і взаємну незалежність чинників, тоді як реальні сигнали корельовані (наприклад, аномальна геолокація й нетиповий час доступу). Побудова довірчих алгоритмів із урахуванням залежностей — байєсівських мереж, моделей виживa-

ння, ансамблів машинного навчання — залишається відкритою науковою задачею.

12.2.4 Варіанти розгортання

NIST SP 800-207 виокремлює три основні підходи до реалізації ZTA. **Підхід на основі керування ідентичностями** робить центральним об'єктом політики ідентичність суб'єкта та її атрибути; він найшвидше впроваджується у середовищах із зрілим керуванням доступом, але слабко захищає від атак на рівні мережі. **Мікросегментація** розміщує PEP безпосередньо біля ресурсів — у вигляді агентів на вузлах, розподілених міжмережевих екранів або мережевих політик оркестратора — і жорстко обмежує латеральне переміщення. **Програмно визначені периметри** (SDP) використовують накладені мережі, у яких ресурс до успішної автентифікації є невидимим (принцип «темної хмари»). На практиці домінують гібридні реалізації.

Кількісно оцінимо ефект мікросегментації щодо латерального переміщення. Нехай мережа містить N вузлів. У пласкій мережі скомпрометований вузол досягає

$$E_1 = N - 1$$

вузлів. Якщо мережу поділено на m рівних сегментів по N/m вузлів, а q — частка дозволених міжсегментних зв'язків, то математичне сподівання кількості безпосередньо досяжних вузлів

$$E_m = \frac{N}{m} - 1 + q\left(N - \frac{N}{m}\right), \qquad G = \frac{E_1}{E_m}, \tag{12.4}$$

де G — коефіцієнт скорочення поверхні латерального переміщення. Для $N = 2000$, $m = 50$, $q = 0{,}02$ маємо $E_m = 39 + 0{,}02 \cdot 1960 = 78{,}2$ і $G \approx 25{,}6$: сегментація зменшує безпосередньо досяжну множину майже на півтора порядку. Водночас формула показує критичну чутливість результату до q: за $q = 0{,}2$ коефіцієнт падає до $G \approx 4{,}6$ (пор. з оцінкою кількості допустимих пар вузлів у розділі 11, яка відповідає випадку $q = 0$). Отже, цінність мікросегментації визначається не кількістю сегментів, а строгістю міжсегментних правил.

12.3 Зрілість і практика впровадження

Для планування переходу застосовують **модель зрілості нульової довіри** CISA [424], що описує п'ять стовпів — ідентичність, пристрої, мережі, застосунки й навантаження, дані — та три наскрізні спроможності (видимість і аналітика, автоматизація й оркестрація, керування). Кожен стовп оцінюється за чотирма стадіями: традиційна, початкова, просунута, оптимальна (табл. 12.1). Практичні аспекти впровадження, зокрема еталонні лабораторні реалізації, узагальнено у NIST SP 1800-35 [341].

Таблиця 12.1 — Стадії зрілості ZTA за моделлю CISA (спрощено)

Стовп	Традиційна	Просунута	Оптимальна
Ідентичність	паролі, локальні каталоги	MFA, централізований каталог	безперервна автентифікація, безпарольність
Пристрої	облік вручну	реєстр активів, перевірка стану	доступ лише за верифікованим станом
Мережі	великі пласкі сегменти	сегментація за зонами	мікросегментація, шифрування всюди
Застосунки	доступ через периметр	доступ за політикою, тестування	безперервна авторизація запитів
Дані	неструктурована класифікація	маркування, шифрування в спокої	динамічні політики на рівні даних

Дорожня карта переходу передбачає послідовність: інвентаризація суб'єктів, пристроїв, ресурсів і потоків; визначення «захищуваної поверхні» — найкритичніших даних, застосунків, активів і сервісів; побудова карти транзакцій; проєктування розміщення PEP; формулювання політик; поетапне впровадження у режимі спостереження з подальшим переведенням у режим примусового застосування; безперервний моніторинг і уточнення. Ключовим є ітеративність: спроба одномоментного переходу всієї організації є найпоширенішою причиною провалу.

До типових помилок належать: ототожнення ZTA з окремим продуктом; впровадження мікросегментації без попередньої інвентаризації потоків, що призводить до масових відмов легітимного трафіку; надмірна довіра до єдиного сигналу (наприклад, лише до MFA) за відсутності перевірки стану пристрою; ігнорування «службових» ідентичностей — сервісних облікових записів, API-ключів, токенів CI/CD, які зазвичай мають надмірні й безстрокові повноваження; відсутність плану аварійного доступу, через що збій площини керування паралізує роботу організації. Окремим ризиком є перетворення PE у нову централізовану точку відмови: площина керування ZTA сама потребує резервування, захисту й моніторингу.

12.4 SDP, SASE та SSE

Програмно визначений периметр (Software-Defined Perimeter, SDP) у специфікації Cloud Security Alliance [374] побудовано за схемою «спершу автентифікація — потім з'єднання»: ініціюючий хост звертається до контролера SDP, і лише після успішної перевірки ідентичності, стану пристрою й політики контролер наказує приймальному хосту прийняти з'єднання. До цього моменту сервіс не відповідає на жодні пакети, зокрема завдяки механізму однопакетної авторизації, тобто є невидимим для сканування. Порівняно з традиційним VPN, який після автентифікації надає доступ до

мережевого сегмента, SDP надає доступ до окремого застосунку, не розкриваючи топології мережі.

Концепція **SASE** (Secure Access Service Edge) об'єднує мережеві функції (SD-WAN, оптимізація маршрутів) із хмарними безпековими сервісами, що надаються з розподілених точок присутності. Її безпекову складову виокремлюють як **SSE** (Security Service Edge), до якої входять: ZTNA — доступ до застосунків за принципами нульової довіри; SWG — захищений вебшлюз із фільтрацією та інспекцією трафіку; CASB — посередник безпеки хмарного доступу, що виявляє «тіньові» сервіси та застосовує політики до SaaS; FWaaS — міжмережевий екран як сервіс; DLP — запобігання витокам даних. Практична перевага моделі — уніфікація політик для всіх користувачів незалежно від їх розташування; практичні ризики — залежність від одного постачальника, концентрація дешифрованого трафіку в його інфраструктурі та юрисдикційні питання, критичні для органів державної влади.

12.5 Хмарні моделі та спільна відповідальність

Згідно з NIST SP 800-145 [279], хмарні обчислення характеризуються п'ятьма ознаками (самообслуговування за запитом, широкий мережевий доступ, об'єднання ресурсів у пул, швидка еластичність, вимірюваність послуги), трьома моделями обслуговування (IaaS, PaaS, SaaS) і чотирма моделями розгортання (приватна, спільнотна, публічна, гібридна). Модель обслуговування безпосередньо визначає **межу спільної відповідальності** між замовником і провайдером (табл. 12.2). Загальні підходи до керування доступом у цих моделях систематизовано у NIST SP 800-210 [204], а деталізований набір контролів — у матриці CCM Cloud Security Alliance [134] і в настановах [358].

Таблиця 12.2 — Розподіл відповідальності за моделями обслуговування

Рівень	IaaS	PaaS	SaaS
Фізична інфраструктура, ЦОД	П	П	П
Віртуалізація, гіпервізор	П	П	П
Гостьова ОС, оновлення	З	П	П
Середовище виконання, ПЗ проміжного рівня	З	П	П
Код застосунку	З	З	П
Конфігурація сервісу та мережі	З	З	З
Ідентичності, ролі, права доступу	З	З	З
Дані та криптографічні ключі	З	З	З

Позначення: П — провайдер; З — замовник

Ключовий висновок таблиці: незалежно від моделі обслуговування замовник завжди залишається відповідальним за дані, ідентичності та конфігурацію. Саме на цих трьох рівнях зосереджено переважну більшість реальних інцидентів. Типовими помилковими конфігураціями є: об'єктні сховища з публічним доступом на читання або запис; надмірно широкі ролі та політики з узагальненими дозволами замість принципу найменших привілеїв; відкриті у публічну мережу керуючі площини — панелі адміністрування, API оркестраторів, сервіси віддаленого доступу; вимкнене журналювання дій у керуючій площині; безстрокові статичні ключі доступу, вбудовані у репозиторії коду.

Для систематичного виявлення таких дефектів застосовують два класи засобів: **CSPM** (Cloud Security Posture Management) — безперервне зіставлення фактичної конфігурації хмарного середовища з еталонними профілями та нормативними вимогами, і **CIEM** (Cloud Infrastructure Entitlement Management) — аналіз фактично використаних повноважень і автоматичне звуження надмірних прав. Обидва класи є прикладом переходу від разового аудиту до безперервного контролю відповідності, що узгоджується з підходом безперервного оцінювання (розділ 14).

12.6 Безпека контейнерів і оркестрації

NIST SP 800-190 [376] систематизує ризики контейнеризації за п'ятьма рівнями життєвого циклу: образи, реєстри, оркестратор, контейнери (середовище виконання) і хост-ОС. Багаторівневу модель захисту контейнерної платформи подано на рис. 12.2, зіставлення основних ризиків із контрзаходами — у табл. 12.3.

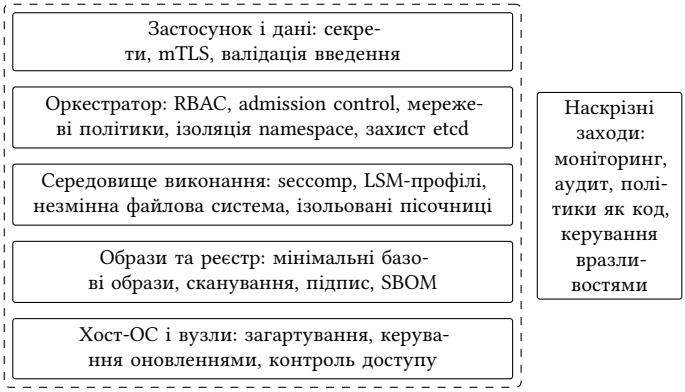


Рис. 12.2 — Багаторівнева модель захисту контейнерної платформи (за [376])

Таблиця 12.3 — Зіставлення ризиків NIST SP 800-190 із контрзаходами

Рівень	Основні ризики	Контрзаходи
Образи	вразливі складники, вбудовані секрети, зайві компоненти	мінімальні образи, сканування у конвеєрі, SBOM, заборона секретів у шарах
Реєстр	незахищені з'єднання, застарілі й непідписані образи	TLS, автентифікація, підпис і перевірка, політики строку придатності
Оркестратор	необмежений адміндоступ, слабка ізоляція навантажень	RBAC із найменшими привілеями, admission control, мережеві політики
Контейнери	вихід за межі ізоляції, надмірні привілеї, вразливості середовища виконання	заборона привілейованих контейнерів, seccomp, LSM, runtime-моніторинг
Хост-ОС	велика поверхня атаки, спільне ядро	спеціалізовані ОС, загартування за еталонними профілями, оновлення

У платформі Kubernetes базовими механізмами захисту є такі. **RBAC** визначає повноваження через чотири об'єкти: `Role` і `RoleBinding` (у межах простору імен), `ClusterRole` і `ClusterRoleBinding` (на рівні кластера) [406]; типовою помилкою є прив'язування ролі `cluster-admin` до сервісних облікових записів. **Мережеві політики** (`NetworkPolicy`) керують трафіком на рівнях 3–4 і реалізують мікросегментацію всередині кластера; критично важливо, що за замовчуванням поди не ізольовані, а самі політики не діють без мережевого втулка, який їх підтримує [296]. Практика полягає у запровадженні в кожному просторі імен політики типу «заборонити все» з подальшим явним дозволом потрібних потоків. **Керування допуском** (admission control) реалізує превентивну перевірку маніфестів: вбудований контролер Pod Security застосовує три профілі — `privileged`, `baseline`, `restricted` [323], а зовнішні механізми політик як коду (OPA Gatekeeper, Kyverno) дозволяють описувати довільні організаційні правила. **Ізоляція просторів імен** доповнюється квотами ресурсів і окремими сервісними обліковими записами. Секрети Kubernetes за замовчуванням зберігаються у сховищі etcd лише у кодуванні Base64, тому обов'язковими є шифрування у стані спокою, обмеження доступу до etcd і, для критичних систем, використання зовнішніх сховищ секретів. Компрометація etcd еквівалентна повній компрометації кластера, тому доступ до нього має бути обмежений мережево й криптографічно. **Runtime-захист** передбачає виявлення аномальної поведінки контейнерів на основі системних викликів і мережевої активності. Еталонні конфігураційні вимоги узагальнено у CIS Kubernetes

Benchmark [130]; практичні рекомендації щодо всіх фаз життєвого циклу — у настанові OWASP [257].

Окремої уваги потребує **ланцюг постачання артефактів**. Підписування образів засобами Sigstore (клієнт `cosign`, посвідчувальний центр Fulcio, журнал прозорості Rekor) забезпечує криптографічну прив'язку артефакту до перевіреної ідентичності без тривалого зберігання ключів [368]. Специфікація SLSA [372] визначає рівні гарантій складання: L1 — наявність автоматично сформованих відомостей про походження артефакту; L2 — складання на керованій платформі з підписаним походженням; L3 — загартоване складання з ізоляцією запусків і захистом ключів підпису. **SBOM** — машиночитний перелік складників програмного забезпечення — є передумовою оперативного визначення ураженості під час оприлюднення нових вразливостей. Інтеграцію цих механізмів у конвеєри CI/CD описано у NIST SP 800-204D [123], а загальні засади керування ризиками ланцюга постачання — у NIST SP 800-161 [103].

12.7 Безсерверні обчислення та мікросервіси

Безсерверна модель (Function as a Service) усуває відповідальність замовника за операційну систему й середовище виконання, але породжує власний профіль загроз. По-перше, це **ін'єкції через події**: функція запускається не лише HTTP-запитом, а й повідомленням черги, записом у сховищі, подією журналу, і кожне таке джерело є недовіреним входом, який часто не перевіряється. По-друге, **надмірні дозволи функцій**: практика надання однієї спільної ролі всім функціям сервісу перетворює компрометацію найпростішої функції на повний доступ до даних. По-третє, **залежності**: функції зазвичай пакують разом із бібліотеками, які рідко оновлюються після розгортання. По-четверте, характерний для FaaS ефект **холодного старту** ускладнює застосування агентів runtime-захисту й спричиняє спокусу зберігати стан у глобальних змінних, що призводить до витоку даних між викликами. Додатковим ризиком є економічне виснаження ресурсів: масовані виклики функцій генерують не відмову в обслуговуванні, а неконтрольовані витрати.

У мікросервісних архітектурах ключовою є проблема авторизації «сервіс-до-сервісу». NIST SP 800-204 [120] і NIST SP 800-204B [122] обґрунтовують перенесення функцій автентифікації й авторизації з коду застосунку до інфраструктурного рівня — **сервісної сітки** (Istio, Linkerd). Сітка розгортає поряд із кожним екземпляром сервісу проксі-компонент (sidecar), який стає розподіленою точкою примусового застосування політики: він встановлює взаємно автентифікований TLS (mTLS) з обома боками, перевіряє ідентичність робочого навантаження на основі короткоживучих сертифікатів, застосовує атрибутні правила доступу й веде однорідне журналюван-

ня. Це узгоджується з моделлю ZTA для хмаро-орієнтованих застосунків у багатохмарних середовищах, викладеною у NIST SP 800-207A [121], де точкою примусового застосування визнано саме проксі рівня сервісу, а ідентичність навантаження — первинним об'єктом політики. Слід ураховувати й витрати: додатковий мережевий перехід збільшує затримку, а сама площина керування сіткою стає критичним компонентом.

12.8 Захист даних у хмарі

Захист даних у хмарних середовищах будується на чотирьох опорах. **Шифрування в русі** забезпечується TLS 1.3 [336] для зовнішніх і внутрішніх з'єднань, зокрема між мікросервісами. **Шифрування у стані спокою** застосовується на рівні томів, об'єктних сховищ, баз даних і резервних копій; для державних інформаційних ресурсів України обов'язковим є застосування національних криптографічних алгоритмів — ДСТУ 7624:2014 та ДСТУ 4145-2002 [17, 16]. Центральним питанням є **керування ключами**: моделі BYOK (замовник постачає власний ключ у сховище провайдера) і HYOK (ключ ніколи не залишає інфраструктури замовника) відрізняються тим, чи має провайдер технічну можливість дешифрувати дані; тільки HYOK усуває цю можливість, ціною складності й обмеженої функціональності хмарних сервісів. **Конфіденційні обчислення** доповнюють картину, захищаючи дані під час оброблення за допомогою апаратних довірених середовищ виконання з віддаленою атестацією; це знімає частину, але не всі, ризиків недовіреного гіпервізора.

Правовий вимір визначається вимогами локалізації, суверенності й транскордонної передачі. Для персональних даних застосовними є GDPR [328] у частині передачі до третіх країн і Закон України «Про захист персональних даних» [53]. Галузевими орієнтирами для хмарних послуг слугують ISO/IEC 27017 [233], що доповнює контролі ISO/IEC 27002 специфічними для хмари вказівками з розподілом ролей замовника й провайдера, та ISO/IEC 27018 [234], що встановлює правила оброблення персональних даних публічними провайдерами, які діють як оператори. Практично важливими є питання доказової бази: право на аудит, доступ до журналів, порядок повідомлення про інциденти та умови повернення й гарантованого знищення даних після припинення договору мають бути закріплені в угоді про рівень послуг, а не залишені на розсуд провайдера.

12.9 Українські аспекти

Правовий режим хмарних послуг в Україні визначає Закон України «Про хмарні послуги» від 17.02.2022 № 2075-IX [62], який запровадив базову термінологію, встановив вимоги до надавачів і врегулював використання хмарних послуг органами державної влади, органами місцевого самовря-

дування та суб'єктами владних повноважень. Закон ухвалено за тиждень до початку широкомасштабного вторгнення, і він набув критичного практичного значення; водночас розміщення державних інформаційних ресурсів у хмарних інфраструктурах за межами України, що доти було фактично неможливим, уможливила на період воєнного стану постанова Кабінету Міністрів України від 12.03.2022 № 263 [11] (сам закон забороняє обробку службової інформації та державної таємниці з використанням центрів обробки даних за кордоном, окрім визначених ним винятків для оборонного сектору).

Практичним наслідком стала безпрецедентна операція з міграції державних реєстрів і даних із фізичних центрів оброблення даних, розташованих у зоні досяжності ракетних ударів, до хмарних середовищ. Ця операція є показовим кейсом забезпечення неперервності функціонування розподілених інформаційних ресурсів в умовах кінетичної загрози: географічна розподіленість, яка в мирний час розглядається переважно як засіб підвищення продуктивності, стала засобом виживання державної інформаційної інфраструктури. Правовий і технологічний режим публічних реєстрів надалі систематизовано Законом України «Про публічні електронні реєстри» [59], який визначає вимоги до створення, ведення, взаємодії та захисту реєстрів, зокрема щодо резервування даних.

Поняття «хмара для державних потреб» позначає модель, за якої держава користується хмарними послугами в режимі, що поєднує еластичність комерційної хмари з підвищеними вимогами до захищеності: обов'язкова відповідність вимогам із захисту інформації, контрольований перелік надавачів, окремі вимоги до розміщення й до персоналу, посилені зобов'язання щодо журналювання й повідомлення про інциденти. Загальні вимоги до захисту інформації в системах, що обробляють державні інформаційні ресурси, залишаються визначеними Правилами, затвердженими постановою Кабінету Міністрів України № 373 [42], а для об'єктів критичної інфраструктури — загальними вимогами до кіберзахисту [22]. Координацію й методичне забезпечення здійснює Держспецзв'язку [8], реагування на інциденти — CERT-UA [117]. Практично важливим є те, що перехід до хмарної моделі не скасовує обов'язку побудови комплексної системи захисту інформації, а змінює її межі: у зону відповідальності власника ресурсу потрапляють конфігурація хмарних сервісів, керування ідентичностями та ключами, тоді як контроль фізичного середовища замінюється контролем договірних і сертифікаційних гарантій провайдера.

12.10 Кейс: перехід відомчої розподіленої системи до нульової довіри

Розглянемо узагальнений кейс центрального органу виконавчої влади, який експлуатує розподілену інформаційну систему: близько 3000 робочих місць у центральному апараті та територіальних органах, 40 внутрішніх застосунків, два приватні хмарні майданчики і два SaaS-сервіси. Вихідний стан: доступ територіальних органів через VPN до пласкої внутрішньої мережі, автентифікація за паролем, спільні адміністративні облікові записи, відсутність інвентаризації сервісних ідентичностей.

Перехід реалізовано у п'ять етапів. *Етап 1 (інвентаризація, 3 місяці)*: побудовано реєстри користувачів, пристроїв, застосунків і сервісних облікових записів; за допомогою пасивного збирання телеметрії складено карту фактичних мережевих потоків. *Етап 2 (ідентичність, 4 місяці)*: централізовано каталог, впроваджено багатофакторну автентифікацію з апаратними автентифікаторами для адміністраторів, ліквідовано спільні облікові записи, запроваджено привілейований доступ за запитом на обмежений час. *Етап 3 (доступ до застосунків, 5 місяців)*: VPN замінено на ZTNA-шлюз; для кожного застосунку описано політику доступу; протягом двох місяців шлюз працював у режимі спостереження, після чого переведений у режим примусового застосування. *Етап 4 (мікросегментація й контейнери, 6 місяців)*: у кластерах Kubernetes запроваджено політику «заборонити все» з явними дозволами, профіль `restricted`, перевірку підписів образів на етапі допуску, шифрування секретів у etcd. *Етап 5 (безперервність контролю)*: розгорнуто CSPM/CIEM, інтегровано журнали PEP і сервісної сітки із SIEM, запроваджено щоквартальний перегляд політик.

Метриками успіху обрано: частку застосунків, доступ до яких надається лише через PEP; частку користувачів із перевіркою стану пристрою; медіанний час життя привілейованої сесії; кількість облікових записів із безстроковими правами; коефіцієнт G зі співвідношення (12.4) за фактичною матрицею дозволених потоків; середній час виявлення аномальної автентифікації. Показовим є те, що перші два етапи не дали помітного зменшення інцидентів, тоді як після етапу 3 різко скоротилася кількість спрацювань на латеральне сканування — ефект нульової довіри виявляється нелінійно й лише після досягнення критичної маси охоплених ресурсів. Основними труднощами стали успадковані застосунки без підтримки сучасних протоколів автентифікації та опір експлуатаційних підрозділів на етапі переведення політик у режим примусового застосування.

Висновки до розділу

Периметрова модель захисту втратила чинність не через недосконалість окремих засобів, а через зникнення самої передумови — сталої межі між

довіреним і недовіреним середовищем. Архітектура нульової довіри пропонує послідовну альтернативу: відсутність неявної довіри, посесійне надання доступу, динамічна політика, безперервна переоцінка. Нульова довіра є властивістю архітектури, а не класом продуктів; її впровадження — ітеративний організаційний процес, що починається з інвентаризації й побудови карти потоків.

Формальні моделі — ваговий довірчий бал, порогове правило рішення, оцінка ризику сесії та коефіцієнт скорочення поверхні латерального переміщення — дозволяють перевести проєктні рішення з площини експертних суджень у площину вимірюваних величин, водночас їх адитивні припущення потребують уточнення з урахуванням кореляції сигналів.

Хмарні й контейнерні середовища не змінюють цілей захисту, але радикально змінюють розподіл відповідальності: за будь-якої моделі обслуговування замовник відповідає за дані, ідентичності та конфігурацію, і саме тут зосереджено більшість реальних інцидентів. Захист контейнерних платформ є багаторівневим і охоплює образи, реєстри, оркестратор, середовище виконання й хост, а довіра до артефактів забезпечується підписуванням, гарантіями складання та відомостями про склад програмного забезпечення.

Для України перехід державних інформаційних ресурсів до хмарних середовищ став не лише технологічним, а й безпековим рішенням, що безпосередньо вплинуло на стійкість державного управління в умовах війни. Відкритими напрямами наукових досліджень залишаються: побудова довірчих алгоритмів із урахуванням залежностей між сигналами та стійких до змагальних впливів; кількісне оцінювання ефективності мікросегментації на реальних топологіях; методи верифікації політик як коду; забезпечення доказовості й аудитоспроможності в багатохмарних середовищах; узгодження вимог національної системи технічного захисту інформації з моделями відповідальності хмарних провайдерів.

Питання для самоперевірки

1. Які припущення покладено в основу периметрової моделі захисту і чому вони перестали виконуватися у сучасних розподілених системах?
2. Сформулюйте сім засадничих принципів нульової довіри за NIST SP 800-207. Який з них є найскладнішим для практичної реалізації і чому?
3. Опишіть призначення компонентів PE, PA і PEP та поясніть розмежування площини керування й площини даних.

4. Які джерела вхідних даних використовує механізм політики для прийняття рішення про доступ? Як їх повнота впливає на якість рішень?
5. Порівняйте критеріальний і ваговий варіанти довірчого алгоритму. За яких умов доцільним є кожен із них?
6. Запишіть вираз довірчого балу сесії та двопорогове правило рішення. Як обґрунтувати вибір порогів через допустимий ризик?
7. Виведіть вираз для математичного сподівання кількості безпосередньо досяжних вузлів у сегментованій мережі. Дослідіть чутливість коефіцієнта G до частки дозволених міжсегментних зв'язків.
8. Охарактеризуйте стадії й стовпи моделі зрілості ZTA CISA. Які наскрізні спроможності вона виокремлює?
9. Назвіть п'ять типових помилок впровадження ZTA і запропонуйте заходи їх запобігання. Чому ZTA не можна придбати як продукт?
10. У чому полягає принципова відмінність SDP від традиційного VPN? Які складники входять до SSE та які ризики породжує їх концентрація в одного постачальника?
11. Побудуйте таблицю спільної відповідальності для конкретного сервісу IaaS, PaaS і SaaS. Які рівні завжди залишаються у зоні відповідальності замовника?
12. Які ризики контейнеризації виокремлює NIST SP 800-190? Зіставте їх із механізмами захисту Kubernetes: RBAC, мережеві політики, контроль допуску, захист etcd.
13. Поясніть роль підписування образів, рівнів SLSA та SBOM у забезпеченні довіри до ланцюга постачання артефактів.
14. Які специфічні загрози властиві безсерверним обчисленням? Як сервісна сітка та mTLS вирішують задачу авторизації «сервіс-до-сервісу»?
15. Проаналізуйте правовий режим використання хмарних послуг державними органами України та обґрунтуйте, які зміни в межах комплексної системи захисту інформації спричиняє міграція державного інформаційного ресурсу до хмари.

РОЗДІЛ 13

Захист розподілених баз даних, сховищ даних і технологій розподіленого реєстру

Дані є кінцевою метою переважної більшості атак на розподілені інформаційні ресурси: мережа, платформа й застосунок цінні для порушника лише як шлях до сховища. Водночас саме на рівні даних розподіленість виявляється найгостріше: один логічний запис фізично існує у кількох копіях, у різних юрисдикціях, під різними адміністративними доменами, а його «істинне» значення визначається не фактом запису, а протоколом узгодження. Розділ систематизує механізми захисту розподілених баз даних, сховищ і озер даних, а також технологій розподіленого реєстру (DLT). Він спирається на криптографічні примітиви розділу 9, моделі керування доступом розділу 10 та архітектуру нульової довіри розділу 12, а питання відновлюваності розгортає далі розділ 15.

13.1 Розподілене зберігання даних як об'єкт захисту

Розподілене зберігання будується на двох ортогональних механізмах — реплікації та шардуванні. **Реплікація** створює кілька копій одного набору даних, підвищуючи доступність і довговічність; **шардування** (секціонування) поділяє набір на непересічні частини, підвищуючи масштабованість. У промислових системах вони поєднуються: кожен шард реплікується на кілька вузлів [251, 394].

Класифікація схем реплікації визначає профіль загроз:

- **«провідний–ведений»** (leader–follower): усі записи проходять через одну репліку. Компрометація провідного вузла означає повний контроль над цілісністю даних; ведені репліки є привабливою ціллю для витоку, бо часто захищені слабше (аналітичні репліки, репліки для звітності).
- **багатопровідна реплікація** (multi-leader): запис приймають кілька вузлів, зазвичай у різних географічних зонах. З'являється клас конфліктів запису й потреба у детермінованому їх розв'язанні; порушник, що контролює один центр, здатний нав'язати «переможну» версію запису.
- **безлідерна** (leaderless) — **кворумна реплікація** без виділеного провідного вузла, де клієнт сам звертається до підмножини реплік. Тут цілісність спирається на арифметику кворумів, а не на довіру до окремого вузла.

Синхронна реплікація гарантує, що підтверджений запис фізично присутній на кількох вузлах (RPO прямує до нуля), але збільшує затримку і робить систему вразливою до «повільного» вузла. Асинхронна реплікація приховує затримку, проте створює вікно втрати даних: підтверджені клієнтові транзакції можуть зникнути під час відмови провідного вузла. З погляду безпеки це не лише питання доступності — це порушення *цілісності* обліку, оскільки система вже повідомила зовнішньому світу про факт, якого потім не існуватиме.

Геореплікація додає правовий вимір: копія персональних даних у іншій юрисдикції є транскордонною передачею у розумінні GDPR [328] і Закону України «Про захист персональних даних» [53], навіть якщо жоден користувач до неї не звертався. Для державних ресурсів це поєднується з вимогами до розміщення, встановленими законодавством про хмарні послуги [62].

Окремий випадок — віддалені майданчики та мобільні пункти обробки, що під'єднуються **безпроводовими** каналами (супутниковими, стільниковими). Для них реплікація має бути асинхронною й криптографічно захищеною на рівні самих даних, бо канал не контролюється власником ресурсу; деталі захисту безпроводових сегментів розглянуто в розділі 11.

13.1.1 Кворумні системи

У кворумній моделі набір із N реплік обслуговує запис, підтверджений W вузлами, і читання, що опитує R вузлів. Умова перетину кворумів

$$W + R > N, \qquad W > \frac{N}{2},$$

гарантує, що будь-яке читання перетинається щонайменше з одним вузлом, який бачив останній підтверджений запис, а друга нерівність унеможливлює два несумісні записи одночасно («розщеплений мозок»). Порушення цих умов — типова помилка конфігурування, що перетворює сховище з узгодженого на «зрештою узгоджене» без відома власника даних.

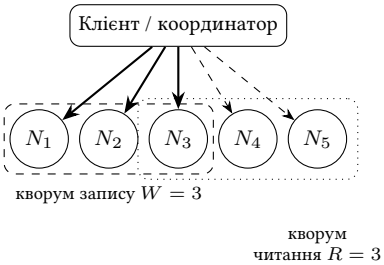


Рис. 13.1 — Перетин кворумів запису й читання при $N = 5, W = R = 3$

Ймовірність втрати шарда, репліки якого відмовляють незалежно з імовірністю p за розрахунковий інтервал, за коефіцієнта реплікації r становить p^r, а для сховища із S шардів імовірність втрати хоча б одного фрагмента

$$P_{\text{втрати}} = 1 - (1 - p^r)^S .$$

Формула показує, чому нарощування кількості шардів без збільшення r погіршує довговічність: за $p = 10^{-3}$, $r = 3$ і $S = 10^4$ дістаємо $P_{\text{втрати}} \approx 10^{-5}$, тоді як за $S = 10^6$ — уже близько 10^{-3}. Ключове припущення — *незалежність* відмов — на практиці хибне: спільне живлення, спільний гіпервізор, однакова версія прошивки або одна й та сама програма-вимагач корелюють відмови, і реальна оцінка має враховувати домени відмов [124].

13.2 Узгодженість, транзакції та безпека даних

Теорема CAP у формалізації С. Гілберта і Н. Лінч [184] (докладніше — у розділі 1) стверджує: за наявності поділу мережі неможливо одночасно забезпечити лінеаризовність і доступність. Для фахівця з безпеки це означає, що вибір рівня узгодженості є рішенням про *ризик*, а не про продуктивність: система, налаштована на доступність, свідомо припускає читання застарілих даних.

Модель ACID (атомарність, узгодженість, ізольованість, довговічність) властива класичним СКБД; модель BASE (базова доступність, «м'який» стан, зрештою узгодженість) — горизонтально масштабованим NoSQL-сховищам. Проміжні рівні ізоляції (read committed, repeatable read, snapshot) допускають аномалії, які у прикладному коді безпеки перетворюються на вразливості: класичний приклад — перевірка залишку коштів або квоти в одній транзакції та списання в іншій (розрив «перевірка–використання», TOCTOU), а за snapshot-ізоляції — «перекіс запису» (write skew), коли дві паралельні транзакції перевіряють спільний інваріант (наприклад, сумарний ліміт) і змінюють різні рядки, що призводить до перевищення ліміту або подвійного витрачання.

Розподілені транзакції розв'язують проблему атомарності між сховищами. Двофазна фіксація (2PC) забезпечує атомарність ціною блокування: відмова координатора залишає учасників у невизначеному стані з утримуваними блокуваннями — це готовий вектор відмови в обслуговуванні. Шаблон **Saga** [180] замінює глобальну транзакцію послідовністю локальних із компенсаційними діями; ціна — проміжні стани, видимі назовні, і потреба робити компенсації ідемпотентними та захищеними від повторного відтворення (replay).

Для багатопровідних і георепліkованих систем застосовують **безконфліктні реплiковані типи даних** (CRDT) [362] — структури, операції над якими комутативні, асоціативні та ідемпотентні, тому репліки збігаються без координації. З погляду безпеки CRDT усувають клас «тихих» втрат оновлень, але не розв'язують задачу авторизації: будь-яка репліка, що приймає операцію, має незалежно перевірити повноваження автора, інакше злиття станів легалізує неавторизовану зміну.

Таблиця 13.1 — Рівні узгодженості та ризики для властивостей безпеки

Рівень	Гарантія	Основний ризик безпеки
Лінеаризовність	кожне читання бачить останній запис	відмова в обслуговуванні при поділі мережі
Причинна	збережено причинно-наслідковий порядок	застарілі дані в рішеннях авторизації
Зрештою узгоджена	збіжність без часових гарантій	рішення за відкликаним доступом; «воскресіння» видалених записів
Кворумна ($W+R>N$)	перетин множин реплік	деградація при зміні N без перерахунку W, R

Особливо небезпечний сценарій — відкликання прав або видалення персональних даних у зрештою узгодженій системі: підтверджена операція видалення може бути «перекрита» пізнішим злиттям із репліки, що не отримала оновлення. Тому операції відкликання реалізують як монотонні (надгробки, tombstones) із явним контролем повноти поширення.

13.3 Консенсус як механізм забезпечення цілісності

Консенсус — це протокол, що дає змогу коректним вузлам узгодити спільну послідовність операцій. Історично першим практичним рішенням для моделі відмов «збій–зупинка» став Paxos Л. Лемпорта [258], згодом — Raft [313], який декомпозує задачу на вибори лідера, реплікацію журналу та забезпечення безпеки і завдяки цьому значно простіший для верифікації та аудиту. Обидва протоколи толерують відмову менш ніж половини вузлів: для f відмов потрібно $n \geq 2f + 1$.

Якщо ж вузол може поводитися довільно — видавати різні відповіді різним учасникам, підробляти повідомлення, вибірково їх приховувати (модель **візантійських відмов**), — потрібен візантійський консенсус. Протокол PBFT М. Кастро і Б. Ліскова [116] забезпечує безпеку й живучість за умови

$$n \geq 3f + 1,$$

де f — максимальна кількість візантійських вузлів. Нерівність має пряме проєктне наслідування: щоб витримати одного зловмисного учасника, консорціум має налічувати щонайменше чотири незалежні організації; щоб витримати двох — сім. «Незалежність» тут не адміністративна формальність, а вимога до некорельованості компрометації: вузли під керуванням одного адміністратора, на одній платформі та з одним постачальником оновлень для моделі $3f + 1$ рахуються як один.

Практичний висновок для розподілених баз даних: класичний консенсус (Raft, Paxos) захищає від *відмов*, а не від *зловмисника* всередині кластера. Якщо в моделі загроз розділу 8 присутній інсайдер-адміністратор СКБД, цілісність слід підпирати незалежними криптографічними засобами — підписами й журналами з підтверджуваною цілісністю (підрозділ 13.6).

13.4 Керування доступом до розподілених даних

Базовий рівень — автентифікація суб'єктів у СКБД. У розподіленому середовищі локальні паролі баз даних є антипатерном: вони не підлягають централізованому відкликанню, погано ротуються й не дають єдиного журналу. Належне рішення — федеративна автентифікація сервісних і людських ідентичностей із короткоживучими обліковими даними (розділ 10), взаємна TLS-автентифікація клієнта [336] та відмова від спільних технологічних облікових записів.

Деталізований контроль доступу реалізують кількома взаємодоповнювальними механізмами:

Рядкова безпека (RLS)
предикат, що автоматично додається до кожного запиту й обмежує видимі рядки атрибутами суб'єкта (підрозділ, регіон, гриф). Перевага — неможливість обійти правило з боку застосунку; ризик — складні предикати стають прихованою логікою безпеки, яку важко тестувати.

Стовпцева безпека
обмеження доступу до окремих атрибутів; типово поєднується з маскуванням.

Маскування даних
динамічна заміна значень (наприклад, показ лише останніх чотирьох цифр) при збереженні оригіналу. Не є засобом захисту від адміністратора БД, бо оригінал наявний у сховищі.

Токенізація
заміна значення випадковим сурогатом із зберіганням відповідності в окремому захищеному сервісі. На відміну від маскування, виносить чутливе значення за межі основного сховища й тому дієва проти компрометації резервних копій аналітичного контуру.

Подання (views)
логічний рівень, що приховує структуру та частину атрибутів; потребує суворого контролю прав на базові таблиці, інакше дає хибне відчуття захищеності.

У сховищах даних (data warehouse) і озерах даних (data lake) додається проблема *деградації контексту безпеки*: під час завантаження (ETL/ELT) дані втрачають початкові мітки й політики, а в озері зберігаються «як є» — у файлових форматах, доступ до яких контролює вже система зберігання об'єктів, а не СКБД. Це створює типову асиметрію: суворо захищена операційна база й слабко захищене її аналітичне відображення. Контрзаходи — наскрізне успадкування міток класифікації, каталог даних із політиками, єдиний рушій авторизації для всіх способів доступу, шифрування об'єктного сховища власними ключами [124, 358].

Принциповою організаційною вимогою є поділ обов'язків між адміністратором СКБД і власником даних: адміністратор забезпечує функціонування, але не повинен мати змоги непомітно читати чи змінювати захищені дані. Технічно це досягається шифруванням на боці клієнта, зовнішнім керуванням ключами, незмінними журналами аудиту, які адміністратор БД не може редагувати, та процедурою «двох осіб» для критичних операцій. Вимоги до розмежування доступу й реєстрації дій установлено НД ТЗІ 2.5-004-99 [33] та Правилами забезпечення захисту інформації [42].

13.5 Шифрування даних у розподілених сховищах

Шифрування **у стані спокою** на рівні томів або файлів (у СКБД — прозоре шифрування даних, TDE) захищає від фізичного викрадення носія й неналежного списання обладнання, але не від суб'єкта, що має легальний доступ до працюючої СКБД: для нього дані розшифровуються автоматично. Шифрування **в русі** (TLS 1.3 [336], IPsec [247]) обов'язкове як для клієнтських з'єднань, так і для трафіку реплікації, який часто залишається незахищеним у внутрішній мережі.

Захист від привілейованого інсайдера дають лише схеми, у яких ключ ніколи не потрапляє на сервер: **шифрування на боці клієнта** та колонкове шифрування з ключем у зовнішньому сховищі (HSM/KMS). Плата — втрата можливості виконувати над зашифрованими стовпцями пошук, сортування та з'єднання. Часткові розв'язки — детерміноване шифрування (однакові відкриті тексти дають однакові шифротексти, що уможливлює порівняння на рівність) і порядкозберігальне шифрування (зберігає відношення порядку, уможливлюючи діапазонні запити). Обидва мають доведені витоки: М. Навід, С. Камара і Ч. Райт [294] показали, що для реальних медичних баз детерміноване та порядкозберігальне шифрування дає змогу відновити переважну частину значень чутливих атрибутів за допомогою атак на

основі частот і впорядкування, навіть без доступу до ключа. Тому такі режими допустимі лише для атрибутів із високою ентропією та після кількісної оцінки залишкового ризику.

Архітектура CryptDB [324] продемонструвала можливість виконання значної частини SQL над зашифрованими даними через «цибулини» шифрів різної міцності, а промислове втілення цього напряму — Always Encrypted у Azure SQL, де операції над шифротекстом виконуються в захищеному анклаві, а ключі залишаються під контролем клієнта [79]. Це підводить до **конфіденційних обчислень**: дані розшифровуються лише всередині апаратно ізольованого середовища виконання, атестованого перед передаванням ключів (докладніше — у розділі 12).

Таблиця 13.2 — Порівняння механізмів шифрування даних сховища

Механізм	Хто володіє ключем	Від чого захищає	Функційні обмеження
TDE / шифрування томів	сервер (СКБД, ОС)	викрадення носія, списання дисків	немає
Колонкове (на сервері)	сервер або KMS	частково — від доступу до файлів	функції над стовпцем
Клієнтське (рандомізоване)	клієнт	адміністратор БД, хмарний провайдер	пошук, сортування, з'єднання неможливі
Детерміноване	клієнт	слабко: витік частот [294]	лише рівність
Порядкозберігальне	клієнт	слабко: витік порядку	рівність і діапазон
Анклав / конфіденційні обчислення	клієнт, атестація анклаву	адміністратор, гіпервізор	залежність від апаратної платформи

Для державних інформаційних ресурсів України криптографічні механізми мають відповідати національним алгоритмам: блоковому перетворенню за ДСТУ 7624:2014 [17], гешуванню за ДСТУ 7564:2014 [18] та електронному підпису за ДСТУ 4145-2002 [16] у поєднанні з вимогами законодавства про електронні довірчі послуги [44].

13.6 Забезпечення цілісності та достовірності записів

Контрольні суми виявляють випадкове спотворення, але не цілеспрямовану підміну: порушник, що змінює блок, перерахує й контрольну суму. Криптографічна цілісність у розподілених сховищах будується на геш-деревах, запропонованих Р. Мерклом [281]. Листя дерева — геші блоків даних, внутрішні вузли — геші конкатенації нащадків, корінь — компактний «відбиток» усього набору. Дві властивості роблять конструкцію незамінною: по-перше, звіряння двох реплік коштує $O(\log n)$ замість повного передаван-

ня даних (механізм anti-entropy у розподілених сховищах); по-друге, доказ належності окремого запису має розмір $O(\log n)$ і перевіряється незалежно від власника сховища.

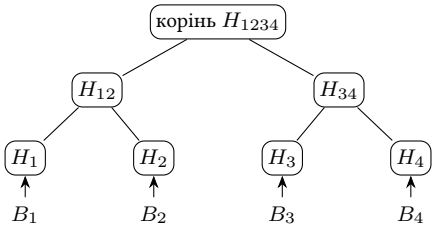


Рис. 13.2 — Геш-дерево Меркла: доказ належності B_2 складають H_1 і H_{34} (за [281])

Практичні застосування у сховищах даних: журнал лише для дописування (**append-only ledger**), у якому кожен запис містить геш попереднього, а періодичні кореневі геші публікуються поза системою (в іншому відомстві, у кваліфікованого надавача довірчих послуг, у публічному реєстрі) — це перетворює непомітну зміну історії на технічно виявний факт. Додатковий рівень — кваліфікований електронний підпис або кваліфікована електронна позначка часу над кожним записом [44], що дає не лише цілісність, а й невідмовність авторства.

У реплікованому середовищі виявлення несанкціонованої зміни спирається на періодичне звіряння кореневих гешів реплік. Розбіжність кореня за збігу журналів консенсусу однозначно вказує на позапротокольну модифікацію — запис безпосередньо у файли сховища або в резервну копію, що є типовим прийомом інсайдера й описаний у матриці MITRE ATT&CK [288].

13.7 Загрози прикладного рівня та захист приватності

Ін'єкції залишаються провідним класом атак на дані [320]. У NoSQL-сховищах вони набувають форми підстановки об'єктів-операторів у запит (наприклад, оператора порівняння замість рядка) і часто не виявляються класичними сигнатурами SQL. Універсальний контрзахід — параметризовані запити й сувора типізація вхідних даних, а не фільтрація рядків.

Не менш небезпечними є надмірні привілеї застосунку: єдиний обліковий запис із правами власника схеми перетворює будь-яку вразливість вебрівня на повний контроль над базою. Належна практика — окремі ролі для читання, запису й міграцій, заборона DDL для робочого облікового запису, обмеження мережевого доступу до СКБД згідно з принципами нульової довіри (розділ 12).

Резервні копії, журнали та аналітичні вивантаження утворюють «тіньовий» периметр даних. Копія бази у файлі на файловому ресурсі, дамп у системі керування завданнями, персональні дані в текстовому журналі помилок або CSV-вивантаження для звітності регулярно стають джерелом витоків, бо на них не поширюються ані RLS, ані шифрування колонок. Обов'язковим є інвентаризація всіх похідних наборів даних та застосування до них того самого класу захисту, що й до первинного.

Окремий клас — **атаки виведення** (inference) та деанонімізація. Знеособлений набір даних може бути повторно ідентифікований поєднанням квазіідентифікаторів. Л. Свіні [392] запропонувала модель **k-анонімності**: кожен запис має бути невідрізнюваним щонайменше від $k-1$ інших за квазіідентифікаторами. Модель уразлива до атак однорідності, що усувається **ℓ-різноманітністю** [273] — вимогою наявності щонайменше ℓ «добре представлених» значень чутливого атрибута в кожному класі еквівалентності. Проте обидві моделі синтаксичні й не дають гарантій проти супутніх знань.

Строгу гарантію дає **диференційна приватність** К. Дворк [153]. Рандомізований механізм $\mathcal{M}$ задовольняє ε-диференційну приватність, якщо для будь-яких сусідніх наборів даних D_1 і D_2, що різняться одним записом, і будь-якої підмножини результатів $S \subseteq \mathrm{Range}(\mathcal{M})$

$$\Pr[\mathcal{M}(D_1) \in S] \le e^{\varepsilon} \cdot \Pr[\mathcal{M}(D_2) \in S].$$

Параметр ε є кількісним «бюджетом приватності»: менші значення означають суворіший захист і більший шум. Для числових запитів із чутливістю Δf достатньо додати шум Лапласа з масштабом $\Delta f / \varepsilon$. Практично важливо, що бюджет *витрачається* з кожним запитом і має відстежуватися централізовано, інакше серія «приватних» запитів відновлює початкові значення. Настанови щодо застосування знеособлення до державних наборів даних систематизовано в NIST SP 800-188 [181].

13.8 Технології розподіленого реєстру та блокчейн

Технологія розподіленого реєстру (DLT) — це спосіб ведення реплікованого журналу транзакцій без єдиного довіреного оператора, у якому цілісність історії забезпечується ланцюгом гешів, а порядок — протоколом консенсусу [420]. Блокчейн у формі, запропонованій С. Накамото [293], поєднує геш-ланцюг блоків, дерево Меркла транзакцій усередині блоку та консенсус на основі доведення роботи (PoW), де за коректність відповідає економічна вартість обчислень.

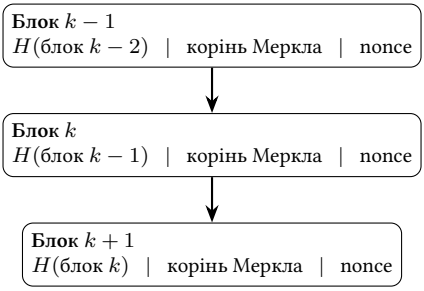


Рис. 13.3 — Геш-зчеплення блоків: зміна одного блоку інвалідує всі наступні

За моделлю допуску розрізняють публічні (бездозвільні, permissionless), приватні та консорціумні (дозвільні, permissioned) реєстри (пор. режим допуску в розділі 2). Вибір типу визначає застосовний механізм консенсусу: у бездозвільних середовищах використовують PoW або доведення частки (PoS), у дозвільних — візантійські протоколи типу PBFT з обмеженням $n \geq 3f + 1$.

Таблиця 13.3 — Порівняння типів розподілених реєстрів

Ознака	Публічний	Консорціумний	Приватний
Доступ до запису	будь-хто	члени консорціуму	один оператор
Консенсус	PoW, PoS	PBFT та похідні	реплікація, Raft
Пропускна здатність	низька	середня	висока
Модель довіри	економічна	взаємний контроль	довіра оператора
Захист від інсайдера	високий	середній	фактично відсутній
Правова прийнятність для реєстрів	низька	умовна	визначається законом

Смартконтракти — програми, що виконуються всіма вузлами реєстру — успадковують усі класичні вразливості, помножені на незмінність коду. Систематизація Н. Атцеї, М. Бартолетті та Т. Чімолі [84] виокремлює реентрантність (повторний рекурсивний виклик до оновлення стану), переповнення цілих, некоректне оброблення винятків, залежність від порядку транзакцій і залежність від часової позначки. Окремий системний ризик — **оракули**: реєстр не має доступу до зовнішнього світу, тому будь-яка прив'язка до реальних фактів (курс, показник лічильника, факт постачання) створює довірену точку поза захищеним периметром і зводить нанівець гарантії консенсусу.

Проблема масштабованості DLT є структурною: вимога, щоб кожен вузол виконував і зберігав кожну транзакцію, обмежує пропускну здатність незалежно від потужності обладнання. Тому для відомчих ресурсів із мільйонами операцій на добу реєстр придатний як *шар засвідчення* (публікація кореневих гешів, позначок часу, журналів доступу), а не як основне сховище.

Некоректними є сценарії, у яких DLT пропонують як заміну реляційній базі державного реєстру «заради незмінності». Такий вибір: (а) не усуває залежності від коректності введених даних; (б) суперечить праву на виправлення й видалення персональних даних. Конфлікт незмінності реєстру зі статтями 16 і 17 GDPR [328] детально проаналізовано у дослідженні Європейського Парламенту [171]: єдиний практично прийнятний підхід — зберігати в ланцюзі лише криптографічні зобов'язання (геші, підписи), а самі персональні дані — поза ланцюгом, із можливістю знищення (унеможливлення відновлення шляхом видалення ключа або первинного образу). Аналогічно вимога Закону України «Про захист персональних даних» [53] щодо видалення даних робить розміщення персональних даних безпосередньо у незмінному реєстрі юридично неприйнятним. Стан і перспективи застосування блокчейн-рішень в Україні розглянуто, зокрема, у роботі С. Спасітєлєвої і В. Бурячка [64].

13.9 Резервне копіювання й архівування розподілених даних

Розподіленість не є резервним копіюванням: реплікація синхронно поширює й помилкове видалення, і шифрування даних програмою-вимагачем. Сучасна галузева практика формулюється як правило **3-2-1-1-0**: три копії даних, на двох різних типах носіїв, одна — поза майданчиком, одна — незмінна або з повітряним зазором, нуль помилок під час перевірки відновлення.

Ключові технічні вимоги:

- **незмінні резервні копії** (immutable, WORM) із блокуванням на визначений строк, яке не може скасувати навіть адміністратор резервного копіювання;
- окремий контур автентифікації системи резервного копіювання — компрометація домену не повинна відкривати доступ до сховища копій;
- **повітряний зазор** (логічний або фізичний) для щонайменше однієї копії;
- шифрування копій ключами, що зберігаються незалежно від сховища;

- регулярна перевірка *відновлюваності* (а не лише факту створення копії) з вимірюванням фактичних RPO/RTO;
- захист самого каталогу резервних копій — його знищення робить відновлення практично неможливим.

Для розподілених баз додається вимога узгодженості копії: копія, зроблена незалежно на кожному вузлі, може не відповідати жодному цілісному стану системи. Потрібні або узгоджені за часом знімки (з фіксацією позиції журналу реплікації), або відновлення на момент часу (PITR) на основі журналу. Детальніше стратегії відновлення й метрики неперервності розглянуто в розділі 15 [226].

13.10 Українські аспекти: захист державних електронних реєстрів

Правовий каркас функціонування державних реєстрів в Україні визначає Закон «Про публічні електронні реєстри» [59], який запроваджує поняття держателя, адміністратора й реєстратора, вимоги до взаємодії реєстрів через систему електронної взаємодії та до захисту реєстрових даних. Захист самих систем регулюється Законом «Про захист інформації в інформаційно-комунікаційних системах» [52], Правилами КМУ № 373 [42] та комплексом НД ТЗІ [31, 34], а для реєстрів, віднесених до критичної інфраструктури, — Загальними вимогами до кіберзахисту [22] і Законом «Про критичну інфраструктуру» [55].

Досвід 2022 року дав унікальний практичний матеріал. До повномасштабного вторгнення значна частина державних реєстрів зберігалася у центрах обробки даних на території України, іноді — в одному фізичному майданчику, що робило їх уразливими до кінетичного ураження. Постанова Кабінету Міністрів України від 12.03.2022 № 263 [11] врегулювала питання функціонування інформаційно-комунікаційних систем і публічних електронних реєстрів в умовах воєнного стану, зокрема створивши правову підставу для перенесення й резервування даних, у тому числі з використанням хмарних ресурсів за межами України. Разом із Законом «Про хмарні послуги» [62] це сформувало модель, у якій публічна хмара є легітимним майданчиком відновлення для державних ресурсів.

Уроки цього досвіду для проєктування захисту розподілених даних:

1. географічний розподіл копій має плануватися *до* настання загрози, разом із перевіреними процедурами перемикання;
2. правовий режим даних (персональні дані, службова інформація, державна таємниця) визначає допустимі майданчики: інформація, що становить державну таємницю [43], не може розміщуватися у публічній хмарі;

3. криптографічний контроль над даними в чужій інфраструктурі (шифрування на боці власника, власне керування ключами) є умовою прийнятності геореплікації;
4. канали зв'язку з резервним майданчиком, у тому числі супутникові й інші **безпроводові**, мають бути частиною плану та регулярно випробовуватися;
5. доступ до реєстрових даних у режимі відновлення потребує посиленого моніторингу, бо саме тоді контроль послаблюється (розділ 14) [117].

13.11 Кейс: проєктування захисту розподіленого сховища даних відомства

Вихідні умови. Центральний орган виконавчої влади експлуатує операційну базу (близько 40 млн записів про фізичних осіб), аналітичне сховище для звітності та озеро даних для міжвідомчого обміну. Три майданчики: основний і резервний в Україні, майданчик відновлення — у публічній хмарі держави ЄС. Вимоги: RPO $\leq$ 15 хв, RTO $\leq$ 4 год, доступність 99,9 %.

Проєктні рішення. Операційна база — кластер із трьох вузлів у режимі синхронної кворумної реплікації ($N = 3$, $W = 2$, $R = 2$) на основному майданчику з асинхронною реплікацією на резервний; узгодженість — лінеаризовна для операцій зміни персональних даних. Ідентифікатори осіб у аналітичному контурі токенізовано, сервіс відповідності розміщено лише на основному майданчику. Стовпці з чутливими атрибутами шифруються на боці клієнта; ключі — в апаратному модулі безпеки, поза контролем адміністраторів СКБД. Доступ аналітиків — через подання з рядковою безпекою; регулярні статистичні вивантаження проходять через механізм диференційної приватності з обліком бюджету ε. Усі зміни реєстрових записів фіксуються у журналі лише для дописування; кореневий геш Меркла щодоби підписується і подається кваліфікованому надавачеві електронних довірчих послуг, що дає незалежний доказ цілісності історії. Резервні копії — за схемою 3-2-1-1-0, незмінні, з окремим контуром автентифікації; щоквартально проводиться повне навчальне відновлення з вимірюванням фактичних RPO/RTO.

Результат кількісної оцінки. За $p = 10^{-3}$ і $r = 3$ для 2000 шардів $P_{\text{втрати}} \approx 2 \cdot 10^{-6}$ на інтервал, що відповідає цільовому рівню довговічності; вузьким місцем залишається кореляція відмов основного майданчика, що й обґрунтовує третю копію в іншій юрисдикції. Залишкові ризики: компрометація сервісу токенізації (усувається поділом обов'язків і посиленим моніторингом) та витік через застарілі аналітичні вивантаження (усувається інвентаризацією й автоматичним знищенням за строком).

Висновки до розділу

Захист розподілених даних не зводиться до шифрування й розмежування доступу: він визначається взаємодією схеми реплікації, моделі узгодженості та протоколу консенсусу, які самі є механізмами безпеки, бо саме вони визначають, який стан даних вважати істинним. Кворумна арифметика $W+R>N$ формалізує гарантію цілісності читання, а нерівність $n \geq 3f+1$ задає мінімальний розмір довіреної групи за наявності зловмисних учасників; обидві умови мають перевірятися як елементи проєкту системи захисту, а не як параметри продуктивності.

Шифрування у розподіленому сховищі слід обирати за критерієм «від кого захищаємо»: TDE не захищає від адміністратора, а функційно зручні детерміноване й порядкозберігальне шифрування мають доведені витоки. Гарантії цілісності доцільно виносити за межі СКБД — у геш-дерева, журнали лише для дописування та зовнішнє засвідчення кореневих гешів. Приватність аналітичних наборів потребує переходу від синтаксичних моделей (k-анонімність, ℓ-різноманітність) до формальних гарантій диференційної приватності з централізованим обліком бюджету.

Технології розподіленого реєстру доцільні там, де відсутній єдиний довірений оператор, а не як універсальна заміна бази даних; їхня незмінність принципово конфліктує з правом на видалення персональних даних, тому в державних системах реєстр застосовний передусім як шар засвідчення. Нарешті, розподіленість не замінює резервного копіювання: лише незмінні копії з повітряним зазором і регулярно перевіреною відновлюваністю захищають від логічного знищення даних. Український досвід 2022 року підтверджує, що завчасне географічне рознесення копій із дотриманням правового режиму даних є критичним чинником стійкості державних інформаційних ресурсів.

Питання для самоперевірки

1. Чим відрізняються реплікація і шардування як механізми та як кожен з них впливає на конфіденційність, цілісність і доступність даних?
2. Сформулюйте умови перетину кворумів. Що станеться з гарантіями системи, якщо адміністратор збільшить N, не змінивши W і R?
3. Поясніть, чому асинхронна реплікація є ризиком не лише для доступності, а й для цілісності обліку.
4. Які аномалії допускає snapshot-ізоляція і як вони можуть перетворитися на вразливість механізму контролю квот або залишків?
5. Порівняйте двофазну фіксацію та шаблон Saga за критеріями стійкості до відмови координатора й видимості проміжних станів.

6. Чому класичний консенсус (Raft, Paxos) не захищає від зловмисного адміністратора кластера? Які механізми потрібно додати?
7. Обґрунтуйте нерівність $n \geq 3f + 1$ та поясніть, яким вимогам мають відповідати вузли, щоб їх можна було вважати незалежними.
8. У чому полягає відмінність маскування від токенізації з погляду захисту резервних копій аналітичного контуру?
9. Чому TDE не захищає дані від адміністратора СКБД і які схеми шифрування розв'язують цю задачу? Якою є їхня функційна ціна?
10. Які витоки інформації властиві детермінованому та порядкозберігальному шифруванню? За яких умов їх застосування є прийнятним?
11. Опишіть, як геш-дерево Меркла дає змогу виявити позапротокольну зміну даних у репліці та довести належність окремого запису.
12. Порівняйте k-анонімність, ℓ-різноманітність і ε-диференційну приватність за силою гарантій; поясніть, чому бюджет ε потребує централізованого обліку.
13. Наведіть коректний і некоректний сценарії застосування DLT для державного інформаційного ресурсу та обґрунтуйте обидва.
14. У чому полягає конфлікт незмінності розподіленого реєстру з правом на видалення персональних даних і які архітектурні підходи його пом'якшують?
15. Запропонуйте методику експериментальної перевірки відновлюваності розподіленої бази даних відомства, що дає змогу виміряти фактичні RPO і RTO та виявити приховані кореляції відмов.

РОЗДІЛ 14

Моніторинг безпеки, виявлення вторгнень та аудит розподілених систем

Жоден комплекс превентивних механізмів не є повним: криптографія, керування доступом і сегментація зменшують імовірність успішної атаки, але не зводять її до нуля. Тому архітектура захисту розподілених інформаційних ресурсів обов'язково доповнюється контуром спостереження — підсистемою, яка збирає свідчення про поведінку системи, виявляє відхилення й дає підстави для реагування. Розділ викладає наукові засади моніторингу безпеки, кількісну теорію виявлення вторгнень, архітектуру SIEM та центрів безпеки, а також науково-організаційні основи аудиту й тестування захищеності. Він спирається на модель загроз розділу 8 та архітектуру нульової довіри розділу 12, а процедури реагування на виявлені інциденти детально розгортає розділ 15.

14.1 Наукові засади моніторингу: спостережуваність розподіленої системи

Поняття **спостережуваності** (observability) прийшло в інженерію розподілених систем із теорії керування, де система вважається спостережуваною, якщо її внутрішній стан однозначно відновлюється за скінченною послідовністю вимірювань виходу. У кібербезпеці цей критерій пом'якшується: йдеться не про точне відновлення стану, а про здатність відрізнити множину станів, які відповідають штатному функціонуванню, від станів, породжених діями порушника.

Нехай S — простір станів розподіленої системи, а O — простір спостережень, породжуваних телеметрією. Відображення $\varphi : S \to O$ є неін'єктивним: різні стани дають однакові спостереження. Множина $\varphi^{-1}(o)$ для конкретного спостереження o визначає невизначеність спостерігача. **Сліпою зоною** моніторингу називають таку підмножину $B \subset S$, для якої всі стани зловмисної природи мають спостережувані образи, невідрізненні від образів легітимних станів. Практично сліпі зони породжуються трьома причинами: відсутністю джерела телеметрії (наприклад, несконфігуроване журналювання доступу до сховища об'єктів), недостатньою деталізацією записів (журнал фіксує факт автентифікації, але не використаний метод), а також втратою подій через переповнення буферів або обмеження бюджету зберігання.

Практика телеметрії спирається на три взаємодоповнювані сигнали: **журнали** (дискретні записи про події з часовою міткою), **метрики** (агрего-

вані числові ряди) і **трасування** (причинно-наслідкові ланцюжки викликів у межах однієї транзакції). Специфікація OpenTelemetry уніфікує їх модель даних та транспорт OTLP, додаючи четвертий сигнал — профілі [316]. Для безпеки критично важливим є саме трасування: у мікросервісній системі лише воно дозволяє встановити, який зовнішній запит спричинив підозрілий доступ до бази даних, коли між ними лежить п'ять проміжних викликів. Водночас повне трасування є дорогим, тому застосовують вибірку (sampling), яка сама стає джерелом сліпих зон — відкидання «нецікавих» трас за низьким порогом затримки систематично приховує повільні, обережні атаки.

Теоретична межа виявлення формулюється так: якщо активність порушника статистично невідрізненна від легітимної на рівні наявної телеметрії, жодний алгоритм не забезпечить виявлення краще за випадкове вгадування. Це прямо випливає з леми Неймана—Пірсона: якість найкращого критерію обмежена відстанню між розподілами спостережень за гіпотезами «норма» і «атака». Наслідок для практики має організаційний характер: інвестиції в аналітику мають сенс лише після того, як забезпечено достатню повноту й якість джерел даних.

14.2 Джерела подій безпеки та нормалізація телеметрії

Склад джерел для розподіленої ІКС визначається межами відповідальності та переліком критичних активів. Типовий мінімум охоплює: журнали автентифікації та привілейованих операцій ОС; журнали серверів застосунків і вебсерверів; аудит СКБД (успішні та невдалі звернення, зміни схеми, експорт великих обсягів); телеметрію мережевих засобів — міжмережевих екранів, потоків NetFlow/IPFIX, DNS-резолверів, зворотних проксі; журнали контролерів безпроводових мереж і безпроводових систем виявлення вторгнень (WIDS); події засобів захисту кінцевих точок класу EDR; журнали хмарних площин керування (створення й видалення ролей, зміна політик доступу, доступ до сховищ); журнали систем керування ідентичністю та PAM. Настанова NIST SP 800-92 наголошує, що більшість проблем журналювання є не технічними, а управлінськими: невизначені вимоги до складу записів, відсутність власника процесу й перевірки повноти [246].

Запис події безпеки має бути придатним для автоматичної кореляції, тож до нього висувають вимоги: однозначний ідентифікатор джерела; часова мітка з часовим поясом і субсекундною точністю; тип події за керованим словником; суб'єкт (обліковий запис, сервісна ідентичність); об'єкт (ресурс, файл, таблиця); результат (успіх/відмова з кодом причини); мережевий контекст; ідентифікатор кореляції (trace-id), що зшиває події різних рівнів.

Нормалізація перетворює різнорідні формати до спільної схеми. Промисловими схемами є Elastic Common Schema [158] та Open Cybersecurity Schema Framework, який із 2024 р. розвивається під егідою Linux Foundation як вендоронезалежна модель подій безпеки [314]. **Збагачення** додає контекст, відсутній у джерелі: геолокацію та репутацію IP-адрес, класифікацію активу за критичністю, належність облікового запису до привілейованої групи, зіставлення з індикаторами компрометації. Збагачення суттєво підвищує цінність події: сам факт входу з нової країни малоінформативний, але вхід із нової країни під обліковим записом адміністратора домену поза робочим часом уже є придатним для правила кореляції.

Окремою передумовою кореляції є **синхронізація часу**. Якщо годинники майданчиків розходяться на десятки секунд, послідовність подій відновлюється неправильно, і причинно-наслідковий ланцюжок атаки руйнується. Для розподіленої ІКС потрібна ієрархія стратумів NTP із власними довіреними серверами на кожному майданчику, контроль розходження як окрема метрика моніторингу та фіксація в записі як локального часу, так і часу приймання колектором.

14.3 Централізоване збирання, зберігання та цілісність журналів

Конвеєр телеметрії будується як багатоступенева система з розв'язанням джерел і споживачів через буферну чергу (рис. 14.1). Буферизація виконує дві функції: згладжує пікові навантаження, які під час атаки зростають на порядок, і забезпечує стійкість до тимчасової недоступності центрального сховища — критична властивість для багатомайданчикової системи з нестабільними каналами.

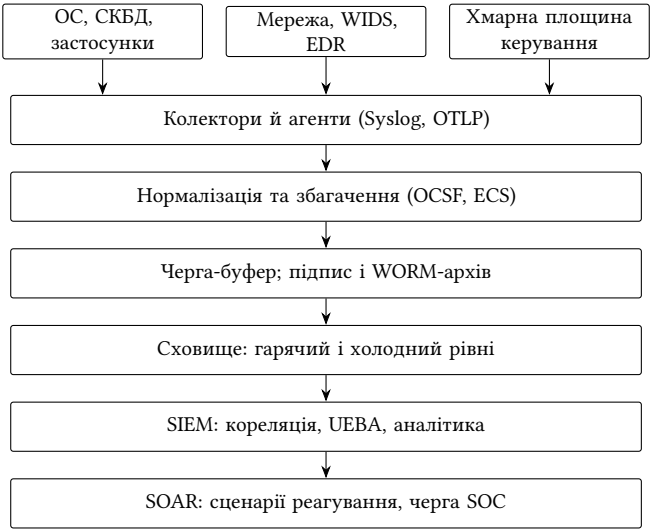


Рис. 14.1 — Конвеєр телеметрії безпеки та місце SIEM у ньому

Транспортом історично є Syslog; сучасний профіль протоколу визначено RFC 5424, який запроваджує структуровані дані та вимагає підтримки транспорту з TLS [182]. Проблему довідності записів розв'язує механізм підписаних повідомлень RFC 5848: блоки підпису забезпечують автентичність походження, цілісність, стійкість до повторів і виявлення пропущених повідомлень [244]. Архітектурно недоторканність журналів досягається поєднанням трьох заходів: односпрямованої передачі до архіву, запису в носій режиму WORM та ланцюжкового гешування блоків записів, коли геш попереднього блока входить до наступного, унеможливлюючи вибіркове видалення.

Строки зберігання визначаються не технічними, а правовими й слідчими міркуваннями. Для об'єктів критичної інфраструктури вимоги випливають із Закону України «Про основні засади забезпечення кібербезпеки України» [58] та Загальних вимог до кіберзахисту об'єктів критичної інфраструктури [22]. Оскільки час від компрометації до виявлення в галузевій статистиці часто вимірюється тижнями, а для прихованих кампаній — місяцями, глибина зберігання менша за 90 діб істотно обмежує ретроспективне розслідування; обґрунтованою практикою є 30 діб «гарячого» індексованого зберігання та 150–335 діб «холодного» архіву.

Журнали майже завжди містять персональні дані — ідентифікатори користувачів, IP-адреси, шляхи до файлів. Тому конвеєр підпадає під дію Закону України «Про захист персональних даних» [53] та, за наявності

європейського сегмента, GDPR [328]: потрібні визначена правова підстава обробки (законний інтерес забезпечення безпеки мережі), мінімізація складу полів, псевдонімізація там, де ідентичність не потрібна для аналізу, обмежені строки та контроль доступу самих аналітиків до чутливих полів.

14.4 Системи виявлення вторгнень: класифікація та якість виявлення

Формальні засади галузі закладено моделлю Дороті Деннінг, у якій виявлення вторгнень трактується як задача статистичного контролю за профілями суб'єктів: система будує профілі нормальної поведінки й сигналізує про статистично значущі відхилення [148]. Сучасна класифікація за точкою спостереження виділяє мережеві (NIDS), вузлові (HIDS/EDR) та гібридні системи; за реакцією — пасивні системи виявлення та системи запобігання (IPS), що активно блокують трафік; за методом — сигнатурні, аномальні та специфікаційні. Систематизацію технологій і рекомендації щодо їх розгортання подано у NIST SP 800-94 [352]. Специфіка розподілених систем полягає в тому, що суцільне мережеве спостереження втрачає силу через наскрізне шифрування та динамічність адрес контейнерів, тому центр ваги зміщується до вузлової телеметрії й журналів площин керування.

Таблиця 14.1 — Порівняння методів виявлення вторгнень

Ознака	Сигнатурний	Аномальний	Специфікаційний
Основа рішення	Збіг із відомим шаблоном	Відхилення від профілю норми	Порушення формальної специфікації
Невідомі атаки	Не виявляє	Потенційно виявляє	Виявляє в межах моделі
Рівень FPR	Низький	Високий	Низький
Підготовка	Ведення бази правил	Навчання на «чистих» даних	Формалізація дозволеної поведінки
Пояснюваність	Висока	Низька	Висока
Ухилення	Мутація, обфускація	Отруєння профілю	Дії в межах специфікації
Застосування	Периметр, EDR	UEBA, мережеві потоки	Контейнери, АСК ТП

Якість виявлення оцінюють через матрицю невідповідностей із величинами TP, FP, TN, FN. Базові показники:

$$TPR = \frac{TP}{TP + FN}, \quad FPR = \frac{FP}{FP + TN}, \qquad P = \frac{TP}{TP + FP}, \qquad F_1 = \frac{2P \cdot TPR}{P + TPR}. \tag{14.1}$$

Крива ROC у координатах (FPR, TPR) і площа під нею (AUC) характеризують детектор незалежно від обраного порога. Проте для задач із украй незбалансованими класами інформативнішою є крива «точність—повнота», оскільки ROC маскує вплив рідкості подій.

Саме рідкість породжує **парадокс базової частоти** (base rate fallacy), який С. Аксельссон описав як фундаментальне обмеження систем виявлення вторгнень [87]. За формулою Байєса ймовірність того, що подія справді є вторгненням (I) за умови спрацювання сигналу (A), дорівнює

$$P(I \mid A) = \frac{P(A \mid I)\,P(I)}{P(A \mid I)\,P(I) + P(A \mid \neg I)\,\bigl(1 - P(I)\bigr)}. \tag{14.2}$$

Числовий приклад. Розподілена ІКС породжує 10^7 подій за добу, з яких справді зловмисними є 20, тобто $P(I) = 2 \cdot 10^{-6}$. Детектор має $TPR = P(A \mid I) = 0{,}99$ і $FPR = P(A \mid \neg I) = 10^{-4}$. Тоді

$$P(I \mid A) = \frac{0{,}99 \cdot 2 \cdot 10^{-6}}{0{,}99 \cdot 2 \cdot 10^{-6} + 10^{-4} \cdot 0{,}999998} \approx \frac{1{,}98 \cdot 10^{-6}}{1{,}02 \cdot 10^{-4}} \approx 0{,}019.$$

Отже, попри «відмінні» показники, лише близько 1,9 % сповіщень є істинними: аналітик отримує приблизно 1000 хибних тривог на 20 справжніх. Щоб досягти $P(I \mid A) = 0{,}5$, потрібно знизити FPR до $\approx 2 \cdot 10^{-6}$, тобто у п'ятдесят разів. Це пояснює, чому практичні архітектури не покладаються на одиночний детектор, а будують багатоступеневу фільтрацію: збагачення контекстом, кореляцію кількох слабких ознак і врахування критичності активу, що фактично підвищує апріорну ймовірність $P(I)$ у підмножині, яка розглядається.

14.5 Кореляція та аналітика: SIEM, UEBA, SOAR

SIEM (Security Information and Event Management) — платформа, що об'єднує централізоване збирання нормалізованих подій, їх довготривале зберігання, кореляцію в реальному часі та інструменти розслідування. Правило кореляції формально є предикатом над скінченним вікном подій; типові класи правил: порогові (кількість невдалих автентифікацій понад n за t), послідовнісні (спрацювання EDR, а потім вихідне з'єднання на нову адресу), статистичні (аномальний обсяг вивантаження з СКБД) та контекстні (дія, яка суперечить кадровому статусу суб'єкта). Для розподіленої системи ключовим є міжмайданчиковий сценарій: подія на одному майданчику набуває сенсу лише разом із подією на іншому — наприклад, успішний вхід у Києві та одночасний вхід під тим самим обліковим записом у хмарному сегменті ЄС («неможлива подорож»).

UEBA доповнює правила поведінковим профілюванням користувачів і сутностей, даючи змогу виявляти зловживання легітимними повноваженнями, які не порушують жодного явного правила. **SOAR** автоматизує реагування за сценаріями (playbooks): збагачення сповіщення, ізоляція вузла, відкликання сесійних токенів, створення тікета. Автоматизація має бути пропорційною ризику хибного спрацювання: автоматичне блокування облікового запису оператора критичного технологічного процесу може завдати більшої шкоди, ніж сама атака.

Машинне навчання застосовують для стиснення потоку сповіщень, кластеризації подібних інцидентів, виявлення аномалій у часових рядах і пріоритезації. Обмеження є суттєвими: відсутність розмічених даних про реальні вторгнення; дрейф понять, коли «норма» змінюється швидше, ніж перенавчається модель; чутливість до отруєння навчальної вибірки, коли порушник поступово привчає модель до своєї активності; вразливість до змагальних збурень (adversarial ML), за яких мінімальні зміни ознак переводять шкідливий зразок у клас «норма». Додатковою перешкодою є проблема пояснюваності: аналітик SOC не може ані підтвердити, ані спростувати сповіщення, для якого модель не подає ознак, що зумовили рішення, а без цього неможливе й формування доказової бази. Дослідницьким пріоритетом є гібридні схеми, у яких модель звужує простір пошуку, а остаточне рішення формулюється поясненним правилом.

14.6 Полювання на загрози та кіберрозвідка

Полювання на загрози (threat hunting) — проактивний пошук ознак компрометації, що вже присутні в системі, але не породили сповіщень. За методологією це наукова діяльність: аналітик формулює гіпотезу, операціоналізує її у вигляді запиту до телеметрії, перевіряє на даних і документує результат незалежно від того, підтвердилася гіпотеза чи ні (рис. 14.2). Негативний результат теж є цінним: він або підтверджує відсутність техніки, або виявляє сліпу зону телеметрії.

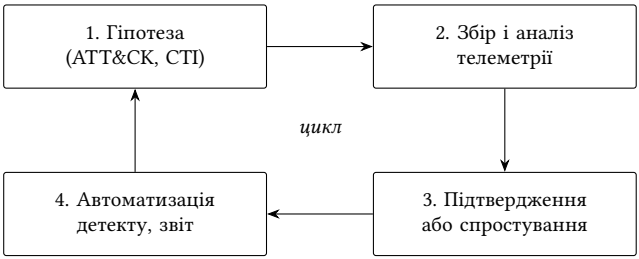


Рис. 14.2 — Гіпотезо-орієнтований цикл полювання на загрози

Джерелом гіпотез слугує матриця MITRE ATT&CK [288] — база знань тактик і технік, побудована на спостереженнях реальних кампаній; її призначення та принципи курування описано в документі «MITRE ATT&CK: Design and Philosophy» [389]. Гіпотеза формулюється як твердження про конкретну техніку: «супротивник використовує дійсні облікові записи для міжмайданчикового горизонтального переміщення через адміністративні протоколи». Пріоритет технік визначається профілем загроз організації: для української критичної інфраструктури це насамперед техніки, задокументовані у сповіщеннях CERT-UA [117] та в оглядах ENISA [161].

Піраміда болю Д. Бьянко впорядковує індикатори за витратами, яких зазнає порушник у разі їх блокування: геші файлів, IP-адреси та доменні імена змінюються тривіально, мережеві й вузлові артефакти та інструменти — складніше, а тактики, техніки й процедури (TTP) вимагають перебудови самого способу дій [97]. Звідси випливає стратегічний висновок: детекти, побудовані на рівні TTP, мають незрівнянно довший строк корисності, ніж списки IP-адрес. Це проводить межу між **індикаторами компрометації** (IoC — свідчення того, що подія вже сталася) та **індикаторами атаки** (IoA — ознаки поведінки, характерної для певної техніки).

Обмін кіберрозвідувальними даними (CTI) стандартизовано специфікаціями OASIS: STIX 2.1 визначає граф-орієнтовану мову опису загроз, спостережних об'єктів і зв'язків між ними [386], а TAXII 2.1 — прикладний протокол їх передавання через колекції та канали [395]. Практичне значення стандартів полягає в можливості автоматично приймати індикатори від національної команди реагування та галузевих спільнот і подавати їх у SIEM без ручного оброблення.

14.7 Організація центру безпеки (SOC)

SOC — організаційна структура, що забезпечує безперервність процесів моніторингу, виявлення та початкового реагування. Розрізняють внутрішній SOC (повний контроль, високі витрати на цілодобове чергування), сервісну модель MSSP (економія, але зовнішній постачальник не володіє контекстом бізнес-процесів і несе обмежену відповідальність) та гібридну модель, у якій зовнішній постачальник забезпечує чергування першої лінії, а внутрішня команда — аналіз, полювання та реагування. Для об'єктів критичної інфраструктури гібридна модель переважає, оскільки передавання повного обсягу телеметрії зовнішній стороні створює власні ризики й правові обмеження.

Класична триярусна модель передбачає першу лінію (тріаж сповіщень за регламентом), другу (розслідування інцидентів, реконструкція ланцюжка) і третю (полювання на загрози, розроблення детектів, форензика). Ключові метрики ефективності: MTTD — середній час до виявлення; MTTR —

середній час до локалізації або відновлення; частка хибнопозитивних сповіщень; покриття технік ATT&CK. Останню метрику формалізують як

$$C = \frac{\sum_{i=1}^{|T|} w_i \, c_i}{\sum_{i=1}^{|T|} w_i}, \qquad c_i \in \{0; 0{,}5; 1\}, \tag{14.3}$$

де T — множина релевантних для профілю загроз технік, $w_i > 0$ — вага техніки за критичністю, c_i — рівень покриття (відсутнє, часткове, повне); нормування на суму ваг забезпечує $C \in [0; 1]$ (за рівних ваг C збігається з показником K із розділу 8). Регулярний перерахунок C перетворює розвиток SOC із набору розрізнених закупівель на керований процес.

Таблиця 14.2 — Фрагмент матриці покриття технік ATT&CK

Тактика	Техніка (приклад)	Джерело телеметрії	Покриття
Первинний доступ	Фішинг із вкладенням	Поштовий шлюз, EDR	Повне
Виконання	Інтерпретатор команд	EDR, аудит процесів	Повне
Закріплення	Створення облікового запису	Журнал каталогу	Повне
Підвищення прав	Зловживання токеном	EDR	Часткове
Ухилення	Вимкнення журналювання	Аудит служби журналів	Часткове
Доступ до даних	Скидання дампу СКБД	Аудит СКБД, потоки	Часткове
Горизонтальний рух	Дійсні облікові записи	Журнали автентифікації	Повне
Вивід даних	Канал до зовнішнього сховища	Проксі, NetFlow, DNS	Відсутнє

Окремою науково-практичною проблемою є **втома від сповіщень** (alert fatigue): за високої частки хибних тривог чутливість аналітика до справжніх сигналів падає, а середній час тріажу зростає. Кількісно проблема прямо випливає з розглянутого парадоксу базової частоти, а контрзаходами є зменшення кількості правил на користь їх якості, обов'язкове збагачення контекстом до подання аналітику, автоматичне згортання однотипних сповіщень в інцидент і регулярний перегляд правил із найгіршим показником точності.

14.8 Аудит безпеки ІКС

Аудит безпеки — систематичний, незалежний і задокументований процес отримання доказів та їх об'єктивного оцінювання для встановлення ступеня виконання критеріїв аудиту. Класифікація охоплює внутрішній аудит (аудит першою стороною), зовнішній аудит замовником або регулятором, аудит відповідності (сертифікаційний) і технічний аудит — інструментальне обстеження конфігурацій, архітектури й захищеності.

Методологічною основою є ISO 19011, що визначає принципи аудиту (доброчесність, неупереджене подання, професійна ретельність, конфіденційність, незалежність, доказовий підхід, ризик-орієнтованість), керування програмою аудиту та вимоги до компетентності аудиторів [225]. Галузеву конкретизацію для систем керування інформаційною безпекою дає ISO/IEC 27007 [232], а критеріями аудиту слугують вимоги ДСТУ EN ISO/IEC 27001:2023 [20] разом із заходами ДСТУ EN ISO/IEC 27002:2023 [21].

Програма аудиту складається з циклу: визначення цілей і обсягу; оцінювання ризиків програми; призначення групи аудиту; підготовка плану та переліку перевірних питань; проведення (вступна нарада, збирання доказів, аналіз, формулювання висновків, заключна нарада); звітування; контроль коригувальних дій. **Доказами аудиту** є записи, констатація фактів та інша перевірна інформація — зокрема витяги з журналів, конфігурації, звіти сканувань, свідчення персоналу. Виявлені **невідповідності** класифікують як суттєві (відсутність або цілковита нерезультативність заходу) та несуттєві (поодинокі відхилення); за ними ініціюють коригувальні дії з аналізом кореневих причин, а не лише усуненням наслідків.

У національному правовому полі аудит захищеності є складовою державного регулювання. Закон України «Про основні засади забезпечення кібербезпеки України» відносить аудит інформаційної безпеки на об'єктах критичної інфраструктури до основних напрямів державної політики та передбачає, що незалежний аудит проводиться відповідно до вимог, установлених законодавством [58]. Порядок проведення огляду стану кіберзахисту критичної інформаційної інфраструктури, державних інформаційних ресурсів та інформації, вимога щодо захисту якої встановлена законом, затверджено постановою Кабінету Міністрів України від 11.11.2020 № 1176 [51]; загальні вимоги до кіберзахисту таких об'єктів — постановою № 518 [22]. Для систем, у яких обробляється інформація з обмеженим доступом, вимога державної експертизи комплексної системи захисту інформації випливає із Закону України «Про захист інформації в інформаційно-комунікаційних системах» [52] та порядку створення КСЗІ [34]. Для суб'єктів, що підпадають під європейське регулювання, додаються обов'язки з NIS 2 щодо оцінювання результативності заходів кіберризик-менеджменту та аудиту [149].

Важливо розрізняти безперервний моніторинг і періодичний аудит. Концепція безперервного моніторингу безпеки, викладена у NIST SP 800-137, розглядає підтримання постійної обізнаності про стан захищеності як окремий процес, що не замінює аудит, а живить його об'єктивними даними [146]. Практично це означає, що показники покриття телеметрії, повноти журналювання й часу реагування мають бути доступні аудиторові як

безперервно накопичувані докази, а не готуватися спеціально до перевірки.

14.9 Тестування захищеності

Технічне тестування дає докази того, що заявлені заходи справді працюють. Методологію систематизовано у NIST SP 800-115, який розрізняє огляд (документів, конфігурацій, журналів), ідентифікацію та аналіз цілей (сканування мережі й вразливостей) і валідацію вразливостей (тестування на проникнення) [353]. Сканування вразливостей є повторюваним, широким за охопленням, але схильним до хибних спрацювань; тестування на проникнення — вужче, дороге, але дає доказ експлуатованості й ланцюжка підвищення прав.

Командні формати розрізняються за цілями: red team імітує супротивника приховано й перевіряє саме здатність виявити атаку; blue team захищає й реагує; purple teaming — спільна ітеративна робота, де кожна виконана техніка одразу перевіряється на наявність відповідного детекту й породжує його доопрацювання. **Симуляція супротивника** (adversary emulation) відрізняється від довільного тестування тим, що відтворює задокументований набір TTP конкретного угруповання за матрицею ATT&CK, тому її результат прямо відображається в матриці покриття. Платформи BAS автоматизують регулярне відтворення технік і забезпечують безперервну перевірку детектів, однак їх результати обмежені сценаріями, закладеними постачальником.

Правові та етичні межі є обов'язковою складовою планування. Несанкціоноване втручання в роботу інформаційно-комунікаційних систем підпадає під кримінальну відповідальність, тому будь-яке тестування потребує письмової авторизації з чітко визначеними: переліком цільових систем і адрес, часовим вікном, переліком заборонених дій (відмова в обслуговуванні, зміна або знищення даних), порядком негайного припинення робіт, режимом поводження з виявленими персональними даними та каналом екстреного зв'язку. Для розподілених систем додається вимога погодження з власниками інфраструктури інших майданчиків і хмарним провайдером, оскільки тестування може порушувати умови надання послуг.

14.10 Кейс: моніторинг безпеки розподіленої ІКС із трьома майданчиками

Розглянемо ІКС оператора послуг критичної інфраструктури: майданчик А — основний центр оброблення даних у Києві (близько 400 віртуальних машин, кластер СКБД, каталог ідентичностей); майданчик Б — резервний центр у західному регіоні (140 машин, репліка СКБД); майданчик В — хмарний сегмент у ЄС (контейнерна платформа, об'єктне сховище). Майданчи-

ки з’єднано шифрованими каналами; частина персоналу працює віддалено через безпроводові мережі філій.

Таблиця 14.3 — Оцінка потоку подій за майданчиками

Майданчик	Основні джерела	EPS (сер.)	Частка, %
А (Київ)	ОС, СКБД, EDR, каталог, проксі	3400	57
Б (резерв)	ОС, репліка СКБД, EDR	1100	18
В (хмара)	Площина керування, контейнери, сховище	1200	20
Периметр	Міжмережеві екрани, DNS, WIDS	300	5

Сумарний середній потік становить $\mathrm{EPS} = 6000$ подій за секунду за формулою $\mathrm{EPS} = \sum_{i} n_i r_i$, де n_i — кількість джерел типу i, r_i — середня інтенсивність джерела. Потрібний обсяг сховища оцінюється як

$$V = \frac{\mathrm{EPS} \cdot \bar{s} \cdot k_{\mathrm{i}} \cdot 86400 \cdot T}{c}, \tag{14.4}$$

де $\bar{s}$ — середній розмір нормалізованого запису, k_{i} — коефіцієнт індексних структур, T — строк зберігання в добах, c — коефіцієнт стиснення. За $\bar{s} = 1{,}2$ КБ, $k_{\mathrm{i}} = 1{,}3$, $c = 8$ і $T = 180$ отримуємо близько 18 ТБ корисної місткості; пікові навантаження враховують коефіцієнтом $k_{\text{пік}} = 3$ під час визначення пропускної здатності каналів і глибини буферної черги, а не місткості сховища.

Сценарії кореляції, специфічні саме для розподіленості: (1) «неможлива подорож» — успішні автентифікації того самого суб’єкта на майданчиках А і В у проміжку, меншому за фізично можливий; (2) аномальна реплікація — зростання обсягу трафіку А→Б поза вікном регламентних робіт у поєднанні з подіями масового читання в аудиті СКБД; (3) зловживання площиною керування — створення ролі з широкими правами в хмарі з IP-адреси, що не належить діапазонам адміністрування; (4) ухилення — зупинення служби журналювання чи агента EDR на будь-якому вузлі, що трактується як інцидент найвищого пріоритету; (5) компрометація безпроводового сегмента філії — поява невідомої точки доступу за даними WIDS із подальшою автентифікацією з нового пристрою.

Цільові показники: покриття телеметрією не менше ніж 95 % вузлів, розходження часу між майданчиками менше за 50 мс, MTTD для технік із критичною вагою — до 30 хвилин, частка хибних спрацювань — не більша ніж 30 %, покриття C за релевантною підмножиною технік ATT&CK — не менше ніж 0,7 із щоквартальною перевіркою методом purple teaming. Окремою

вимогою є автономність: за втрати зв'язку з центральним SIEM кожен майданчик має локально буферизувати телеметрію щонайменше 72 години — вимога, безпосередньо зумовлена досвідом роботи української інфраструктури в умовах пошкодження каналів і енергопостачання.

Висновки до розділу

Моніторинг безпеки розподіленої системи є не набором інструментів, а дослідницьким процесом, обмеженим властивостями спостережуваності. Повнота й якість джерел телеметрії визначають теоретичну межу виявлення, і жодний алгоритм не здатний компенсувати сліпі зони. Три стовпи телеметрії — журнали, метрики й трасування — у поєднанні зі строгою нормалізацією та синхронізацією часу утворюють фундамент кореляції.

Кількісний аналіз якості виявлення показує, що показники TPR і FPR самі по собі не характеризують практичну придатність детектора: через украй малу апріорну ймовірність вторгнення переважна більшість сповіщень виявляється хибними. Наведений числовий приклад демонструє, що навіть за $TPR = 0{,}99$ і $FPR = 10^{-4}$ прогностична цінність позитивного результату становить менш як 2 %. Практичний висновок — багатоступенева фільтрація, збагачення контекстом і кореляція слабких ознак замість нарощування кількості одиночних правил.

Полювання на загрози переводить моніторинг із реактивного режиму в дослідницький: гіпотези, сформульовані мовою технік ATT&CK, перевіряються на телеметрії, а негативні результати виявляють сліпі зони. Піраміда болю обґрунтовує пріоритет детектів рівня TTP над списками змінюваних індикаторів, а стандарти STIX/TAXII забезпечують автоматизований обмін кіберрозвідкою.

Аудит безпеки доповнює безперервний моніторинг періодичною незалежною оцінкою: методологію задає ISO 19011 та ISO/IEC 27007, критерії — ДСТУ EN ISO/IEC 27001:2023, а національні вимоги — законодавство про кібербезпеку та критичну інфраструктуру. Технічне тестування — від сканування вразливостей до симуляції супротивника — перетворює декларовану захищеність на перевірене твердження, за обов'язкової умови документованої авторизації. Розглянутий кейс демонструє, що проєктування системи моніторингу для багатомайданчикової ІКС є кількісною інженерною задачею: оцінювання потоку подій, обсягу сховища, часових бюджетів і покриття технік має передувати вибору конкретних продуктів.

Питання для самоперевірки

1. Як поняття спостережуваності з теорії керування переноситься на задачі моніторингу безпеки розподіленої системи?

2. Що таке сліпі зони моніторингу і якими причинами вони породжуються?
3. Схарактеризуйте три стовпи телеметрії. Чому трасування має особливе значення саме для мікросервісних архітектур?
4. Які вимоги висуваються до складу запису події безпеки, придатного для автоматичної кореляції?
5. Чому синхронізація часу є передумовою кореляції, і як контролювати її якість у багатомайданчиковій ІКС?
6. Порівняйте схеми нормалізації OCSF та ECS. Яку роль виконує збагачення подій?
7. Якими механізмами забезпечується цілісність і недоторканність журналів? Яку роль відіграє RFC 5848?
8. Порівняйте сигнатурні, аномальні та специфікаційні методи виявлення за критеріями FPR, виявлення невідомих атак і пояснюваності.
9. Обчисліть $P(I \mid A)$ за $P(I) = 10^{-5}$, $TPR = 0{,}95$, $FPR = 10^{-3}$. Який висновок для проєктування SOC випливає з результату?
10. Чому для сильно незбалансованих задач крива «точність—повнота» інформативніша за ROC?
11. Які класи правил кореляції застосовують у SIEM і які сценарії є специфічними саме для розподіленості?
12. У чому полягають обмеження машинного навчання у виявленні аномалій і що таке змагальні атаки на моделі виявлення?
13. Поясніть логіку піраміди болю та різницю між індикаторами компрометації й індикаторами атаки.
14. Опишіть структуру програми аудиту за ISO 19011 і поясніть, що є доказом аудиту та як класифікують невідповідності.
15. Які правові та організаційні умови мають бути виконані перед початком тестування на проникнення в розподіленій ІКС?

РОЗДІЛ 15

Реагування на інциденти, неперервність функціонування та відновлення розподілених сервісів

Жодна система захисту не є абсолютною: припущення про неминучість успішної атаки чи відмови є вихідним постулатом сучасної інженерії безпеки. Тому поряд із запобіганням однаково важливими є здатність швидко виявити подію, обмежити її наслідки та повернути сервіс до штатного стану з контрольованими втратами даних і часу. У розподіленому середовищі це завдання ускладнюється тим, що інцидент розгортається одночасно на кількох майданчиках, у кількох адміністративних доменах і, нерідко, у кількох юрисдикціях, а стан системи в момент інциденту не є єдиним і однозначно визначеним. Розділ систематизує понятійний апарат реагування, моделі життєвого циклу інциденту, організаційну й національну систему реагування в Україні, технічні та криміналістичні аспекти роботи з розподіленими артефактами, а також кількісні основи управління неперервністю діяльності, планування відновлення після катастроф і проєктування кіберстійких систем. Він спирається на засоби моніторингу й виявлення, викладені в розділі 14, і на моделі ризиків розділу 8.

15.1 Понятійний апарат і класифікація інцидентів

Термінологічна дисципліна тут не є формальністю: від кваліфікації обставин залежать строки повідомлення, склад залучених сторін і юридичні наслідки.

Подія (event) — будь-яка ідентифікована зміна стану системи, мережі або сервісу, що може мати значення для безпеки [365]. Переважна більшість подій є нормальними; лише мала їх частка потребує реакції. **Інцидент інформаційної безпеки** — одна або кілька небажаних чи неочікуваних подій, які з високою ймовірністю компрометують діяльність організації та загрожують інформаційній безпеці [236]. Закон України «Про основні засади забезпечення кібербезпеки України» [58] вводить власну систему понять: **кіберінцидент** — подія або низка несприятливих подій ненавмисного характеру (природного, технічного, технологічного, помилкового, зокрема внаслідок дії людського фактора) та/або таких, що мають ознаки можливої (потенційної) кібератаки, які становлять загрозу безпеці систем електронних комунікацій, створюють імовірність порушення штатного режиму функціонування таких систем, зривають та/або блокують роботу інформаційних ресурсів, порушують установлені законодавством права; **кібератака** — спрямовані (навмисні) дії в кіберпросторі, які здійснюються за

допомогою засобів електронних комунікацій і спрямовані на досягнення однієї або сукупності таких цілей: порушення конфіденційності, цілісності, доступності електронних інформаційних ресурсів; порушення штатного режиму функціонування об'єктів критичної інфраструктури. Отже, кібератака є підмножиною кіберінцидентів за ознакою навмисності. Нарешті, **криза** — стан, за якого наслідки інциденту виходять за межі компетенції команди реагування й потребують рішень вищого керівництва щодо пріоритетів, ресурсів і публічної комунікації; перехід «інцидент → криза» має бути описаний формальними критеріями, а не залишатися предметом розсуду.

Класифікація інцидентів будується щонайменше за трьома незалежними ознаками: за *типом* (шкідливе програмне забезпечення, зокрема програми-вимагачі та знищувачі даних; несанкціонований доступ; компрометація облікових даних; відмова в обслуговуванні; витік даних; порушення цілісності; інцидент ланцюга постачання); за *джерелом* (зовнішній порушник, інсайдер, постачальник послуг, помилка персоналу, техногенний чи природний чинник); за *критичністю*. Саме критичність визначає пріоритет обробки. Практично зручною є двовимірна шкала, у якій пріоритет P обчислюють як функцію функційного впливу I (частка порушених критичних процесів) і зусиль на відновлення R, з урахуванням поширення інциденту в розподіленій системі: жодна оцінка не може бути нижчою за оцінку найкритичнішого з уражених майданчиків. Категорування узгоджують із переліком критичних процесів, отриманим під час аналізу впливу на діяльність (див. підрозділ 15.6), інакше шкала пріоритезації втрачає зв'язок із реальними наслідками для організації.

Таблиця 15.1 — Рівні критичності інцидентів та строки повідомлення

Рівень	Ознаки	Внутрішня ескалація	Зовнішнє повідомлення
S1 (критичний)	зупинено критичний процес; ознаки компрометації домену або центру сертифікації; шифрування/знищення даних	негайно, керівник організації, кризовий штаб	CERT-UA — негайно; регулятор — за галузевими вимогами
S2 (високий)	уражено кілька вузлів або майданчиків; витік персональних даних	до 1 год, керівник СЗІ	24 год — раннє попередження, 72 год — повідомлення [149]; 72 год для персональних даних [328]
S3 (середній)	локальна компрометація без поширення	до 4 год, черговий аналітик	підсумкове звітування
S4 (низький)	підозріла активність, заблокована засобами захисту	у робочому порядку	не потребує

Строки в таблиці відображають логіку європейського регулювання: Директива NIS 2 [149] запроваджує триетапне звітування (раннє попередження протягом 24 год, повідомлення про інцидент — 72 год, підсумковий звіт — протягом місяця), Регламент GDPR [328] — 72 год для порушень захисту персональних даних, Регламент DORA [329] — аналогічну багатоетапну схему для фінансового сектору. Для України обов'язок повідомляти про кіберінциденти встановлено законом [58] та загальними вимогами до кіберзахисту об'єктів критичної інфраструктури [22].

15.2 Життєвий цикл реагування на інциденти

Класичною є чотирифазна модель NIST SP 800-61 [128] (редакція 2, 2012 р.; у 2025 р. замінена редакцією 3, див. нижче): підготовка; виявлення й аналіз; стримування, викорінення та відновлення; післяінцидентна діяльність. Ключова її властивість — циклічність: висновки останньої фази живлять першу, а всередині розслідування можливе повернення від стримування до аналізу, коли виявлено новий вектор або додаткові уражені активи.

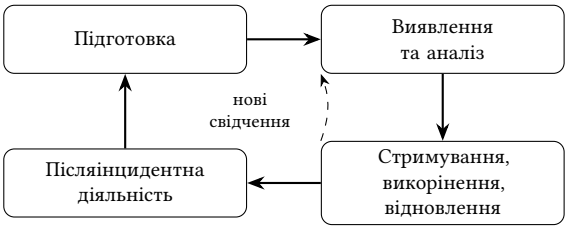


Рис. 15.1 — Цикл реагування на інцидент (за [128])

Стандарт ISO/IEC 27035-1 [236] описує п'ятифазну модель: планування й підготовка; виявлення й звітування; оцінювання й ухвалення рішення; реагування; засвоєні уроки. Зіставлення моделей подано в табл. 15.2. Змістовна відмінність полягає в акцентах: NIST детальніше опрацьовує технічний бік обробки, тоді як ISO виокремлює в самостійну фазу *оцінювання й ухвалення рішення* — момент, коли подія формально кваліфікується як інцидент і призначається її категорія. Для аспірантського дослідження важливо, що саме ця фаза є вузьким місцем: помилка кваліфікації може багаторазово збільшити час до стримування. Третя редакція NIST SP 800-61 [295] відмовляється від жорсткого поділу на фази й переописує реагування як профіль функцій Cybersecurity Framework 2.0 [307], підкреслюючи неперервність: керування (GOVERN), ідентифікація та захист створюють умови готовності, а виявлення, реагування й відновлення утворюють власне обробку інциденту.

Таблиця 15.2 — Зіставлення моделей реагування

NIST SP 800-61 [128]	ISO/IEC 27035-1 [236]
Підготовка	Планування та підготовка
Виявлення й аналіз	Виявлення та звітування; оцінювання й ухвалення рішення
Стримування, викорінення, відновлення	Реагування (зокрема відновлення)
Післяінцидентна діяльність	Засвоєні уроки

Специфіка розподіленого середовища змінює зміст кожної фази. По-перше, *виявлення* спирається на кореляцію подій із джерел, розділених годинниками й політиками журналювання; без надійної синхронізації часу хронологія інциденту не відновлюється. По-друге, *стримування* потребує узгодженої дії кількох операторів: ізоляція вузла в одному хмарному регіоні не має сенсу, якщо той самий обліковий запис активний в іншому. По-третє, з'являється *юрисдикційний* вимір: сповіщення регуляторів, доступ до журналів провайдера та вилучення носіїв регулюються правом країни розміщення, і ці умови мають бути зафіксовані в договорі про рівень послуг *до* інциденту, а не з'ясовуватися під час нього.

15.3 Організація реагування та національна система

Носієм спроможності реагування є **команда реагування на інциденти** (CSIRT/CERT). RFC 2350 [108] визначає мінімальний набір відомостей, які команда оприлюднює для своєї спільноти: сфера відповідальності, перелік послуг, політики класифікації та розкриття інформації, захищені канали

зв'язку. Каталог послуг систематизовано у CSIRT Services Framework [139], а рівні зрілості — у методиці ENISA [159]; настанови щодо створення команд і центрів моніторингу узагальнено в [202, 189].

Ролі в команді розмежовують за принципом розділення повноважень: керівник реагування (єдина точка ухвалення рішень щодо стримування), аналітик (технічне розслідування), відповідальний за докази, зв'язковий із керівництвом, зв'язковий із зовнішніми сторонами (регулятор, правоохоронні органи, провайдери), відповідальний за комунікацію із суб'єктами даних. Критичною є **матриця повноважень**: заздалегідь визначено, хто саме має право відключити майданчик, відкликати сертифікат або примусово завершити всі сесії, і за яких умов ця дія не потребує додаткового погодження. Відсутність такого мандата — типова причина втрати часу на фазі стримування.

Національна система реагування в Україні побудована навколо урядової команди CERT-UA [117], що діє у складі Державної служби спеціального зв'язку та захисту інформації України [8]. Закон [58] закріплює за основними суб'єктами національної системи кібербезпеки функції реагування, а за власниками об'єктів критичної інфраструктури [55, 22] — обов'язок повідомляти про кіберінциденти та взаємодіяти з CERT-UA. Розподіл компетенцій такий: Держспецзв'язку — технічний захист, координація кіберзахисту й реагування; Кіберполіція — досудове розслідування кіберзлочинів; СБУ — протидія кібершпигунству, кібертероризму та кібератакам на державні інформаційні ресурси й об'єкти критичної інфраструктури. Формуються також секторальні команди реагування: у банківській системі відповідні вимоги встановлено Положенням про організацію кіберзахисту в банківській системі України [41], яке зобов'язує банки створювати підрозділи кіберзахисту, реєструвати та класифікувати кіберінциденти й інформувати CSIRT-NBU.

Обмін інформацією про загрози (threat intelligence sharing) є окремою організаційною функцією. Індикатори компрометації, отримані під час розслідування, мають цінність лише за умови швидкого поширення в спільноті; водночас передавання їх без деперсоналізації створює ризик розкриття відомостей про потерпілого. Тому обмін регламентують: протоколом світлофора (TLP) для рівнів розкриття, структурованими форматами подання даних і двосторонніми угодами. Зіставлення спостережуваних дій із матрицею тактик і технік [288] дає спільну мову для опису інциденту і, що важливіше, дає змогу прогнозувати наступні кроки порушника ще до завершення розслідування.

15.4 Технічні аспекти реагування в розподіленому середовищі

Стримування — обмеження поширення інциденту — у розподіленій системі має кілька рівнів гранулярності: ізоляція процесу чи контейнера, вузла, мережевого сегмента (зокрема безпроводового сегмента, де ізоляція досягається відключенням точки доступу або переведенням клієнтів у карантинну мережу), майданчика, облікового запису, федеративного зв'язку з постачальником ідентичності. Правильний вибір рівня визначається двома конкуруючими критеріями: мінімізацією подальших збитків і збереженням можливості розслідування. *Ризик передчасного стримування* полягає в тому, що поспішне вимкнення вузла знищує оперативну пам'ять із ключами й активними з'єднаннями, сигналізує порушникові про виявлення і провокує його перейти до руйнівного сценарію або активувати запасні канали керування. Тому стандартна практика — спершу забезпечити спостережність і зняти летючі дані, а вже потім ізолювати, крім випадків активного знищення чи шифрування даних, коли пріоритет однозначно на боці негайного припинення.

Особливий клас становить *компрометація облікових даних і криптографічних довіреностей*. У федеративній архітектурі відкликання пароля не припиняє дії вже виданих маркерів доступу: до закінчення терміну їх чинності порушник зберігає повноваження. Тому послідовність дій має бути такою: примусове завершення всіх активних сесій і відкликання маркерів оновлення; ротація секретів застосунків і сервісних облікових записів; перевірка доданих порушником другого чинника автентифікації, делегувань, правил пересилання пошти та застосунків із наданим доступом; лише після цього — відновлення доступу для користувача. У разі компрометації центру сертифікації сценарій жорсткіший: відкликання всіх виданих із моменту компрометації сертифікатів, публікація оновленого списку відкликаних сертифікатів [140], перевидання ключів і — за потреби — виведення кореневого ключа з експлуатації, що для кваліфікованих надавачів електронних довірчих послуг регулюється окремо [44]. Оскільки перевірка статусу відкликання в розподілених системах часто виконується з кешуванням, реальний час набуття чинності відкликання перевищує номінальний, і цей лаг слід ураховувати як самостійний ризик.

15.5 Цифрова криміналістика розподілених систем

Криміналістичне забезпечення реагування поділяють на **живу** криміналістику (збирання даних із працездатної системи) та **післясмертну** (аналіз образів вимкнених носіїв). У розподілених системах баланс зміщується на користь живої: значна частина стану існує лише в оперативній пам'яті або в ефемерних об'єктах. Порядок збирання визначається принципом спадання леткості [107]: регістри й кеші, оперативна пам'ять, стан мережевих

з'єднань і таблиць маршрутизації, тимчасові файли, дискові носії, віддалені журнали, архіви. Методику інтеграції криміналістичних технік у реагування описано в NIST SP 800-86 [245].

Хмарні й контейнерні середовища створюють специфічні труднощі. Контейнер живе хвилини, його файлова система знищується разом із ним, а вузол оркестратора може бути повернутий у пул до початку розслідування. Практичні наслідки: образ пам'яті контейнера має зніматися автоматично за спрацюванням правила виявлення, а не за рішенням аналітика; уражений вузол слід виводити зі складу кластера в стан «карантин» (позначення як непридатного для планування) замість видалення; знімок диска віртуальної машини та експорт журналів площини керування хмари мають виконуватися одним автоматизованим сценарієм. Обмеження моделі спільної відповідальності [358] означає, що частина артефактів — журнали гіпервізора, мережеві потоки на рівні провайдера — доступна лише за запитом до постачальника, і порядок такого запиту має бути передбачений договором.

Криміналістика мережевого трафіку та журналів у розподіленій системі спирається на три передумови: єдина шкала часу з відомою похибкою; захист журналів від модифікації (додавання лише в кінець, геш-зчеплення, винесення на окремий носій); повнота охоплення — відсутність «сліпих зон» у міжсервісній взаємодії. Порушення будь-якої з них знецінює доказову базу.

Ланцюг збереження доказів (chain of custody) — документована послідовність осіб, які володіли доказом, із зазначенням часу, місця, дій і контрольних сум. Для цифрових доказів обов'язковим є фіксування геш-значення образу в момент вилучення та підтвердження його незмінності на кожному наступному етапі. В українському правовому полі електронні дані як докази розглядає Кримінальний процесуальний кодекс України [28]; допустимість таких доказів визначається дотриманням процесуального порядку їх отримання, тому взаємодія команди реагування з правоохоронними органами має бути налагоджена *до* інциденту: узгоджені форми актів, порядок залучення спеціаліста, вимоги до опису обладнання. Типова помилка — самостійне «очищення» уражених систем до фіксації стану, після чого притягнення винних до відповідальності стає неможливим.

15.6 Управління неперервністю діяльності та показники відновлення

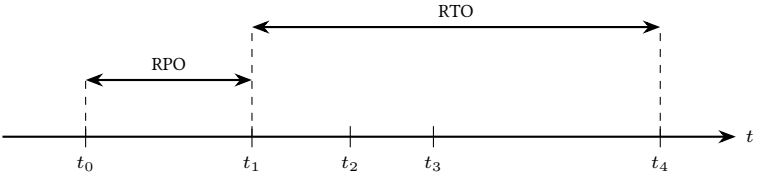
Управління неперервністю діяльності (BCM) — цілісний процес ідентифікації потенційних загроз діяльності та формування спроможності реагувати на них так, щоб захистити інтереси зацікавлених сторін і репутацію організації [226]. Його вихідною процедурою є **аналіз впливу на діяльність**

(BIA): для кожного бізнес-процесу визначають наслідки його переривання як функцію часу, ідентифікують інформаційні ресурси, від яких процес залежить, і встановлюють цільові показники відновлення. Саме BIA, а не інвентаризація IT-активів, є джерелом переліку критичних систем: ресурс критичний не сам собою, а через процес, який він підтримує.

Базові показники визначають так. **RTO** (recovery time objective) — максимально припустимий час від переривання до відновлення функціювання процесу; **RPO** (recovery point objective) — максимально припустимий обсяг втрати даних, виражений у часі; **MTPD** (maximum tolerable period of disruption), або MAO, — гранична тривалість переривання, після якої наслідки стають неприйнятними; **MBCO** (minimum business continuity objective) — мінімальний рівень надання послуг, прийнятний на час переривання. Між ними діє обов'язкове співвідношення

$$\mathrm{RTO} < \mathrm{MTPD},$$

порушення якого означає, що план відновлення не забезпечує виживання процесу.



t_0 — остання узгоджена копія (репліка);
t_1 — настання інциденту; t_2 — виявлення;
t_3 — рішення про відновлення; t_4 — відновлення сервісу

Рис. 15.2 — Часова шкала інциденту та показники RPO і RTO

Фактичні значення показників за рис. 15.2 обчислюють як

$$\mathrm{RPO}_{\text{ф}} = t_1 - t_0, \qquad \mathrm{RTO}_{\text{ф}} = t_4 - t_1.$$

Для асинхронної реплікації з періодом Δ і поточним лагом λ справджується оцінка $\mathrm{RPO}_{\text{ф}} \le \Delta + \lambda$, звідки випливає практичний висновок: декларований RPO є досяжним лише за умови неперервного контролю лагу реплікації, і саме перевищення λ, а не відмова резервного копіювання, є найчастішою причиною недосягнення цільового показника. Окремо зауважимо, що інтервал $t_2 - t_1$ (час до виявлення) не входить до RTO за визначенням, але повністю входить до реальних збитків; скорочення цього інтервалу засобами моніторингу (розділ 14) дає найдешевший приріст стійкості.

15.7 Планування відновлення після катастроф

План відновлення після катастроф (DRP) є технічною складовою BCM і описує процедури відновлення інфраструктури й даних [391]. Ключове архітектурне рішення — тип резервного майданчика (табл. 15.3).

Таблиця 15.3 — Порівняння типів резервних майданчиків

Тип	Типовий RTO	Типовий RPO	Зміст
Холодний	дні	доба й більше	приміщення та канали; обладнання й дані завантажуються після події
Теплий	години	години	обладнання розгорнуто, дані — періодична реплікація
Гарячий	хвилини	хвилини	повна копія середовища, безперервна реплікація
Активний–активний	секунди	близько нуля	обидва майданчики обслуговують запити, синхронна реплікація
Хмарний (*pilot light*)	десятки хвилин	хвилини	мінімальне ядро сервісу постійно активне, решта — за шаблоном

Вибір не зводиться до «що швидше — те краще». Синхронна реплікація, потрібна для нульового RPO, обмежує географічне рознесення майданчиків (затримка підтвердження запису зростає із відстанню) і тим самим підвищує ризик спільної причини — ураження обох майданчиків одним фізичним впливом. Асинхронна геореплікація знімає це обмеження ціною ненульового RPO. Крім того, активний–активний режим переносить ризик у площину логічної цілісності: хибний або зловмисний запис реплікується на всі майданчики миттєво, тому реплікація *не є* резервним копіюванням. Захист від логічного руйнування забезпечують лише незмінні (write-once) резервні копії з контрольованим періодом зберігання та щонайменше однією копією, ізольованою від операційного середовища за обліковими даними й мережею.

Економічне обґрунтування будують на зіставленні витрат на відновлення й очікуваних збитків. Позначимо через $L(T)$ збитки від простою тривалістю T:

$$L(T) = C_0 + c\,T + \beta T^2,$$

де C_0 — одноразові витрати на реагування, c — питомі втрати за годину простою, а член βT^2 відображає нелінійне зростання наслідків (штрафи, каскадні відмови залежних процесів, репутаційні втрати). Річні витрати на утримання інфраструктури, здатної забезпечити відновлення за час T, апроксимують гіперболою $K(T) = a/T$: удвічі менший час відновлення потребує приблизно вдвічі більших інвестицій. За інтенсивності руйнівних інциден-

тів p (подій на рік) сумарні очікувані річні витрати становлять

$$F(T) = \frac{a}{T} + p\left(C_0 + c\,T + \beta T^2\right) \;\longrightarrow\; \min_{T}.$$

Нехтуючи членом βT^2 для малих T, з умови $F'(T) = 0$ дістаємо оптимальний цільовий час відновлення

$$T^{*} = \sqrt{\frac{a}{p\,c}}.$$

Числовий приклад. Нехай $a = 1{,}2$ млн грн·год на рік, $p = 0{,}4$ рік$^{-1}$, $c = 0{,}9$ млн грн/год. Тоді $T^{*} = \sqrt{1{,}2/(0{,}4\cdot 0{,}9)} \approx 1{,}83$ год, а сумарні очікувані витрати $F(T^{*}) \approx 1{,}31$ млн грн на рік (без урахування pC_0), причому обидві складові в оптимумі рівні. Отже, обґрунтованим є цільовий RTO близько двох годин — рівень теплого або хмарного майданчика; інвестиція в гарячий резерв була б економічно виправданою лише за суттєво більших p або c. Такий розрахунок є прикладом застосування кількісних методів системного аналізу до задачі захисту й безпосередньо реалізує компетентність КФ-2.

Готовність системи характеризують **коефіцієнтом готовності**

$$A = \frac{\mathrm{MTBF}}{\mathrm{MTBF} + \mathrm{MTTR}},$$

де MTBF — середнє напрацювання між відмовами, MTTR — середній час відновлення. Для n майданчиків із резервуванням та часткою відмов зі спільної причини ρ (модель β-фактора)

$$A_{\text{сис}} = 1 - \left[(1-\rho)(1-A)^{n} + \rho\,(1-A)\right].$$

За $A = 0{,}99$ і $n = 3$ ідеальне резервування дало б $A_{\text{сис}} = 1 - 10^{-6}$, тоді як за $\rho = 0{,}05$ маємо $A_{\text{сис}} \approx 0{,}9995$: відмови зі спільної причини збільшують неготовність у 500 разів, тобто майже на три порядки (пор. з аналогічною моделлю в розділі 7). Практичний висновок — нарощування кількості реплік безглузде без усунення спільних залежностей: єдиного постачальника хмари, єдиної системи керування конфігурацією, спільного постачальника електроживлення, однакового образу операційної системи.

15.8 Кіберстійкість розподілених систем

Кіберстійкість (cyber resilience) — здатність передбачати, витримувати, відновлюватися після несприятливих умов, стресів, атак чи компрометацій кіберресурсів і пристосовуватися до них [343]. Принципова відмінність від класичного захисту — припущення, що порушник уже всередині системи;

проєктні рішення мають зберігати місію навіть за компрометованих компонентів. NIST SP 800-160 Vol. 2 систематизує цілі (передбачати, витримувати, відновлюватися, адаптуватися), методи (аналітичний моніторинг, координований захист, обман, різноманітність, динамічне позиціювання, непередбачуваність, привілейоване обмеження, реалокація, сегментація, підтверджена цілісність) та принципи проєктування.

Для розподілених систем найважливішими є:

- **деградація з гідністю** — за нестачі ресурсів сервіс переходить до режиму MBCO: вимикає некритичні функції, зберігаючи основну (напр., реєстр приймає запити на реєстрацію, але тимчасово не формує аналітичні витяги);
- **аварійні режими** — заздалегідь спроєктовані стани («лише читання», «локальна автономія майданчика», «офлайнове обслуговування за попередньо завантаженим кешем»), кожен із визначеною політикою безпеки; принципово, щоб аварійний режим не був режимом *без* захисту;
- **ізоляція збоїв** — поділ на домени відмов і застосування шаблонів запобіжника (circuit breaker), перегородки (bulkhead) та обмеження швидкості, що не дають локальній відмові каскадувати;
- **різноманітність** — уникнення однакових реалізацій у резервних трактах, що прямо зменшує ρ у наведеній вище моделі.

Емпіричним методом перевірки цих властивостей є **хаос-інженерія** — дисципліна експериментування над системою з метою набуття впевненості в її здатності витримувати збурення в промисловій експлуатації [325]. Метод передбачає формулювання гіпотези про стійкий стан (вимірюваний показник, напр. частка успішних запитів), унесення реалістичного збурення (відмова вузла, зростання затримки, поділ мережі), порівняння контрольної та експериментальної груп і обов'язкове обмеження «радіуса ураження». Для систем безпеки цінним є розширення методу на сценарії безпеки: відкликання сертифіката, недоступність постачальника ідентичності, компрометація сервісного облікового запису. Відкритою науковою проблемою залишається формальне обґрунтування достатності набору експериментів: хаос-інженерія доводить наявність слабких місць, але не доводить їх відсутності.

15.9 Тестування планів і навчання

План, який не перевіряли, слід вважати непрацездатним. Формами перевірки є:

Аналіз документа
— перевірка актуальності контактів, ролей, залежностей; найдешевша й найчастіша форма.

Настільні навчання
— обговорення сценарію в колі відповідальних осіб без впливу на системи; виявляють прогалини в повноваженнях і комунікації.

Імітація (walkthrough, симуляція)
— відпрацювання процедур на тестовому середовищі з фактичним виконанням команд.

Повномасштабні навчання з перемиканням
— реальне переведення навантаження на резервний майданчик і повернення; єдина форма, що дає достовірне вимірювання фактичних RTO і RPO.

Кібернавчання
— сценарій із протидією умовному порушникові, що перевіряє водночас виявлення, реагування та відновлення.

Критерії успішності мають бути кількісними й визначеними *до* навчання: досягнуті RTO і RPO, частка процедур, виконаних без відхилень, час до першої правильної кваліфікації інциденту, повнота зібраних доказів, час доведення інформації до керівництва й регулятора. Результати документують у звіті, кожне відхилення перетворюють на пункт плану коригувальних дій із відповідальним і строком, а сам план оновлюють. Так замикається цикл удосконалення, вимогу до якого встановлюють і [226], і [20].

15.10 Український досвід і кейс відновлення відомчої ІКС

Повномасштабна війна перетворила Україну на унікальний полігон перевірки концепцій неперервності. Узагальнені уроки, що мають методичне значення, такі. По-перше, *географічне рознесення в межах країни виявилося недостатнім*: одночасний вплив на кілька регіонів зробив обов'язковим рознесення за межі зони ураження, що потребувало зміни правового режиму: постанова Кабінету Міністрів України № 263 [11] на період воєнного стану дозволила розміщення даних державних реєстрів і ІКС за кордоном, а Закон України «Про хмарні послуги» [62] унормував використання хмарних послуг публічними користувачами. По-друге, *евакуація даних* має бути спланованою процедурою з випробуваними каналами й попередньо погодженими постачальниками, а не імпровізацією. По-третє, критичним чинником стало *енергозабезпечення*: знеструмлення уражає одночасно обчислювальні потужності, канали зв'язку та кінцевих користувачів, тому автономне живлення потрібне на всіх ланках тракту, а не лише в центрі оброблення даних. По-четверте, підтвердилася цінність *автономних режимів* — здатності територіального підрозділу працювати за локальною копією да-

них із подальшою синхронізацією; це вимагає заздалегідь розв'язаної задачі узгодження конфліктів (розділ 13). По-п'яте, масовані атаки з використанням програм-знищувачів даних показали, що резервна копія, доступна з операційного домену, знищується разом із продуктивним середовищем. Роль CERT-UA [117] у цих умовах вийшла за межі технічного реагування: команда стала вузлом обміну індикаторами компрометації, що дало змогу превентивно захищати організації, ще не уражені конкретною кампанією. Європейські узагальнення практик кризового управління [96, 161] підтверджують ті самі висновки.

Кейс. Розподілена відомча ІКС (центральний апарат і 24 територіальні підрозділи, реляційна БД із синхронною реплікацією між двома майданчиками, власний центр сертифікації, каталог користувачів) зазнала атаки: через скомпрометований обліковий запис підрядника порушник дістав доступ до системи керування конфігураціями й розгорнув знищувач даних на серверах обох майданчиків. Синхронна реплікація призвела до того, що пошкодження даних відтворилося на резервному майданчику за секунди. Послідовність відновлення: (1) кваліфікація як S1 і активація кризового штабу; (2) стримування — відключення системи керування конфігураціями, блокування федеративного зв'язку, примусове завершення всіх сесій, ізоляція обох майданчиків від зовнішніх мереж зі збереженням каналу для команди реагування; (3) фіксація доказів — образи пам'яті серверів керування конфігураціями, експорт журналів каталогу та мережевих потоків, розрахунок і депонування геш-значень; (4) визнання центру сертифікації скомпрометованим, відкликання виданих сертифікатів, підготовка нової ієрархії ключів; (5) відновлення з незмінної резервної копії, ізольованої від операційного домену, у чистому мережевому сегменті з попередньою перевіркою образів; (6) поетапне повернення сервісів відповідно до пріоритетів BIA: спершу МВСО (приймання документів у режимі «лише запис» з обробленням у відкладеному порядку), далі — повна функційність; (7) повідомлення CERT-UA і регулятора у строки згідно з табл. 15.1, залучення правоохоронних органів із дотриманням ланцюга збереження доказів; (8) післяінцидентний аналіз. Фактичні показники: $\mathrm{RPO}_{\text{ф}} = 6$ год (період створення незмінних копій), $\mathrm{RTO}_{\text{ф}} = 31$ год за цільового RTO 8 год. Основні причини розриву — відсутність відпрацьованої процедури перевидання ключів центру сертифікації та ручне відновлення конфігурацій. Коригувальні дії: автоматизоване відтворення інфраструктури з описів як коду, скорочення періоду незмінних копій до 1 год для критичних наборів даних, запровадження окремого контуру керування конфігураціями з підвищеними вимогами до автентифікації та щоквартальні навчання з перемиканням. Цей кейс демонструє головну тезу розділу: реплікація забезпечує доступність,

але не відновлюваність, а фактичні показники відновлення визначаються не архітектурою на папері, а відпрацьованістю процедур.

Висновки до розділу

Реагування на інциденти та неперервність функціонування утворюють єдиний контур управління, замкнений на здатність організації виконувати свою місію попри несприятливі впливи. Понятійна база, закріплена законом [58] та стандартами [236, 226], задає межі відповідальності, строки повідомлення й склад залучених сторін, тому кваліфікація події є не технічною, а нормативно значущою дією. Моделі життєвого циклу NIST SP 800-61 та ISO/IEC 27035 узгоджуються за змістом фаз, але по-різному розставляють акценти; сучасна тенденція, зафіксована в третій редакції [295], полягає в інтеграції реагування в загальний контур керування кіберризиком.

Розподіленість змінює механіку кожної фази: виявлення потребує кореляції різнорідних джерел і єдиної шкали часу; стримування — узгоджених дій кількох операторів і врахування ефекту передчасної ізоляції; криміналістика — роботи з ефемерними об'єктами й обмеженнями моделі спільної відповідальності. Кількісний бік завдання описують показники RTO, RPO, MTPD і MBCO, співвідношення між якими є критерієм життєздатності плану, а економічний вибір цільового часу відновлення допускає формальну постановку як задачі мінімізації сумарних витрат. Модель коефіцієнта готовності з β-фактором показує, що резервування без усунення спільних залежностей дає ілюзорний виграш.

Кіберстійкість переносить акцент із недопущення компрометації на збереження місії за її наявності, надаючи інженерний інструментарій: деградацію з гідністю, аварійні режими, ізоляцію збоїв, різноманітність — і експериментальний метод їх перевірки у вигляді хаос-інженерії. Український досвід воєнного часу емпірично підтвердив пріоритетність автономних режимів, позазонального рознесення, ізольованих незмінних резервних копій та енергетичної незалежності всього тракту надання послуги. Головний практичний висновок: цінність мають лише перевірені плани, а перевіркою вважається навчання з фактичним перемиканням і кількісним вимірюванням досягнутих показників.

Питання для самоперевірки

1. Розмежуйте поняття «подія», «інцидент», «кіберінцидент», «кібератака» і «криза». Які юридичні наслідки має кваліфікація події як кіберінциденту за законодавством України?

2. За якими незалежними ознаками класифікують інциденти і чому шкала критичності має бути узгоджена з результатами аналізу впливу на діяльність?
3. Порівняйте моделі життєвого циклу NIST SP 800-61 та ISO/IEC 27035. Яку фазу ISO виокремлює додатково і чому вона є вузьким місцем?
4. У чому полягає ризик передчасного стримування? Наведіть умови, за яких цим ризиком слід свідомо знехтувати.
5. Опишіть повну послідовність дій за компрометації облікових даних привілейованого користувача у федеративній архітектурі. Чому зміни пароля недостатньо?
6. Які додаткові дії потрібні за компрометації центру сертифікації і чому реальний час набуття чинності відкликання перевищує номінальний?
7. Сформулюйте принцип спадання леткості. Як він застосовується до контейнерного середовища, де об'єкт живе кілька хвилин?
8. Які артефакти в хмарному середовищі недоступні власникові системи без участі провайдера і як це врахувати в договорі про рівень послуг?
9. Що таке ланцюг збереження доказів і які технічні дії забезпечують його для цифрового доказу?
10. Дайте визначення RTO, RPO, MTPD і MBCO. Доведіть, що співвідношення $\mathrm{RTO} < \mathrm{MTPD}$ є необхідною умовою життєздатності плану.
11. Виведіть оцінку $\mathrm{RPO}_{\text{ф}} \le \Delta + \lambda$ і поясніть, який параметр треба контролювати неперервно, щоб декларований RPO залишався досяжним.
12. Використовуючи модель $F(T) = a/T + p\,L(T)$, обчисліть оптимальний цільовий час відновлення за $a = 2{,}0$ млн грн·год/рік, $p = 0{,}5$ рік$^{-1}$, $c = 1{,}0$ млн грн/год і поясніть, який тип резервного майданчика цьому відповідає.
13. Чому нарощування кількості резервних майданчиків без усунення відмов зі спільної причини дає незначний приріст готовності? Обґрунтуйте формулою.
14. Чому реплікація не є резервним копіюванням? Які властивості має мати резервна копія, щоб протистояти програмі-знищувачу даних?
15. Запропонуйте програму хаос-експериментів для перевірки стійкості механізмів безпеки розподіленої системи (не лише її доступності) і сформулюйте критерії, за якими можна було б оцінити повноту такої програми.

РОЗДІЛ 16

Захист розподілених ресурсів об'єктів критичної інфраструктури, операційних технологій та IoT

Розділ розглядає найскладніший клас розподілених інформаційних ресурсів — ті, що вбудовані у фізичні технологічні процеси й безпосередньо впливають на життєзабезпечення суспільства. Якщо у попередніх розділах простір загроз описувався переважно в термінах конфіденційності, цілісності та доступності даних, то тут до нього додається вимір **безпечності** (safety): наслідком успішної кібератаки стає не витік чи спотворення інформації, а зупинення генерувального обладнання, знеструмлення регіону або відмова системи водопостачання. Матеріал розділу утворює методичну основу компетентності КФ-7 — планування й реалізації заходів захисту на об'єктах критичної інфраструктури — і безпосередньо спирається на положення розділів 8 (моделювання загроз), 11 (захист мережевої інфраструктури), 14 (моніторинг) і 15 (неперервність та відновлення).

16.1 Критична інфраструктура як розподілена соціотехнічна система

Критична інфраструктура — сукупність об'єктів, які є стратегічно важливими для функціонування суспільства й держави, порушення функціонування яких завдає шкоди національним інтересам. Закон України «Про критичну інфраструктуру» [55] визначає секторальну модель: енергетика, електронні комунікації, транспорт, водопостачання й водовідведення, продовольство, охорона здоров'я, фінанси, оборонно-промисловий комплекс, хімічна промисловість тощо. Для кожного сектору визначено **секторальний орган** — центральний орган виконавчої влади, відповідальний за формування секторальної політики захищеності.

Із системного погляду критична інфраструктура — це не набір ізольованих підприємств, а **розподілена соціотехнічна система** з інтенсивними взаємозалежностями. У теорії інфраструктурних взаємозалежностей розрізняють чотири їх типи:

- **фізичні** — вихід одного об'єкта є ресурсним входом іншого (електроенергія для насосних станцій водоканалу);
- **кіберфізичні** (інформаційні) — керування об'єктом залежить від стану інформаційно-комунікаційної системи (диспетчерське керування розподільними мережами);

- **географічні** — об’єкти різних секторів зосереджені в одному просторі й уражаються спільною подією (кабельний колектор, підстанція та вузол зв’язку в межах одного майданчика);
- **логічні** — зв’язок опосередкований ринковими, договірними чи людськими механізмами (спільний постачальник обладнання, спільний підрядник з обслуговування).

Наявність взаємозалежностей породжує **каскадні відмови**: локальна подія поширюється мережею залежностей і призводить до втрат, непорівнянно більших за первинне ураження. Формалізувати поширення зручно матрицею впливу $W = [w_{ij}]$, де $w_{ij} \in [0,1]$ — умовна ймовірність того, що втрата працездатності об’єкта i спричинить втрату працездатності об’єкта j. Якщо $p_j^{(k)}$ — імовірність ураження об’єкта j на кроці k ітеративного поширення, то

$$p_j^{(k+1)} \;=\; p_j^{(k)} + \bigl(1 - p_j^{(k)}\bigr)\Bigl[\,1 - \prod_{i \neq j} \bigl(1 - w_{ij}\, p_i^{(k)}\bigr)\Bigr]. \tag{16.1}$$

Ітерації виконують до збіжності $\max_j |p_j^{(k+1)} - p_j^{(k)}| < \varepsilon$. Інтегральну «каскадну вагу» об’єкта в лінійному наближенні дає ряд Неймана: якщо спектральний радіус $\rho(W) < 1$, то сумарна матриця впливів дорівнює $S = (I - W)^{-1} - I$, а **індекс каскадної критичності** об’єкта i

$$C_i \;=\; \sum_{j \neq i} s_{ij}\, v_j, \tag{16.2}$$

де v_j — нормована суспільна цінність (кількість споживачів, обсяг послуги) об’єкта j. Величина C_i дозволяє ранжувати об’єкти за пріоритетністю захисту й обґрунтовано розподіляти обмежений бюджет заходів — це типова задача системного аналізу в сенсі компетентності КФ-2. Приклад практичного застосування — обґрунтування черговості встановлення автономного живлення на об’єктах водоканалу за критерієм максимального C_i.

Окремої уваги потребує співвідношення понять. **Об’єкт критичної інфраструктури** (ОКІ) — це підприємство, установа, споруда чи їх сукупність, віднесені до критичної інфраструктури в порядку, встановленому Кабінетом Міністрів України [14]; критичність визначається за категоріями (від I — особливо важливі, до IV) на підставі оцінки наслідків припинення функціонування. **Об’єкт критичної інформаційної інфраструктури** (ОКІІ) — це інформаційно-комунікаційна система, порушення функціонування якої призводить до негативних наслідків для ОКІ; ОКІІ вноситься до відповідного переліку згідно із Законом «Про основні засади забезпечення кібербезпеки України» [58]. Отже, ОКІІ є інформаційною «проєкцією» ОКІ, і один

ОКІ може мати кілька ОКІІ (корпоративна система, АСК ТП, система комерційного обліку). Реєстр об'єктів критичної інфраструктури ведеться уповноваженим органом і має обмежений доступ, оскільки сам є чутливим інформаційним ресурсом.

16.2 Нормативні вимоги до кіберзахисту об'єктів критичної інфраструктури

Ядро національних вимог утворюють Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури, затверджені постановою Кабінету Міністрів України від 19.06.2019 № 518 [22]. Документ побудований за логікою системи управління: він вимагає визначити відповідальну особу (підрозділ) з кіберзахисту, розробити й затвердити політику, вести облік активів ОКІІ, здійснювати керування вразливостями та оновленнями, розмежовувати доступ, забезпечувати реєстрацію подій та їх зберігання, планувати неперервність і відновлення, а також періодично проводити **аудит інформаційної безпеки** ОКІІ. Практичним доповненням є Порядок проведення огляду стану кіберзахисту критичної інформаційної інфраструктури, державних інформаційних ресурсів та інформації, вимога щодо захисту якої встановлена законом [51], що визначає процедуру державного огляду, зокрема із залученням Держспецзв'язку.

Оператор ОКІІ зобов'язаний взаємодіяти з національною системою кібербезпеки: повідомляти CERT-UA про кіберінциденти, отримувати й опрацьовувати індикатори компрометації, брати участь у навчаннях [117, 8]. Досвід 2022–2024 років показав, що саме швидкість передавання індикаторів між енергетичними компаніями, CERT-UA та міжнародними партнерами була вирішальним чинником запобігання масштабним відключенням.

Європейський контекст задають два взаємодоповнювані акти. Директива NIS2 [149] встановлює вимоги до кіберзахисту «суттєвих» і «важливих» суб'єктів, вводить відповідальність керівництва, обов'язкове звітування про інциденти за схемою «24 години — 72 години — один місяць» та вимоги до безпеки ланцюга постачання. Директива CER [150] регулює *фізичну* й організаційну стійкість критичних суб'єктів: оцінювання ризиків, плани стійкості, перевірку персоналу, забезпечення функціонування в умовах кризи. Вітчизняні норми концептуально ближчі до NIS2, проте українське законодавство — на відміну від європейського — історично поєднує режим кіберзахисту ОКІІ з режимом комплексної системи захисту інформації (КСЗІ) за НД ТЗІ [34], що для операційних технологій створює методологічну напругу: КСЗІ орієнтована на захист інформації, тоді як в АСК ТП захищають *процес*. Гармонізація цих режимів — відкрита науково-практична проблема, розв'язання якої потребує адаптації IEC 62443 до національної нормативної бази.

16.3 Операційні технології та промислові системи керування

Операційні технології (OT) — апаратні й програмні засоби, які виявляють або спричиняють зміни фізичних процесів через безпосереднє спостереження та керування обладнанням [388]. Типова архітектура автоматизованої системи керування технологічним процесом (АСК ТП) містить: **давачі** й виконавчі механізми; **PLC** (програмовані логічні контролери), **RTU** (віддалені термінали телемеханіки) та **IED** (інтелектуальні електронні пристрої релейного захисту); **SCADA** — систему диспетчерського керування й збору даних; **DCS** — розподілену систему керування безперервним виробництвом; **HMI** — людино-машинний інтерфейс; **історизатор** — сервер довготривалого зберігання технологічних параметрів. Окремим, найвідповідальнішим контуром є **ПАЗ** (SIS, safety instrumented system) — система протиаварійного захисту, що незалежно від АСК ТП переводить процес у безпечний стан.

Структурування OT-систем спирається на **еталонну модель Purdue** (PERA), яку прийнято за основу зонування в IEC 62443 [216] та NIST SP 800-82 [388] (рис. 16.1).

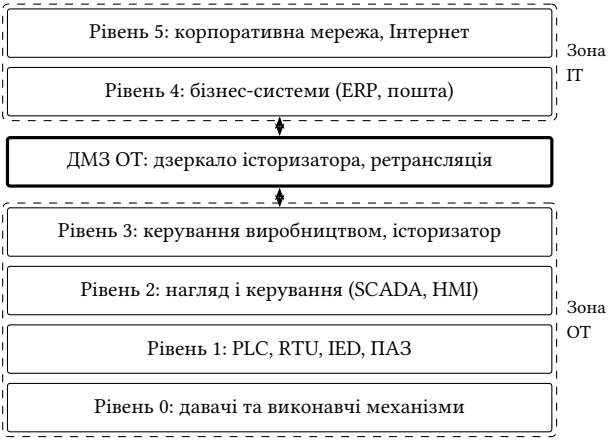


Рис. 16.1 — Еталонна модель Purdue та базове зонування OT-середовища (за [388, 216])

Принципова відмінність OT від IT полягає не в технологіях, а в *ієрархії цілей*. В IT пріоритет має конфіденційність, в OT — безпечність і доступність: втрата керованості реактора або газорозподільної станції неприпустима навіть на секунди, тоді як розкриття значення технологічного параметра зазвичай не має катастрофічних наслідків. Це зумовлює істотні відмінності у виборі захисних заходів (табл. 16.1).

Таблиця 16.1 — Порівняння середовищ IT та OT за суттєвими для захисту ознаками

Ознака	IT-середовище	OT-середовище
Пріоритет властивостей	Конфіденційність, цілісність, доступність	Безпечність, доступність, цілісність, конфіденційність
Наслідок відмови	Втрата або витік даних	Загроза життю, довкіллю, зупинення процесу
Життєвий цикл	3–5 років	15–30 років
Оновлення ПЗ	Регулярне, автоматизоване	Рідке, лише у вікна зупинки, з валідацією
Вимоги до затримки	Десятки–сотні мс, толерантні	Одиниці мс, детерміновані
Перезавантаження	Прийнятне	Часто неприпустиме
Антивірусний захист	Стандартний	Обмежений; переважно «білі списки»
Тестування захищеності	Активне сканування	Пасивне; активне — лише на стенді
Власник ризику	CIO / CISO	Головний інженер, служба охорони праці

Наведене зіставлення пояснює, чому пряме перенесення IT-практик в OT є хибним: активне сканування портів здатне «покласти» PLC, а примусове встановлення оновлень — порушити сертифікацію ПАЗ. Замість цього застосовують **компенсувальні заходи** — сегментацію, моніторинг, обмеження доступу, — які знижують ризик, не змінюючи технологічного обладнання.

16.4 Промислові протоколи та їхні вразливості

Більшість промислових протоколів створювалася для ізольованих мереж, тому автентифікація, цілісність і шифрування в них або відсутні, або є пізнішим доповненням.

Modbus

Найпоширеніший протокол «ведучий—ведений» з простим форматом кадру; у варіанті Modbus/TCP не передбачає ані автентифікації, ані контролю цілісності. Будь-який вузол, що має мережевий доступ, може надіслати команду запису в регістр.

DNP3

Протокол телемеханіки, стандартизований як IEEE 1815 [217]; має розширення Secure Authentication (DNP3-SA) на основі HMAC із заздалегідь розподіленими ключами, проте на практиці воно ввімкнене далеко не завжди.

IEC 60870-5-101/104

Протоколи телемеханіки, поширені в європейській та українській енергетиці; IEC 60870-5-104 працює поверх TCP/IP і в базовому вигляді не автен-

тифікує джерело команд. Саме його використовував Industroyer2 для подавання команд на комутаційні апарати [165].

IEC 61850

Комплекс стандартів автоматизації підстанцій: об'єктна модель, послуги MMS, а також протоколи реального часу GOOSE та Sampled Values, що працюють на канальному рівні з жорсткими обмеженнями затримки (до 3–4 мс). Мережеве проєктування таких сегментів регламентує IEC TR 61850-90-4 [214]. Через відсутність маршрутизації GOOSE-трафік захищають переважно фізичною й канальною сегментацією.

PROFINET

Промисловий Ethernet для дискретного виробництва з ізохронним режимом; захист забезпечується здебільшого на рівні мережевої інфраструктури.

OPC UA

Сучасний платформонезалежний протокол, у якому механізми захисту вбудовані: взаємна автентифікація застосунків за сертифікатами X.509 [140], підписування й шифрування повідомлень, керування правами користувачів, аудит подій; модель захисту описано в IEC TR 62541-2 [215]. OPC UA є рекомендованою заміною OPC DA, що ґрунтувався на DCOM і вимагав відкриття широкого діапазону портів.

Промислові протоколи належать до класу «таких, що не прощають» (unforgiving): вони чутливі до затримок, джитера та повторних передач. Тому засоби захисту, звичні для IT (глибока інспекція з розшифруванням, вбудовані проксі, агенти на кінцевих вузлах), у контурах реального часу застосовувати не можна — натомість використовують пасивний моніторинг із дзеркальних портів і «прозорі» міжмережеві екрани з розбором промислових протоколів.

16.5 Стандарт IEC 62443: зони, канали й рівні захищеності

Серія IEC 62443 — основний міжнародний стандарт кібербезпеки промислових систем автоматизації та керування (IACS). Її структура чотиричастинна: частина 1 — термінологія, концепції та моделі [216]; частина 2 — вимоги до програм безпеки власника активу й постачальників послуг [210]; частина 3 — системний рівень, зокрема методика оцінювання ризику й проєктування [211] та системні вимоги й рівні захищеності [212]; частина 4 — вимоги до процесу розробки й до компонентів [213]. Стандарт чітко розподіляє відповідальність між трьома ролями: **власник активу** (asset owner) визначає цільові рівні захищеності й експлуатує систему, **системний інтегратор** проєктує й впроваджує рішення, **постачальник продукту** забезпечує захищеність компонентів і підтримку впродовж життєвого циклу.

Центральним архітектурним поняттям є **зони й канали** (zones and conduits). Зона — сукупність активів зі спільними вимогами до захищеності; канал — контрольований шлях обміну між зонами, що сам є об'єктом захисту. Методика IEC 62443-3-2 [211] передбачає послідовність: визначити систему, що розглядається (SuC) → виконати попереднє оцінювання ризику → розділити систему на зони й канали → для кожної зони визначити цільовий рівень захищеності SL-T → виконати детальне оцінювання ризику → задокументувати вимоги в специфікації вимог кібербезпеки (CRS). Обов'язковими є окремі зони для ПАЗ, для безпроводових сегментів та для тимчасово підключеного обладнання (ноутбуки підрядників).

Рівень захищеності — це міра стійкості зони до порушника певного класу (табл. 16.2).

Таблиця 16.2 — Рівні захищеності SL за IEC 62443

SL	Клас порушника	Орієнтовні заходи
SL 1	Випадкове або ненавмисне порушення	Базове розмежування доступу, реєстрація подій, документована конфігурація
SL 2	Навмисне, прості засоби, низька мотивація, загальні навички	Сегментація, індивідуальні облікові записи, керування вразливостями, резервне копіювання
SL 3	Складні засоби, помірні ресурси, спеціальні знання про IACS	Багатофакторна автентифікація, криптографічний захист каналів, моніторинг OT-трафіку, контроль цілісності
SL 4	Складні засоби, значні ресурси, висока мотивація (державні актори)	Односторонні шлюзи, апаратний корінь довіри, розділення обов'язків, безперервне виявлення аномалій, резервний контур керування

Рівні визначають окремо для семи **базових вимог** (foundational requirements, FR): FR 1 — ідентифікація та автентифікація; FR 2 — керування використанням; FR 3 — цілісність системи; FR 4 — конфіденційність даних; FR 5 — обмеження потоків даних; FR 6 — своєчасне реагування на події; FR 7 — доступність ресурсів. Розрізняють SL-T (цільовий), SL-C (спроможність продукту) та SL-A (досягнутий). Обов'язковою умовою коректного проєктування є виконання $\text{SL-A}(z, \text{FR}_k) \geq \text{SL-T}(z, \text{FR}_k)$ для кожної зони z і кожної базової вимоги; розрив між SL-T і SL-C компонентів усувається компенсувальними заходами на рівні зони або каналу. Такий покомпонентний профіль захищеності методологічно близький до функціональних профілів захищеності НД ТЗІ 2.5-005-99 [32], що відкриває шлях до їх зіставлення в межах національної нормативної бази.

16.6 Загрози та інциденти в операційних технологіях

Емпіричну базу для проєктування захисту дає аналіз реальних кампаній. Найважливіші з них такі.

Stuxnet (виявлений 2010 р.) — перший відомий зразок шкідливого програмного забезпечення, створеного для фізичного руйнування обладнання. Він поширювався через змінні носії, долав «повітряний зазор», підміняв бібліотеку зв'язку із середовищем програмування PLC та змінював частоту обертання центрифуг, приховуючи це від оператора підміною телеметрії. Урок: ізоляція мережі не є достатнім заходом, а цілісність програм PLC потребує окремого контролю.

BlackEnergy 3 / KillDisk — атака на українські обленерго в грудні 2015 р. Початковим вектором стала цільова розсилка з макросами; після закріплення в корпоративній мережі зловмисники здобули доступ до SCADA і *вручну*, через легітимний HMI, розімкнули вимикачі, після чого знищили дані KillDisk та перепрошили перетворювачі «послідовний інтерфейс — Ethernet», щоб унеможливити віддалене відновлення [125, 68]. Знеструмлення тривало близько шести годин, живлення відновлювали переведенням підстанцій у ручний режим.

Industroyer / CrashOverride — атака в грудні 2016 р. на підстанцію 330 кВ. На відміну від попередньої, шкідливе програмне забезпечення містило модулі, що самостійно «розмовляли» промисловими протоколами IEC 60870-5-101, IEC 60870-5-104, IEC 61850 та OPC DA, а також модуль відмови в обслуговуванні для пристроїв релейного захисту [126, 69]. Це означало перехід від ручного керування атакою до масштабованого автоматизованого впливу.

TRITON / TRISIS / HatMan (2017) — перша відома атака на систему протиаварійного захисту: фреймворк взаємодіяв із контролерами Triconex через відтворений протокол TriStation, намагаючись змінити логіку ПАЗ [400]. Наслідком могла стати аварія з людськими жертвами. Урок: ПАЗ має бути в окремій зоні з найвищим SL-T, а ключ перемикання режиму програмування — фізично в положенні RUN.

Industroyer2 (квітень 2022 р.) — спроба знеструмлення високовольтних підстанцій в Україні. Зразок реалізовував лише IEC 60870-5-104 з жорстко закодованою конфігурацією й супроводжувався набором «витирачів» (CaddyWiper та ін.) для знищення слідів і ускладнення відновлення; атаку виявлено й нейтралізовано завдяки спільній роботі CERT-UA й дослідників ESET [165, 117]. Цей кейс — показовий приклад того, як поєднання оперативного обміну індикаторами, попереднього посилення сегментації та готовності до ручного режиму дозволило запобігти наслідкам.

Для систематизації тактик і технік в OT застосовують матрицю **MITRE ATT&CK for ICS** [287, 288], що містить дванадцять тактик, зокрема специфічні для OT: «Inhibit Response Function» (пригнічення функції реагування, тобто ПАЗ і релейного захисту) та «Impair Process Control» (порушення керування процесом). Двоетапну структуру втручання описує **ICS Cyber Kill**

Chain [83]: перший етап — класичне вторгнення в ІТ-мережу й закріплення, другий — розвідка технологічного процесу, розробка й випробування впливу, доставлення та виконання. Ключовий практичний висновок: між етапами минають тижні або місяці, і саме цей проміжок є вікном для виявлення — за умови наявності моніторингу ОТ-сегмента.

16.7 Захисні заходи для ОТ-середовищ

Архітектурною основою захисту є **сегментація з керованими каналами**. Мінімальна конфігурація — ДМЗ ОТ між рівнями 3 і 4: жоден потік не перетинає межу ІТ/ОТ безпосередньо, натомість дані реплікуються в дзеркало історизатора в ДМЗ, звідки їх зчитують бізнес-системи. Для зон із найвищим SL-T застосовують **діод даних** — апаратний односторонній шлюз, у якому фізична неможливість зворотного каналу забезпечується оптичним трактом з передавачем на одному боці й приймачем на іншому (рис. 16.2).



Рис. 16.2 — Захищений ОТ-сегмент з одностороннім шлюзом і контрольованим віддаленим обслуговуванням

Комплекс заходів для ОТ доцільно згрупувати так.

1. **Керування доступом і віддалене обслуговування.** Підрядники підключаються лише через виділений термінал доступу з багатофакторною автентифікацією, запис сеансу, обмеженням часового вікна й дозволом «за заявкою»; постійні тунелі від виробника обладнання заборонені. Технічні деталі — у розділах 10 і 12.
2. **Керування змінами й оновленнями.** Оновлення проходить цикл «стенд → валідація з виробником → вікно зупинки → план відкату». Для систем, оновлення яких неможливе, обов'язковим є перелік компенсувальних заходів із зазначенням залишкового ризику.

3. **Контроль цілісності конфігурацій.** Періодичне зняття й порівняння логіки PLC та уставок релейного захисту з еталоном; підписані резервні копії проєктів.
4. **Резервування й безпечні аварійні стани.** Дубльовані контролери, наперед визначені безпечні стани виконавчих механізмів при втраті зв'язку, відпрацьована процедура переходу на ручне (місцеве) керування — саме вона врятувала ситуацію у 2015 р.
5. **Моніторинг OT-трафіку.** Пасивний збір із дзеркальних портів, побудова базової лінії «нормальної» поведінки протоколів, виявлення нових вузлів, нетипових функціональних кодів (наприклад, запису в регістри з незвичного джерела) та команд поза регламентом.
6. **Захист ланцюга постачання.** Вимоги до постачальників за IEC 62443-2-4 [210] і NIST SP 800-161 [103], приймальні випробування захищеності, перевірка вбудованого ПЗ.

Кількісним критерієм достатності заходів відновлення слугує співвідношення технологічних буферів. Нехай V — корисний обсяг буферної ємності (резервуара, накопичувача) на момент відмови, q — витрата споживання, $T_{\text{в}}$ — час виявлення інциденту, $T_{\text{р}}$ — час реагування й переходу на ручне керування. Тоді допустимий час відновлення керованості

$$T_{\text{дон}} \;\le\; \frac{V}{q} - \bigl(T_{\text{в}} + T_{\text{р}}\bigr), \tag{16.3}$$

а вимога до готовності технологічної функції на інтервалі T_0 (наприклад, рік) записується як

$$A \;=\; \frac{\text{MTBF}}{\text{MTBF} + \text{MTTR}} \;\ge\; 1 - \frac{D_{\max}}{T_0}, \tag{16.4}$$

де $D_{\max}$ — нормативно допустима сумарна тривалість перерви послуги. Співвідношення (16.3)–(16.4) перетворюють абстрактні цілі кіберзахисту на перевірні інженерні вимоги й слугують основою для обґрунтування показників RTO/RPO (розділ 15).

16.8 Інтернет речей та промисловий Інтернет речей

Інтернет речей (IoT) розширює периметр критичної інфраструктури до десятків тисяч слабко захищених вузлів: приладів обліку, давачів тиску й якості води, метеостанцій, камер, контролерів вуличного освітлення. Специфіка захисту зумовлена чотирма чинниками: обмеженість обчислювальних, енергетичних і пам'яттєвих ресурсів; тривалий життєвий цикл (10–15 років) за швидкої деградації криптографічних припущень; масштаб (керува-

ння ідентичністю мільйонів пристроїв); фізична доступність і часта неможливість оновлення.

Прикладні протоколи IoT — **MQTT** (публікація/підписка через брокер) [292], **CoAP** (полегшений аналог HTTP для обмежених вузлів) [363] та **LwM2M** (керування пристроями) — самі по собі не забезпечують захисту й покладаються на нижні рівні: MQTT — на TLS [336], CoAP — на DTLS або OSCORE. Типова помилка розгортання — брокер MQTT, доступний з Інтернету без автентифікації, що дає змогу і читати телеметрію, і публікувати керувальні повідомлення.

Безпроводові технології IoT мають власні механізми захисту. **LoRaWAN** використовує два незалежні сеансові ключі — мережевий (цілісність кадру) і прикладний (шифрування корисного навантаження), причому в версії 1.1 ключі виводяться з кореневих під час процедури приєднання; критичним є захист самих кореневих ключів і уникнення повторного використання лічильників кадрів. **Zigbee** застосовує AES-128 із мережевим і канальним ключами, проте історично вразливий на етапі початкового розподілу ключа. **NB-IoT** як стільникова технологія успадковує механізми автентифікації та шифрування мобільних мереж на базі SIM/eSIM, що робить її привабливою для комунального обліку. Загальні питання захисту безпроводових сегментів розглянуто в розділі 11.

Життєвий цикл захищеного пристрою описують настанови NIST IR 8259 [168] та NIST SP 800-213 [167], а також настанови ENISA [190]. Ключові механізми: **безпечне завантаження** (перевірка підпису вбудованого ПЗ ланцюжком від апаратного кореня довіри); **атестація пристрою** — криптографічне підтвердження цілісності стану перед наданням доступу до мережі; **унікальна ідентичність** — індивідуальний ключ і сертифікат, записані на етапі виробництва, замість типових паролів; **FOTA** — оновлення «через повітря» з підписаними образами, захистом від відкату та відмовостійким подвійним банком пам'яті; **виведення з експлуатації** — відкликання сертифіката й гарантоване стирання ключів.

Наслідком нехтування цими механізмами є ботнети з IoT-пристроїв. Ботнет Mirai (2016) сканував Інтернет і підбирав типові заводські облікові дані вбудованих пристроїв (камер, маршрутизаторів), формуючи потужності для розподілених атак на відмову в обслуговуванні, які виводили з ладу великі сервіси. Для критичної інфраструктури це подвійна загроза: власні пристрої стають зброєю проти інших, а канали зв'язку об'єкта — ціллю.

16.9 Периферійні та кіберфізичні системи

Периферійні (edge) обчислення переносять оброблення ближче до джерела даних, зменшуючи затримку й залежність від каналу до центру. В критичній інфраструктурі це шафи локальної автоматики на підстанціях, вузли

агрегації телеметрії водоканалу, обчислювачі на транспортних об'єктах. Захист таких вузлів має три особливості. По-перше, вони фізично доступні, тому потрібні контроль розкриття корпусу, шифрування носіїв та зберігання ключів в апаратному захищеному модулі. По-друге, вони працюють автономно й повинні мати визначену поведінку за втрати зв'язку з центром: локальне кешування подій, обмежений автономний режим, безпечний стан. По-третє, довіра до периферійного вузла має бути *доказовою*: перед прийманням його даних центр перевіряє атестацію та підпис, що узгоджується з принципами архітектури нульової довіри [342] (розділ 12).

Кіберфізична природа таких систем породжує клас атак, невідомий класичній IT-безпеці, — **підміна фізичного вимірювання**. Зловмисник може не втручатися в мережу, а вплинути на давач (нагрівання, магнітне поле, підміна еталона), внаслідок чого коректно автентифікований і криптографічно захищений канал передаватиме хибні дані. Протидія — надлишковість і крос-валідація: узгодження показань кількох незалежних давачів, перевірка фізичної правдоподібності (баланс мас і енергій), виявлення статистичних аномалій. Це — перспективний напрям досліджень на стику теорії керування та кібербезпеки.

16.10 Кейс: планування кіберзахисту розподіленого об'єкта водопостачання

Розглянемо обласне підприємство водопостачання: центральна диспетчерська, дві водозабірні станції, шість насосних станцій, розподілена мережа з приладами обліку та давачами тиску, що передають дані через NB-IoT. Планування заходів виконують у шість етапів.

Етап 1. Інвентаризація й визначення критичності. Формується перелік активів OT (контролери, HMI, комутатори, перетворювачі інтерфейсів) із зазначенням версій ПЗ; за методикою [14] обґрунтовується віднесення об'єкта до категорії критичності, а АСК ТП і система диспетчеризації визначаються як ОКІ.

Етап 2. Аналіз взаємозалежностей. Будується матриця W (підрозд. 16.1), де враховано залежність насосних станцій від електропостачання й від каналів NB-IoT; обчислюється C_i за (16.2). Виявляється, що дві насосні станції мають найбільший індекс каскадної критичності, тож саме там першочергово встановлюють автономне живлення й резервний канал зв'язку.

Етап 3. Зонування. Виокремлюють зони: Z1 — польова (давачі, виконавчі механізми); Z2 — контролерна (PLC насосних станцій); Z3 — диспетчерська (SCADA, HMI); Z4 — ДМЗ OT (дзеркало історизатора); Z5 — корпоративна IT; Z6 — телеметрія IoT. Канали: Z2↔Z3 (промисловий протокол, окремий VLAN, «прозорий» екран із розбором протоколу); Z3→Z4 (реплікація);

Z4→Z5 (діод даних); Z6→Z4 (брокер із взаємною автентифікацією за сертифікатами).

Етап 4. Визначення SL-T. За результатами оцінювання ризику [211, 300]: Z2 і Z3 — SL-T 3 (модель порушника — державний актор із помірними ресурсами, підтверджена практикою [165]); Z4 — SL-T 3 з одностороннім каналом; Z6 — SL-T 2 з компенсацією за рахунок неможливості керування з боку телеметрії (лише читання).

Етап 5. Перелік заходів. Індивідуальні облікові записи й багатофакторна автентифікація для доступу до SCADA; вимкнення невикористовуваних служб на контролерах і фіксація ключа режиму в положенні RUN; «білі списки» застосунків на робочих місцях операторів; пасивний моніторинг OT-трафіку з передаванням подій до SIEM у ДМЗ; підписані резервні копії проєктів PLC із щоквартальною перевіркою відновлення; регламент переходу на ручне керування з навчанням персоналу двічі на рік; договірні вимоги кібербезпеки до підрядників за [210]; підключення до обміну індикаторами компрометації з CERT-UA [117].

Етап 6. Показники результативності. Частка інвентаризованих активів OT; частка зон, для яких SL-A $\geq$ SL-T за всіма FR; медіанний час виявлення аномалії в OT-сегменті; частка успішних навчальних переходів на ручне керування в межах $T_{\text{дон}}$ за (16.3); середній час усунення критичної вразливості або документування компенсувального заходу; кількість позаштатних сеансів віддаленого доступу. Показники переглядають щороку за результатами аудиту згідно з [22] і огляду стану кіберзахисту [51].

Висновки до розділу

Захист розподілених ресурсів об'єктів критичної інфраструктури принципово відрізняється від захисту корпоративних інформаційних систем, оскільки предметом захисту є не лише дані, а керованість і безпечність фізичного процесу. Це змінює ієрархію властивостей безпеки, обмежує застосовність звичних IT-заходів і робить обов'язковим використання компенсувальних механізмів.

Критична інфраструктура є соціотехнічною системою із взаємозалежностями чотирьох типів, тому оцінювання ризику неможливе без урахування каскадних ефектів; наведені формули (16.1)–(16.2) дають робочий інструмент ранжування об'єктів за індексом каскадної критичності.

Національна нормативна база — Закон «Про критичну інфраструктуру», Загальні вимоги ПКМУ № 518, порядок огляду стану кіберзахисту — концептуально узгоджується з європейськими директивами NIS2 і CER, проте потребує методичного узгодження режиму КСЗІ з процесним підходом IEC 62443; це самостійна наукова задача.

Методологічним ядром інженерного проєктування захисту OT є модель Purdue разом із зонами й каналами та рівнями захищеності SL 1–4 за семи базовими вимогами. Практичну перевірку цієї методології дали реальні інциденти: BlackEnergy (2015), Industroyer (2016), TRITON (2017) та Industroyer2 (2022), уроки яких прямо трансформуються у вимоги — окрема зона ПАЗ, контроль цілісності логіки контролерів, готовність до ручного керування, пасивний моніторинг OT-трафіку.

Розширення периметра за рахунок IoT та периферійних обчислень додає проблеми масштабованого керування ідентичністю пристроїв, безпечного завантаження, атестації та оновлення «через повітря»; безпроводові технології потребують окремого зонування. Відкритими напрямами досліджень залишаються виявлення підміни фізичних вимірювань методами крос-валідації, кількісне оцінювання каскадних ризиків у міжсекторних моделях та перехід до постквантової криптографії у пристроях із десятилітнім життєвим циклом.

Питання для самоперевірки

1. Дайте визначення критичної інфраструктури та назвіть її сектори за Законом України «Про критичну інфраструктуру».
2. Чим об'єкт критичної інформаційної інфраструктури відрізняється від об'єкта критичної інфраструктури? Наведіть приклад, коли одному ОКІ відповідає кілька ОКІІ.
3. Схарактеризуйте чотири типи інфраструктурних взаємозалежностей і поясніть механізм виникнення каскадної відмови.
4. Які основні обов'язки оператора ОКІІ встановлюють Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури (ПКМУ № 518)?
5. Порівняйте вимоги Директиви NIS2 і Директиви CER. Які з них стосуються кіберзахисту, а які — фізичної стійкості?
6. Опишіть архітектуру АСК ТП і призначення компонентів SCADA, DCS, PLC, RTU, IED, HMI, історизатора та ПАЗ.
7. Поясніть рівні еталонної моделі Purdue. Яку роль відіграє ДМЗ OT і чому пряме з'єднання рівнів 3 і 4 небажане?
8. Чому пріоритети властивостей безпеки в IT та OT різні? Наведіть три заходи, які припустимі в IT, але неприпустимі в OT, і поясніть чому.
9. Які вразливості притаманні протоколам Modbus та IEC 60870-5-104? Які механізми захисту пропонує OPC UA?
10. Розкрийте зміст понять «зони й канали», SL-T, SL-C і SL-A та перелічіть сім базових вимог (FR) IEC 62443. Сформулюйте умову коректності проєктування захисту зони.

11. Порівняйте атаки 2015 і 2016 років на українську енергосистему за вектором проникнення, способом впливу на процес і способом ускладнення відновлення. Які проєктні висновки з цього випливають?
12. Чому атака TRITON вважається якісно новим типом загрози? Які вимоги до зонування вона обґрунтовує?
13. Обґрунтуйте застосування діода даних: у яких випадках він доцільніший за міжмережевий екран і які функціональні обмеження створює?
14. Які механізми забезпечують довіру до IoT-пристрою впродовж життєвого циклу — від виробництва до виведення з експлуатації?
15. Складіть план зонування та перелік заходів кіберзахисту для розподіленої системи теплопостачання міста; визначте SL-T для кожної зони й запропонуйте три показники результативності.

РОЗДІЛ 17

Управління безпекою розподілених ресурсів: СУІБ, DevSecOps і напрями наукових досліджень

Попередні розділи розглядали окремі шари захисту розподілених інформаційних ресурсів: архітектури й загрози, класи розподілених систем і механізми координації, нормативну базу, кількісні моделі, криптографію, керування доступом, мережеву й хмарну безпеку, захист даних, моніторинг, реагування та специфіку критичної інфраструктури. Проте сукупність технічних механізмів ще не утворює захищеної системи: без керувального контуру вона деградує — заходи застарівають, конфігурації дрейфують, відповідальність розмивається між власниками сервісів. Цей заключний розділ розглядає механізм, що зшиває окремі заходи в керовану цілісність — систему управління інформаційною безпекою (СУІБ), — а також інтеграцію безпеки в життєвий цикл розроблення (DevSecOps), економічне обґрунтування захисту, роль штучного інтелекту й методологію наукового дослідження, якою аспірант має скористатися, щоб перейти від засвоєння матеріалу до продукування нового знання.

17.1 Система управління інформаційною безпекою як механізм інтеграції

17.1.1 Цикл PDCA і структура вимог

Система управління інформаційною безпекою — це частина загальної системи управління організації, побудована на оцінюванні ризиків і призначена для встановлення, впровадження, підтримування та постійного поліпшення інформаційної безпеки [20]. Ключова теза, важлива саме для розподілених ресурсів: СУІБ керує не активами як такими, а *процесами* прийняття рішень щодо них. Коли ресурс фізично розміщений у трьох юрисдикціях, обслуговується двома постачальниками й змінюється десятки разів на добу, єдиним стабільним об'єктом управління залишається процес.

Структура ДСТУ EN ISO/IEC 27001:2023 відповідає моделі високого рівня (HLS), спільній для всіх стандартів систем управління, і реалізує цикл **PDCA** (Plan–Do–Check–Act):

- **Контекст організації** (розд. 4): визначення внутрішніх і зовнішніх чинників, зацікавлених сторін та їхніх вимог, а головне — *сфери застосування* СУІБ. Для розподілених систем окреслення сфери є найтоншим місцем: межа проходить не по периметру мережі, а по межі

керованості — усередину включають те, щодо чого організація має повноваження ухвалювати й забезпечувати рішення, а зовнішні залежності опрацьовують механізмами керування ризиками ланцюга постачання [103].

- **Лідерство** (розд. 5): зобов'язання найвищого керівництва, політика, розподіл ролей і відповідальності. Практика показує, що в розподілених середовищах формальний власник ризику часто не збігається з фактичним розпорядником ресурсу (наприклад, команда продукту самостійно обирає хмарний регіон), і саме цей розрив породжує «сирітські» активи.
- **Планування** (розд. 6): дії щодо ризиків і можливостей, оцінювання та обробляння ризиків за ISO/IEC 27005 [231, 227], формулювання цілей безпеки, вимірних і прив'язаних до строків, а також планування змін.
- **Підтримка** (розд. 7): ресурси, компетентність, обізнаність, комунікація, керування документованою інформацією.
- **Функціонування** (розд. 8): операційне планування й контроль, виконання оцінювання й обробляння ризиків — шар, який змістовно наповнюють розділи 9–13 і 16 цього посібника.
- **Оцінювання дієвості** (розд. 9): моніторинг, вимірювання, аналіз, внутрішній аудит, аналізування з боку керівництва (розділ 14).
- **Поліпшення** (розд. 10): реагування на невідповідності, коригувальні дії, неперервне поліпшення (розділ 15).

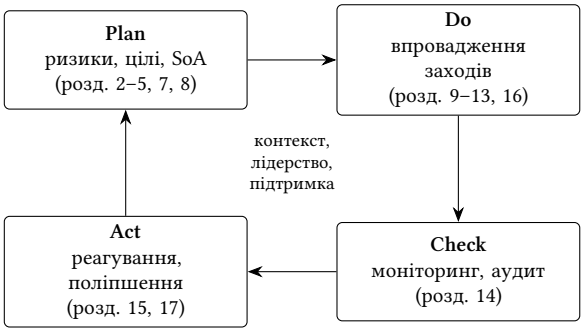


Рис. 17.1 — Цикл PDCA системи управління інформаційною безпекою та його наповнення матеріалом розділів посібника (за [20])

17.1.2 Положення про застосовність і вибір заходів

Положення про застосовність (Statement of Applicability, SoA) — документ, у якому для кожного заходу з додатка А наведено рішення про його застосування чи незастосування, обґрунтування рішення та стан упровадження.

SoA формально пов'язує результати оцінювання ризиків із механізмами захисту й тому є доказовою базою під час сертифікаційного аудиту.

Перегляд стандарту 2022 року (в Україні — ДСТУ EN ISO/IEC 27002:2023) реструктурував заходи: замість чотирнадцяти розділів запроваджено чотири теми й 93 заходи, кожен з яких описано п'ятьма атрибутами. Атрибутивна модель принципово важлива для розподілених систем, бо дає змогу формувати динамічні подання одного й того самого набору заходів — «зріз за функціями NIST CSF», «зріз за властивостями безпеки», «зріз за концепціями кіберзахисту» — і в такий спосіб узгоджувати СУІБ із суміжними рамками [21, 307].

Таблиця 17.1 — Структура заходів ДСТУ EN ISO/IEC 27002:2023

Тема	К-сть	Характерні для розподілених ресурсів заходи
Організаційні	37	політики, ролі, керування активами, вимоги до постачальників хмарних послуг, безпека в ланцюгу постачання ІКТ
Персональні	8	перевіряння кандидатів, умови праці, обізнаність, дисциплінарний процес, віддалена робота
Фізичні	14	зони безпеки, безпека обладнання, носії, комунальні послуги, захист кабельної мережі
Технологічні	34	криптографія, керування вразливостями, безпечне розроблення, реєстрування подій, сегментація, резервне копіювання

Атрибути заходу: тип заходу (запобіжний / виявний / коригувальний); властивість безпеки (конфіденційність / цілісність / доступність); концепція кібербезпеки (ідентифікувати / захищати / виявляти / реагувати / відновлювати); операційна спроможність; сфера безпеки.

17.2 Політики та документована інформація

Документація СУІБ утворює ієрархію, у якій кожен рівень відповідає на власне питання. **Політика** відповідає на питання «чого і навіщо» — це короткий, затверджений найвищим керівництвом документ із принципами й розподілом відповідальності. **Стандарт** відповідає на питання «що конкретно» — обов'язкові технічні або організаційні вимоги (мінімальна довжина ключа, перелік дозволених шифронаборів, базові конфігурації). **Процедура** описує «хто і в якій послідовності», **інструкція** — «як саме» на рівні конкретних дій оператора.

Політика безпеки розподілених ресурсів має додатково врегулювати питання, що не виникають у монолітних системах: правила розміщення даних за юрисдикціями й класами, вимоги до взаємної автентифікації сервісів, дозволені моделі делегування повноважень, відповідальність за спільно керовані компоненти, правила під'єднання безпроводових сегментів до

корпоративного домену, порядок використання зовнішніх програмних залежностей і моделей машинного навчання.

Типові дефекти політик, які виявляє аудит: (а) декларативність — документ переказує стандарт, не встановлюючи жодної перевірної вимоги; (б) відсутність адресності — вимога не має власника, тож ніхто не відповідає за її виконання; (в) неузгодженість із фактичними процесами — політика забороняє те, що щодня роблять команди, унаслідок чого нормалізується вибіркове виконання; (г) відсутність механізму винятків, що породжує «тіньову» інфраструктуру; (д) застарілість після зміни архітектури. Керування документованою інформацією (розд. 7.5 ДСТУ EN ISO/IEC 27001:2023) вимагає ідентифікації, формату, схвалення, контролю версій, доступності та захисту документів [20].

17.3 Вимірювання дієвості: показники, метрики, дашборди

Розділ 9 стандарту вимагає визначити, *що* вимірювати, *якими* методами, *коли* і *хто* аналізує результати; методологію вимірювання деталізує ISO/IEC 27004 [230]. Розрізняють **KPI** (показники дієвості — наскільки добре працює процес) і **KRI** (показники ризику — наскільки близько система до неприйнятного стану). Вимоги до метрики зручно перевіряти за критеріями: вимірність об'єктивними засобами без ручного оцінювання; відтворюваність; наявність цільового значення й порогу; чутливість до реальних змін стану; неможливість тривіального «поліпшення» без поліпшення захищеності; прийнятна вартість збирання.

Показники, придатні для розподілених середовищ: частка активів у централізованому інвентарі; 90-й процентиль часу усунення критичних вразливостей; частка міжсервісних з'єднань із взаємною автентифікацією; середній час виявлення (MTTD) і локалізації (MTTC) інциденту; частка успішних навчальних відновлень з резервних копій; частка безпроводових точок доступу з актуальним профілем захисту.

Для комунікації з керівництвом окремі метрики агрегують в індекс захищеності. Адитивна згортка $I_a = \sum_i w_i m_i$ (де $m_i \in [0,1]$ — нормовані показники, $\sum_i w_i = 1$) є простою, проте допускає компенсацію: критично низьке значення одного показника «маскується» високими значеннями інших. Для безпеки, де слабка ланка визначає результат, коректнішою є мультиплікативна (геометрична) згортка:

$$I_g = \prod_{i=1}^{n} m_i^{\,w_i}, \qquad \sum_{i=1}^{n} w_i = 1, \quad m_i \in (0,1]. \tag{17.1}$$

Оскільки $I_g \le I_a$ і $I_g \to 0$ за $m_i \to 0$, індекс автоматично «штрафує» провали за окремими напрямами. Ваги w_i доцільно визначати не експер-

тним голосуванням, а методом аналізу ієрархій із перевіркою узгодженості матриці парних порівнянь (розділ 7). Дашборд для керівництва має містити не більше 7–9 елементів: індекс I_g у динаміці, кілька KRI з пороговими зонами, стан виконання плану обробляння ризиків і перелік прийнятих залишкових ризиків із термінами перегляду.

17.4 Моделі зрілості та оцінювання спроможностей

Метрики фіксують поточний стан, моделі зрілості — *здатність* організації стабільно відтворювати результат. NIST CSF 2.0 визначає шість функцій: Govern (управління) — нову функцію, що охоплює стратегію, політику, ролі й нагляд за ланцюгом постачання, — а також Identify, Protect, Detect, Respond, Recover [307]. Рівні впровадження (Tiers) 1–4 («Partial», «Risk Informed», «Repeatable», «Adaptive») характеризують не якість окремих заходів, а строгість процесів керування ризиками та інтегрованість безпеки в діяльність організації.

Модель C2M2 (Cybersecurity Capability Maturity Model, версія 2.1) деталізує оцінювання: 10 доменів, близько 350 практик, чотири рівні індикаторів зрілості MIL0–MIL3, де MIL1 — виконувані, але неформалізовані практики, MIL2 — задокументовані й забезпечені ресурсами, MIL3 — керовані, з періодичним переглядом і призначеною відповідальністю [143]. Модель початково розроблено для енергетичного сектору, що робить її особливо доречною для українських операторів критичної інфраструктури (розділ 16).

Практичний алгоритм самооцінювання: (1) визначити цільовий профіль, виходячи з регуляторних вимог (Закон України «Про основні засади забезпечення кібербезпеки України», постанова КМУ № 518, NIS 2 для європейських партнерів) [58, 22, 149]; (2) оцінити поточний профіль за доменами; (3) обчислити розриви й ранжувати їх за добутком «величина розриву $\times$ внесок у ризик $\div$ вартість усунення»; (4) сформувати дорожню карту на 2–3 горизонти (0–6, 6–18, 18–36 місяців); (5) повторити оцінювання після кожного горизонту. Показовим є український кейс: після 2022 року міграція державних інформаційних ресурсів до хмарних середовищ і закордонних дата-центрів відбувалася під нормативним супроводом Держспецзв'язку, і саме потреба швидко довести відповідність базовим вимогам зробила профільне самооцінювання практичним інструментом, а не формальністю [8].

17.5 Безпека життєвого циклу розроблення: SSDF і DevSecOps

Значна частина інцидентів у розподілених системах пов'язана з дефектами програмного забезпечення й ланцюга його постачання. NIST SP 800-218 (Secure Software Development Framework, SSDF v1.1) описує практики чотирма групами: PO — підготувати організацію; PS — захистити програмне забезпечення; PW — створювати захищене ПЗ; RV — реагувати на вразливості

[380]. SSDF свідомо не прив'язаний до методології розроблення, тому однаково застосовний до водоспадного циклу й до безперервного постачання.

DevSecOps — практика вбудовування безпекових перевірок безпосередньо в конвеєр безперервної інтеграції та постачання, з принципами: «зсув уліво» (shift left) — виявляти дефекти якомога раніше; автоматизація замість ручного погодження; безпека як код (політики, правила й базові конфігурації зберігаються у сховищі версій); спільна відповідальність команд розроблення й безпеки; швидкий зворотний зв'язок розробникові в звичному для нього інструменті.

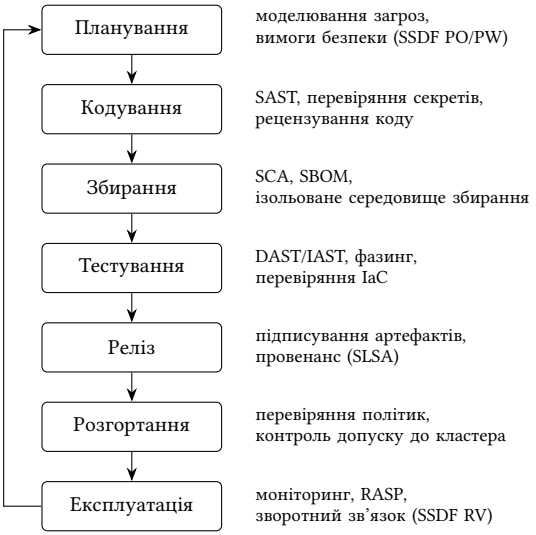


Рис. 17.2 — Конвеєр DevSecOps і точки контролю безпеки (за [380, 372])

Основні класи інструментального контролю: **SAST** — статичний аналіз початкового коду (широке покриття, високий рівень хибних спрацьовувань); **DAST** — динамічне тестування працездатного застосунку ззовні (низький рівень хибних спрацьовувань, слабке покриття внутрішніх шляхів); **IAST** — інтерактивний аналіз із інструментуванням середовища виконання; **SCA** — аналіз складу програмного забезпечення, тобто відкритих залежностей, з формуванням переліку компонентів (SBOM). Жоден клас не є замінником іншого: емпірично їхні множини знахідок перетинаються слабко, що саме по собі є предметом наукового дослідження.

Критично важливим є усвідомлення, що *сам конвеєр є розподіленим інформаційним ресурсом найвищої критичності*: він має право запису в промислове середовище, зберігає облікові дані до всіх контурів і виконує сто-

ронній код (плагіни, дії, образи збирача). Компрометація конвеєра еквівалентна компрометації всіх систем, які він обслуговує. Звідси вимоги: ізоляція виконавців збирання й ефемерність їхніх середовищ; заборона довготривалих статичних секретів на користь короткочасних маркерів доступу з федеративною ідентичністю (розділ 10); мінімальні права службових облікових записів у розрізі окремих проєктів; підписування артефактів і перевіряння підпису на етапі допуску (розділ 9); незмінні, придатні до аудиту журнали конвеєра (розділ 14); закріплення версій сторонніх дій за гешсумою, а не за рухомим тегом. Модель SLSA формалізує рівні гарантій провенансу артефакту — від наявності підписаного свідчення про збирання до гарантій ізольованості й відтворюваності процесу [372]. Інфраструктура як код (IaC) робить конфігурацію придатною для статичного перевіряння політик до розгортання.

17.6 Керування вразливостями та змінами

Цикл керування вразливостями охоплює: інвентаризацію активів і компонентів; виявлення (сканування, дані SCA, повідомлення постачальників, бюлетені CERT-UA); нормалізацію й дедуплікацію; пріоритезацію; усунення або компенсаційний захід; перевіряння результату; звітування [378, 117]. Вузьким місцем є пріоритезація: у великому розподіленому середовищі кількість виявлених позицій на порядки перевищує пропускну здатність команд.

Класична оцінка CVSS характеризує *властивості* вразливості, а не ймовірність її використання. Тому сучасна практика поєднує три джерела: базову й середовищну оцінки CVSS v4.0 [138], імовірнісну оцінку EPSS — прогноз імовірності експлуатації протягом наступних 30 днів [164] — та факт наявності вразливості в каталозі KEV, тобто підтвердженого використання «в дикій природі» [253]. Практичний пріоритет зручно виражати як

$$P_i = C_i^{\text{env}} \cdot p_i^{\text{EPSS}} \cdot \left(1 + \alpha \mathbb{1}_{\text{KEV}}(i)\right) \cdot \beta_i, \tag{17.2}$$

де C_i^{env} — середовищна оцінка CVSS, нормована до $[0,1]$; $p_i^{\text{EPSS}} \in [0,1]$; $\mathbb{1}_{\text{KEV}}$ — індикатор входження до каталогу KEV; $\alpha > 0$ — ваговий коефіцієнт підтвердженої експлуатації; β_i — коефіцієнт критичності активу, визначений за результатами аналізу впливу на діяльність (розділ 15). Емпіричне обґрунтування значень α і β для конкретного класу організацій — цілком придатна тема прикладного дисертаційного дослідження.

Керування змінами в розподіленому середовищі має власну специфіку. Вікно обслуговування не існує глобально: у геонезалежній системі «нічний» інтервал одного регіону є піковим для іншого. Тому оновлення виконують поетапно (канарковий випуск, поступове розгортання за частками трафіку) із критеріями автоматичного відкату. Окремої уваги потребує

дрейф конфігурацій — поступове відхилення фактичного стану вузлів від затвердженого базового профілю внаслідок ручних утручань. Протидія — періодичне звіряння з базовою конфігурацією (CIS Benchmarks, що деталізують вимоги CIS Controls [129]), незмінна інфраструктура, за якої вузол не змінюють, а замінюють новим примірником із перевіреного образу, та контроль допуску, що відхиляє ресурси з невідповідною конфігурацією.

17.7 Людський і організаційний вимір

Соціотехнічний підхід розглядає систему захисту як єдність технічної та соціальної підсистем: зміна однієї без узгодження з іншою призводить до компенсаційної поведінки персоналу, яка нівелює захід [4]. Класичний приклад — надмірно жорстка парольна політика, що спричиняє записування паролів, або надто дрібне гранулювання доступу, що породжує практику обміну обліковими записами.

Культура безпеки вимірюється не кількістю проведених інструктажів, а спостережуваними індикаторами: часткою самостійно повідомлених працівниками підозрілих подій, часткою запитів на легальні винятки замість обходу правил, готовністю повідомити про власну помилку без страху покарання. Програма обізнаності має бути диференційованою за ролями, а її результативність перевіряють симуляційними кампаніями з навчальним, а не каральним використанням результатів.

Інсайдерський ризик у розподілених системах посилюється тим, що привілейований адміністратор часто має технічну можливість дії, яка не залишає слідів у підконтрольних йому журналах. Заходи: винесення журналів у незалежний контур із записом лише на додавання (розділ 14), розділення обов'язків, правило чотирьох очей для критичних операцій, доступ «точно вчасно» замість постійних привілеїв, поведінкова аналітика. Робота з підрядниками потребує договірного закріплення вимог безпеки, права на аудит, зобов'язань щодо повідомлення про інциденти у визначені строки, вимог до субпідрядників і процедур припинення відносин із гарантованим вилученням даних та відкликанням доступів [103, 21].

17.8 Економіка захисту розподілених ресурсів

Найвідомішою формальною моделлю оптимальних інвестицій у захист є модель Гордона–Лоуба [191]. Нехай інформаційний ресурс характеризується потенційними збитками L у разі порушення захисту та початковою вразливістю $v \in [0,1]$ — імовірністю успішної атаки за відсутності додаткових інвестицій. Функція $S(z, v)$ задає ймовірність порушення після інвестування суми $z \geq 0$, причому $S(0, v) = v$, $S(z, 0) = 0$, S спадна й опукла за z. Очікуваний чистий виграш від інвестицій в інформаційну безпеку становить

$$\mathrm{ENBIS}(z) = \big[v - S(z, v)\big]\, L - z, \tag{17.3}$$

а оптимальний обсяг $z^*(v)$ задовольняє умову першого порядку $-\partial S(z,v)/\partial z \cdot L = 1$, тобто гранична вигода дорівнює граничним витратам. Головний і контрінтуїтивний висновок авторів: для широких класів функцій S оптимальні витрати не перевищують приблизно $\frac{1}{e}\, vL \approx 0{,}37\, vL$, а максимум інвестицій припадає не на найвразливіші ресурси, а на ресурси *середньої* вразливості: захист надзвичайно вразливого активу коштує непропорційно дорого, тож раціональніше або істотно змінити його архітектуру, або перенести ризик. Для розподілених систем це має пряме архітектурне прочитання: якщо сегмент неможливо захистити за прийнятних витрат, його слід ізолювати, замінити або вивести з контуру — але не «посилювати» нескінченно.

Для комунікації з фінансовим керівництвом використовують показник повернення інвестицій у безпеку:

$$\mathrm{ROSI} = \frac{\big(\mathrm{ALE}_0 - \mathrm{ALE}_1\big) - C}{C}, \qquad \mathrm{ALE} = \mathrm{SLE} \times \mathrm{ARO}, \tag{17.4}$$

де ALE_0 і ALE_1 — очікувані річні збитки до і після впровадження заходу, C — річна сукупна вартість заходу, SLE — збиток від одного інциденту, ARO — очікувана річна частота. Обмеження показника слід називати прямо: оцінки ARO для рідкісних подій із важкими наслідками статистично ненадійні, розподіли збитків мають важкі хвости, а середнє значення погано характеризує ризик руйнівного сценарію. Тому ROSI доцільно доповнювати аналізом чутливості, поданням у вигляді діапазонів (наприклад, за методом Монте-Карло, розділ 8) та окремим розглядом «хвостових» сценаріїв. Вартість C має охоплювати весь життєвий цикл заходу — від упровадження й експлуатації до виведення з обігу.

17.9 Штучний інтелект: інструмент захисту і нове джерело загроз

Машинне навчання застосовують у захисті розподілених ресурсів насамперед для виявлення аномалій — у мережевому трафіку, поведінці облікових записів, послідовностях системних викликів, — а також для пріоритезації сповіщень, кореляції подій і автоматизації типових дій реагування (розділ 14). Обмеження методів слід оцінювати тверезо: базова частота атак украй низька, тому навіть висока точність класифікатора за теоремою Байєса дає низьку апостеріорну ймовірність істинного спрацьовування; розподіл нормальної поведінки в розподілених системах нестаціонарний, що спричиняє дрейф моделі; рішення моделі потребує пояснюваності для юридично значущих дій.

Водночас самі системи штучного інтелекту утворюють новий клас захищуваних ресурсів із власним простором загроз, систематизованим у базі знань MITRE ATLAS [286]: отруєння навчальних даних і закладання «задніх дверей» у модель; змагальні приклади, що спричиняють хибну класифікацію за мінімальних збурень входу; інверсія моделі та атаки визначення належності, які порушують конфіденційність навчальних даних; крадіжка (екстракція) моделі через масові запити до інтерфейсу; впровадження інструкцій у запит (prompt injection) та непряме впровадження через оброблювані дані. Особливо гострими є ризики *агентних* систем, здатних самостійно викликати зовнішні інструменти: агент із доступом до інтерфейсів керування фактично є привілейованим суб'єктом розподіленої системи, а тому потребує тих самих механізмів — ідентичності, мінімальних привілеїв, журналювання, підтвердження критичних дій людиною — і, додатково, ізоляції каналів недовіреного вводу від каналів команд.

Нормативні рамки формуються швидко. NIST AI RMF 1.0 пропонує чотири функції керування ризиками ШІ — Govern, Map, Measure, Manage — і перелік характеристик довіреності системи [299]; NIST SP 800-218A поширює практики SSDF на розроблення генеративних моделей [102]; ISO/IEC 42001:2023 визначає вимоги до системи управління штучним інтелектом, структурно сумісної із СУІБ [237]. Регламент (ЄС) 2024/1689 (Акт про штучний інтелект) запроваджує ризик-орієнтований підхід: заборонені практики, високоризикові системи з вимогами до якості даних, документації, реєстрування, людського нагляду, точності, робастності й кібербезпеки, а також окремі зобов'язання для моделей загального призначення [331]. Для України цей регламент має значення як орієнтир адаптації законодавства в межах євроінтеграційних зобов'язань. Критична настанова: застосування ШІ в захисті не усуває жодної з класичних вимог — воно додає новий об'єкт захисту й нову поверхню атаки.

17.10 Методологія наукових досліджень аспіранта

Перехід від інженерної діяльності до наукової починається з коректного формулювання **наукової проблеми** — суперечності між потребою й наявними засобами її задоволення, яку не можна усунути прямим застосуванням відомих рішень. Типова помилка початківця — підміна наукової проблеми технічним завданням («упровадити SIEM у відомстві»). Наукове формулювання вимагає вказати, чого саме бракує в *знанні*: моделі, методу, критерію, оцінки границь застосовності.

Далі формулюють **гіпотезу** — перевірне твердження, з якого випливають наслідки, здатні бути спростованими. Вибір методу визначається природою гіпотези:

Таблиця 17.2 — Напрями досліджень і адекватні їм методи

Напрям	Переважні методи та критерії достовірності
Оцінювання захищеності розподіленої системи	аналітичне моделювання (марковські процеси, мережі Петрі, теорія ігор); достовірність — доведення коректності моделі та перевіряння припущень
Продуктивність механізмів захисту	імітаційне моделювання й стендовий експеримент; повторність, довірчі інтервали, контроль сторонніх чинників
Аналіз протоколів безпеки	формальна верифікація, автоматизоване доведення; достовірність — строгість моделі порушника
Виявлення атак методами ML	емпіричний аналіз даних; крос-валідація, незалежний тестовий набір, метрики, стійкі до дисбалансу класів
Організаційні та людські чинники	опитування, експеримент із респондентами, кейс-стаді; репрезентативність вибірки, етичне погодження
Узагальнення стану галузі	систематичний огляд літератури за протоколом; відтворюваний пошуковий запит, критерії включення й виключення

Систематичний огляд літератури (systematic literature review) виконують за наперед зафіксованим протоколом: дослідницькі питання, пошукові запити, бази даних, критерії включення/виключення, процедура оцінювання якості джерел, форма видобування даних, спосіб синтезу [250]. Саме протокол, зафіксований *до* початку пошуку, відрізняє систематичний огляд від довільної добірки джерел.

Критерії **наукової новизни** у дисертаційній роботі формулюють через дієслова «уперше», «удосконалено», «дістало подальший розвиток», причому кожне положення має бути співвіднесене з конкретним результатом і містити вказівку на відмінність від відомих рішень та на наслідки цієї відмінності. Формула новизни без вимірного покращення або без окреслення умов застосовності науковою не є.

Відтворюваність стає обов'язковою нормою: публікація має супроводжуватися описом середовища експерименту, версіями інструментів, наборами даних або процедурою їх генерування, кодом оброблення результатів. Планування експерименту передбачає визначення залежних і незалежних змінних, факторів, що контролюються, числа повторень, достатнього для досягнення заданої статистичної потужності, і способу оцінювання значущості відмінностей. Достовірність результатів обґрунтовують поєднанням методів: аналітична модель підтверджується імітаційним експериментом, імітація — натурним стендом, стенд — даними експлуатації.

Етика досліджень у кібербезпеці має особливу гостроту. Неприпустимими є експерименти на чужих системах без письмового дозволу, публікація працездатних експлойтів до усунення вразливості, оброблення персональних даних без правової підстави [53, 328]. Норма галузі — скоординоване розкриття вразливостей: повідомлення власника, погоджений строк

усунення, публікація лише після виправлення або спливу строку. Робота з реальними даними інцидентів потребує знеособлення й погодження з власником.

Публікаційна стратегія аспіранта передбачає поєднання: доповіді на конференціях для швидкого зворотного зв'язку; статті у фахових виданнях України (зокрема «Кібербезпека: освіта, наука, техніка» — категорія «Б», ISSN 2663-4023 [23, 6, 67], «Захист інформації», «Радіоелектронні і комп'ютерні системи», «Ukrainian Information Security Research Journal»); публікації у виданнях, індексованих Scopus і Web of Science, для міжнародного визнання. Наукометричні показники (індекс Гірша, квартиль видання) є допоміжними індикаторами, а не метою; обов'язковою є перевірка доброчесності видання (перелік МОН, прозорість рецензування).

17.11 Відкриті наукові проблеми й перспективні напрями

Перелік нижче не є вичерпним, проте окреслює простір задач, у яких сьогодні бракує усталених рішень і в яких можливий вагомий науковий результат.

- **Постквантова міграція.** Стандартизація ML-KEM і ML-DSA [302, 301] відкриває, а не закриває проблему: відкритими залишаються методи інвентаризації криптографічних залежностей у великих розподілених системах, стратегії гібридних схем, оцінювання впливу збільшених розмірів ключів і підписів на протоколи та на пристрої з обмеженими ресурсами, планування міграції за критерієм часу захисту даних (модель «збери зараз — розшифруй потім»).
- **Безпека агентних систем ШІ.** Формальні моделі повноважень автономного агента, механізми відокремлення недовіреного вводу від команд, верифіковані обмеження дій, оцінювання ризику каскадних збоїв у мультиагентних середовищах [286, 299].
- **Конфіденційні обчислення.** Довірені середовища виконання, гомоморфне шифрування, безпечні багатосторонні обчислення, федеративне навчання: практичною проблемою залишається співвідношення «гарантії — продуктивність — складність засвідчення» та довіра до апаратного кореня довіри постачальника.
- **Автоматизоване доведення властивостей протоколів.** Масштабування формальної верифікації на композиції протоколів і на реалізації, а не лише специфікації; узгодження моделей порушника з реальними каналами побічного витоку.
- **Кіберстійкість критичної інфраструктури в умовах воєнного стану.** Моделі стійкості за одночасних кінетичних і кібернетичних впливів, деградаційні режими, автономність сегментів за відсутності

зв'язку та живлення, метрики стійкості [343, 55]. Український досвід є унікальним емпіричним матеріалом світового значення.

- **Децентралізована ідентичність.** Самокеровані ідентифікатори й перевірні свідчення, відкликання без централізованого реєстру, сумісність із вимогами до електронних довірчих послуг [44, 192].
- **Безпека 6G і периферійних обчислень.** Захист безпроводових сегментів надвисокої щільності, автентифікація за фізичним рівнем, мобільність обчислювальних функцій, розподіл довіри між оператором, периферійним вузлом і хмарою (розділ 11).

Висновки до розділу

Система управління інформаційною безпекою перетворює набір розрізнених заходів на керований процес: цикл PDCA забезпечує повторюваність, Положення про застосовність — простежуваний зв'язок ризиків із заходами, а вимірювання дієвості — зворотний зв'язок, без якого поліпшення неможливе. Показано, що для агрегованих індексів захищеності мультиплікативна згортка є коректнішою за адитивну, оскільки не допускає компенсації провалів за окремими напрямами. Моделі зрілості (NIST CSF 2.0, C2M2) доповнюють метрики оцінюванням спроможностей і дають основу для дорожньої карти вдосконалення.

Інтеграція безпеки в життєвий цикл розроблення (SSDF, DevSecOps) переносить основну частину контролю з етапу експлуатації на етапи проєктування й збирання, водночас перетворюючи сам конвеєр CI/CD на розподілений ресурс найвищої критичності. Пріоритезація вразливостей вимагає поєднання властивісних (CVSS), імовірнісних (EPSS) і фактологічних (KEV) джерел із урахуванням критичності активу. Модель Гордона–Лоуба показує, що раціональні інвестиції обмежені зверху й не мають спрямовуватися на найвразливіші активи, а ROSI, попри свою комунікаційну зручність, потребує обережного поводження з оцінками частот рідкісних подій. Штучний інтелект розглянуто симетрично — як інструмент виявлення й водночас як новий об'єкт захисту з власним простором загроз і нормативними рамками, що формуються.

Посібник загалом провів читача від властивостей і загроз розподілених систем, їхніх координаційних класів і специфічних атак через нормативну базу, кількісні методи й технічні механізми захисту до управлінського контуру, що зв'язує їх. Наскрізна теза така: захищеність розподіленого ресурсу не є властивістю жодного окремого механізму; вона є властивістю системи в цілому й підтримується лише неперервним керувальним процесом. Для аспіранта посібник має слугувати не завершеним склепінням знань, а картою місцевості, на якій позначено як освоєні ділянки, так і білі плями, що чекають на власне дослідження.

Питання для самоперевірки

1. Поясніть, чому об'єктом управління в СУІБ доцільно вважати процес, а не актив, і як це впливає на окреслення сфери застосування системи для геонезалежного ресурсу.
2. Які рішення документує Положення про застосовність і чому саме воно, а не перелік упроваджених засобів, є доказовою базою під час аудиту?
3. Назвіть чотири теми заходів ДСТУ EN ISO/IEC 27002:2023 та поясніть практичне призначення атрибутивної моделі опису заходу.
4. Побудуйте ієрархію «політика — стандарт — процедура — інструкція» для правил міжсервісної автентифікації та вкажіть, який зміст належить кожному рівню.
5. Сформулюйте п'ять вимог до метрики безпеки й перевірте за ними показник «кількість заблокованих міжмережевим екраном пакетів за добу».
6. Порівняйте адитивну та мультиплікативну згортки часткових показників у зведений індекс захищеності; за яких умов їхні висновки розходяться?
7. Чим рівні впровадження NIST CSF 2.0 відрізняються від індикаторів зрілості MIL C2M2 і в яких випадках доцільніше застосовувати кожну з моделей?
8. Обґрунтуйте, чому конвеєр CI/CD слід класифікувати як розподілений ресурс найвищої критичності, і перелічіть щонайменше п'ять заходів його захисту.
9. Порівняйте SAST, DAST, IAST і SCA за покриттям, рівнем хибних спрацьовувань і етапом застосування; поясніть, чому вони не є взаємозамінними.
10. У чому полягає обмеженість CVSS як інструмента пріоритезації і як його компенсують EPSS та каталог KEV?
11. Поясніть, чому в моделі Гордона–Лоуба максимум оптимальних інвестицій припадає не на найвразливіші ресурси, і сформулюйте архітектурний висновок із цього для розподіленої системи.
12. Які припущення робить показник ROSI і за яких умов його застосування призводить до систематичного заниження ризику?
13. *Дослідницьке завдання.* Запропонуйте методику емпіричного обґрунтування вагових коефіцієнтів α і β у формулі пріоритезації вразливостей для конкретного класу організацій; визначте джерела даних, план експерименту й критерії достовірності.

14. *Дослідницьке завдання.* Розробіть протокол систематичного огляду літератури з теми «безпека агентних систем штучного інтелекту»: дослідницькі питання, пошукові запити, критерії включення й виключення, спосіб синтезу результатів.
15. *Дослідницьке завдання.* Сформулюйте наукову проблему, гіпотезу та положення новизни для дослідження кіберстійкості розподіленого сервісу критичної інфраструктури за одночасних кінетичних і кібернетичних впливів; оберіть методи й обґрунтуйте достовірність очікуваних результатів.

Список використаних джерел

[1] Абрамов В., Глушак О., Плоха А., Довженко Т. Проєктування мережевої інфраструктури з урахуванням вимог кібербезпеки: підходи та реалізація на базі Cisco. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 1, № 29. С. 59–72. DOI: 10.28925/2663-4023.2025.29.845. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/845.

[2] Андрущак І., Кошелюк В. Аудит безпеки lightweight Kubernetes-кластерів із використанням механізмів довіри на базі MultiChain. *Кібербезпека: освіта, наука, техніка.* 2026. Т. 4, № 32. С. 463–477. DOI: 10.28925/2663-4023.2026.32.1097. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1097.

[3] Банах Р. Виявлення атаки Evil Twin на бездротові мережі стандарту IEEE 802.11 в умовах щільної забудови. *Кібербезпека: освіта, наука, техніка.* 2026. Т. 1, № 33. С. 842–856. DOI: 10.28925/2663-4023.2026.33.1279. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1279.

[4] Бурячок В. Л., Толубко В. Б., Хорошко В. О., Толюпа С. В. Інформаційна та кібербезпека: соціотехнічний аспект: підручник / за заг. ред. В. Б. Толубка. Київ: ДУТ, 2015. 288 с.

[5] Горбенко І. Д., Горбенко Ю. І. Прикладна криптологія: теорія, практика, застосування: монографія. Харків: Форт, 2012. 878 с.

[6] Гречанінов В. Метод стратегічного планування заходів з кіберзахисту на основі концепції SWOT. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 2, № 30. С. 66–88. DOI: 10.28925/2663-4023.2025.30.953. URL: https://doi.org/10.28925/2663-4023.2025.30.953.

[7] Грищук О., Грищук Р. Оцінювання захищеності блокчейн-вузла від екліпс-атаки та троянського шкідливого програмного забезпечення на основі диференціально-ігрових моделей. *Кібербезпека: освіта, наука, техніка.* 2026. Т. 4, № 32. С. 633–653. DOI: 10.28925/2663-4023.2026.32.1150. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1150.

[8] Державна служба спеціального зв'язку та захисту інформації України: офіційний вебсайт. URL: https://cip.gov.ua/.

[9] Деякі питання електронної взаємодії електронних інформаційних ресурсів: постанова Кабінету Міністрів України від 08.09.2016 № 606 (у редакції від 03.10.2025). URL: https://zakon.rada.gov.ua/laws/show/606-2016-п.

[10] Деякі питання електронної ідентифікації та електронних довірчих послуг: постанова Кабінету Міністрів України від 28.06.2024 № 764. URL: https://zakon.rada.gov.ua/laws/show/764-2024-п.

[11] Деякі питання забезпечення функціонування інформаційно-комунікаційних систем, електронних комунікаційних систем, публічних електронних реє-

стрів в умовах воєнного стану: постанова Кабінету Міністрів України від 12.03.2022 № 263. URL: https://zakon.rada.gov.ua/laws/show/263-2022-п.

[12] Деякі питання ліцензування господарської діяльності з надання послуг у галузі криптографічного захисту інформації (крім послуг електронного цифрового підпису) та технічного захисту інформації за переліком, що визначається Кабінетом Міністрів України: постанова Кабінету Міністрів України від 16.11.2016 № 821. URL: https://zakon.rada.gov.ua/laws/show/821-2016-п.

[13] Деякі питання об'єктів критичної інформаційної інфраструктури: постанова Кабінету Міністрів України від 09.10.2020 № 943. URL: https://zakon.rada.gov.ua/laws/show/943-2020-п.

[14] Деякі питання об'єктів критичної інфраструктури: постанова Кабінету Міністрів України від 09.10.2020 № 1109. URL: https://zakon.rada.gov.ua/laws/show/1109-2020-п.

[15] Деякі питання організації електронної взаємодії державних електронних інформаційних ресурсів: постанова Кабінету Міністрів України від 10.05.2018 № 357 (редакція від 01.01.2024). URL: https://zakon.rada.gov.ua/laws/show/357-2018-п.

[16] ДСТУ 4145-2002. Інформаційні технології. Криптографічний захист інформації. Цифровий підпис, що ґрунтується на еліптичних кривих. Формування та перевіряння. Київ: Держспоживстандарт України, 2003.

[17] ДСТУ 7624:2014. Інформаційні технології. Криптографічний захист інформації. Алгоритм симетричного блокового перетворення. Київ: Мінекономрозвитку України, 2015.

[18] ДСТУ 7564:2014. Інформаційні технології. Криптографічний захист інформації. Функція гешування. Київ: Мінекономрозвитку України, 2015.

[19] ДСТУ 8845:2019. Інформаційні технології. Криптографічний захист інформації. Алгоритм симетричного потокового перетворення. Київ: ДП «УкрНДНЦ», 2019.

[20] ДСТУ EN ISO/IEC 27001:2023. Інформаційна безпека, кібербезпека та захист приватності. Системи керування інформаційною безпекою. Вимоги (EN ISO/IEC 27001:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[21] ДСТУ EN ISO/IEC 27002:2023. Інформаційна безпека, кібербезпека та захист приватності. Заходи інформаційної безпеки (EN ISO/IEC 27002:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[22] Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури: затв. постановою Кабінету Міністрів України від 19.06.2019 № 518. URL: https://zakon.rada.gov.ua/laws/show/518-2019-п.

[23] Кібербезпека: освіта, наука, техніка: науковий журнал / Київський столичний університет імені Бориса Грінченка. URL: https://csecurity.kubg.edu.ua/.

[24] Корольков Р., Лаптєв С. Натурне моделювання атаки «war driving» на бездротову мережу. *Кібербезпека: освіта, наука, техніка.* 2022. Т. 2, № 18. С. 99–107.

DOI: 10.28925/2663-4023.2022.18.99107. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/407.

[25] Котов М. Деревоподібний шардинг стану для масштабування та балансування навантаження в мультичейн системах. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 392–408. DOI: 10.28925/2663-4023.2024.26.702. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/702.

[26] Кренцін М., Куперштейн Л. Метод обміну ідентифікаційними даними між вузлами пірингової мережі на основі технології NFC. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 1, № 25. С. 79–88. DOI: 10.28925/2663-4023.2024.25.7988. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/586.

[27] Кримінальний кодекс України від 05.04.2001 № 2341-III (розділ XVI «Кримінальні правопорушення у сфері використання електронно-обчислювальних машин (комп'ютерів), систем та комп'ютерних мереж і мереж електрозв'язку»). URL: https://zakon.rada.gov.ua/laws/show/2341-14.

[28] Кримінальний процесуальний кодекс України від 13.04.2012 № 4651-VI. URL: https://zakon.rada.gov.ua/laws/show/4651-17.

[29] Маньковський Б., Довбняк В., Опірський І. Дослідження можливості реалізації концепції Zero Trust в IoT-системах. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 1, № 29. С. 73–91. DOI: 10.28925/2663-4023.2025.29.864. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/864.

[30] Мельничук О. Виявлення Sybil акаунтів у соціальних мережах в еру штучного інтелекту. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 1, № 29. С. 696–703. DOI: 10.28925/2663-4023.2025.29.885. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/885.

[31] НД ТЗІ 1.1-002-99. Загальні положення щодо захисту інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999. URL: https://cip.gov.ua/ua/news/normativni-dokumenti-z-pitan-tzi.

[32] НД ТЗІ 2.5-005-99. Класифікація автоматизованих систем і стандартні функціональні профілі захищеності оброблюваної інформації від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999.

[33] НД ТЗІ 2.5-004-99. Критерії оцінки захищеності інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999.

[34] НД ТЗІ 3.7-003-05. Порядок проведення робіт із створення комплексної системи захисту інформації в інформаційно-телекомунікаційній системі. Київ: ДСТСЗІ СБ України, 2005.

[35] НД ТЗІ 1.4-001-2000. Типове положення про службу захисту інформації в автоматизованій системі. Київ: ДСТСЗІ СБ України, 2000.

[36] Особливості деструктивних кібератак Sandworm у відношенні українських провайдерів (CERT-UA#7627) / Урядова команда реагування на комп'ютерні надзвичайні події України CERT-UA. 2023. URL: https://cert.gov.ua/article/6123309.

[37] Палко Д. Інтелектуальні моделі оцінки ризиків кібербезпеки в розподілених системах на основі нейромережевого підходу. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 3, № 27. С. 429–448. DOI: 10.28925/2663-4023.2025.27.764. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/764.

[38] Палко Д., Мирутенко Л. Метод комплексної оцінки ризиків кібербезпеки в розподілених інформаційних системах. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 487–502. DOI: 10.28925/2663-4023.2024.26.731. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/731.

[39] Пархоменко І., Огієвич Р. Криптоекономічна стійкість децентралізованої мережі з використанням випадкових часових челендж-токенів (RTCT). *Кібербезпека: освіта, наука, техніка.* 2025. Т. 4, № 28. С. 465–477. DOI: 10.28925/2663-4023.2025.28.817. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/817.

[40] Питання Єдиного державного вебпорталу електронних послуг та Реєстру адміністративних послуг: постанова Кабінету Міністрів України від 04.12.2019 № 1137. URL: https://zakon.rada.gov.ua/laws/show/1137-2019-п.

[41] Положення про організацію кіберзахисту в банківській системі України: затв. постановою Правління Національного банку України від 12.08.2022 № 178. URL: https://zakon.rada.gov.ua/laws/show/v0178500-22.

[42] Правила забезпечення захисту інформації в інформаційних, електронних комунікаційних та інформаційно-комунікаційних системах: затв. постановою Кабінету Міністрів України від 29.03.2006 № 373. URL: https://zakon.rada.gov.ua/laws/show/373-2006-п.

[43] Про державну таємницю: Закон України від 21.01.1994 № 3855-XII. URL: https://zakon.rada.gov.ua/laws/show/3855-12.

[44] Про електронні довірчі послуги: Закон України від 05.10.2017 № 2155-VIII. URL: https://zakon.rada.gov.ua/laws/show/2155-19.

[45] Про електронні комунікації: Закон України від 16.12.2020 № 1089-IX. URL: https://zakon.rada.gov.ua/laws/show/1089-20.

[46] Про затвердження Положення про державну експертизу у сфері технічного захисту інформації: наказ Адміністрації Державної служби спеціального зв'язку та захисту інформації України від 16.05.2007 № 93. URL: https://zakon.rada.gov.ua/laws/show/z0820-07.

[47] Про затвердження Положення про інтегровану систему електронної ідентифікації: постанова Кабінету Міністрів України від 03.11.2023 № 1150. URL: https://zakon.rada.gov.ua/laws/show/1150-2023-п.

[48] Про затвердження Положення про організацію заходів із забезпечення інформаційної безпеки в банківській системі України: постанова Правління Національного банку України від 28.09.2017 № 95. URL: https://zakon.rada.gov.ua/laws/show/v0095500-17.

[49] Про затвердження Положення про Систему BankID Національного банку України: постанова Правління Національного банку України від 17.03.2020 № 32. URL: https://zakon.rada.gov.ua/laws/show/v0032500-20.

[50] Про затвердження Порядку використання електронних довірчих послуг в органах державної влади, органах місцевого самоврядування, підприємствах, установах та організаціях державної форми власності: постанова Кабінету Міністрів України від 01.08.2023 № 798. URL: https://zakon.rada.gov.ua/laws/show/798-2023-п.

[51] Про затвердження Порядку проведення огляду стану кіберзахисту критичної інформаційної інфраструктури, державних інформаційних ресурсів та інформації, вимога щодо захисту якої встановлена законом: постанова Кабінету Міністрів України від 11.11.2020 № 1176. URL: https://zakon.rada.gov.ua/laws/show/1176-2020-п.

[52] Про захист інформації в інформаційно-комунікаційних системах: Закон України від 05.07.1994 № 80/94-ВР. URL: https://zakon.rada.gov.ua/laws/show/80/94-вр.

[53] Про захист персональних даних: Закон України від 01.06.2010 № 2297-VI. URL: https://zakon.rada.gov.ua/laws/show/2297-17.

[54] Про інформацію: Закон України від 02.10.1992 № 2657-XII. *Відомості Верховної Ради України.* URL: https://zakon.rada.gov.ua/laws/show/2657-12.

[55] Про критичну інфраструктуру: Закон України від 16.11.2021 № 1882-IX. URL: https://zakon.rada.gov.ua/laws/show/1882-20.

[56] Про ліцензування видів господарської діяльності: Закон України від 02.03.2015 № 222-VIII. *Відомості Верховної Ради України.* URL: https://zakon.rada.gov.ua/laws/show/222-19.

[57] Про національну безпеку України: Закон України від 21.06.2018 № 2469-VIII. URL: https://zakon.rada.gov.ua/laws/show/2469-19.

[58] Про основні засади забезпечення кібербезпеки України: Закон України від 05.10.2017 № 2163-VIII (редакція від 19.10.2025). URL: https://zakon.rada.gov.ua/laws/show/2163-19.

[59] Про публічні електронні реєстри: Закон України від 18.11.2021 № 1907-IX. URL: https://zakon.rada.gov.ua/laws/show/1907-20.

[60] Про рішення Ради національної безпеки і оборони України від 14 травня 2021 року «Про Стратегію кібербезпеки України»: Указ Президента України від 26.08.2021 № 447/2021. URL: https://zakon.rada.gov.ua/laws/show/447/2021.

[61] Про стандартизацію: Закон України від 05.06.2014 № 1315-VII. *Відомості Верховної Ради України.* URL: https://zakon.rada.gov.ua/laws/show/1315-18.

[62] Про хмарні послуги: Закон України від 17.02.2022 № 2075-IX (редакція від 28.06.2024). URL: https://zakon.rada.gov.ua/laws/show/2075-20.

[63] Соколов В., Складанний П. Методика оцінки комплексних збитків від інциденту інформаційної безпеки. *Кібербезпека: освіта, наука, техніка.* 2023. Т. 1,

№ 21. С. 99–120. DOI: 10.28925/2663-4023.2023.21.99120. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/498.

[64] Спасітєлєва С. О., Бурячок В. Л. Перспективи розвитку додатків блокчейн в Україні. *Кібербезпека: освіта, наука, техніка*. 2018. Т. 1, № 1. С. 35–48. DOI: 10.28925/2663-4023.2018.1.3548. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/18.

[65] Угода про асоціацію між Україною, з однієї сторони, та Європейським Союзом, Європейським співтовариством з атомної енергії і їхніми державами-членами, з іншої сторони: міжнародний документ від 27.06.2014; ратифіковано Законом України від 16.09.2014 № 1678-VII. URL: https://zakon.rada.gov.ua/laws/show/984_011.

[66] Центральний засвідчувальний орган: офіційний вебсайт. Довірчий список кваліфікованих надавачів електронних довірчих послуг. Київ: Міністерство цифрової трансформації України. URL: https://czo.gov.ua/.

[67] Юдіна Д. Метод розрахунку рівня кіберзахисту об'єктів критичної інформаційної інфраструктури. *Кібербезпека: освіта, наука, техніка*. 2025. Т. 2, № 30. С. 473–487. DOI: 10.28925/2663-4023.2025.30.986. URL: https://doi.org/10.28925/2663-4023.2025.30.986.

[68] 2015 Ukraine Electric Power Attack (Campaign C0028). MITRE ATT&CK for ICS. The MITRE Corporation. URL: https://attack.mitre.org/campaigns/C0028/.

[69] 2016 Ukraine Electric Power Attack (Campaign C0025). MITRE ATT&CK for ICS. The MITRE Corporation. URL: https://attack.mitre.org/campaigns/C0025/.

[70] 3GPP TS 33.501. Security Architecture and Procedures for 5G System: technical specification. Release 20, V20.2.0. Sophia Antipolis: 3rd Generation Partnership Project. URL: https://portal.3gpp.org/desktopmodules/Specifications/SpecificationDetails.aspx?specificationId=3169.

[71] Abadi D. Consistency Tradeoffs in Modern Distributed Database System Design: CAP is Only Part of the Story. *Computer*. 2012. Vol. 45, no. 2. P. 37–42. DOI: 10.1109/MC.2012.33.

[72] Aboba B., Blunk L., Vollbrecht J., Carlson J., Levkowetz H. (Ed.). Extensible Authentication Protocol (EAP). RFC 3748. IETF, 2004. DOI: 10.17487/RFC3748. URL: https://www.rfc-editor.org/rfc/rfc3748.

[73] Adams C., Cain P., Pinkas D., Zuccherato R. Internet X.509 Public Key Infrastructure Time-Stamp Protocol (TSP). RFC 3161. IETF, 2001. DOI: 10.17487/RFC3161. URL: https://www.rfc-editor.org/rfc/rfc3161.

[74] Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations. Cybersecurity Advisory AA20-352A. CISA, 2020 (rev. 15.04.2021). URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a.

[75] Albert R., Jeong H., Barabási A.-L. Error and attack tolerance of complex networks. *Nature*. 2000. Vol. 406, no. 6794. P. 378–382. DOI: 10.1038/35019019.

[76] Alpern B., Schneider F. B. Defining liveness. *Information Processing Letters*. 1985. Vol. 21, no. 4. P. 181–185. DOI: 10.1016/0020-0190(85)90056-0.

[77] Althouse J. et al. JA4+: Network Fingerprinting Suite. FoxIO, LLC, 2023–2026. URL: https://github.com/FoxIO-LLC/ja4.

[78] Andriesse D., Rossow C., Stone-Gross B., Plohmann D., Bos H. Highly resilient peer-to-peer botnets are here: An analysis of Gameover Zeus. *2013 8th International Conference on Malicious and Unwanted Software: «The Americas» (MALWARE)*. Fajardo, PR: IEEE, 2013. P. 116–123. DOI: 10.1109/MALWARE.2013.6703693.

[79] Antonopoulos P., Arasu A., Singh K. D. et al. Azure SQL Database Always Encrypted. *Proceedings of the 2020 ACM SIGMOD International Conference on Management of Data*. New York: ACM, 2020. P. 1511–1525. DOI: 10.1145/3318464.3386141.

[80] Apostolaki M., Zohar A., Vanbever L. Hijacking Bitcoin: Routing Attacks on Cryptocurrencies. *2017 IEEE Symposium on Security and Privacy (SP)*. San Jose, CA: IEEE, 2017. P. 375–392. DOI: 10.1109/SP.2017.29.

[81] Arends R. et al. DNS Security Introduction and Requirements. RFC 4033. IETF, 2005. DOI: 10.17487/RFC4033. URL: https://www.rfc-editor.org/rfc/rfc4033.

[82] Arends R., Austein R., Larson M., Massey D., Rose S. Protocol Modifications for the DNS Security Extensions. RFC 4035. IETF, 2005. DOI: 10.17487/RFC4035. URL: https://www.rfc-editor.org/rfc/rfc4035.

[83] Assante M. J., Lee R. M. The Industrial Control System Cyber Kill Chain: SANS white paper. Bethesda, MD: SANS Institute, 2015. URL: https://www.sans.org/white-papers/36297/.

[84] Atzei N., Bartoletti M., Cimoli T. A Survey of Attacks on Ethereum Smart Contracts (SoK). *Principles of Security and Trust (POST 2017)*. Lecture Notes in Computer Science. Berlin; Heidelberg: Springer, 2017. P. 164–186. DOI: 10.1007/978-3-662-54455-6_8.

[85] Avizienis A. The N-version approach to fault-tolerant software. *IEEE Transactions on Software Engineering*. 1985. Vol. SE-11, no. 12. P. 1491–1501. DOI: 10.1109/TSE.1985.231893.

[86] Avizienis A., Laprie J.-C., Randell B., Landwehr C. Basic concepts and taxonomy of dependable and secure computing. *IEEE Transactions on Dependable and Secure Computing*. 2004. Vol. 1, no. 1. P. 11–33. DOI: 10.1109/TDSC.2004.2.

[87] Axelsson S. The base-rate fallacy and the difficulty of intrusion detection. *ACM Transactions on Information and System Security*. 2000. Vol. 3, No. 3. P. 186–205. DOI: 10.1145/357830.357849.

[88] Barker E. Recommendation for Key Management: Part 1 — General. NIST SP 800-57 Part 1, Rev. 5. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-57pt1r5. URL: https://csrc.nist.gov/pubs/sp/800/57/pt1/r5/final.

[89] Barker E., Chen L., Roginsky A., Vassilev A., Davis R. Recommendation for Pair-Wise Key-Establishment Schemes Using Discrete Logarithm Cryptography. NIST SP 800-56A, Rev. 3. Gaithersburg, MD, 2018. DOI: 10.6028/NIST.SP.800-56Ar3. URL: https://csrc.nist.gov/pubs/sp/800/56/a/r3/final.

[90] Barker E., Dang Q., Frankel S., Scarfone K., Wouters P. Guide to IPsec VPNs. NIST Special Publication 800-77, Rev. 1. Gaithersburg, MD: NIST, 2020. DOI: 10.6028/NIST.SP.800-77r1. URL: https://csrc.nist.gov/pubs/sp/800/77/r1/final.

[91] Barnes R., Beurdouche B., Robert R., Millican J., Omara E., Cohn-Gordon K. The Messaging Layer Security (MLS) Protocol. RFC 9420. IETF, 2023. DOI: 10.17487/RFC9420. URL: https://www.rfc-editor.org/rfc/rfc9420.

[92] Baset S. A., Schulzrinne H. G. An Analysis of the Skype Peer-to-Peer Internet Telephony Protocol. *Proceedings IEEE INFOCOM 2006: 25th IEEE International Conference on Computer Communications*. Barcelona: IEEE, 2006. P. 1–11. DOI: 10.1109/INFOCOM.2006.312.

[93] Baumgart I., Mies S. S/Kademlia: A practicable approach towards secure key-based routing. *2007 International Conference on Parallel and Distributed Systems (ICPADS 2007)*. Hsinchu: IEEE, 2007. P. 1–8. DOI: 10.1109/ICPADS.2007.4447808.

[94] Bell D. E., LaPadula L. J. Secure Computer System: Unified Exposition and Multics Interpretation. Technical Report ESD-TR-75-306, MTR-2997 Rev. 1. Bedford, MA: The MITRE Corporation, 1976. URL: https://csrc.nist.gov/csrc/media/publications/conference-paper/1998/10/08/proceedings-of-the-21st-nissc-1998/documents/early-cs-papers/bell76.pdf.

[95] Bernstein D. J., Lange T. Post-quantum cryptography. *Nature*. 2017. Vol. 549. P. 188–194. DOI: 10.1038/nature23461.

[96] Best Practices for Cyber Crisis Management. Athens: European Union Agency for Cybersecurity, 2024. URL: https://www.enisa.europa.eu/publications/best-practices-for-cyber-crisis-management.

[97] Bianco D. J. The Pyramid of Pain. *Enterprise Detection & Response*. 01.03.2013 (оновлено 17.01.2014). URL: https://detect-respond.blogspot.com/2013/03/the-pyramid-of-pain.html.

[98] Biba K. J. Integrity Considerations for Secure Computer Systems. Technical Report ESD-TR-76-372, MTR-3153 Rev. 1. Bedford, MA: The MITRE Corporation, 1977. URL: https://seclab.cs.ucdavis.edu/projects/history/papers/biba75.pdf.

[99] Birman K., Joseph T. Exploiting virtual synchrony in distributed systems. *Proceedings of the Eleventh ACM Symposium on Operating Systems Principles (SOSP'87)*. New York: ACM, 1987. P. 123–138. DOI: 10.1145/41457.37515.

[100] Bitcoin Core 0.20.0 Release Notes. Bitcoin Core project, 2020. URL: https://github.com/bitcoin/bitcoin/blob/master/doc/release-notes/release-notes-0.20.0.md.

[101] Bitcoin Core 0.21.0 Release Notes. Bitcoin Core project, 2021. URL: https://github.com/bitcoin/bitcoin/blob/master/doc/release-notes/release-notes-0.21.0.md.

[102] Booth H., Souppaya M., Vassilev A., Ogata M., Stanley M., Scarfone K. Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile. NIST Special Publication 800-218A. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.SP.800-218A. URL: https://csrc.nist.gov/pubs/sp/800/218/a/final.

[103] Boyens J. et al. Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations. NIST SP 800-161, Rev. 1. Gaithersburg, MD, 2022. DOI: 10.6028/NIST.SP.800-161r1. URL: https://csrc.nist.gov/pubs/sp/800/161/r1/final.

[104] Bracha G. Asynchronous Byzantine agreement protocols. *Information and Computation*. 1987. Vol. 75, no. 2. P. 130–143. DOI: 10.1016/0890-5401(87)90054-X.

[105] Braiterman Z., Shostack A., Marcil J. et al. Threat Modeling Manifesto. 2020. URL: https://www.threatmodelingmanifesto.org/.

[106] Brewer D. F. C., Nash M. J. The Chinese Wall security policy. *Proceedings of the 1989 IEEE Symposium on Security and Privacy*. Oakland, CA: IEEE, 1989. P. 206–214. DOI: 10.1109/SECPRI.1989.36295. URL: https://doi.org/10.1109/SECPRI.1989.36295.

[107] Brezinski D., Killalea T. Guidelines for Evidence Collection and Archiving. RFC 3227 (BCP 55). IETF, 2002. DOI: 10.17487/RFC3227. URL: https://www.rfc-editor.org/rfc/rfc3227.

[108] Brownlee N., Guttman E. Expectations for Computer Security Incident Response. RFC 2350 (BCP 21). IETF, 1998. DOI: 10.17487/RFC2350. URL: https://www.rfc-editor.org/rfc/rfc2350.

[109] Cachin C., Guerraoui R., Rodrigues L. Introduction to Reliable and Secure Distributed Programming. 2nd ed. Berlin; Heidelberg: Springer, 2011. DOI: 10.1007/978-3-642-15260-3.

[110] Campbell B., Bradley J., Sakimura N., Lodderstedt T. OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens. RFC 8705. IETF, 2020. DOI: 10.17487/RFC8705. URL: https://www.rfc-editor.org/rfc/rfc8705.

[111] Cantor S., Kemp J., Philpott R., Maler E. (Eds.). Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0: OASIS Standard, 15 March 2005. Burlington, MA: OASIS, 2005. URL: https://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf.

[112] CAPEC: Common Attack Pattern Enumeration and Classification. Version 3.9. The MITRE Corporation, 2023. URL: https://capec.mitre.org/.

[113] Cappalli T., Kumar A., Lundberg E., Miller M., Pascoe J., Satragno N. (Eds.). Web Authentication: An API for accessing Public Key Credentials — Level 3: W3C Recommendation. World Wide Web Consortium, 2026. URL: https://www.w3.org/TR/webauthn-3/.

[114] Caralli R. A., Stevens J. F., Young L. R., Wilson W. R. Introducing OCTAVE Allegro: Improving the Information Security Risk Assessment Process. Technical Report CMU/SEI-2007-TR-012. Pittsburgh: Software Engineering Institute, Carnegie Mellon University, 2007. URL: https://www.sei.cmu.edu/library/.

[115] Castro M., Druschel P., Ganesh A., Rowstron A., Wallach D. S. Secure routing for structured peer-to-peer overlay networks. *ACM SIGOPS Operating Systems Review*. 2002. Vol. 36, SI. P. 299–314. DOI: 10.1145/844128.844156.

[116] Castro M., Liskov B. Practical byzantine fault tolerance and proactive recovery. *ACM Transactions on Computer Systems*. 2002. Vol. 20, no. 4. P. 398–461. DOI: 10.1145/571637.571640.

[117] CERT-UA: Урядова команда реагування на комп'ютерні надзвичайні події України. URL: https://cert.gov.ua/.

[118] Chandra T. D., Hadzilacos V., Toueg S. The weakest failure detector for solving consensus. *Journal of the ACM*. 1996. Vol. 43, no. 4. P. 685–722. DOI: 10.1145/234533.234549.

[119] Chandra T. D., Toueg S. Unreliable failure detectors for reliable distributed systems. *Journal of the ACM*. 1996. Vol. 43, no. 2. P. 225–267. DOI: 10.1145/226643.226647.

[120] Chandramouli R. Security Strategies for Microservices-based Application Systems. NIST Special Publication 800-204. Gaithersburg, MD: NIST, 2019. DOI: 10.6028/NIST.SP.800-204. URL: https://csrc.nist.gov/pubs/sp/800/204/final.

[121] Chandramouli R., Butcher Z. A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments. NIST Special Publication 800-207A. Gaithersburg, MD: NIST, 2023. DOI: 10.6028/NIST.SP.800-207A. URL: https://csrc.nist.gov/pubs/sp/800/207/a/final.

[122] Chandramouli R., Butcher Z., Chetal A. Attribute-based Access Control for Microservices-based Applications using a Service Mesh. NIST Special Publication 800-204B. Gaithersburg, MD: NIST, 2021. DOI: 10.6028/NIST.SP.800-204B. URL: https://csrc.nist.gov/pubs/sp/800/204/b/final.

[123] Chandramouli R., Kautz F., Torres-Arias S. Strategies for the Integration of Software Supply Chain Security in DevSecOps CI/CD Pipelines. NIST Special Publication 800-204D. Gaithersburg, MD: NIST, 2024. DOI: 10.6028/NIST.SP.800-204D. URL: https://csrc.nist.gov/pubs/sp/800/204/d/final.

[124] Chandramouli R., Pinhas D. Security Guidelines for Storage Infrastructure. NIST Special Publication 800-209. Gaithersburg, MD: NIST, 2020. DOI: 10.6028/NIST.SP.800-209. URL: https://csrc.nist.gov/pubs/sp/800/209/final.

[125] Cherepanov A. BlackEnergy by the SSHBearDoor: attacks against Ukrainian news media and electric industry. *WeLiveSecurity by ESET*. 2016. 3 January. URL: https://www.welivesecurity.com/2016/01/03/blackenergy-sshbeardoor-details-2015-attacks-ukrainian-news-media-electric-industry/.

[126] Cherepanov A., Lipovsky R. Industroyer: Biggest threat to industrial control systems since Stuxnet. *WeLiveSecurity by ESET*. 2017. 12 June. URL: https://www.welivesecurity.com/2017/06/12/industroyer-biggest-threat-industrial-control-systems-since-stuxnet/.

[127] Chockler G. V., Keidar I., Vitenberg R. Group communication specifications: a comprehensive study. *ACM Computing Surveys*. 2001. Vol. 33, no. 4. P. 427–469. DOI: 10.1145/503112.503113.

[128] Cichonski P., Millar T., Grance T., Scarfone K. Computer Security Incident Handling Guide. NIST SP 800-61, Rev. 2. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-61r2. URL: https://csrc.nist.gov/pubs/sp/800/61/r2/final.

[129] CIS Critical Security Controls, Version 8.1. Center for Internet Security, 2024. URL: https://www.cisecurity.org/controls/v8-1.

[130] CIS Kubernetes Benchmark, v2.0.1. East Greenbush, NY: Center for Internet Security, 2025. URL: https://www.cisecurity.org/benchmark/kubernetes.

[131] Claise B. (Ed.), Trammell B. (Ed.), Aitken P. Specification of the IP Flow Information Export (IPFIX) Protocol for the Exchange of Flow Information. RFC 7011, STD 77. IETF, 2013. DOI: 10.17487/RFC7011. URL: https://www.rfc-editor.org/rfc/rfc7011.

[132] Clark D. D., Wilson D. R. A Comparison of Commercial and Military Computer Security Policies. *Proceedings of the 1987 IEEE Symposium on Security and Privacy*. Oakland, CA: IEEE, 1987. P. 184–194. DOI: 10.1109/SP.1987.10001. URL: https://doi.org/10.1109/SP.1987.10001.

[133] Clarkson M. R., Schneider F. B. Hyperproperties. *Journal of Computer Security*. 2010. Vol. 18, no. 6. P. 1157–1210. DOI: 10.3233/JCS-2009-0393.

[134] Cloud Controls Matrix (CCM) v4.1: 197 control objectives structured in 17 domains. Seattle, WA: Cloud Security Alliance, 2023. URL: https://cloudsecurityalliance.org/research/cloud-controls-matrix.

[135] Cohen B. The BitTorrent Protocol Specification. BEP 3. BitTorrent.org, 2008 (last modified 2017). URL: https://www.bittorrent.org/beps/bep_0003.html.

[136] Cohen R., Erez K., ben-Avraham D., Havlin S. Breakdown of the Internet under Intentional Attack. *Physical Review Letters*. 2001. Vol. 86, no. 16. P. 3682–3685. DOI: 10.1103/PhysRevLett.86.3682.

[137] Cohen R., Erez K., ben-Avraham D., Havlin S. Resilience of the Internet to Random Breakdowns. *Physical Review Letters*. 2000. Vol. 85, no. 21. P. 4626–4628. DOI: 10.1103/PhysRevLett.85.4626.

[138] Common Vulnerability Scoring System version 4.0: Specification Document. Document Version 1.2. Cary, NC: FIRST.Org, Inc., 2023–2024. URL: https://www.first.org/cvss/v4-0/specification-document.

[139] Computer Security Incident Response Team (CSIRT) Services Framework. Version 2.1. Cary, NC: FIRST, 2019. URL: https://www.first.org/standards/frameworks/csirts/csirt_services_framework_v2.1.

[140] Cooper D. et al. Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. RFC 5280. IETF, 2008. DOI: 10.17487/RFC5280. URL: https://www.rfc-editor.org/rfc/rfc5280.

[141] Cooper D., Apon D., Dang Q., Davidson M., Dworkin M., Miller C. Recommendation for Stateful Hash-Based Signature Schemes. NIST SP 800-208. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-208. URL: https://csrc.nist.gov/pubs/sp/800/208/final.

[142] CVE-2015-3456 Detail (VENOM). *National Vulnerability Database*. National Institute of Standards and Technology, published 13.05.2015. URL: https://nvd.nist.gov/vuln/detail/CVE-2015-3456.

[143] Cybersecurity Capability Maturity Model (C2M2). Version 2.1. Washington, DC: U.S. Department of Energy, Office of Cybersecurity, Energy Security, and Emergency Response, 2022. URL: https://www.energy.gov/ceser/cybersecurity-capability-maturity-model-c2m2.

[144] Daian P., Goldfeder S., Kell T., Li Y., Zhao X., Bentov I., Breidenbach L., Juels A. Flash Boys 2.0: Frontrunning in Decentralized Exchanges, Miner Extractable Value, and Consensus Instability. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco, CA: IEEE, 2020. P. 910–927. DOI: 10.1109/SP40000.2020.00040.

[145] Demers A., Greene D., Hauser C., Irish W., Larson J. et al. Epidemic algorithms for replicated database maintenance. *Proceedings of the Sixth Annual ACM Symposium on Principles of Distributed Computing (PODC'87)*. New York: ACM, 1987. P. 1–12. DOI: 10.1145/41840.41841.

[146] Dempsey K., Chawla N. S., Johnson L. A. et al. Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations. NIST Special Publication 800-137. Gaithersburg, MD: NIST, 2011. DOI: 10.6028/NIST.SP.800-137. URL: https://csrc.nist.gov/pubs/sp/800/137/final.

[147] Deng M., Wuyts K., Scandariato R., Preneel B., Joosen W. A privacy threat analysis framework: supporting the elicitation and fulfillment of privacy requirements. *Requirements Engineering*. 2011. Vol. 16, iss. 1. P. 3–32. DOI: 10.1007/s00766-010-0115-7.

[148] Denning D. E. An Intrusion-Detection Model. *IEEE Transactions on Software Engineering*. 1987. Vol. SE-13, No. 2. P. 222–232. DOI: 10.1109/TSE.1987.232894.

[149] Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive). *Official Journal of the EU*. L 333. P. 80–152. URL: https://eur-lex.europa.eu/eli/dir/2022/2555/oj.

[150] Directive (EU) 2022/2557 of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC. *Official Journal of the European Union*. 2022. L 333. P. 164–198. URL: https://eur-lex.europa.eu/eli/dir/2022/2557/oj.

[151] Donenfeld J. A. WireGuard: Next Generation Kernel Network Tunnel. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2017)*. Reston: Internet Society, 2017. URL: https://www.ndss-symposium.org/ndss2017/ndss-2017-programme/wireguard-next-generation-kernel-network-tunnel/.

[152] Douceur J. R. The Sybil Attack. *Peer-to-Peer Systems (IPTPS 2002)*. Lecture Notes in Computer Science. Vol. 2429. Berlin; Heidelberg: Springer, 2002. P. 251–260. DOI: 10.1007/3-540-45748-8_24.

[153] Dwork C. Differential Privacy. *Automata, Languages and Programming (ICALP 2006)*. Lecture Notes in Computer Science. Berlin; Heidelberg: Springer, 2006. P. 1–12. DOI: 10.1007/11787006_1.

[154] Dwork C., Lynch N., Stockmeyer L. Consensus in the presence of partial synchrony. *Journal of the ACM*. 1988. Vol. 35, no. 2. P. 288–323. DOI: 10.1145/42282.42283.

[155] Dworkin M. Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC. NIST SP 800-38D. Gaithersburg, MD, 2007. DOI: 10.6028/NIST.SP.800-38D. URL: https://csrc.nist.gov/pubs/sp/800/38/d/final.

[156] Défago X., Schiper A., Urbán P. Total order broadcast and multicast algorithms: taxonomy and survey. *ACM Computing Surveys*. 2004. Vol. 36, no. 4. P. 372–421. DOI: 10.1145/1041680.1041682.

[157] ECMA-424. CycloneDX Bill of Materials Standard. Geneva: Ecma International; OWASP Foundation, 2024. URL: https://cyclonedx.org/.

[158] Elastic Common Schema (ECS) Reference. Elastic N. V. URL: https://www.elastic.co/docs/reference/ecs.

[159] ENISA CSIRT Maturity Framework: Updated and Improved. Athens: European Union Agency for Cybersecurity, 2022. URL: https://www.enisa.europa.eu/publications/enisa-csirt-maturity-framework.

[160] ENISA NIS360 2024. Athens: European Union Agency for Cybersecurity, 2025. URL: https://www.enisa.europa.eu/publications/enisa-nis360-2024.

[161] ENISA Threat Landscape 2024. Athens: European Union Agency for Cybersecurity, 2024. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-2024.

[162] ENISA Threat Landscape for 5G Networks. Athens: European Union Agency for Cybersecurity, 2019. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-for-5g-networks.

[163] ENISA Threat Landscape for Supply Chain Attacks. Athens: European Union Agency for Cybersecurity, 2021. 44 p. URL: https://www.enisa.europa.eu/publications/threat-landscape-for-supply-chain-attacks.

[164] EPSS: The Exploit Prediction Scoring System. EPSS Special Interest Group. Cary, NC: FIRST.Org, Inc. URL: https://www.first.org/epss/.

[165] ESET Research. Industroyer2: Industroyer reloaded. *WeLiveSecurity by ESET*. 2022. 12 April. URL: https://www.welivesecurity.com/2022/04/12/industroyer2-industroyer-reloaded/.

[166] Eyal I., Sirer E. G. Majority Is Not Enough: Bitcoin Mining Is Vulnerable. *Financial Cryptography and Data Security (FC 2014)*. Lecture Notes in Computer Science. Vol. 8437. Berlin; Heidelberg: Springer, 2014. P. 436–454. DOI: 10.1007/978-3-662-45472-5_28.

[167] Fagan M., Marron J., Brady K., Cuthill B., Megas K., Herold R., Lemire D., Hoehn B. IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements. NIST SP 800-213. Gaithersburg, MD: National Institute of Standards and Technology, 2021. DOI: 10.6028/NIST.SP.800-213. URL: https://csrc.nist.gov/pubs/sp/800/213/final.

[168] Fagan M., Megas K., Scarfone K., Smith M. Foundational Cybersecurity Activities for IoT Device Manufacturers. NIST IR 8259. Gaithersburg, MD: National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.IR.8259. URL: https://csrc.nist.gov/pubs/ir/8259/final.

[169] Fajardo V. (Ed.), Arkko J., Loughney J., Zorn G. (Ed.). Diameter Base Protocol. RFC 6733. IETF, 2012. DOI: 10.17487/RFC6733. URL: https://www.rfc-editor.org/rfc/rfc6733.

[170] Ferraiolo D. F., Sandhu R., Gavrila S., Kuhn D. R., Chandramouli R. Proposed NIST standard for role-based access control. *ACM Transactions on Information and System Security*. 2001. Vol. 4, No. 3. P. 224–274. DOI: 10.1145/501978.501980. URL: https://csrc.nist.gov/pubs/journal/2001/08/proposed-nist-standard-for-rolebased-access-contro/final.

[171] Finck M. Blockchain and the General Data Protection Regulation: Can distributed ledgers be squared with European data protection law? Study PE 634.445. Brussels: European Parliamentary Research Service, 2019. URL: https://www.europarl.europa.eu/thinktank/en/document/EPRS_STU(2019)634445.

[172] Fischer M. J., Lynch N. A., Paterson M. S. Impossibility of Distributed Consensus with One Faulty Process. *Journal of the ACM*. 1985. Vol. 32, no. 2. P. 374–382. DOI: 10.1145/3149.214121. URL: https://groups.csail.mit.edu/tds/papers/Lynch/jacm85.pdf.

[173] Franke D., Sibold D., Teichel K., Dansarie M., Sundblad R. Network Time Security for the Network Time Protocol. RFC 8915. IETF, 2020. DOI: 10.17487/RFC8915. URL: https://www.rfc-editor.org/rfc/rfc8915.

[174] Frankel S., Eydt B., Owens L., Scarfone K. Establishing Wireless Robust Security Networks: A Guide to IEEE 802.11i. NIST Special Publication 800-97. Gaithersburg, MD: NIST, 2007 (вилучено з обігу 31.12.2025 із відсиланням до чинної редакції IEEE 802.11). DOI: 10.6028/NIST.SP.800-97. URL: https://csrc.nist.gov/pubs/sp/800/97/final.

[175] Frequently Asked Questions (FAQ). *etcd Documentation*. Version 3.5. The etcd Authors; Cloud Native Computing Foundation. URL: https://etcd.io/docs/v3.5/faq/.

[176] Freund A. Backdoor in upstream xz/liblzma leading to ssh server compromise (CVE-2024-3094): oss-security mailing list announcement, 29.03.2024. URL: https://www.openwall.com/lists/oss-security/2024/03/29/4.

[177] Freund J., Jones J. Measuring and Managing Information Risk: A FAIR Approach. Waltham: Butterworth-Heinemann; Elsevier, 2014. 408 p. ISBN 978-0-12-420231-3.

[178] Garcia M., Bessani A., Gashi I., Neves N., Obelheiro R. Analysis of operating system diversity for intrusion tolerance. *Software: Practice and Experience*. 2014. Vol. 44, no. 6. P. 735–770. DOI: 10.1002/spe.2180.

[179] Garcia M., Bessani A., Neves N. Lazarus: automatic management of diversity in BFT systems. *Proceedings of the 20th International Middleware Conference (Middleware'19)*. New York: ACM, 2019. P. 241–254. DOI: 10.1145/3361525.3361550.

[180] Garcia-Molina H., Salem K. Sagas. *Proceedings of the 1987 ACM SIGMOD International Conference on Management of Data (SIGMOD'87)*. New York: ACM Press, 1987. P. 249–259. DOI: 10.1145/38713.38742.

[181] Garfinkel S., Guttman B., Near J., Dajani A., Singer P. De-Identifying Government Datasets: Techniques and Governance. NIST Special Publication 800-188. Gaithersburg, MD: NIST, 2023. DOI: 10.6028/NIST.SP.800-188. URL: https://csrc.nist.gov/pubs/sp/800/188/final.

[182] Gerhards R. The Syslog Protocol. RFC 5424. IETF, 2009. DOI: 10.17487/RFC5424. URL: https://www.rfc-editor.org/rfc/rfc5424.

[183] Gervais A., Karame G. O., Wüst K., Glykantzis V., Ritzdorf H., Capkun S. On the Security and Performance of Proof of Work Blockchains. *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security (CCS'16)*. New York: ACM, 2016. P. 3–16. DOI: 10.1145/2976749.2978341.

[184] Gilbert S., Lynch N. Brewer's conjecture and the feasibility of consistent, available, partition-tolerant web services. *ACM SIGACT News*. 2002. Vol. 33, no. 2. P. 51–59. DOI: 10.1145/564585.564601.

[185] Gilbert S., Lynch N. Perspectives on the CAP Theorem. *Computer*. 2012. Vol. 45, no. 2. P. 30–36. DOI: 10.1109/MC.2011.389. URL: https://groups.csail.mit.edu/tds/papers/Gilbert/Brewer2.pdf.

[186] Gilman E., Barth D. Zero Trust Networks: Building Secure Systems in Untrusted Networks. Sebastopol: O'Reilly Media, 2017. 240 p.

[187] Gkantsidis C., Mihail M., Saberi A. Random walks in peer-to-peer networks. *IEEE INFOCOM 2004*. Hong Kong: IEEE, 2004. Vol. 1. P. 120–130. DOI: 10.1109/INFCOM.2004.1354487.

[188] Goguen J. A., Meseguer J. Security Policies and Security Models. *Proceedings of the 1982 IEEE Symposium on Security and Privacy*. Oakland, CA: IEEE, 1982. P. 11–20. DOI: 10.1109/SP.1982.10014. URL: https://doi.org/10.1109/SP.1982.10014.

[189] Good Practice Guide for Incident Management. Heraklion: European Network and Information Security Agency, 2010. URL: https://www.enisa.europa.eu/publications/good-practice-guide-for-incident-management.

[190] Good Practices for Security of IoT — Secure Software Development Lifecycle. Athens: European Union Agency for Cybersecurity (ENISA), 2019. URL: https://www.enisa.europa.eu/publications/good-practices-for-security-of-iot-1.

[191] Gordon L. A., Loeb M. P. The Economics of Information Security Investment. *ACM Transactions on Information and System Security*. 2002. Vol. 5, No. 4. P. 438–457. DOI: 10.1145/581271.581274.

[192] Grassi P. A., Garcia M. E., Fenton J. L. Digital Identity Guidelines. NIST SP 800-63-3. Gaithersburg, MD, 2017. DOI: 10.6028/NIST.SP.800-63-3. URL: https://csrc.nist.gov/pubs/sp/800/63/3/final.

[193] Hadzilacos V., Toueg S. A Modular Approach to Fault-Tolerant Broadcasts and Related Problems: Technical Report TR94-1425. Ithaca, NY: Cornell University, Department of Computer Science, 1994. URL: https://hdl.handle.net/1813/6207.

[194] Hardt D. The OAuth 2.0 Authorization Framework. RFC 6749. IETF, 2012. DOI: 10.17487/RFC6749. URL: https://www.rfc-editor.org/rfc/rfc6749.

[195] Harkins D. (Ed.), Kumari W. (Ed.). Opportunistic Wireless Encryption. RFC 8110. IETF, 2017. DOI: 10.17487/RFC8110. URL: https://www.rfc-editor.org/rfc/rfc8110.

[196] Harrison M. A., Ruzzo W. L., Ullman J. D. Protection in operating systems. *Communications of the ACM*. 1976. Vol. 19, no. 8. P. 461–471. DOI: 10.1145/360303.360333. URL: https://doi.org/10.1145/360303.360333.

[197] Heilman E., Kendler A., Zohar A., Goldberg S. Eclipse Attacks on Bitcoin's Peer-to-Peer Network. *Proceedings of the 24th USENIX Security Symposium (USENIX Security 15)*. Washington, D.C.: USENIX Association, 2015. P. 129–144. URL: https://www.usenix.org/conference/usenixsecurity15/technical-sessions/presentation/heilman.

[198] Herlihy M. P., Wing J. M. Linearizability: a correctness condition for concurrent objects. *ACM Transactions on Programming Languages and Systems*. 1990. Vol. 12, no. 3. P. 463–492. DOI: 10.1145/78969.78972.

[199] Herzberg A., Jarecki S., Krawczyk H., Yung M. Proactive secret sharing or: how to cope with perpetual leakage. *Advances in Cryptology — CRYPTO'95*. Lecture Notes in Computer Science. Vol. 963. Berlin; Heidelberg: Springer, 1995. P. 339–352. DOI: 10.1007/3-540-44750-4_27.

[200] Hoffman P., McManus P. DNS Queries over HTTPS (DoH). RFC 8484. IETF, 2018. DOI: 10.17487/RFC8484. URL: https://www.rfc-editor.org/rfc/rfc8484.

[201] Holz T., Steiner M., Dahl F., Biersack E., Freiling F. Measurements and Mitigation of Peer-to-Peer-based Botnets: A Case Study on Storm Worm. *First USENIX Workshop on Large-Scale Exploits and Emergent Threats (LEET 08)*. San Francisco, CA: USENIX Association, 2008. URL: https://www.usenix.org/conference/leet-08/measurements-and-mitigation-peer-peer-based-botnets-case-study-storm-worm.

[202] How to Set Up CSIRT and SOC: Good Practice Guide. Athens: European Union Agency for Cybersecurity, 2020. URL: https://www.enisa.europa.eu/publications/how-to-set-up-csirt-and-soc.

[203] Hu V. C., Ferraiolo D., Kuhn R., Schnitzer A., Sandlin K., Miller R., Scarfone K. Guide to Attribute Based Access Control (ABAC) Definition and Considerations. NIST Special Publication 800-162. Gaithersburg, MD, 2014 (з оновленнями станом на 25.02.2019). URL: https://csrc.nist.gov/pubs/sp/800/162/upd1/final.

[204] Hu V. C., Iorga M., Bao W., Li A., Li Q., Gouglidis A. General Access Control Guidance for Cloud Systems. NIST Special Publication 800-210. Gaithersburg, MD: NIST, 2020. DOI: 10.6028/NIST.SP.800-210. URL: https://csrc.nist.gov/pubs/sp/800/210/final.

[205] Hu Z., Zhu L., Heidemann J., Mankin A., Wessels D., Hoffman P. Specification for DNS over Transport Layer Security (TLS). RFC 7858. IETF, 2016. DOI: 10.17487/RFC7858. URL: https://www.rfc-editor.org/rfc/rfc7858.

[206] Hunt P., Konar M., Junqueira F. P., Reed B. ZooKeeper: Wait-free Coordination for Internet-scale Systems. *Proceedings of the 2010 USENIX Annual Technical Conference (USENIX ATC 10)*. Boston, MA: USENIX Association, 2010. URL: https://www.usenix.org/conference/usenix-atc-10/zookeeper-wait-free-coordination-internet-scale-systems.

[207] Hutchins E. M., Cloppert M. J., Amin R. M. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. Bethesda: Lockheed Martin Corporation, 2011. URL: https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Intel-Driven-Defense.pdf.

[208] Hwang C.-L., Yoon K. Multiple Attribute Decision Making: Methods and Applications. Berlin; Heidelberg: Springer, 1981. (Lecture Notes in Economics and Mathematical Systems). ISBN 978-3-540-10558-9. DOI: 10.1007/978-3-642-48318-9. URL: https://doi.org/10.1007/978-3-642-48318-9.

[209] IEC 61508-6:2010. Functional safety of electrical/electronic/programmable electronic safety-related systems. Part 6: Guidelines on the application of IEC 61508-2 and IEC 61508-3. Ed. 2.0. Geneva: IEC, 2010. URL: https://webstore.iec.ch/en/publication/5520.

[210] IEC 62443-2-4:2015+AMD1:2017 CSV. Security for industrial automation and control systems — Part 2-4: Security program requirements for IACS service providers. Ed. 1.1. Geneva: IEC, 2017. URL: https://webstore.iec.ch/publication/61335.

[211] IEC 62443-3-2:2020. Security for industrial automation and control systems — Part 3-2: Security risk assessment for system design. Ed. 1.0. Geneva: IEC, 2020. URL: https://webstore.iec.ch/publication/30727.

[212] IEC 62443-3-3:2013. Industrial communication networks — Network and system security — Part 3-3: System security requirements and security levels. Geneva: IEC, 2013. URL: https://webstore.iec.ch/publication/7033.

[213] IEC 62443-4-2:2019. Security for industrial automation and control systems — Part 4-2: Technical security requirements for IACS components. Ed. 1.0. Geneva: IEC, 2019. URL: https://webstore.iec.ch/publication/34421.

[214] IEC TR 61850-90-4:2020. Communication networks and systems for power utility automation — Part 90-4: Network engineering guidelines. Ed. 2.0. Geneva: IEC, 2020. URL: https://webstore.iec.ch/publication/64801.

[215] IEC TR 62541-2:2020. OPC Unified Architecture — Part 2: Security Model. Ed. 3.0. Geneva: IEC, 2020. URL: https://webstore.iec.ch/publication/61110.

[216] IEC TS 62443-1-1:2009. Industrial communication networks — Network and system security — Part 1-1: Terminology, concepts and models. Ed. 1.0. Geneva: IEC, 2009. URL: https://webstore.iec.ch/publication/7029.

[217] IEEE 1815-2012. IEEE Standard for Electric Power Systems Communications — Distributed Network Protocol (DNP3). New York: IEEE, 2012. URL: https://standards.ieee.org/ieee/1815/5414/.

[218] IEEE Std 802.11-2024. IEEE Standard for Information Technology — Telecommunications and Information Exchange between Systems — Local and Metropolitan Area Networks — Specific Requirements — Part 11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications. New York: IEEE, 2025. URL: https://standards.ieee.org/standard/802_11-2024.html.

[219] IEEE Std 802.1AE-2018. IEEE Standard for Local and Metropolitan Area Networks — Media Access Control (MAC) Security. New York: IEEE, 2018. URL: https://standards.ieee.org/ieee/802.1AE/7154/.

[220] IEEE Std 802.1X-2020. IEEE Standard for Local and Metropolitan Area Networks — Port-Based Network Access Control. New York: IEEE, 2020. URL: https://standards.ieee.org/ieee/802.1X/7345/.

[221] INCITS 359-2012. Information Technology — Role Based Access Control. Washington, DC: InterNational Committee for Information Technology Standards, 2012. URL: https://csrc.nist.gov/projects/role-based-access-control.

[222] International action against «Gameover Zeus» botnet and «CryptoLocker» ransomware. *Europol: Newsroom.* The Hague, 2014. URL: https://www.europol.europa.eu/media-press/newsroom/news/international-action-against-gameover-zeus-botnet-and-cryptolocker-ransomware.

[223] Intrusions Affecting Multiple Victims Across Multiple Sectors: Alert TA17-117A. Cybersecurity and Infrastructure Security Agency, 27.04.2017 (last revised 20.12.2018). URL: https://www.cisa.gov/news-events/alerts/2017/04/27/intrusions-affecting-multiple-victims-across-multiple-sectors.

[224] Iorga M., Feldman L., Barton R., Martin M. J., Goren N., Mahmoudi C. Fog Computing Conceptual Model. NIST Special Publication 500-325. Gaithersburg, MD, 2018. DOI: 10.6028/NIST.SP.500-325. URL: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.500-325.pdf.

[225] ISO 19011:2018. Guidelines for auditing management systems. 3rd ed. Geneva: ISO, 2018. 46 p. URL: https://www.iso.org/standard/70017.html.

[226] ISO 22301:2019. Security and resilience — Business continuity management systems — Requirements. Geneva: ISO, 2019. URL: https://www.iso.org/standard/75106.html.

[227] ISO 31000:2018. Risk management — Guidelines. Geneva: ISO, 2018. URL: https://www.iso.org/standard/65694.html.

[228] ISO 7498-2:1989. Information processing systems — Open Systems Interconnection — Basic Reference Model — Part 2: Security Architecture. Geneva: ISO, 1989.

[229] ISO/IEC 15408-1:2022. Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model. Geneva: ISO, 2022. URL: https://www.iso.org/standard/72891.html.

[230] ISO/IEC 27004:2016. Information technology — Security techniques — Information security management — Monitoring, measurement, analysis and evaluation. Geneva: ISO, 2016.

[231] ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks. Geneva: ISO, 2022. URL: https://www.iso.org/standard/80585.html.

[232] ISO/IEC 27007:2020. Information security, cybersecurity and privacy protection — Guidelines for information security management systems auditing. 3rd ed. Geneva: ISO, 2020. URL: https://www.iso.org/standard/77802.html.

[233] ISO/IEC 27017:2015. Code of practice for information security controls based on ISO/IEC 27002 for cloud services. Geneva: ISO, 2015. URL: https://www.iso.org/standard/43757.html.

[234] ISO/IEC 27018:2019. Code of practice for protection of personally identifiable information (PII) in public clouds acting as PII processors. Geneva: ISO, 2019. URL: https://www.iso.org/standard/76559.html.

[235] ISO/IEC 27031:2011. Information technology — Security techniques — Guidelines for information and communication technology readiness for business continuity. Geneva: ISO, 2011.

[236] ISO/IEC 27035-1:2023. Information technology — Information security incident management — Part 1: Principles and process. Geneva: ISO, 2023. URL: https://www.iso.org/standard/78973.html.

[237] ISO/IEC 42001:2023. Information technology — Artificial intelligence — Management system. Geneva: ISO, 2023.

[238] ISO/IEC 5962:2021. Information technology — SPDX® Specification V2.2.1. Geneva: ISO, 2021. URL: https://spdx.dev/.

[239] Jensen M., Schwenk J., Gruschka N., Lo Iacono L. On Technical Security Issues in Cloud Computing. *2009 IEEE International Conference on Cloud Computing (CLOUD'09)*. Bangalore: IEEE, 2009. P. 109–116. DOI: 10.1109/CLOUD.2009.60.

[240] Jones M., Bradley J., Sakimura N. JSON Web Token (JWT). RFC 7519. IETF, 2015. DOI: 10.17487/RFC7519. URL: https://www.rfc-editor.org/rfc/rfc7519.

[241] Josefsson S., Liusvaara I. Edwards-Curve Digital Signature Algorithm (EdDSA). RFC 8032. IETF, 2017. DOI: 10.17487/RFC8032. URL: https://www.rfc-editor.org/rfc/rfc8032.

[242] Kamvar S. D., Schlosser M. T., Garcia-Molina H. The EigenTrust algorithm for reputation management in P2P networks. *Proceedings of the 12th International Conference on World Wide Web (WWW'03)*. New York: ACM, 2003. P. 640–651. DOI: 10.1145/775152.775242.

[243] Keller N., Quinn S., Scarfone K., Smith M., Johnson V. National Online Informative References (OLIR) Program: Overview, Benefits, and Use. NIST IR 8278, Rev. 1. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.IR.8278r1. URL: https://csrc.nist.gov/pubs/ir/8278/r1/final.

[244] Kelsey J., Callas J., Clemm A. Signed Syslog Messages. RFC 5848. IETF, 2010. DOI: 10.17487/RFC5848. URL: https://www.rfc-editor.org/rfc/rfc5848.

[245] Kent K., Chevalier S., Grance T., Dang H. Guide to Integrating Forensic Techniques into Incident Response. NIST Special Publication 800-86. Gaithersburg, MD, 2006. DOI: 10.6028/NIST.SP.800-86. URL: https://csrc.nist.gov/pubs/sp/800/86/final.

[246] Kent K., Souppaya M. Guide to Computer Security Log Management. NIST Special Publication 800-92. Gaithersburg, MD: NIST, 2006. DOI: 10.6028/NIST.SP.800-92. URL: https://csrc.nist.gov/pubs/sp/800/92/final.

[247] Kent S., Seo K. Security Architecture for the Internet Protocol. RFC 4301. IETF, 2005. DOI: 10.17487/RFC4301. URL: https://www.rfc-editor.org/rfc/rfc4301.

[248] Khan S., Kabanov I., Hua Y., Madnick S. A Systematic Analysis of the Capital One Data Breach: Critical Lessons Learned. *ACM Transactions on Privacy and Security*. 2023. Vol. 26, no. 1. P. 1–29. DOI: 10.1145/3546068.

[249] Kim Y., Perrig A., Tsudik G. Tree-based group key agreement. *ACM Transactions on Information and System Security*. 2004. Vol. 7, no. 1. P. 60–96. DOI: 10.1145/984334.984337.

[250] Kitchenham B., Charters S. Guidelines for Performing Systematic Literature Reviews in Software Engineering. EBSE Technical Report EBSE-2007-01. Keele University; Durham University, 2007.

[251] Kleppmann M. Designing Data-Intensive Applications. Sebastopol: O'Reilly Media, 2017. 616 p.

[252] Knight J. C., Leveson N. G. An experimental evaluation of the assumption of independence in multiversion programming. *IEEE Transactions on Software Engineering*. 1986. Vol. SE-12, no. 1. P. 96–109. DOI: 10.1109/TSE.1986.6312924.

[253] Known Exploited Vulnerabilities Catalog. Cybersecurity and Infrastructure Security Agency (CISA). URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

[254] Kocher P., Horn J., Fogh A., Genkin D., Gruss D., Haas W., Hamburg M., Lipp M., Mangard S., Prescher T., Schwarz M., Yarom Y. Spectre Attacks: Exploiting Speculative Execution. *2019 IEEE Symposium on Security and Privacy (SP)*. San Francisco, CA: IEEE, 2019. P. 1–19. DOI: 10.1109/SP.2019.00002.

[255] Krawczyk H., Eronen P. HMAC-based Extract-and-Expand Key Derivation Function (HKDF). RFC 5869. IETF, 2010. DOI: 10.17487/RFC5869. URL: https://www.rfc-editor.org/rfc/rfc5869.

[256] Krebs B. What We Can Learn from the Capital One Hack. *Krebs on Security*. 2019. 2 August. URL: https://krebsonsecurity.com/2019/08/what-we-can-learn-from-the-capital-one-hack/.

[257] Kubernetes Security Cheat Sheet. OWASP Cheat Sheet Series. OWASP Foundation. URL: https://cheatsheetseries.owasp.org/cheatsheets/Kubernetes_Security_Cheat_Sheet.html.

[258] Lamport L. The part-time parliament. *ACM Transactions on Computer Systems*. 1998. Vol. 16, no. 2. P. 133–169. DOI: 10.1145/279227.279229.

[259] Lamport L. Time, Clocks, and the Ordering of Events in a Distributed System. *Communications of the ACM*. 1978. Vol. 21, no. 7. P. 558–565. DOI: 10.1145/359545.359563. URL: https://lamport.azurewebsites.net/pubs/time-clocks.pdf.

[260] Lamport L., Shostak R., Pease M. The Byzantine Generals Problem. *ACM Transactions on Programming Languages and Systems*. 1982. Vol. 4, no. 3. P. 382–401. DOI: 10.1145/357172.357176. URL: https://lamport.azurewebsites.net/pubs/byz.pdf.

[261] Laurie B., Messeri E., Stradling R. Certificate Transparency Version 2.0. RFC 9162. IETF, 2021. DOI: 10.17487/RFC9162. URL: https://www.rfc-editor.org/rfc/rfc9162.

[262] Liang J., Kumar R., Ross K. W. The FastTrack overlay: A measurement study. *Computer Networks*. 2006. Vol. 50, no. 6. P. 842–858. DOI: 10.1016/j.comnet.2005.07.014.

[263] Liang J., Kumar R., Xi Y., Ross K. W. Pollution in P2P file sharing systems. *Proceedings IEEE 24th Annual Joint Conference of the IEEE Computer and Communications Societies (INFOCOM 2005)*. Miami, FL: IEEE, 2005. Vol. 2. P. 1174–1185. DOI: 10.1109/INFCOM.2005.1498344.

[264] Liang J., Naoumov N., Ross K. W. The Index Poisoning Attack in P2P File Sharing Systems. *Proceedings IEEE INFOCOM 2006: 25th IEEE International Conference on Computer Communications*. Barcelona: IEEE, 2006. P. 1–12. DOI: 10.1109/INFOCOM.2006.232.

[265] Lianza T. A Byzantine failure in the real world. *The Cloudflare Blog*. 2020. 27 Nov. URL: https://blog.cloudflare.com/a-byzantine-failure-in-the-real-world/.

[266] LINDDUN privacy threat modeling framework. DistriNet Research Unit, KU Leuven. URL: https://linddun.org/.

[267] Lipp M., Schwarz M., Gruss D., Prescher T., Haas W., Horn J., Mangard S., Kocher P., Genkin D., Yarom Y., Hamburg M., Strackx R. Meltdown: reading kernel memory from user space. *Communications of the ACM*. 2020. Vol. 63, no. 6. P. 46–56. DOI: 10.1145/3357033.

[268] Lipton R. J., Snyder L. A Linear Time Algorithm for Deciding Subject Security. *Journal of the ACM*. 1977. Vol. 24, no. 3. P. 455–464. DOI: 10.1145/322017.322025. URL: https://doi.org/10.1145/322017.322025.

[269] Lodderstedt T., Bradley J., Labunets A., Fett D. Best Current Practice for OAuth 2.0 Security. RFC 9700 (BCP 240). IETF, 2025. DOI: 10.17487/RFC9700. URL: https://www.rfc-editor.org/rfc/rfc9700.

[270] Loewenstern A., Norberg A. DHT Protocol. BEP 5. BitTorrent.org, 2008 (last modified 2020). URL: https://www.bittorrent.org/beps/bep_0005.html.

[271] Lua E. K., Crowcroft J., Pias M., Sharma R., Lim S. A survey and comparison of peer-to-peer overlay network schemes. *IEEE Communications Surveys & Tutorials*. 2005. Vol. 7, no. 2. P. 72–93. DOI: 10.1109/COMST.2005.1610546.

[272] Lv Q., Cao P., Cohen E., Li K., Shenker S. Search and replication in unstructured peer-to-peer networks. *Proceedings of the 16th International Conference on Supercomputing (ICS'02)*. New York: ACM, 2002. P. 84–95. DOI: 10.1145/514191.514206.

[273] Machanavajjhala A., Kifer D., Gehrke J., Venkitasubramaniam M. ℓ-diversity: Privacy beyond k-anonymity. *ACM Transactions on Knowledge Discovery from Data*. 2007. Vol. 1, no. 1. Article 3. DOI: 10.1145/1217299.1217302.

[274] Malhotra A., Cohen I. E., Brakke E., Goldberg S. Attacking the Network Time Protocol. *Proceedings of the 2016 Network and Distributed System Security Symposium (NDSS 2016)*. San Diego, CA: Internet Society, 2016. DOI: 10.14722/ndss.2016.23090.

[275] Manadhata P. K., Wing J. M. An Attack Surface Metric. *IEEE Transactions on Software Engineering*. 2011. Vol. 37, no. 3. P. 371–386. DOI: 10.1109/TSE.2010.60. URL: https://doi.org/10.1109/TSE.2010.60.

[276] Marcus Y., Heilman E., Goldberg S. Low-Resource Eclipse Attacks on Ethereum's Peer-to-Peer Network. *Cryptology ePrint Archive*. 2018. Paper 2018/236. URL: https://eprint.iacr.org/2018/236.

[277] Maymounkov P., Mazières D. Kademlia: A Peer-to-Peer Information System Based on the XOR Metric. *Peer-to-Peer Systems (IPTPS 2002)*. Lecture Notes in Computer Science. Vol. 2429. Berlin; Heidelberg: Springer, 2002. P. 53–65. DOI: 10.1007/3-540-45748-8_5.

[278] McIntosh M., Austel P. XML signature element wrapping attacks and countermeasures. *Proceedings of the 2005 Workshop on Secure Web Services (SWS'05)*. New York: ACM, 2005. P. 20–27. DOI: 10.1145/1103022.1103026.

[279] Mell P., Grance T. The NIST Definition of Cloud Computing. NIST SP 800-145. Gaithersburg, MD, 2011. DOI: 10.6028/NIST.SP.800-145. URL: https://csrc.nist.gov/pubs/sp/800/145/final.

[280] Menezes A., van Oorschot P., Vanstone S. Handbook of Applied Cryptography. Boca Raton: CRC Press, 1996. 810 p. URL: https://cacr.uwaterloo.ca/hac/.

[281] Merkle R. C. A Digital Signature Based on a Conventional Encryption Function. *Advances in Cryptology — CRYPTO'87*. Lecture Notes in Computer Science. Berlin; Heidelberg: Springer, 1988. P. 369–378. DOI: 10.1007/3-540-48184-2_32.

[282] Metro-Goldwyn-Mayer Studios Inc. v. Grokster, Ltd., 545 U.S. 913 (2005): decision of the Supreme Court of the United States of 27.06.2005, No. 04-480. URL: https://www.law.cornell.edu/supct/html/04-480.ZS.html.

[283] Microsoft Threat Modeling Tool threats: the STRIDE model. Microsoft Learn, 2026. URL: https://learn.microsoft.com/en-us/azure/security/develop/threat-modeling-tool-threats.

[284] Mills D., Martin J. (Ed.), Burbank J., Kasch W. Network Time Protocol Version 4: Protocol and Algorithms Specification. RFC 5905. IETF, 2010. DOI: 10.17487/RFC5905. URL: https://www.rfc-editor.org/rfc/rfc5905.

[285] Mitigating Log4Shell and Other Log4j-Related Vulnerabilities. Cybersecurity Advisory AA21-356A. CISA, FBI, NSA et al., 2021. URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-356a.

[286] MITRE ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems. The MITRE Corporation. URL: https://atlas.mitre.org/.

[287] MITRE ATT&CK for ICS: Matrix for Industrial Control Systems. The MITRE Corporation. URL: https://attack.mitre.org/matrices/ics/.

[288] MITRE ATT&CK®: Adversarial Tactics, Techniques, and Common Knowledge. The MITRE Corporation. URL: https://attack.mitre.org/.

[289] MITRE D3FEND: A Knowledge Graph of Cybersecurity Countermeasures. Version 1.6.0. The MITRE Corporation. URL: https://d3fend.mitre.org/.

[290] Mohapatra P., Scudder J., Ward D., Bush R., Austein R. BGP Prefix Origin Validation. RFC 6811. IETF, 2013. DOI: 10.17487/RFC6811. URL: https://www.rfc-editor.org/rfc/rfc6811.

[291] Moreau L., Missier P. (eds.). PROV-DM: The PROV Data Model. W3C Recommendation 30 April 2013. URL: https://www.w3.org/TR/prov-dm/.

[292] MQTT Version 5.0: OASIS Standard / ed. by A. Banks, E. Briggs, K. Borgendale, R. Gupta. OASIS, 07 March 2019. URL: https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html.

[293] Nakamoto S. Bitcoin: A Peer-to-Peer Electronic Cash System. 2008. 9 p. URL: https://bitcoin.org/bitcoin.pdf.

[294] Naveed M., Kamara S., Wright C. V. Inference Attacks on Property-Preserving Encrypted Databases. *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security (CCS'15)*. New York: ACM, 2015. P. 644–655. DOI: 10.1145/2810103.2813651.

[295] Nelson A., Rekhi S., Souppaya M., Scarfone K. Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. NIST Special Publication 800-61r3. Gaithersburg, MD, 2025. DOI: 10.6028/NIST.SP.800-61r3. URL: https://csrc.nist.gov/pubs/sp/800/61/r3/final.

[296] Network Policies. Kubernetes Documentation. The Kubernetes Authors / Cloud Native Computing Foundation. URL: https://kubernetes.io/docs/concepts/services-networking/network-policies/.

[297] Neuman C., Yu T., Hartman S., Raeburn K. The Kerberos Network Authentication Service (V5). RFC 4120. IETF, 2005. DOI: 10.17487/RFC4120. URL: https://www.rfc-editor.org/rfc/rfc4120.

[298] Nir Y., Langley A. ChaCha20 and Poly1305 for IETF Protocols. RFC 8439. IETF, 2018. DOI: 10.17487/RFC8439. URL: https://www.rfc-editor.org/rfc/rfc8439.

[299] NIST. Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. Gaithersburg, MD, 2023. DOI: 10.6028/NIST.AI.100-1. URL: https://www.nist.gov/itl/ai-risk-management-framework.

[300] NIST. Guide for Conducting Risk Assessments. NIST SP 800-30, Rev. 1. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-30r1. URL: https://csrc.nist.gov/pubs/sp/800/30/r1/final.

[301] NIST. Module-Lattice-Based Digital Signature Standard. FIPS 204. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.FIPS.204. URL: https://csrc.nist.gov/pubs/fips/204/final.

[302] NIST. Module-Lattice-Based Key-Encapsulation Mechanism Standard. FIPS 203. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.FIPS.203. URL: https://csrc.nist.gov/pubs/fips/203/final.

[303] NIST. Risk Management Framework for Information Systems and Organizations. NIST SP 800-37, Rev. 2. Gaithersburg, MD, 2018. DOI: 10.6028/NIST.SP.800-37r2. URL: https://csrc.nist.gov/pubs/sp/800/37/r2/final.

[304] NIST. Security and Privacy Controls for Information Systems and Organizations. NIST SP 800-53, Rev. 5. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final.

[305] NIST. Security Requirements for Cryptographic Modules. FIPS 140-3. Gaithersburg, MD, 2019. DOI: 10.6028/NIST.FIPS.140-3. URL: https://csrc.nist.gov/pubs/fips/140-3/final.

[306] NIST. Stateless Hash-Based Digital Signature Standard. FIPS 205. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.FIPS.205. URL: https://csrc.nist.gov/pubs/fips/205/final.

[307] NIST. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-20/final.

[308] NIST. Transition to Post-Quantum Cryptography Standards. NIST IR 8547 (Initial Public Draft). Gaithersburg, MD, 2024. DOI: 10.6028/NIST.IR.8547.ipd. URL: https://csrc.nist.gov/pubs/ir/8547/ipd.

[309] Norberg A. DHT Security extension. BEP 42. BitTorrent.org, 2014 (last modified 2016). URL: https://www.bittorrent.org/beps/bep_0042.html.

[310] Oliynykov R., Gorbenko I., Kazymyrov O., Ruzhentsev V., Kuznetsov O., Gorbenko Yu., Dyrda O., Dolgov V., Pushkaryov A., Mordvinov R., Kaidalov D. A New Encryption Standard of Ukraine: The Kalyna Block Cipher. *Cryptology ePrint Archive*. 2015. Report 2015/650. URL: https://eprint.iacr.org/2015/650.

[311] Oliynykov R., Gorbenko I., Kazymyrov O., Ruzhentsev V., Kuznetsov O., Gorbenko Yu., Boiko A., Dyrda O., Dolgov V., Pushkaryov A. A New Standard of Ukraine: The Kupyna Hash Function. *Cryptology ePrint Archive*. 2015. Report 2015/885. URL: https://eprint.iacr.org/2015/885.

[312] Ongaro D. Consensus: Bridging Theory and Practice: PhD dissertation. Stanford, CA: Stanford University, 2014. URL: https://web.stanford.edu/~ouster/cgi-bin/papers/OngaroPhD.pdf.

[313] Ongaro D., Ousterhout J. In Search of an Understandable Consensus Algorithm. *Proceedings of the 2014 USENIX Annual Technical Conference (USENIX ATC'14)*. Philadelphia, PA: USENIX Association, 2014. P. 305–319. URL: https://www.usenix.org/conference/atc14/technical-sessions/presentation/ongaro.

[314] Open Cybersecurity Schema Framework (OCSF). The Linux Foundation, 2024. URL: https://ocsf.io/.

[315] Open Policy Agent: policy language (Rego): documentation. Cloud Native Computing Foundation. URL: https://www.openpolicyagent.org/docs/policy-language (дата звернення: 10.09.2026).

[316] OpenTelemetry Specification. Cloud Native Computing Foundation, 2025. URL: https://opentelemetry.io/docs/specs/otel/.

[317] Operating etcd clusters for Kubernetes. *Kubernetes Documentation*. The Kubernetes Authors; Cloud Native Computing Foundation. URL: https://kubernetes.io/docs/tasks/administer-cluster/configure-upgrade-etcd/.

[318] Ou X., Boyer W. F., McQueen M. A. A scalable approach to attack graph generation. *Proceedings of the 13th ACM Conference on Computer and Communications Security (CCS '06)*. New York: ACM, 2006. P. 336–345. DOI: 10.1145/1180405.1180446. URL: https://doi.org/10.1145/1180405.1180446.

[319] OWASP API Security Top 10 — 2023. OWASP Foundation, 2023. URL: https://owasp.org/www-project-api-security/.

[320] OWASP Top 10:2021 — The Ten Most Critical Web Application Security Risks. OWASP Foundation, 2021. URL: https://owasp.org/Top10/.

[321] Pang R., Caceres R., Burrows M., Chen Z., Dave P., Germer N., Golynski A., Graney K., Kang N., Kissner L., Korn J. L., Parmar A., Richards C. D., Wang M. Zanzibar: Google's Consistent, Global Authorization System. *Proceedings of the 2019 USENIX Annual Technical Conference (USENIX ATC '19)*. Renton, WA: USENIX Association, 2019. URL: https://www.usenix.org/conference/atc19/presentation/pang.

[322] Pittel B. On spreading a rumor. *SIAM Journal on Applied Mathematics*. 1987. Vol. 47, no. 1. P. 213–223. DOI: 10.1137/0147013.

[323] Pod Security Standards. Kubernetes Documentation. The Kubernetes Authors / Cloud Native Computing Foundation. URL: https://kubernetes.io/docs/concepts/security/pod-security-standards/.

[324] Popa R. A., Redfield C. M. S., Zeldovich N., Balakrishnan H. CryptDB: protecting confidentiality with encrypted query processing. *Proceedings of the Twenty-Third ACM Symposium on Operating Systems Principles (SOSP'11)*. New York: ACM, 2011. P. 85–100. DOI: 10.1145/2043556.2043566.

[325] Principles of Chaos Engineering. Chaos Engineering Community, 2019. URL: https://principlesofchaos.org/.

[326] Prünster B., Marsalek A., Zefferer T. Total Eclipse of the Heart — Disrupting the InterPlanetary File System. *Proceedings of the 31st USENIX Security Symposium (USENIX Security 22)*. Boston, MA: USENIX Association, 2022. P. 3735–3752. URL: https://www.usenix.org/conference/usenixsecurity22/presentation/prunster.

[327] Ratnasamy S., Francis P., Handley M., Karp R., Shenker S. A scalable content-addressable network. *Proceedings of the 2001 Conference on Applications, Technologies, Architectures, and Protocols for Computer Communications (SIGCOMM'01)*. New York: ACM, 2001. P. 161–172. DOI: 10.1145/383059.383072.

[328] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation). *Official Journal of the EU*. L 119. P. 1–88. URL: https://eur-lex.europa.eu/eli/reg/2016/679/oj.

[329] Regulation (EU) 2022/2554 on digital operational resilience for the financial sector (DORA). *Official Journal of the EU*. L 333. P. 1–79. URL: https://eur-lex.europa.eu/eli/reg/2022/2554/oj.

[330] Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework. *Official Journal of the EU*. L series, 2024/1183, 30.04.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/1183/oj.

[331] Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (Artificial Intelligence

Act). *Official Journal of the EU*. L series, 12.07.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/1689/oj.

[332] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). *Official Journal of the EU*. L series, 20.11.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/2847/oj.

[333] Regulation (EU) No 910/2014 of the European Parliament and of the Council of 23 July 2014 on electronic identification and trust services for electronic transactions in the internal market and repealing Directive 1999/93/EC (eIDAS). *Official Journal of the EU*. L 257, 28.08.2014. P. 73–114. URL: https://eur-lex.europa.eu/eli/reg/2014/910/oj.

[334] Reiter M. K. Secure agreement protocols: reliable and atomic group multicast in Rampart. *Proceedings of the 2nd ACM Conference on Computer and Communications Security (CCS'94)*. New York: ACM, 1994. P. 68–80. DOI: 10.1145/191177.191194.

[335] Reiter M. K., Birman K. P. How to securely replicate services. *ACM Transactions on Programming Languages and Systems*. 1994. Vol. 16, no. 3. P. 986–1009. DOI: 10.1145/177492.177745.

[336] Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446. IETF, 2018. DOI: 10.17487/RFC8446. URL: https://www.rfc-editor.org/rfc/rfc8446.

[337] Rigney C., Willens S., Rubens A., Simpson W. Remote Authentication Dial In User Service (RADIUS). RFC 2865. IETF, 2000. DOI: 10.17487/RFC2865. URL: https://www.rfc-editor.org/rfc/rfc2865.

[338] Ripeanu M. Peer-to-peer architecture case study: Gnutella network. *Proceedings First International Conference on Peer-to-Peer Computing (P2P 2001)*. Linköping: IEEE, 2001. P. 99–100. DOI: 10.1109/P2P.2001.990433.

[339] Risk Taxonomy (O-RT), Version 3.0.1. Open Group Standard C20B. Reading: The Open Group, 2021. URL: https://publications.opengroup.org/c20b.

[340] Ristenpart T., Tromer E., Shacham H., Savage S. Hey, you, get off of my cloud: exploring information leakage in third-party compute clouds. *Proceedings of the 16th ACM Conference on Computer and Communications Security (CCS'09)*. New York: ACM, 2009. P. 199–212. DOI: 10.1145/1653662.1653687.

[341] Rose S., Borchert O., Kerman A., Souppaya M. et al. Implementing a Zero Trust Architecture. NIST Special Publication 1800-35. Gaithersburg, MD: NIST, 2025. DOI: 10.6028/NIST.SP.1800-35. URL: https://csrc.nist.gov/pubs/sp/1800/35/final.

[342] Rose S., Borchert O., Mitchell S., Connelly S. Zero Trust Architecture. NIST Special Publication 800-207. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/pubs/sp/800/207/final.

[343] Ross R., Pillitteri V., Graubart R., Bodeau D., McQuaid R. Developing Cyber-Resilient Systems: A Systems Security Engineering Approach. NIST Special Publication 800-160, Vol. 2, Rev. 1. Gaithersburg, MD, 2021. DOI: 10.6028/NIST.SP.800-160v2r1. URL: https://csrc.nist.gov/pubs/sp/800/160/v2/r1/final.

[344] Rossow C., Andriesse D., Werner T., Stone-Gross B., Plohmann D., Dietrich C. J., Bos H. SoK: P2PWNED — Modeling and Evaluating the Resilience of Peer-to-Peer Botnets. *2013 IEEE Symposium on Security and Privacy*. Berkeley, CA: IEEE, 2013. P. 97–111. DOI: 10.1109/SP.2013.17.

[345] Rowstron A., Druschel P. Pastry: Scalable, Decentralized Object Location, and Routing for Large-Scale Peer-to-Peer Systems. *Middleware 2001*. Lecture Notes in Computer Science. Vol. 2218. Berlin; Heidelberg: Springer, 2001. P. 329–350. DOI: 10.1007/3-540-45518-3_18.

[346] Saaty T. L. How to make a decision: The analytic hierarchy process. *European Journal of Operational Research*. 1990. Vol. 48, no. 1. P. 9–26. DOI: 10.1016/0377-2217(90)90057-I. URL: https://doi.org/10.1016/0377-2217(90)90057-I.

[347] Sakimura N., Bradley J., Jones M., de Medeiros B., Mortimore C. OpenID Connect Core 1.0 incorporating errata set 2. OpenID Foundation, 15 December 2023. URL: https://openid.net/specs/openid-connect-core-1_0.html.

[348] Santesson S., Myers M., Ankney R., Malpani A., Galperin S., Adams C. X.509 Internet Public Key Infrastructure Online Certificate Status Protocol — OCSP. RFC 6960. IETF, 2013. DOI: 10.17487/RFC6960. URL: https://www.rfc-editor.org/rfc/rfc6960.

[349] Sapirshtein A., Sompolinsky Y., Zohar A. Optimal Selfish Mining Strategies in Bitcoin. *Financial Cryptography and Data Security (FC 2016)*. Lecture Notes in Computer Science. Vol. 9603. Berlin; Heidelberg: Springer, 2017. P. 515–532. DOI: 10.1007/978-3-662-54970-4_30.

[350] Saroiu S., Gummadi P. K., Gribble S. D. Measurement study of peer-to-peer file sharing systems. *Multimedia Computing and Networking 2002*. Proceedings of SPIE. Vol. 4673. San Jose, CA: SPIE, 2001. P. 156–170. DOI: 10.1117/12.449977.

[351] Scarfone K., Hoffman P. Guidelines on Firewalls and Firewall Policy. NIST Special Publication 800-41, Rev. 1. Gaithersburg, MD: NIST, 2009. DOI: 10.6028/NIST.SP.800-41r1. URL: https://csrc.nist.gov/pubs/sp/800/41/r1/final.

[352] Scarfone K., Mell P. Guide to Intrusion Detection and Prevention Systems (IDPS). NIST Special Publication 800-94. Gaithersburg, MD: NIST, 2007. DOI: 10.6028/NIST.SP.800-94. URL: https://csrc.nist.gov/pubs/sp/800/94/final.

[353] Scarfone K., Souppaya M., Cody A., Orebaugh A. Technical Guide to Information Security Testing and Assessment. NIST Special Publication 800-115. Gaithersburg, MD: NIST, 2008. DOI: 10.6028/NIST.SP.800-115. URL: https://csrc.nist.gov/pubs/sp/800/115/final.

[354] Scarfone K., Souppaya M., Hoffman P. Guide to Security for Full Virtualization Technologies. NIST SP 800-125. Gaithersburg, MD: National Institute of Standards and Technology, 2011. 35 p. DOI: 10.6028/NIST.SP.800-125.

[355] Schneider F. B. Implementing fault-tolerant services using the state machine approach: a tutorial. *ACM Computing Surveys*. 1990. Vol. 22, no. 4. P. 299–319. DOI: 10.1145/98163.98167.

[356] Schneier B. Attack Trees: Modeling security threats. *Dr. Dobb's Journal*. 1999. Vol. 24, no. 12. December. URL: https://www.schneier.com/academic/archives/1999/12/attack_trees.html.

[357] Schroeder K., Trinh H., Pillitteri V. Measurement Guide for Information Security: Volume 1 — Identifying and Selecting Measures. NIST Special Publication 800-55v1. Gaithersburg, MD: National Institute of Standards and Technology, 2024. DOI: 10.6028/NIST.SP.800-55v1. URL: https://csrc.nist.gov/pubs/sp/800/55/v1/final.

[358] Security Guidance for Critical Areas of Focus in Cloud Computing v5. Cloud Security Alliance, 2024. URL: https://cloudsecurityalliance.org/research/guidance.

[359] Sermersheim J. (Ed.). Lightweight Directory Access Protocol (LDAP): The Protocol. RFC 4511. IETF, 2006. DOI: 10.17487/RFC4511. URL: https://www.rfc-editor.org/rfc/rfc4511.

[360] Shamir A. How to Share a Secret. *Communications of the ACM*. 1979. Vol. 22, No. 11. P. 612–613. DOI: 10.1145/359168.359176.

[361] Shannon C. E. Communication Theory of Secrecy Systems. *Bell System Technical Journal*. 1949. Vol. 28, no. 4. P. 656–715. DOI: 10.1002/j.1538-7305.1949.tb00928.x. URL: https://doi.org/10.1002/j.1538-7305.1949.tb00928.x.

[362] Shapiro M., Preguiça N., Baquero C., Zawirski M. Conflict-Free Replicated Data Types. *Stabilization, Safety, and Security of Distributed Systems (SSS 2011)*. Lecture Notes in Computer Science. Berlin; Heidelberg: Springer, 2011. P. 386–400. DOI: 10.1007/978-3-642-24550-3_29.

[363] Shelby Z., Hartke K., Bormann C. The Constrained Application Protocol (CoAP). RFC 7252. IETF, 2014. DOI: 10.17487/RFC7252. URL: https://www.rfc-editor.org/rfc/rfc7252.

[364] Sheyner O., Haines J., Jha S., Lippmann R., Wing J. M. Automated generation and analysis of attack graphs. *Proceedings of the 2002 IEEE Symposium on Security and Privacy*. Berkeley, CA: IEEE, 2002. P. 273–284. DOI: 10.1109/SECPRI.2002.1004377. URL: https://doi.org/10.1109/SECPRI.2002.1004377.

[365] Shirey R. Internet Security Glossary, Version 2. RFC 4949. IETF, 2007. DOI: 10.17487/RFC4949. URL: https://www.rfc-editor.org/rfc/rfc4949.

[366] Shostack A. Threat Modeling: Designing for Security. Indianapolis: Wiley, 2014. 624 p.

[367] Shoup V. Practical threshold signatures. *Advances in Cryptology — EUROCRYPT 2000*. Lecture Notes in Computer Science. Vol. 1807. Berlin; Heidelberg: Springer, 2000. P. 207–220. DOI: 10.1007/3-540-45539-6_15.

[368] Sigstore Documentation: Cosign, Fulcio, Rekor. San Francisco, CA: The Linux Foundation, Open Source Security Foundation (OpenSSF). URL: https://docs.sigstore.dev/.

[369] Singh A., Ngan T.-W., Druschel P., Wallach D. S. Eclipse Attacks on Overlay Networks: Threats and Defenses. *Proceedings IEEE INFOCOM 2006: 25th IEEE International Conference on Computer Communications*. Barcelona: IEEE, 2006. P. 1–12. DOI: 10.1109/INFOCOM.2006.231.

[370] Singhal A., Winograd T., Scarfone K. Guide to Secure Web Services. NIST SP 800-95. Gaithersburg, MD: National Institute of Standards and Technology, 2007. DOI: 10.6028/NIST.SP.800-95.

[371] Sit E., Morris R. Security Considerations for Peer-to-Peer Distributed Hash Tables. *Peer-to-Peer Systems (IPTPS 2002)*. Lecture Notes in Computer Science. Vol. 2429. Berlin; Heidelberg: Springer, 2002. P. 261–269. DOI: 10.1007/3-540-45748-8_25.

[372] SLSA: Supply-chain Levels for Software Artifacts. Version 1.2. Open Source Security Foundation (OpenSSF). URL: https://slsa.dev/.

[373] Software Bill of Materials (SBOM). Cybersecurity and Infrastructure Security Agency (CISA). URL: https://www.cisa.gov/sbom.

[374] Software-Defined Perimeter (SDP) Specification v2.0. Seattle, WA: Cloud Security Alliance, 2022. URL: https://cloudsecurityalliance.org/artifacts/software-defined-perimeter-zero-trust-specification-v2.

[375] Somorovsky J., Heiderich M., Jensen M., Schwenk J., Gruschka N., Lo Iacono L. All your clouds are belong to us: security analysis of cloud management interfaces. *Proceedings of the 3rd ACM Workshop on Cloud Computing Security Workshop (CCSW'11)*. New York: ACM, 2011. P. 3–14. DOI: 10.1145/2046660.2046664.

[376] Souppaya M., Morello J., Scarfone K. Application Container Security Guide. NIST SP 800-190. Gaithersburg, MD, 2017. DOI: 10.6028/NIST.SP.800-190. URL: https://csrc.nist.gov/pubs/sp/800/190/final.

[377] Souppaya M., Scarfone K. Guide to Data-Centric System Threat Modeling. NIST Special Publication 800-154 (Initial Public Draft). Gaithersburg, MD: NIST, 2016. URL: https://csrc.nist.gov/pubs/sp/800/154/ipd.

[378] Souppaya M., Scarfone K. Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology. NIST Special Publication 800-40, Rev. 4. Gaithersburg, MD, 2022. DOI: 10.6028/NIST.SP.800-40r4. URL: https://csrc.nist.gov/pubs/sp/800/40/r4/final.

[379] Souppaya M., Scarfone K. Guidelines for Securing Wireless Local Area Networks (WLANs). NIST Special Publication 800-153. Gaithersburg, MD: NIST, 2012. DOI: 10.6028/NIST.SP.800-153. URL: https://csrc.nist.gov/pubs/sp/800/153/final.

[380] Souppaya M., Scarfone K., Dodson D. Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities. NIST Special Publication 800-218. Gaithersburg, MD, 2022. DOI: 10.6028/NIST.SP.800-218. URL: https://csrc.nist.gov/pubs/sp/800/218/final.

[381] SPIFFE: Secure Production Identity Framework for Everyone: overview and specifications. URL: https://spiffe.io/docs/latest/spiffe-about/overview/ (дата звернення: 10.09.2026).

[382] Sporny M., Guy A., Sabadello M., Reed D. (Eds.). Decentralized Identifiers (DIDs) v1.0: W3C Recommendation, 19 July 2022. World Wide Web Consortium, 2022. URL: https://www.w3.org/TR/did-1.0/.

[383] Sporny M., Thibodeau Jr T., Herman I., Cohen G., Jones M. B. (Eds.). Verifiable Credentials Data Model v2.0: W3C Recommendation, 15 May 2025. World Wide Web Consortium, 2025. URL: https://www.w3.org/TR/vc-data-model-2.0/.

[384] Sqalli M. H., Al-Haidari F., Salah K. EDoS-Shield — A Two-Steps Mitigation Technique against EDoS Attacks in Cloud Computing. *2011 Fourth IEEE International Conference on Utility and Cloud Computing (UCC)*. Melbourne: IEEE, 2011. P. 49–56. DOI: 10.1109/UCC.2011.17.

[385] Steiner M., En-Najjary T., Biersack E. W. Exploiting KAD: possible uses and misuses. *ACM SIGCOMM Computer Communication Review*. 2007. Vol. 37, no. 5. P. 65–70. DOI: 10.1145/1290168.1290176.

[386] STIX Version 2.1. OASIS Standard. 10 June 2021 / eds. B. Jordan, R. Piazza, T. Darley. Burlington, MA: OASIS Open, 2021. URL: https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html.

[387] Stoica I., Morris R., Karger D., Kaashoek M. F., Balakrishnan H. Chord: A Scalable Peer-to-Peer Lookup Service for Internet Applications. *Proceedings of the 2001 Conference on Applications, Technologies, Architectures, and Protocols for Computer Communications (SIGCOMM'01)*. New York: ACM, 2001. P. 149–160. DOI: 10.1145/383059.383071.

[388] Stouffer K., Pease M., Tang C., Zimmerman T., Pillitteri V., Lightman S., Hahn A., Saravia S., Sherule A., Thompson M. Guide to Operational Technology (OT) Security. NIST Special Publication 800-82, Rev. 3. Gaithersburg, MD: National Institute of Standards and Technology, 2023. DOI: 10.6028/NIST.SP.800-82r3. URL: https://csrc.nist.gov/pubs/sp/800/82/r3/final.

[389] Strom B. E., Applebaum A., Miller D. P., Nickels K. C., Pennington A. G., Thomas C. B. MITRE ATT&CK®: Design and Philosophy. MITRE Product MP180360R1. McLean, VA: The MITRE Corporation, 2020. URL: https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf.

[390] Suri N. Distributed Systems Security Knowledge Area. Version 1.0.1 / ed. E. Lupu. *The Cyber Security Body of Knowledge (CyBOK)*. © Crown Copyright, The National Cyber Security Centre, 2021. Licensed under the Open Government Licence v3.0. URL: https://www.cybok.org/media/downloads/Distributed_Systems_Security_v1.0.1.pdf.

[391] Swanson M., Bowen P., Phillips A., Gallup D., Lynes D. Contingency Planning Guide for Federal Information Systems. NIST Special Publication 800-34, Rev. 1. Gaithersburg, MD, 2010. DOI: 10.6028/NIST.SP.800-34r1. URL: https://csrc.nist.gov/pubs/sp/800/34/r1/upd1/final.

[392] Sweeney L. k-anonymity: a model for protecting privacy. *International Journal of Uncertainty, Fuzziness and Knowledge-Based Systems*. 2002. Vol. 10, no. 5. P. 557–570. DOI: 10.1142/S0218488502001648.

[393] Tambe M. Security and Game Theory: Algorithms, Deployed Systems, Lessons Learned. Cambridge: Cambridge University Press, 2011. DOI: 10.1017/CBO9780511973031. URL: https://doi.org/10.1017/CBO9780511973031.

[394] Tanenbaum A. S., van Steen M. Distributed Systems. 4th ed. Maarssen: Distributed-systems.net, 2023. 686 p. URL: https://www.distributed-systems.net/index.php/books/ds4/.

[395] TAXII Version 2.1. OASIS Standard. 10 June 2021 / eds. B. Jordan, D. Piazza, T. Darley. Burlington, MA: OASIS Open, 2021. URL: https://docs.oasis-open.org/cti/taxii/v2.1/os/taxii-v2.1-os.html.

[396] Temoshok D., Fenton J., Choong Y.-Y., Lefkovitz N., Regenscheid A., Galluzzo R., Richer J. Digital Identity Guidelines: Authentication and Authenticator Management. NIST Special Publication 800-63B-4. Gaithersburg, MD, 2025. DOI: 10.6028/NIST.SP.800-63b-4. URL: https://csrc.nist.gov/pubs/sp/800/63/b/4/final.

[397] Temoshok D., Richer J., Choong Y.-Y., Fenton J., Lefkovitz N., Regenscheid A., Galluzzo R. Digital Identity Guidelines: Federation and Assertions. NIST Special Publication 800-63C-4. Gaithersburg, MD, 2025. DOI: 10.6028/NIST.SP.800-63c-4. URL: https://csrc.nist.gov/pubs/sp/800/63/c/4/final.

[398] Threat Modeling Cheat Sheet. OWASP Cheat Sheet Series. OWASP Foundation. URL: https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html.

[399] Transport security model. *etcd Documentation*. Version 3.5. The etcd Authors; Cloud Native Computing Foundation. URL: https://etcd.io/docs/v3.5/op-guide/security/.

[400] Triton (Software S1009; aliases: TRISIS, HatMan). MITRE ATT&CK for ICS. The MITRE Corporation. URL: https://attack.mitre.org/software/S1009/.

[401] Tuning. *etcd Documentation*. Version 3.5. The etcd Authors; Cloud Native Computing Foundation. URL: https://etcd.io/docs/v3.5/tuning/.

[402] Turan M. S., Barker E., Kelsey J., McKay K., Baish M., Boyle M. Recommendation for the Entropy Sources Used for Random Bit Generation. NIST SP 800-90B. Gaithersburg, MD, 2018. DOI: 10.6028/NIST.SP.800-90B. URL: https://csrc.nist.gov/pubs/sp/800/90/b/final.

[403] UcedaVélez T., Morana M. M. Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis. Hoboken: John Wiley & Sons, 2015. 696 p. DOI: 10.1002/9781118988374.

[404] Urdaneta G., Pierre G., van Steen M. A survey of DHT security techniques. *ACM Computing Surveys*. 2011. Vol. 43, no. 2. Article 8. P. 1–49. DOI: 10.1145/1883612.1883615.

[405] Use the Instance Metadata Service to access instance metadata. *Amazon Elastic Compute Cloud User Guide*. Amazon Web Services. URL: https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-instance-metadata-service.html.

[406] Using RBAC Authorization. Kubernetes Documentation. The Kubernetes Authors / Cloud Native Computing Foundation. URL: https://kubernetes.io/docs/reference/access-authn-authz/rbac/.

[407] van Dijk M., Juels A., Oprea A., Rivest R. L. FlipIt: The Game of «Stealthy Takeover». *Journal of Cryptology*. 2013. Vol. 26, no. 4. P. 655–713. DOI: 10.1007/s00145-012-9134-5. URL: https://doi.org/10.1007/s00145-012-9134-5.

[408] Vanhoef M., Piessens F. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. *Proceedings of the 24th ACM SIGSAC Conference on Computer and Communications Security (CCS '17)*. New York: ACM, 2017. DOI: 10.1145/3133956.3134027. URL: https://www.krackattacks.com/.

[409] Vanhoef M., Ronen E. Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco: IEEE, 2020. DOI: 10.1109/SP40000.2020.00031. URL: https://wpa3.mathyvanhoef.com/.

[410] Varadarajan V., Kooburat T., Farley B., Ristenpart T., Swift M. M. Resource-freeing attacks: improve your cloud performance (at your neighbor's expense). *Proceedings of the 2012 ACM Conference on Computer and Communications Security (CCS'12)*. New York: ACM, 2012. P. 281–292. DOI: 10.1145/2382196.2382228.

[411] Wallner D., Harder E., Agee R. Key Management for Multicast: Issues and Architectures. RFC 2627. IETF, 1999. DOI: 10.17487/RFC2627. URL: https://www.rfc-editor.org/rfc/rfc2627.

[412] Wang L., Jajodia S., Singhal A., Cheng P., Noel S. *k*-Zero Day Safety: A Network Security Metric for Measuring the Risk of Unknown Vulnerabilities. *IEEE Transactions on Dependable and Secure Computing*. 2014. Vol. 11, no. 1. P. 30–44. DOI: 10.1109/TDSC.2013.24. URL: https://doi.org/10.1109/TDSC.2013.24.

[413] Wang L., Kangasharju J. Real-world sybil attacks in BitTorrent mainline DHT. *2012 IEEE Global Communications Conference (GLOBECOM)*. Anaheim, CA: IEEE, 2012. P. 826–832. DOI: 10.1109/GLOCOM.2012.6503215.

[414] Warner J. October 21 post-incident analysis. *The GitHub Blog*. 2018. URL: https://github.blog/news-insights/company-news/oct21-post-incident-analysis/.

[415] Web Services Atomic Transaction (WS-AtomicTransaction) Version 1.2. OASIS Standard, 2 February 2009. URL: https://docs.oasis-open.org/ws-tx/wstx-wsat-1.2-spec-os/wstx-wsat-1.2-spec-os.html.

[416] Web Services Security: SOAP Message Security Version 1.1.1. OASIS Standard, 18 May 2012. URL: https://docs.oasis-open.org/wss-m/wss/v1.1.1/os/wss-SOAPMessageSecurity-v1.1.1-os.html.

[417] Wong C. K., Gouda M., Lam S. S. Secure group communications using key graphs. *ACM SIGCOMM Computer Communication Review*. 1998. Vol. 28, no. 4. P. 68–79. DOI: 10.1145/285243.285260.

[418] X-Road Architecture: Technical Specification. Doc. ID: ARC-G. Version 1.15. Nordic Institute for Interoperability Solutions (NIIS), 2025. URL: https://github.com/nordic-institute/X-Road/blob/develop/doc/Architecture/arc-g_x-road_arhitecture.md.

[419] XML Signature Best Practices: W3C Working Group Note 11 April 2013 / eds. F. Hirsch, P. Datta. World Wide Web Consortium, 2013. URL: https://www.w3.org/TR/xmldsig-bestpractices/.

[420] Yaga D., Mell P., Roby N., Scarfone K. Blockchain Technology Overview. NISTIR 8202. Gaithersburg, MD: NIST, 2018. DOI: 10.6028/NIST.IR.8202. URL: https://csrc.nist.gov/pubs/ir/8202/final.

[421] Yu H., Gibbons P. B., Kaminsky M., Xiao F. SybilLimit: A Near-Optimal Social Network Defense against Sybil Attacks. *2008 IEEE Symposium on Security and Privacy (SP 2008)*. Oakland, CA: IEEE, 2008. P. 3–17. DOI: 10.1109/SP.2008.13.

[422] Yu H., Kaminsky M., Gibbons P. B., Flaxman A. SybilGuard: Defending Against Sybil Attacks via Social Networks. *Proceedings of the 2006 Conference on Applications, Technologies, Architectures, and Protocols for Computer Communications (SIGCOMM'06)*. New York: ACM, 2006. P. 267–278. DOI: 10.1145/1159913.1159945.

[423] Zadeh L. A. Fuzzy sets. *Information and Control*. 1965. Vol. 8, no. 3. P. 338–353. DOI: 10.1016/S0019-9958(65)90241-X. URL: https://doi.org/10.1016/S0019-9958(65)90241-X.

[424] Zero Trust Maturity Model. Version 2.0. Washington, DC: Cybersecurity and Infrastructure Security Agency, Cybersecurity Division, April 2023. 32 p. URL: https://www.cisa.gov/zero-trust-maturity-model.

[425] Zgurovsky M. Z., Pankratova N. D. System Analysis: Theory and Applications. Berlin; Heidelberg: Springer, 2007. (Data and Knowledge in a Changing World). ISBN 978-3-540-48879-8. DOI: 10.1007/978-3-540-48880-4. URL: https://doi.org/10.1007/978-3-540-48880-4.

[426] Zhang Y., Juels A., Reiter M. K., Ristenpart T. Cross-VM side channels and their use to extract private keys. *Proceedings of the 2012 ACM Conference on Computer and Communications Security (CCS'12)*. New York: ACM, 2012. P. 305–316. DOI: 10.1145/2382196.2382230.

Додаток А. Завдання для самостійної роботи

Завдання згруповано за змістовими модулями робочої програми дисципліни. Для кожної теми зазначено зміст роботи та форму подання результату. Основні відомості наведено в розділах 2–5, опорним джерелом є [390]. Результати доцільно оформлювати як фрагменти дослідницької роботи аспіранта: з постановкою задачі, обґрунтуванням методу, числовими результатами та висновками.

А.1. Теми практичних занять

Змістовий модуль 1. Класи розподілених систем і вразливостей

1. **Класи розподілених систем.** Для трьох реальних систем різних класів (наприклад, однорангова мережа обміну файлами, кластер під керуванням оркестратора контейнерів, система електронної взаємодії державних електронних інформаційних ресурсів) визначити клас координації, побудувати структурну схему й виокремити чотири функціональні елементи: доступ і допуск, транспортування даних, координацію, керування даними. Для кожного елемента визначити поверхню атаки. *Результат:* схема та порівняльна таблиця класів (розділ 2).
2. **Служби управління ресурсами та координація.** Змоделювати (або розгорнути на стенді) координаційну службу з трьох і п'яти вузлів (наприклад, etcd або Apache ZooKeeper). Дослідити поведінку за відмови та мережевої ізоляції вузлів, розрахувати доступність кворуму й описати сценарії атак на координацію: відмову в обслуговуванні лідера, порушення синхронізації часу, отруєння метаданих. *Результат:* протокол експерименту, розрахунок і перелік контрзаходів (розділи 2 і 4).

Змістовий модуль 2. Децентралізовані моделі P2P і атакуючі P2P системи

3. **Неструктуровані протоколи P2P.** Побудувати імітаційну модель пошуку затопленням і пліткового поширення (gossip) у випадковому графі. Дослідити залежність охоплення й трафіку від TTL, а також вплив отруєння відповідей і частки Sybil-вузлів на ймовірність отримати коректний результат. *Результат:* графіки залежностей і висновки щодо стійкості (розділ 3).
4. **Ієрархічні протоколи P2P.** Змоделювати мережу із суперпірами та порівняти її стійкість із пласкою топологією за випадкових відмов і за цілеспрямованого виведення з ладу суперпірів. Запропонувати та кількісно оцінити захисні заходи: репутацію, ротацію та резервування су-

перпірів. *Результат:* звіт із моделлю, метриками зв'язності й рекомендаціями (розділ 3).

Змістовий модуль 3. Розподілені системи: скоординована кластеризація ресурсів

5. **Стилі координації систем.** Порівняти централізовану координацію (з координатором), координацію з обраним лідером і безлідерну координацію на прикладі реплікованого сервісу. Оцінити узгодженість, доступність, наявність єдиних точок відмови та стійкість до візантійських вузлів. *Результат:* порівняльна таблиця й обґрунтований вибір стилю для заданого класу задач (розділ 4).
6. **Схема керування та координації реплікації: основа пом'якшення атак.** Для заданих вимог до доступності й цілісності розрахувати параметри кворумів (N, W, R) та мінімальну кількість реплік за умови $n \geq 3f + 1$. Змоделювати атаку візантійського вузла або атаку відкату стану, обґрунтувати схему реплікації та перевірити поведінку кластера Raft за відмови лідера. *Результат:* розрахунок, протокол експерименту та висновки (розділ 4).

Змістовий модуль 4. Розподілені системи: координаційні класи та напади

7. **Клас координації ресурсів — розгляд інфраструктури.** Побудувати модель загроз для інфраструктури хмарного або кластерного типу (гіпервізор, оркестратор, планувальник, розподілене сховище). Скласти дерево атак на спільні ресурси: вичерпання ресурсів, «шумного сусіда», побічні канали, компрометацію планувальника. Запропонувати заходи та показники їхньої результативності. *Результат:* дерево атак і матриця «загроза — захід — показник» (розділ 5).
8. **Клас координації послуг — розгляд програм.** Проаналізувати захищеність сервісно-орієнтованої або мікросервісної програми: оркестрацію та хореографію сервісів, реєстри сервісів, розподілені транзакції. Визначити атаки на композицію сервісів (підміна сервісу, атаки на повідомлення та API, порушення транзакційної координації) і зіставити їх із контрзаходами. *Результат:* модель загроз програми та план заходів (розділ 5).

А.2. Теми для самостійного опрацювання

Змістовий модуль 1. Класи розподілених систем і вразливостей

1. **Класи розподілених систем.** Скласти аналітичний огляд класифікацій розподілених систем за типом координації та зіставити їх із таксономією архітектур із розділу 1. *Форма:* огляд обсягом 5–7 сторінок із порівняльною таблицею.

2. **Класи вразливостей і загроз.** Для обраної розподіленої системи відобразити вразливості кожного функціонального елемента на техніки MITRE ATT&CK [288]. *Форма:* матриця відповідності з коментарями.
3. **Контроль доступу/допуску та керування ідентифікаторами.** Проаналізувати механізми допуску вузлів до розподіленої системи та методи протидії атаці Sybil: ресурсні тести, централізовану сертифікацію, соціальні графи. *Форма:* порівняльний аналіз із переліком обмежень кожного методу.
4. **Транспортування даних.** Дослідити загрози оверлейним каналам розподіленої системи та засоби їх захисту на транспортному й оверлейному рівнях. *Форма:* есе-аналіз із прикладами інцидентів.
5. **Служби управління ресурсами та координація.** Описати архітектуру та модель довіри однієї координаційної служби (etcd, ZooKeeper або Consul) і визначити її критичні конфігураційні параметри безпеки. *Форма:* контрольний перелік налаштувань.
6. **Безпека даних.** Проаналізувати ризики для цілісності й конфіденційності даних у реплікованому середовищі (витоки через репліки, кеші та резервні копії, походження даних). *Форма:* модель загроз і перелік заходів.

Змістовий модуль 2. Децентралізовані моделі P2P і атакуючі P2P системи

7. **Неструктуровані протоколи P2P.** Порівняти механізми пошуку в неструктурованих мережах (затоплення, випадкові блукання, gossip) за ефективністю та стійкістю до зловживань. *Форма:* таблиця з оцінками складності та коротким обґрунтуванням.
8. **Структуровані протоколи P2P.** Розібрати маршрутизацію в розподілених геш-таблицях (Chord, Kademlia) та атаки на неї: маршрутизаційні, eclipse, Sybil. *Форма:* схема маршрутизації й аналіз умов успіху атак.
9. **Гібридні протоколи P2P.** Проаналізувати гібридні архітектури з централізованим індексом і децентралізованим обміном. Визначити, які централізовані компоненти стають пріоритетними цілями атак. *Форма:* аналітична записка.
10. **Ієрархічні протоколи P2P.** Дослідити роль суперпірів і наслідки їх компрометації для доступності та цілісності мережі. *Форма:* розрахунок показників зв'язності для модельної топології.
11. **Типи атак.** Скласти класифікацію атак на P2P-системи (Sybil, eclipse, маршрутизаційні, отруєння вмісту, відмова в обслуговуванні, атаки на зберігання) за цільовою властивістю безпеки. *Форма:* класифікаційна таблиця.

12. **Напади та їх пом'якшення.** Для двох атак із попереднього завдання проаналізувати методи пом'якшення та їхню ціну (накладні витрати, вплив на продуктивність). *Форма:* порівняльний аналіз із посиланнями на першоджерела.

Змістовий модуль 3. Розподілені системи: скоординована кластеризація ресурсів

13. **Стилі координації систем.** Описати стилі координації (з координатором, з лідером, безлідерну, на основі подій) і їхній вплив на поверхню атаки. *Форма:* конспект-схема.
14. **Надійне та безпечне групове спілкування.** Проаналізувати властивості надійної та впорядкованої групової розсилки й механізми керування груповими ключами за зміни складу групи. *Форма:* огляд із формальним описом властивостей.
15. **Координаційні властивості.** Систематизувати координаційні властивості (упорядкування, узгодженість, живучість, безпечність) та атаки, спрямовані на їх порушення. *Форма:* таблиця «властивість — атака — захист».
16. **Схема керування та координації реплікації: основа пом'якшення атак.** Порівняти протоколи з моделлю аварійних відмов і візантійські протоколи реплікації за стійкістю та вартістю (розділи 4 і 13). *Форма:* розрахунково-аналітична записка.

Змістовий модуль 4. Розподілені системи: координаційні класи та напади

17. **Клас координації ресурсів — розгляд інфраструктури.** Дослідити атаки на хмарну, кластерну або ґрід-інфраструктуру (вичерпання ресурсів, побічні канали, компрометація площини керування) та відповідні заходи. *Форма:* аналітичний огляд із прикладами публічно описаних інцидентів.
18. **Клас координації послуг — розгляд програм.** Проаналізувати атаки на вебсервіси та мікросервісні програми (атаки на API, повідомлення, реєстри сервісів і транзакційну координацію) з урахуванням OWASP Top 10 [320] та OWASP API Security Top 10 [319]. *Форма:* модель загроз і перелік контрзаходів.

А.3. Комплексні завдання за розділами посібника

1. **Аналіз архітектури розподіленої системи як об'єкта захисту** (розділ 1). Побудова структурної схеми обраної системи, виокремлення меж довіри, складання переліку активів і поверхонь атаки. *Самостійно:* огляд наукових публікацій за темою дослідження щодо архітектурних загроз.

2. **Аналіз нормативних вимог до захисту конкретного інформаційного ресурсу** (розділ 6). Визначення правового режиму інформації, застосовних законів, НД ТЗІ та стандартів; складання переліку обов'язкових вимог. *Самостійно:* порівняння вимог NIS2 із національними вимогами за обраним сектором.
3. **Формальне моделювання політики безпеки** (розділи 7 і 10). Побудова моделі доступу (мандатної або рольової) для заданої системи; перевірка несуперечливості. *Самостійно:* розв'язання розрахункових задач із розділу 7.
4. **Побудова графа атак і кількісне оцінювання ризику** (розділи 7 і 8). Формування дерева атак, розрахунок ALE, аналіз чутливості. *Самостійно:* моделювання загроз власної дослідницької системи за STRIDE.
5. **Криптографічний захист обміну даними між вузлами** (розділ 9). Проєктування схеми керування ключами, обґрунтування вибору алгоритмів (у т. ч. ДСТУ), план постквантової міграції. *Самостійно:* аналіз стійкості обраної схеми.
6. **Проєктування схеми керування доступом** (розділ 10). Розроблення рольової та атрибутної моделей для розподіленої ІКС, опис федеративного сценарію автентифікації. *Самостійно:* рецертифікація прав доступу на модельних даних.
7. **Проєктування захищеної мережевої архітектури** (розділ 11). Сегментація, розміщення засобів захисту, налаштування захисту безпроводового сегмента. *Самостійно:* оцінювання стійкості до відмов в обслуговуванні.
8. **Розроблення дорожньої карти переходу до архітектури нульової довіри** (розділ 12). Визначення поточного рівня зрілості, етапів, метрик успіху. *Самостійно:* аналіз конфігураційних ризиків хмарного середовища.
9. **Проєктування захисту розподіленого сховища даних** (розділ 13). Схема реплікації, шифрування, контролю цілісності та резервного копіювання. *Самостійно:* обґрунтування доцільності (або недоцільності) застосування DLT.
10. **Побудова системи моніторингу безпеки** (розділ 14). Визначення джерел телеметрії, сценаріїв кореляції, розрахунок обсягу подій і сховища, оцінювання якості виявлення. *Самостійно:* формулювання й перевірка гіпотези полювання на загрози.
11. **Розроблення плану реагування на інцидент та відновлення** (розділ 15). Визначення RTO, RPO, сценаріїв стримування та відновлення; проведення настільних навчань. *Самостійно:* розрахунок вартості простою й обґрунтування архітектури резервного майданчика.

12. **Планування заходів кіберзахисту об'єкта критичної інфраструктури** (розділ 16). Зонування за IEC 62443, вибір рівнів захищеності, перелік заходів. *Самостійно:* аналіз одного з відомих інцидентів в операційних технологіях.
13. **Розроблення фрагмента СУІБ та програми дослідження** (розділ 17). Положення про застосовність, система показників, план наукового експерименту за темою дисертації. *Самостійно:* підготовка розгорнутого плану наукової публікації.